CompTIA Security+ SY0-701 - Guia Completa de Estudio en Espanol

Preguntas y teoria organizadas por dominio oficial del examen
Fuente: ExamCompass.com + Objetivos Oficiales del Examen CompTIA v6.0
Teoria 100% en espanol, conceptos tecnicos con terminologia bilingue

Dominio	Nombre	%
1.0	Conceptos Generales de Seguridad	12%
2.0	Amenazas, Vulnerabilidades y Mitigaciones	22%
3.0	Arquitectura de Seguridad	18%
4.0	Operaciones de Seguridad	28%
5.0	Gestión del Programa de Seguridad	20%

Total preguntas: 590
Las opciones marcadas en verde son las respuestas correctas.

1.0 Conceptos Generales de Seguridad (12% del examen)

1.1 - Comparar y contrastar los distintos tipos de controles de seguridad.

Conceptos clave:

- Categorias: Tecnico, Administrativo (Managerial), Operacional, Fisico
- Tipos de control: Preventivo, Disuasorio, Detective, Correctivo, Compensatorio, Directivo

Teoria detallada:

Los controles de seguridad se clasifican por CATEGORIA y por TIPO. Memorizalos como una tabla de doble entrada.

CATEGORIAS (el QUE protegen):

- Tecnico (logico): firewalls, cifrado, antivirus, IDS
- Administrativo (Managerial): politicas, procedimientos, evaluaciones de riesgo
- Operacional: formacion de usuarios, gestion de medios, controles fisicos operados por personas
- Fisico: cerraduras, vallas, camaras, guardias de seguridad

TIPOS (el COMO actuan):

- Preventivo (Preventive): evita que ocurra el incidente (firewall bloqueando trafico)
- Disuasorio (Deterrent): disuade al atacante sin bloquearlo fisicamente (camara visible, cartel de advertencia)
- Detective: detecta que algo ocurrio (logs, IDS, CCTV)
- Correctivo (Corrective): corrige tras el incidente (patch, restaurar backup, antivirus que elimina malware)
- Compensatorio (Compensating): control alternativo cuando el principal no es viable (MFA en lugar de tarjeta inteligente)
- Directivo (Directive): indica que se debe hacer (politica de uso aceptable, formacion obligatoria)

TRUCO NEMOTECNICO para los tipos: 'Por Dios, Del Cielo Caen Dones' → Preventive, Deterrent, Detective, Corrective, Compensating, Directive

Ejemplo de examen: Un firewall es un control TECNICO + PREVENTIVO. Una camara de seguridad es FISICO + DETECTIVE. Una politica de contrasenas es ADMINISTRATIVO + DIRECTIVO.

Preguntas de practica (21):

1. ¿Cuáles son los ejemplos de controles preventivos de seguridad? (Seleccione 3 respuestas)

A) Cifrado
B) identificación
C) Sensores
✓ D) Cortafuegos
E) Señales de advertencia
✓ F) software audiovisual

2. ¿Cuál de las respuestas enumeradas a continuación se refiere(s) a los controles de seguridad de detectives? (Seleccione todo lo que corresponda)

A) Iluminación
✓ B) Monitoreo de registros
C) Zona de arena
✓ D) Auditorías de seguridad
✓ E) circuito cerrado de televisión
✓ F) identificación
✓ G) Escaneo de vulnerabilidades

3. ¿Cuál de las respuestas enumeradas a continuación se refiere(s) a controles de seguridad compensatorios? (Seleccione todo lo que corresponda)

A) Sistemas de energía de respaldo
B) Videovigilancia
✓ C) Ministerio de Asuntos Exteriores
✓ D) Zona de pruebas de aplicaciones
✓ E) Segmentación de red

4. ¿Cuál de los siguientes términos entran en la categoría de controles de seguridad directivos? (Seleccione 2 respuestas)

A) PIR

✓ B) PUA

C) identificación

D) Ministerio de Asuntos Exteriores

E) IPS

5. ¿Cuáles son los ejemplos de controles preventivos de seguridad? (Seleccione 3 respuestas)

A) Cifrado

B) identificación

C) Sensores

✓ D) Cortafuegos

E) Señales de advertencia

✓ F) software audiovisual

6. ¿Cuál de las respuestas enumeradas a continuación se refiere(s) a los controles de seguridad de detectives? (Seleccione todo lo que corresponda)

A) Iluminación

✓ B) Monitoreo de registros

C) Zona de arena

✓ D) Auditorías de seguridad

✓ E) circuito cerrado de televisión

✓ F) identificación

✓ G) Escaneo de vulnerabilidades

7. ¿Cuál de las respuestas enumeradas a continuación se refiere(s) a controles de seguridad compensatorios? (Seleccione todo lo que corresponda)

A) Sistemas de energía de respaldo

B) Videovigilancia

✓ C) Ministerio de Asuntos Exteriores

✓ D) Zona de pruebas de aplicaciones

✓ E) Segmentación de red

8. ¿Cuál de los siguientes términos entran en la categoría de controles de seguridad directivos? (Seleccione 2 respuestas)

A) PIR

✓ B) PUA

C) identificación

D) Ministerio de Asuntos Exteriores

E) IPS

9. ¿Cuál de las siguientes respuestas se puede utilizar para describir los controles técnicos de seguridad? (Seleccione 3 respuestas)

A) Enfocados en proteger los bienes materiales

✓ B) A veces se les llama controles de seguridad lógicos.

✓ C) Ejecutado por sistemas informáticos (en lugar de personas)

D) También conocidos como controles administrativos.

✓ E) Implementado con tecnología.

F) Principalmente implementado y ejecutado por personas (a diferencia de los sistemas informáticos)

10. ¿Cuál de las siguientes respuestas se refiere a los rasgos característicos de los controles de seguridad gerenciales? (Seleccione 3 respuestas)

A) También conocidos como controles administrativos.

B) A veces denominados controles de seguridad lógicos.

✓ C) Enfocados en reducir el riesgo de incidentes de seguridad

D) Ejecutado por sistemas informáticos (en lugar de personas)

✓ **E) Documentado en políticas escritas.**

F) Enfocados en proteger los bienes materiales

11. ¿Cuál de las respuestas enumeradas a continuación se puede utilizar para describir los controles de seguridad operativos? (Seleccione 3 respuestas)

A) También conocidos como controles administrativos.

✓ **B) Enfocados en los procedimientos del día a día de una organización.**

C) Ejecutado por sistemas informáticos (en lugar de personas)

✓ **D) Se utiliza para garantizar que el equipo continúe funcionando según lo especificado.**

E) Enfocados en la gestión del riesgo

✓ **F) Principalmente implementado y ejecutado por personas (a diferencia de los sistemas informáticos)**

12. ¿Cuál de las respuestas enumeradas a continuación se refiere a controles de seguridad diseñados para disuadir, detectar y prevenir el acceso no autorizado, el robo, el daño o la destrucción de activos materiales?

A) Controles de seguridad gerenciales

✓ **B) Controles de seguridad física**

C) Controles técnicos de seguridad

D) Controles operativos de seguridad

13. ¿Cuál de las afirmaciones enumeradas a continuación no se refiere a una técnica de respuesta y remediación de vulnerabilidades?

A) Aplicar actualizaciones o correcciones proporcionadas por proveedores de software para abordar la vulnerabilidad (parches)

B) Garantizar la recuperación financiera de los costos asociados con un ciberataque exitoso (seguro)

C) Dividir una red en zonas más pequeñas y aisladas para limitar el impacto potencial de una vulnerabilidad (segmentación)

D) Mitigar el riesgo asociado con una vulnerabilidad que no se puede reparar de inmediato mediante la implementación de medidas de seguridad alternativas (controles de compensación)

E) Retrasar o renunciar a un parche para un sistema específico, por ejemplo, cuando aplicar un parche puede no ser factible debido a problemas de compatibilidad o posibles interrupciones en sistemas críticos (excepciones y exenciones).

✓ **F) Todas las respuestas anteriores son ejemplos de técnicas de respuesta y remediación de vulnerabilidades.**

14. ¿Cuál es la mejor contramedida contra los ataques de ingeniería social?

A) Conciencia situacional

B) Política de denegación implícita

✓ **C) Educación del usuario**

D) Fuertes controles de seguridad

15. ¿Cuál de las siguientes respuestas se puede utilizar para describir los controles técnicos de seguridad? (Seleccione 3 respuestas)

A) Enfocados en proteger los bienes materiales

✓ **B) A veces se les llama controles de seguridad lógicos.**

✓ **C) Ejecutado por sistemas informáticos (en lugar de personas)**

D) También conocidos como controles administrativos.

✓ **E) Implementado con tecnología.**

F) Principalmente implementado y ejecutado por personas (a diferencia de los sistemas informáticos)

16. ¿Cuál de las siguientes respuestas se refiere a los rasgos característicos de los controles de seguridad gerenciales? (Seleccione 3 respuestas)

A) También conocidos como controles administrativos.

B) A veces denominados controles de seguridad lógicos.

✓ **C) Enfocados en reducir el riesgo de incidentes de seguridad**

D) Ejecutado por sistemas informáticos (en lugar de personas)

✓ **E) Documentado en políticas escritas.**

F) Enfocados en proteger los bienes materiales

17. ¿Cuál de las respuestas enumeradas a continuación se puede utilizar para describir los controles de seguridad operativos? (Seleccione 3 respuestas)

A) También conocidos como controles administrativos.

✓ **B) Enfocados en los procedimientos del día a día de una organización.**

C) Ejecutado por sistemas informáticos (en lugar de personas)

✓ **D) Se utiliza para garantizar que el equipo continúe funcionando según lo especificado.**

E) Enfocados en la gestión del riesgo

✓ **F) Principalmente implementado y ejecutado por personas (a diferencia de los sistemas informáticos)**

18. ¿Cuál de las respuestas enumeradas a continuación se refiere a controles de seguridad diseñados para disuadir, detectar y prevenir el acceso no autorizado, el robo, el daño o la destrucción de activos materiales?

A) Controles de seguridad gerenciales

✓ **B) Controles de seguridad física**

C) Controles técnicos de seguridad

D) Controles operativos de seguridad

19. Escaneo de vulnerabilidades: (Seleccione todas las que correspondan)

A) Identifica falta de controles de seguridad

B) Prueba activamente los controles de seguridad.

✓ **C) Identifica errores de configuración comunes**

D) Explota vulnerabilidades

✓ **E) Prueba pasivamente los controles de seguridad.**

20. ¿Cuál de las afirmaciones enumeradas a continuación no se refiere a una técnica de respuesta y remediación de vulnerabilidades?

A) Aplicar actualizaciones o correcciones proporcionadas por proveedores de software para abordar la vulnerabilidad (parches)

B) Garantizar la recuperación financiera de los costos asociados con un ciberataque exitoso (seguro)

C) Dividir una red en zonas más pequeñas y aisladas para limitar el impacto potencial de una vulnerabilidad (segmentación)

D) Mitigar el riesgo asociado con una vulnerabilidad que no se puede reparar de inmediato mediante la implementación de medidas de seguridad alternativas (controles de compensación)

E) Retrasar o renunciar a un parche para un sistema específico, por ejemplo, cuando aplicar un parche puede no ser factible debido a problemas de compatibilidad o posibles interrupciones en sistemas críticos (excepciones y exenciones).

✓ **F) Todas las respuestas anteriores son ejemplos de técnicas de respuesta y remediación de vulnerabilidades.**

21. Pruebas de penetración: (Seleccione todas las que correspondan)

A) Salta los controles de seguridad

B) Sólo identifica falta de controles de seguridad

✓ **C) Prueba activamente los controles de seguridad.**

✓ **D) Explota vulnerabilidades**

E) Prueba pasivamente los controles de seguridad.

1.2 - Resumir los conceptos fundamentales de seguridad.

Conceptos clave:

- Triada CIA: Confidencialidad, Integridad, Disponibilidad
- No repudio
- AAA: Autenticacion, Autorizacion, Auditoria (Accounting)
- Zero Trust: Plano de control, Plano de datos, Motor de politicas
- Seguridad fisica: Bolardos, Vallas, Videovigilancia, Iluminacion, Sensores
- Tecnologia de engano: Honeypot, Honeynet, Honeyfile, Honeytoken

Teoria detallada:

TRIADA CIA - El nucleo de toda la seguridad:

- Confidencialidad (Confidentiality): solo acceden los autorizados. Controles: cifrado, control de acceso
- Integridad (Integrity): los datos no se modifican sin autorizacion. Controles: hashing, firmas digitales
- Disponibilidad (Availability): los sistemas estan accesibles cuando se necesitan. Controles: redundancia, backups

NO REPUDIO (Non-repudiation): nadie puede negar haber realizado una accion. Se consigue con firmas digitales y logs de auditoria. Ejemplo: si firmas digitalmente un email, no puedes negar haberlo enviado.

MARCO AAA:

- Autenticacion (Authentication): verificar quien eres (usuario + contrasena, MFA)
- Autorizacion (Authorization): que puedes hacer una vez autenticado (permisos, roles)
- Auditoria (Accounting): registro de lo que has hecho (logs)

Protocolos AAA: RADIUS (UDP 1812/1813), TACACS+ (TCP 49, cifra todo el payload)

ZERO TRUST - 'Nunca confiar, siempre verificar':

- Plano de control: donde se toman decisiones de acceso (Motor de politicas + Administrador de politicas)
- Plano de datos: donde fluye el trafico real (Punto de cumplimiento de politicas)
- Principio: no se asume confianza por estar dentro de la red corporativa

SEGURIDAD FISICA:

- Bolardos (Bollards): postes antiimpacto para proteger edificios de vehiculos
- Mantrap (airlock): doble puerta que atrapa a intrusos entre ambas
- Jaula de Faraday: bloquea senales electromagneticas
- Iluminacion: como disuasor

TECNOLOGIA DE ENGANO:

- Honeypot: sistema falso que atrae atacantes para estudiarlos
- Honeynet: red entera de honeypots
- Honeyfile: archivo falso que alerta si alguien lo abre
- Honeytoken: credencial falsa que si se usa, delata al atacante

Preguntas de practica (101):

1. En la arquitectura de seguridad AAA, el proceso de otorgar o denegar acceso a recursos se conoce como:

A) Autenticación

✓ B) Autorización

✓ C) Contabilidad

---

2. ¿Qué parte de la arquitectura de seguridad AAA se ocupa de la verificación de la identidad de una persona o proceso?

A) Contabilidad

✓ B) Autenticación

C) Revisión de cuentas

D) Autorización

---

3. El término "no repudio" describe la incapacidad de negar la responsabilidad por realizar una acción específica. En el contexto de la seguridad de los datos, el no repudio garantiza la confidencialidad de los datos, proporciona prueba de la integridad de los datos y prueba del origen de los datos.

A) Verdadero

✓ B) FALSO

---

4. ¿Cuál de las siguientes soluciones proporciona la funcionalidad AAA? (Seleccione todo lo que corresponda)

A) CAP

✓ B) TACACS+

C) PAPILLA

✓ D) RADIO

E) MS-CHAP

---

5. ¿Qué parte de IPsec proporciona confidencialidad, integridad de datos y autenticación?

A) AES

B) sha

C) Ah

✓ D) ESP

---

6. ¿Cuáles son los rasgos característicos de RADIUS? (Seleccione 3 respuestas)

A) Se utiliza principalmente para acceso a la red.

B) Cifra toda la carga útil del paquete de solicitud de acceso.

✓ C) Combina autenticación y autorización

✓ **D) Cifra solo la contraseña en el paquete de solicitud de acceso.**

E) Se utiliza principalmente para la administración de dispositivos.

F) Separa la autenticación y la autorización

7. ¿Cuál de las respuestas enumeradas a continuación se refieren a DSA? (Seleccione 3 respuestas)

A) Algoritmo asimétrico

B) Utilizado para el proceso de intercambio de claves.

C) Algoritmo simétrico

✓ **D) Proporciona autenticación, integridad y no repudio.**

✓ **E) Diseñado específicamente para crear y verificar firmas digitales.**

F) Utilizado para cifrado

8. ¿Cuál de las respuestas enumeradas a continuación describe las características de ECDSA? (Seleccione todo lo que corresponda)

A) Proporciona autenticación, integridad y no repudio.

✓ **B) Basado en criptografía de curva elíptica**

C) Diseñado para el cifrado de datos

✓ **D) Diseñado específicamente para crear y verificar firmas digitales.**

✓ **E) Más eficiente computacionalmente que otros algoritmos de firma**

F) Habilita el proceso de intercambio de claves.

9. ¿Qué parte de IPsec proporciona autenticación, integridad y confidencialidad?

A) SPD

B) PFS

C) Ah

✓ **D) ESP**

10. ¿Qué modo de cifrado en bloque combina CTM para el cifrado con un mecanismo de autenticación para garantizar la confidencialidad e integridad de los datos?

A) CBC

✓ **B) GCM**

C) BCE

D) CFB

11. ¿Cuáles de las respuestas que se enumeran a continuación se refieren a métodos comunes de autenticación de dispositivos utilizados dentro del marco AAA? (Seleccione 3 respuestas)

A) Nombres de usuario y contraseñas

✓ **B) Certificados digitales**

✓ **C) direcciones IP**

D) Ministerio de Asuntos Exteriores

E) Autenticación biométrica

✓ **F) Direcciones MAC**

12. ¿Cuáles de las siguientes afirmaciones sobre los honeypots son ciertas? (Seleccione 2 respuestas)

A) Los Honeypots siempre son parte de una Honeynet.

✓ **B) Los Honeypots imitan sistemas reales para atraer ciberatacantes**

C) Los Honeypots son un tipo de solución antimalware

✓ **D) Los Honeypots contienen vulnerabilidades aparentes que son monitoreadas de cerca por un equipo de seguridad.**

E) Los Honeypots se utilizan para lanzar ataques contra ciberatacantes

13. La especificación MIME extiende el formato de los mensajes de correo electrónico más allá del texto plano, permitiendo la transferencia de archivos de gráficos, audio y vídeo a través del sistema de correo de Internet. S/MIME es una versión mejorada del protocolo MIME que habilita funciones de seguridad del correo electrónico al proporcionar cifrado, autenticación, integridad de mensajes y otros servicios relacionados.

A) Verdadero

B) FALSO

14. ¿Cuál de las respuestas enumeradas a continuación se refiere a un conjunto de protocolos y tecnologías que proporcionan cifrado, autenticación e integridad de datos para el tráfico de red?

A) TLS

B) SSH

✓ C) IPSec

D) vpn

---

15. ¿Cuáles son las características del modo empresarial WPA2/WPA3? (Seleccione 3 respuestas)

A) Adecuado para grandes redes corporativas

B) IEEE 802.1D

C) No requiere un servidor de autenticación

✓ D) IEEE 802.1X

E) Adecuado para todo tipo de LAN inalámbricas

✓ F) Requiere servidor de autenticación RADIUS

---

16. ¿Cuál de las respuestas enumeradas a continuación se refiere a un protocolo de red seguro utilizado para proporcionar cifrado, autenticación e integridad para la comunicación multimedia en tiempo real?

A) IPSec

B) SORBO

C) VoIP

✓ D) SRTP

---

17. OpenID Connect es un protocolo utilizado para:

A) Atestación

B) Autorización

C) Revisión de cuentas

✓ D) Autenticación

---

18. ¿Cuáles son los rasgos característicos de SAML? (Seleccione 3 respuestas)

A) Permite solo el intercambio de datos de autorización SSO

✓ B) Maneja tanto la autenticación como la autorización para SSO

✓ C) Utiliza XML para el intercambio de datos.

✓ D) Comúnmente utilizado en entornos empresariales y sistemas heredados.

E) Permite solo el intercambio de datos de autenticación SSO

F) Utiliza JSON para el intercambio de datos.

G) Diseñado específicamente para aplicaciones web y móviles

---

19. Un subsistema de autenticación que permite a un usuario acceder a múltiples componentes del sistema conectados (como hosts separados en una red) después de un único inicio de sesión en solo uno de los componentes se denomina:

A) NAC

✓ B) SSO

C) aaa

D) Ministerio de Asuntos Exteriores

---

20. ¿Cuál de las respuestas enumeradas a continuación se refiere a un conjunto de protocolos y tecnologías que proporcionan cifrado, autenticación e integridad de datos para el tráfico de red?

A) TLS

B) SSH

C) IPSec

D) vpn

---

21. La especificación MIME amplía el formato de los mensajes de correo electrónico más allá del simple texto, permitiendo la transferencia de archivos de gráficos, audio y vídeo a través del sistema de correo de Internet. S/MIME es una versión mejorada del protocolo MIME que habilita funciones de seguridad del correo electrónico al proporcionar cifrado, autenticación, integridad de mensajes y otros servicios relacionados.

A) Verdadero

B) FALSO

22. Un ataque de disociación inalámbrica es un tipo de: (Seleccione 2 respuestas)

A) Ataque de degradación

✓ B) Ataque de desautenticación

C) Ataque de fuerza bruta

✓ D) Ataque DoS

E) Ataque criptográfico

23. ¿Cuál de las respuestas enumeradas a continuación se refiere a una tecnología que proporciona control sobre el uso de un dispositivo móvil dentro de un área designada?

A) Geocerca

B) Portal cautivo

C) Mielero

D) Geolocalización

Respuesta no detectada automaticamente

24. ¿Cuáles son las características del modo empresarial WPA2/WPA3? (Seleccione 3 respuestas)

A) Adecuado para grandes redes corporativas

B) IEEE 802.1D

C) No requiere un servidor de autenticación

✓ D) IEEE 802.1X

E) Adecuado para todo tipo de LAN inalámbricas

✓ F) Requiere servidor de autenticación RADIUS

25. ¿Cuál de las respuestas enumeradas a continuación se refiere a un protocolo de autenticación de red inalámbrica estándar abierto que mejora la seguridad al encapsular el proceso de autenticación dentro de un túnel TLS cifrado?

A) PEAP

B) PAE

C) SALTO

D) RADIO

Respuesta no detectada automaticamente

26. ¿Cuáles son los ejemplos de controles preventivos de seguridad? (Seleccione 3 respuestas)

A) Cifrado

B) identificación

C) Sensores

✓ D) Cortafuegos

E) Señales de advertencia

✓ F) software audiovisual

27. ¿Cuál de las respuestas enumeradas a continuación se refiere(s) a los controles de seguridad de detectives? (Seleccione todo lo que corresponda)

A) Iluminación

✓ B) Monitoreo de registros

C) Zona de arena

✓ D) Auditorías de seguridad

✓ E) circuito cerrado de televisión

✓ F) identificación

✓ G) Escaneo de vulnerabilidades

28. ¿Qué tipo de cuenta de usuario viola el concepto de no repudio?

A) Cuenta de usuario estándar

✓ B) cuenta compartida

C) Cuenta de usuario invitado

D) cuenta de servicio

29. ¿Cuál de los siguientes términos describe el proceso de identificar diferencias entre la postura de seguridad actual de una organización y su postura de seguridad deseada?

A) Ejercicio de mesa

✓ B) Análisis de brechas

C) Capacitación en concientización sobre seguridad.

D) Evaluación de riesgos

---

30. ¿Cuál de las respuestas enumeradas a continuación se refiere a un enfoque de seguridad del plano de control de confianza cero que tiene en cuenta la identidad del usuario, la seguridad del dispositivo, las condiciones de la red y otra información contextual para permitir decisiones de acceso dinámico?

A) Confianza implícita

B) Monitoreo y registro

✓ C) Identidad adaptativa

D) Microsegmentación

---

31. En la arquitectura de seguridad Zero Trust, el punto de aplicación de políticas (PEP) es un componente del plano de datos que aplica las políticas de seguridad definidas en el plano de control por el punto de decisión de políticas (PDP).

A) Verdadero

B) FALSO

Respuesta no detectada automaticamente

---

32. ¿Cuál de las respuestas enumeradas a continuación se refiere a un ejemplo de red trampa?

A) Una red de sitios web falsos

B) Una red de servidores falsos

C) Una red de bases de datos falsas

D) Una red de archivos compartidos falsos

✓ E) Todo lo anterior

---

33. Un archivo Honey se puede utilizar para:

A) Atraer a los ciberatacantes

B) Activar alertas cuando se accede

C) Monitoreo de la actividad de la red

✓ D) Todo lo anterior

---

34. ¿Cuál de los siguientes no debería usarse como tokens de miel? (Seleccione todo lo que corresponda)

A) Credenciales de cuenta de usuario activo

B) Entradas de bases de datos que imitan datos reales

✓ C) URL reales a sitios web o recursos activos

D) Registros de servidor ficticios con información atractiva

E) Identificadores falsos, incluidos nombres de usuario, contraseñas, direcciones de correo electrónico y direcciones IP

---

35. ¿Cuál es el uso típico de una clave pública?

A) Cifrado de datos

B) Descifrado de datos

C) Autenticación de usuario/dispositivo

D) Todo lo anterior

---

36. ¿Cuál de las respuestas enumeradas a continuación se refiere a tecnología de software diseñada para brindar confidencialidad a todo un dispositivo de almacenamiento de datos?

A) TPM

B) FDE

C) EFS

D) HSM

---

37. ¿Cuál de las respuestas enumeradas a continuación se refiere a un método de autenticación secreto compartido utilizado en WPA, WPA2 y EAP?

A) PSK

B) 802.1X
C) SAE
D) TKIP

38. ¿Cuál de las siguientes respuestas se refiere a un microcontrolador integrado que se utiliza para arranque seguro, cifrado de disco y verificación de la integridad del sistema?

A) TPM
B) SoC
C) UEFI
✓ D) HSM

39. ¿Cuál es el propósito de la esteganografía?

A) Comprobación de la integridad de los datos
B) Verificando valores hash
✓ C) Ocultar datos dentro de otro dato
D) Cifrar datos

40. Las funciones hash encuentran uso en una variedad de aplicaciones, que incluyen:

A) Criptografía
B) Verificación de la integridad de los datos
C) Verificación y almacenamiento de contraseña
D) Firmas digitales
E) tecnología de cadena de bloques
✓ F) Todo lo anterior

41. ¿Cuál de las siguientes respuestas se refiere a una familia de funciones hash criptográficas diseñadas para diversas aplicaciones relacionadas con la seguridad, incluidas firmas digitales, almacenamiento de contraseñas, comunicaciones seguras y verificación de la integridad de los datos?

A) RSA
B) AES
C) PKCS
✓ D) sha

42. ¿Cuál de los siguientes combina una función hash criptográfica con una clave secreta para proporcionar un medio para verificar tanto la autenticidad como la integridad de un mensaje o datos?

A) MD5
B) DSA
✓ C) HMAC
D) DES

43. Ejemplos de vectores de amenazas directamente relacionados con el uso de dispositivos extraíbles incluyen: (Seleccione 2 respuestas)

A) Pretexto
✓ B) Entrega de malware
C) Ataques de abrevadero
✓ D) Exfiltración de datos
E) Ataques de ingeniería social

44. ¿Cuál de las siguientes respuestas se refiere a vectores de amenazas comunes que se aplican a los MSP, vendedores y proveedores en la cadena de suministro? (Seleccione 2 respuestas)

A) Violaciones de cumplimiento
B) Daño a la reputación de la marca
✓ C) Propagación de malware
D) Interrupciones operativas
✓ E) Técnicas de ingeniería social

45. ¿Qué ataque de ingeniería social se basa en el robo de identidad?

A) Pretexto

B) Phishing de lanza
C) Seguir de cerca
✓ **D) Interpretación**

46. ¿Cuál de las respuestas enumeradas a continuación se refiere a una técnica de ingeniería social en la que un atacante crea un escenario o situación falsa para engañar a la víctima para que revele información confidencial?

A) Interpretación
B) Recolección de credenciales
✓ **C) Pretexto**
D) Ataque al abrevadero

47. La práctica de instalar aplicaciones móviles desde sitios web y tiendas de aplicaciones distintos de los mercados oficiales se conoce como:

A) jailbreak
B) Enraizamiento
✓ **C) Carga lateral**
D) Desbloqueo del operador

48. ¿Cuáles son los rasgos característicos de una ID de sesión? (Seleccione todo lo que corresponda)

A) Permite al servidor identificar la sesión y recuperar los datos de la sesión correspondientes.
✓ **B) Un identificador único asignado por el sitio web a un usuario específico.**
C) Contiene las credenciales de autenticación del usuario, por ejemplo, nombre de usuario y contraseña.
✓ **D) Un dato que puede almacenarse en una cookie o incrustarse como un parámetro de URL**
✓ **E) Almacenado en el lado del cliente (en el navegador del usuario) y enviado al servidor con cada solicitud**
F) Un identificador único asignado a un servidor.

49. ¿Cuál de los siguientes facilita(n) los ataques de escalada de privilegios? (Seleccione todo lo que corresponda)

A) Vulnerabilidades del sistema/aplicación
B) Hash de contraseña
✓ **C) Configuraciones erróneas del sistema/aplicación**
D) Segmentación de red
✓ **E) Técnicas de ingeniería social**

50. Un ataque de punto, punto y barra también se conoce como:

A) Ataque de disociación
B) Ataque en el camino
✓ **C) Ataque transversal de directorio**
D) Ataque de degradación

51. ¿Cuál de las siguientes políticas se aplica a cualquier solicitud que no cumpla con los criterios definidos en una ACL?

A) Política de acceso justo
✓ **B) Política de denegación implícita**
C) confianza transitiva
D) Autenticación consciente del contexto

52. ¿Cuál de las respuestas enumeradas a continuación se refiere a una tecnología que proporciona control sobre el uso de un dispositivo móvil dentro de un área designada?

A) Geocerca
B) Seguimiento de dispositivos
C) Seguridad perimetral
D) Geolocalización

53. ¿Cuál de las respuestas enumeradas a continuación se refiere a la función principal del equilibrio de carga?

A) Mantiene copias idénticas de datos en múltiples servidores para mejorar la disponibilidad y confiabilidad de los datos.

✓ **B) Distribuye la carga de trabajo entre múltiples servidores para mejorar el rendimiento.**

✓ **C) Agrupa servidores para proporcionar alta disponibilidad y tolerancia a fallos.**

D) Distribuye contenido geográficamente entre múltiples servidores para mejorar el rendimiento, reducir la latencia y manejar grandes volúmenes de tráfico.

---

54. La implementación del cifrado completo del dispositivo es uno de los métodos para proteger los datos confidenciales en un teléfono inteligente. Cuando está habilitado, este tipo de cifrado funciona junto con el bloqueo de pantalla del teléfono, es decir, para descifrar el teléfono (que permanece cifrado siempre que está bloqueado), el usuario primero debe desbloquear la pantalla. En los dispositivos Android, los métodos de desbloqueo incluyen ingresar un PIN, una contraseña o dibujar un patrón simple con un dedo. Los dispositivos Apple utilizan códigos de acceso, reconocimiento facial (Face ID) y huellas dactilares (Touch ID).

A) Verdadero

B) FALSO

Respuesta no detectada automaticamente

---

55. ¿Cuál de las respuestas enumeradas a continuación se refiere al proceso de evaluación del entorno físico, como la distribución del edificio, para identificar posibles fuentes de interferencia y determinar la ubicación óptima de un WAP?

A) Análisis de brechas

B) Planificación de capacidad

✓ **C) Estudio del sitio**

D) Escaneo de vulnerabilidades

---

56. Un SSID es un identificador único (también conocido como nombre de red inalámbrica) para una WLAN. Las redes inalámbricas anuncian su presencia transmitiendo periódicamente SSID en un paquete especial llamado marco de baliza. En redes inalámbricas con funciones de seguridad deshabilitadas, conocer el SSID de la red es suficiente para acceder a la red. SSID también identifica el enrutador inalámbrico que actúa como WAP. Los enrutadores inalámbricos del mismo fabricante suelen configurarse con nombres SSID predeterminados (conocidos). Dado que varios dispositivos con el mismo SSID mostrado en la lista de redes disponibles crean confusión y fomentan el acceso accidental por parte de usuarios no autorizados (se aplica a redes que carecen de seguridad), cambiar el SSID predeterminado es una práctica recomendada.

A) Verdadero

B) FALSO

Respuesta no detectada automaticamente

---

57. ¿Cuál de las siguientes siglas se refiere a un método de autenticación de cliente utilizado en el modo WPA3 Personal?

A) SAE

B) IKE

C) PSK

D) AES

---

58. ¿Cuál de las siguientes respuestas se refiere a un protocolo de autenticación inalámbrica obsoleto desarrollado por Cisco?

A) PEAP

B) EAP-TTLS

✓ **C) SALTO**

D) EAP-TLS

---

59. ¿Cuál de las siguientes afirmaciones no se aplica a la web oscura?

A) Normalmente requiere software especializado para acceder a sus contenidos.

✓ **B) Forma una gran parte de la web profunda.**

C) No indexado por los motores de búsqueda tradicionales.

D) A menudo se asocia con el comercio de datos robados, malware y amenazas cibernéticas.

---

60. Un programa de divulgación responsable es un proceso formal establecido por una organización para alentar a los investigadores de seguridad y a los piratas informáticos éticos a informar las vulnerabilidades que descubren en los sistemas o software de la organización. Un programa de recompensas por errores es

un tipo específico de programa de divulgación responsable que ofrece recompensas financieras a los investigadores de seguridad por informar vulnerabilidades válidas.

A) Verdadero

B) FALSO

---

61. ¿Cuál de las afirmaciones enumeradas a continuación no se refiere a una técnica de respuesta y remediación de vulnerabilidades?

A) Aplicar actualizaciones o correcciones proporcionadas por proveedores de software para abordar la vulnerabilidad (parches)

B) Garantizar la recuperación financiera de los costos asociados con un ciberataque exitoso (seguro)

C) Dividir una red en zonas más pequeñas y aisladas para limitar el impacto potencial de una vulnerabilidad (segmentación)

D) Mitigar el riesgo asociado con una vulnerabilidad que no se puede reparar de inmediato mediante la implementación de medidas de seguridad alternativas (controles de compensación)

E) Retrasar o renunciar a un parche para un sistema específico, por ejemplo, cuando aplicar un parche puede no ser factible debido a problemas de compatibilidad o posibles interrupciones en sistemas críticos (excepciones y exenciones).

✓ F) Todas las respuestas anteriores son ejemplos de técnicas de respuesta y remediación de vulnerabilidades.

---

62. ¿Cuál de las siguientes respuestas se refiere a un marco de políticas que permite a los propietarios de dominios especificar cómo los receptores de correo electrónico deben manejar los correos electrónicos que no pasan las comprobaciones de autenticación?

✓ A) DKIM

B) FPS

C) PEM

✓ D) DMARC

---

63. ¿Cuál de las respuestas enumeradas a continuación se refiere a un método de autenticación que permite firmar un mensaje de correo electrónico saliente con una firma digital?

A) FPS

B) DKIM

C) DMARC

D) PEM

---

64. ¿Cuál de las siguientes respuestas se refiere a un mecanismo de autenticación de correo electrónico que permite a los propietarios de dominios especificar qué direcciones IP están autorizadas para enviar correos electrónicos en nombre de su dominio?

A) DMARC

B) PEM

C) DKIM

D) FPS

---

65. ¿Cuál de las respuestas enumeradas a continuación se refiere al proceso de mantener la integridad de archivos y datos?

A) DLP

B) SIEM

C) FIM

D) sha

---

66. ¿Cuál de las siguientes respuestas se refiere a una solución que ayuda a las organizaciones a mitigar los riesgos asociados con filtraciones de datos, amenazas internas e infracciones de cumplimiento?

A) EDR

B) DLP

C) SOY

D) UTM

---

67. ¿Cuál de las respuestas enumeradas a continuación se refiere a un tipo de medio que se puede utilizar como token de autenticación de hardware? (Seleccione todo lo que corresponda)

A) tarjeta inteligente

✓ B) llavero

✓ **C) clave de seguridad**

D) frase de contraseña

E) Lector biométrico

✓ **F) insignia rfid**

68. ¿Cuál de las respuestas enumeradas a continuación se refieren a las características de una llave de seguridad? (Seleccione 3 respuestas)

A) Se utiliza para generación de OTP, acceso remoto a vehículos y acceso a edificios.

✓ **B) Token de autenticación de hardware**

✓ **C) Normalmente, una memoria USB física o un dispositivo del tamaño de un llavero**

✓ **D) Utilizado principalmente para seguridad digital (2FA/MFA)**

E) Token de autenticación de software

F) Normalmente, una tarjeta de plástico del tamaño de una tarjeta de crédito con un chip integrado.

69. ¿Cuál de las siguientes respuestas se refiere a un término general utilizado para describir un grupo especializado dentro de una organización que se centra en tareas o áreas de responsabilidad específicas?

A) Concejo

B) consejo asesor

C) Comité

D) grupo de trabajo

70. ¿Cuál de las respuestas enumeradas a continuación se refiere a organizaciones del sector público que establecen y hacen cumplir leyes y regulaciones a nivel local, regional o nacional?

A) Entidades gubernamentales

B) Asociaciones comerciales

C) Organismos estatutarios

D) Agencias reguladoras

71. ¿Cuál de los términos enumerados a continuación se refiere a una situación en la que la imparcialidad de una parte podría ser cuestionada debido a posibles ganancias personales o financieras?

A) relación dual

B) Influencia indebida

✓ **C) Incompatibilidad**

D) Auto-negociación

72. ¿Cuál de los términos enumerados a continuación se utiliza para describir las acciones tomadas para abordar y mitigar los riesgos ya identificados?

A) debida diligencia

B) Estándar de atención

✓ **C) debido cuidado**

D) Deber fiduciario

73. ¿Cuál es la mejor contramedida contra los ataques de ingeniería social?

A) Conciencia situacional

B) Política de denegación implícita

✓ **C) Educación del usuario**

D) Fuertes controles de seguridad

74. Un tipo de documento que estipula reglas de comportamiento que deben seguir los usuarios de computadoras, redes y recursos asociados se denomina:

A) SLA

B) CLUF

✓ **C) PUA**

D) BPA

75. ¿Cuál de las siguientes respuestas se refiere a un método de autenticación secreto compartido utilizado en WPA, WPA2 y EAP?

A) PSK

B) 802.1X
C) SAE
D) TKIP
Respuesta no detectada automaticamente

76. ¿Cuál de las siguientes respuestas se refiere a una familia de funciones hash criptográficas utilizadas en una variedad de aplicaciones de seguridad, incluidas firmas digitales, almacenamiento de contraseñas, comunicaciones seguras y verificación de la integridad de los datos?

A) RSA
B) IDEA
C) AES
✓ D) sha

77. ¿Cuál de los términos enumerados a continuación se aplica al proceso de autenticación?

A) Ministerio de Asuntos Exteriores
B) MMC
C) DM
D) MFD

78. ¿Cuál de las siguientes respuestas se refiere a un microcontrolador integrado que se utiliza para arranque seguro, cifrado de disco y verificación de la integridad del sistema?

A) TPM
B) SoC
C) UEFI
D) HSM

79. Una tecnología de software diseñada para brindar confidencialidad a todo un dispositivo de almacenamiento de datos se conoce como:

A) TPM
✓ B) FDE
C) EFS
D) HSM

80. ¿Cuál de las respuestas enumeradas a continuación se refiere a un protocolo de autenticación de acceso remoto que periódicamente vuelve a autenticar al cliente a intervalos aleatorios para evitar el secuestro de sesión?

A) PAE
B) CAP
C) PAPILLA
D) PEAP

81. ¿Cuál de los acrónimos enumerados a continuación se refiere a una pieza de hardware y software/firmware asociado diseñado para proporcionar funciones criptográficas y de administración de claves?

A) EFS
✓ B) HSM
C) SFC
D) TPM

82. ¿Cuál de las respuestas enumeradas a continuación se refiere a un mecanismo de control de acceso basado en reglas asociado con archivos y/o directorios?

A) EFS
✓ B) FACL
C) FIM
D) NTFS

83. ¿Cuál de las respuestas enumeradas a continuación se refiere al proceso de mantener la integridad de archivos y datos?

A) DLP
B) SIEM
C) FIM
D) sha

84. ¿Cuál de las respuestas enumeradas a continuación se refiere a un protocolo de autenticación inalámbrica obsoleto desarrollado por Cisco?

A) PEAP
B) EAP-TTLS
C) SALTO
D) EAP-TLS

85. ¿Cuál de los siguientes combina una función hash criptográfica con una clave secreta para proporcionar un medio para verificar tanto la autenticidad como la integridad de un mensaje o datos?

A) MD5
B) DSA
✓ C) HMAC
D) DES

86. ¿Cuáles son los ejemplos de controles preventivos de seguridad? (Seleccione 3 respuestas)

A) Cifrado
B) identificación
C) Sensores
✓ D) Cortafuegos
E) Señales de advertencia
✓ F) software audiovisual

87. ¿Cuál de las respuestas enumeradas a continuación se refiere(s) a los controles de seguridad de detectives? (Seleccione todo lo que corresponda)

A) Iluminación
✓ B) Monitoreo de registros
C) Zona de arena
✓ D) Auditorías de seguridad
✓ E) circuito cerrado de televisión
✓ F) identificación
✓ G) Escaneo de vulnerabilidades

88. ¿Cuál de las respuestas enumeradas a continuación se refiere a una técnica criptográfica que verifica la autenticidad e integridad de documentos o mensajes digitales mediante el uso de un identificador cifrado único del remitente?

A) Firma digital
B) Función hash criptográfica
C) Certificado digital
D) Cifrado asimétrico

89. Una superficie de ataque es la suma de todos los puntos potenciales (vulnerabilidades) a través de los cuales un atacante puede interactuar o comprometer un sistema o red, lo que indica la exposición general a amenazas potenciales. Ejemplos de superficies de ataque pueden ser todo software, hardware e interfaces de red con fallas de seguridad conocidas. Un vector de amenaza representa el método o medio a través del cual se introduce o entrega una amenaza cibernética a un sistema objetivo. Describe la vía o vía utilizada por los atacantes para explotar las vulnerabilidades. Los tipos de vectores de amenazas comunes incluyen correos electrónicos de phishing, malware, descargas no autorizadas y técnicas de ingeniería social.

A) Verdadero
B) FALSO
Respuesta no detectada automaticamente

90. Una técnica de ingeniería social mediante la cual los atacantes, disfrazados de una solicitud legítima, intentan obtener acceso a información confidencial se denomina comúnmente:

A) Phishing
B) aplastando
C) Farmacéutica
D) suplantación de identidad

91. ¿Cuál de las siguientes respuestas se refiere a un ataque de ingeniería social que aprovecha los SMS o mensajes de texto para engañar a los destinatarios para que realicen acciones dañinas, como revelar información confidencial o hacer clic en enlaces maliciosos?

A) Farmacéutica
B) suplantación de identidad
C) quishing
✓ **D) aplastando**

92. ¿Cuál de los siguientes términos describe mejor información deliberadamente falsa o engañosa difundida con la intención de engañar o manipular?

A) Desinformación
B) Engaño
C) Iluminación de gas
D) Manipulación
Respuesta no detectada automaticamente

93. La práctica de instalar aplicaciones móviles desde sitios web y tiendas de aplicaciones distintos de los mercados oficiales se conoce como:

A) jailbreak
B) Enraizamiento
✓ **C) Carga lateral**
D) Desbloqueo del operador

94. ¿Cuál de las respuestas enumeradas a continuación se refiere a la función principal del equilibrio de carga?

A) Mantiene copias idénticas de datos en múltiples servidores para mejorar la disponibilidad y confiabilidad de los datos.
✓ **B) Distribuye la carga de trabajo entre múltiples servidores para mejorar el rendimiento.**
✓ **C) Agrupa servidores para proporcionar alta disponibilidad y tolerancia a fallos.**
D) Distribuye contenido geográficamente entre múltiples servidores para mejorar el rendimiento, reducir la latencia y manejar grandes volúmenes de tráfico.

95. Un SSID es un identificador único (también conocido como nombre de red inalámbrica) para una WLAN. Las redes inalámbricas anuncian su presencia transmitiendo periódicamente SSID en un paquete especial llamado marco de baliza. En redes inalámbricas con funciones de seguridad deshabilitadas, conocer el SSID de la red es suficiente para acceder a la red. SSID también identifica el enrutador inalámbrico que actúa como WAP. Los enrutadores inalámbricos del mismo fabricante suelen configurarse con nombres SSID predeterminados (conocidos). Dado que varios dispositivos con el mismo SSID mostrado en la lista de redes disponibles crean confusión y fomentan el acceso accidental por parte de usuarios no autorizados (se aplica a redes que carecen de seguridad), cambiar el SSID predeterminado es una práctica recomendada.

A) Verdadero
B) FALSO
Respuesta no detectada automaticamente

96. ¿Cuál de las siguientes siglas se refiere a un método de autenticación de cliente utilizado en el modo WPA3 Personal?

A) SAE
B) IKE
C) PSK
D) AES

97. ¿Cuál de las siguientes afirmaciones no se aplica a la web oscura?

A) Normalmente requiere software especializado para acceder a sus contenidos.

✓ B) Forma una gran parte de la web profunda.

C) No indexado por los motores de búsqueda tradicionales.

D) A menudo se asocia con el comercio de datos robados, malware y amenazas cibernéticas.

---

98. Un programa de divulgación responsable es un proceso formal establecido por una organización para alentar a los investigadores de seguridad y a los piratas informáticos éticos a informar las vulnerabilidades que descubren en los sistemas o software de la organización. Un programa de recompensas por errores es un tipo específico de programa de divulgación responsable que ofrece recompensas financieras a los investigadores de seguridad por informar vulnerabilidades válidas.

A) Verdadero

B) FALSO

---

99. ¿Cuál de las afirmaciones enumeradas a continuación no se refiere a una técnica de respuesta y remediación de vulnerabilidades?

A) Aplicar actualizaciones o correcciones proporcionadas por proveedores de software para abordar la vulnerabilidad (parches)

B) Garantizar la recuperación financiera de los costos asociados con un ciberataque exitoso (seguro)

C) Dividir una red en zonas más pequeñas y aisladas para limitar el impacto potencial de una vulnerabilidad (segmentación)

D) Mitigar el riesgo asociado con una vulnerabilidad que no se puede reparar de inmediato mediante la implementación de medidas de seguridad alternativas (controles de compensación)

E) Retrasar o renunciar a un parche para un sistema específico, por ejemplo, cuando aplicar un parche puede no ser factible debido a problemas de compatibilidad o posibles interrupciones en sistemas críticos (excepciones y exenciones).

✓ F) Todas las respuestas anteriores son ejemplos de técnicas de respuesta y remediación de vulnerabilidades.

---

100. ¿Qué técnica criptográfica se utiliza para evitar la eficacia de las tablas arcoíris a la hora de descifrar contraseñas hash?

A) Enmascaramiento de datos

B) Autenticación de dos factores (2FA)

C) Estiramiento clave

✓ D) Salazón

---

101. El proceso de mantener un registro documentado del manejo y movimiento de la evidencia para asegurar su integridad y admisibilidad en el tribunal se denomina:

A) cadena de custodia

B) Cadena de evidencia

C) Cadena de rendición de cuentas

D) cadena de responsabilidad

Respuesta no detectada automaticamente

1.3 - Explicar la importancia de los procesos de gestion del cambio.

Conceptos clave:

- Procesos de negocio: Aprobacion, Propietario, Analisis de impacto, Plan de retroceso, Ventana de mantenimiento
- Implicaciones tecnicas: Listas de permitidos/denegados, Tiempo de inactividad, Apps legacy, Dependencias
- Documentacion: Actualizar diagramas, politicas y procedimientos
- Control de versiones

Teoria detallada:

La gestion del cambio evita que cambios no controlados rompan la seguridad o la disponibilidad de sistemas.

PROCESO DE CAMBIO:

- Solicitud de cambio (RFC): solicitud formal del cambio
- Aprobacion: aprobacion por el Comite Asesor de Cambios (CAB)
- Analisis de impacto: evaluar que puede fallar
- Plan de retroceso (Backout plan): plan para revertir si algo va mal (CRITICO para el examen)
- Ventana de mantenimiento: tiempo autorizado para hacer el cambio (normalmente de madrugada)
- Propietario del cambio: persona responsable del cambio

IMPLICACIONES TECNICAS:

- Listas de permitidos/denegados: actualizar tras un cambio
- Tiempo de inactividad: planificar interrupciones
- Aplicaciones legacy: sistemas viejos que pueden romperse con nuevas dependencias
- Dependencias: un cambio en A puede romper B, C y D

DOCUMENTACION: siempre actualizar diagramas de red, politicas y procedimientos tras un cambio. Control de versiones para el codigo y configuraciones.

Regla de oro del examen: si una pregunta menciona 'que hacer antes de implementar un cambio critico', la respuesta casi siempre incluye 'plan de retroceso' y 'analisis de impacto'.

Preguntas de practica (4):

1. ¿Cuál de las respuestas enumeradas a continuación se refiere a un cifrado de flujo obsoleto utilizado en algunas aplicaciones heredadas, como WEP?

A) RSA
B) DES
C) SSL
D) RC4

---

2. ¿Cuál de los términos enumerados a continuación se refiere al seguimiento y administración de componentes de aplicaciones de software, como bibliotecas de terceros y otras dependencias?

A) Control de versiones
B) Monitoreo de paquetes
C) Aplicación de la configuración
D) Endurecimiento de aplicaciones

---

3. ¿Cuál de las siguientes respuestas se refiere a un cifrado de flujo obsoleto utilizado en algunas aplicaciones heredadas, como WEP?

A) RSA
B) DES
C) SSL
D) RC4

---

4. ¿Cuál de los términos enumerados a continuación se refiere al seguimiento y administración de componentes de aplicaciones de software, como bibliotecas de terceros y otras dependencias?

A) Control de versiones
B) Monitoreo de paquetes
C) Aplicación de la configuración
D) Endurecimiento de aplicaciones

1.4 - Explicar la importancia de usar soluciones criptograficas adecuadas.

Conceptos clave:

- PKI: Clave publica, Clave privada, Deposito de claves
- Cifrado: Disco completo, Particion, Archivo, Volumen, BD, Simetrico, Asimetrico
- Herramientas: TPM, HSM, Sistema de gestion de claves, Enclave seguro
- Ofuscacion: Esteganografia, Tokenizacion, Enmascaramiento de datos
- Hashing, Salting, Firmas digitales, Estiramiento de clave, Blockchain
- Certificados: CA, CRL, OCSP, CSR, Wildcard, Autofirmado

Teoria detallada:

PKI (Infraestructura de Clave Publica):

- Clave publica: se comparte con todos, cifra datos o verifica firmas
- Clave privada: solo la tiene el dueno, descifra datos o firma
- Deposito de claves (Key escrow): copia de la clave privada guardada por un tercero (para recuperacion)
- Autoridad de Certificacion (CA): entidad que firma y emite certificados digitales
- CRL (Lista de Revocacion de Certificados): lista de certificados revocados

• OCSP: protocolo para verificar en tiempo real si un certificado esta revocado

CIFRADO SIMETRICO vs ASIMETRICO:

• Simetrico: misma clave para cifrar y descifrar. RAPIDO. Problema: distribucion segura de la clave
Algoritmos: AES (estandar actual, 128/256 bits), 3DES (obsoleto), ChaCha20

• Asimetrico: par de claves publica/privada. LENTO. Resuelve el problema de distribucion
Algoritmos: RSA (2048+ bits), ECC (mas eficiente), Diffie-Hellman

• En la practica: asimetrico intercambia la clave simetrica, luego simetrico para los datos (TLS/HTTPS)

HASHING - No es cifrado, es una huella digital:

• Produce una salida de longitud fija a partir de cualquier entrada
• Es UNIDIRECCIONAL: no se puede revertir
• Algoritmos: MD5 (roto), SHA-1 (obsoleto), SHA-256/SHA-3 (actuales)
• Salting: anadir un valor aleatorio antes de hashear para evitar ataques de tabla arcoiris
• Estiramiento de clave (Key stretching): hacer el hash mas lento intencionalmente (bcrypt, PBKDF2, Argon2)

FIRMAS DIGITALES:

1. El emisor genera un hash del mensaje
2. Cifra ese hash con su CLAVE PRIVADA → firma digital
3. El receptor descifra la firma con la CLAVE PUBLICA del emisor
4. Compara el hash: si coincide, el mensaje es autentico e integro

Garantiza: autenticidad + integridad + no repudio

OTROS CONCEPTOS:

• TPM (Modulo de Plataforma Confiable): chip en la placa base que almacena claves y verifica el arranque seguro
• HSM (Modulo de Seguridad Hardware): dispositivo dedicado a operaciones criptograficas de alta seguridad
• Esteganografia: ocultar informacion dentro de otros archivos (imagen, audio) sin que sea visible
• Tokenizacion: sustituir datos sensibles por un token sin valor criptografico (usado en pagos)
• Enmascaramiento de datos: ocultar parte de los datos (ej: mostrar solo los ultimos 4 digitos de una tarjeta)
• Blockchain: registro distribuido e inmutable, cada bloque encadena el hash del anterior

CERTIFICADOS DIGITALES:

• Certificado wildcard: cubre un dominio y todos sus subdominios (*.ejemplo.com)
• SAN (Nombre Alternativo del Sujeto): un certificado para multiples dominios
• Autofirmado: firmado por uno mismo, no validado por CA externa
• CSR (Solicitud de Firma de Certificado): solicitud enviada a la CA para obtener un certificado

Preguntas de practica (354):

1. En el cifrado asimétrico, cualquier mensaje cifrado con el uso de una clave pública sólo puede descifrarse aplicando el mismo algoritmo y una clave privada coincidente (y viceversa).

A) Verdadero
B) FALSO

---

2. ¿Cuál de los siguientes algoritmos no entra en la categoría de cifrado asimétrico? (Seleccione todo lo que corresponda)

A) AES
✓ B) DES
C) DHE
D) ECC
✓ E) IDEA
✓ F) RC4
G) RSA

---

3. ¿Cuál de las respuestas enumeradas a continuación se refiere a una técnica criptográfica que verifica la autenticidad e integridad de documentos o mensajes digitales mediante el uso de un identificador cifrado único del remitente?

A) Firma digital
B) Función hash criptográfica
C) Certificado digital

D) Cifrado asimétrico

4. ¿Cuál de las respuestas enumeradas a continuación se refiere a un conjunto de estándares y especificaciones que definen diversas técnicas criptográficas, incluidos formatos para claves públicas, claves privadas, firmas digitales y certificados digitales?

A) ITIL
B) RFC
C) PKCS
D) ISO/CEI

5. ¿Cuál de las respuestas enumeradas a continuación se refiere a un conjunto de estándares y especificaciones que definen diversas técnicas criptográficas, incluidos formatos para claves públicas, claves privadas, firmas digitales y certificados digitales?

A) ITIL
B) RFC
C) PKCS
D) ISO/CEI

6. ¿Cuál de las siguientes respuestas se refiere a un algoritmo de cifrado de bloque de clave simétrica obsoleto (en gran medida reemplazado por AES)?

A) ECDSA
B) RSA
C) IDEA
D) DSA

7. ¿Cuál de las respuestas enumeradas a continuación se refieren a DSA? (Seleccione 3 respuestas)

A) Algoritmo asimétrico
B) Utilizado para el proceso de intercambio de claves.
C) Algoritmo simétrico
✓ D) Proporciona autenticación, integridad y no repudio.
✓ E) Diseñado específicamente para crear y verificar firmas digitales.
F) Utilizado para cifrado

8. ¿Cuál de las siguientes respuestas se refiere a un algoritmo de cifrado de bloque de clave simétrica obsoleto (en gran medida reemplazado por AES)?

A) ECDSA
B) RSA
C) IDEA
D) DSA
Respuesta no detectada automaticamente

9. ¿Cuál de las siguientes respuestas se refiere a protocolos de cifrado y funciones hash criptográficas obsoletas o inseguras? (Seleccione todo lo que corresponda)

A) DES
B) AES-256
✓ C) MD5
D) ECC
✓ E) SHA-1
✓ F) SSL
✓ G) RC4

10. Ejemplos de técnicas utilizadas para cifrar información incluyen el cifrado simétrico (también llamado cifrado de clave pública) y el cifrado asimétrico (también llamado cifrado de clave secreta o cifrado de clave de sesión).

A) Verdadero
✓ B) FALSO

11. ¿Cuáles de los algoritmos enumerados a continuación no son cifrados simétricos? (Seleccione 3 respuestas)

A) AES

✓ B) DES

✓ C) DHE

✓ D) ECC

E) IDEA

F) RC4

✓ G) RSA

---

12. ¿Cuál de las siguientes respuestas se refiere a un microcontrolador integrado que se utiliza para arranque seguro, cifrado de disco y verificación de la integridad del sistema?

A) TPM

B) SoC

C) UEFI

✓ D) HSM

---

13. ¿Cuál de las siguientes respuestas se refiere a una familia de funciones hash criptográficas diseñadas para diversas aplicaciones relacionadas con la seguridad, incluidas firmas digitales, almacenamiento de contraseñas, comunicaciones seguras y verificación de la integridad de los datos?

A) RSA

B) AES

C) PKCS

✓ D) sha

---

14. Dadas las limitaciones computacionales de los dispositivos IoT, las tarjetas inteligentes y los dispositivos móviles, ¿cuál de los siguientes algoritmos de firma digital sería la opción más eficiente debido a su menor tamaño de clave y menores requisitos de procesamiento?

A) RSA

B) ECDHE

C) DSA

✓ D) ECDSA

E) ECC

---

15. ¿Cuál de las respuestas enumeradas a continuación se refiere a una técnica que permite convertir datos de entrada en una cadena de tamaño fijo, lo que dificulta revertir o recuperar los datos originales?

✓ A) Ofuscación

✓ B) Tokenización

C) hash

D) Cifrado

---

16. ¿Cuál de las siguientes respuestas se refiere a una familia de funciones hash criptográficas utilizadas en una variedad de aplicaciones de seguridad, incluidas firmas digitales, almacenamiento de contraseñas, comunicaciones seguras y verificación de la integridad de los datos?

A) RSA

B) IDEA

C) AES

✓ D) sha

---

17. ¿Cuál de las siguientes respuestas se refiere a un microcontrolador integrado que se utiliza para arranque seguro, cifrado de disco y verificación de la integridad del sistema?

A) TPM

B) SoC

C) UEFI

D) HSM

---

18. ¿Cuál de las siguientes respuestas se refiere a un criptosistema de clave pública utilizado para firmas digitales, intercambio seguro de claves y cifrado?

A) DHE
B) RSA
C) AES
D) DSA

19. ¿Cuál es la forma más rápida de comprobar la validez de un certificado digital?

A) CRL
B) OSPF
C) RSE
✓ D) OCSP

20. ¿Cuál de las respuestas enumeradas a continuación se refiere a un método de codificación (y un formato de archivo) para almacenar objetos criptográficos como certificados X.509, CRL y claves privadas?

A) BCE
✓ B) PEM
C) FIM
D) PFS

21. Dadas las limitaciones computacionales de los dispositivos IoT, las tarjetas inteligentes y los dispositivos móviles, ¿cuál de los siguientes algoritmos de firma digital sería la opción más eficiente debido a su menor tamaño de clave y menores requisitos de procesamiento?

A) RSA
B) ECDHE
C) DSA
✓ D) ECDSA
E) ECC

22. Un tipo de documento digital que verifica la identidad de un individuo, dispositivo, servicio u organización en las comunicaciones en línea se conoce como:

A) Clave de cifrado
✓ B) Certificado digital
C) Token de identidad
D) Firma digital

23. ¿Cuál de las respuestas enumeradas a continuación se refiere a un protocolo que permite consultar bajo demanda el estado de revocación de un certificado digital?

A) CSP
✓ B) OCSP
C) DN
D) CRL

24. ¿Cuál de las respuestas enumeradas a continuación se refiere a una técnica que permite convertir datos de entrada en una cadena de tamaño fijo, lo que dificulta revertir o recuperar los datos originales?

A) Ofuscación
B) Tokenización
✓ C) hash
D) Cifrado

25. Un sistema jerárquico para la creación, gestión, almacenamiento, distribución y revocación de certificados digitales se conoce como:

A) PKI
B) REAL ACADEMIA DE BELLAS ARTES
C) PKCS
D) California

26. ¿Cuál es el uso típico de una clave pública?

A) Cifrado de datos
B) Descifrado de datos
C) Autenticación de usuario/dispositivo
D) Todo lo anterior

27. ¿Cuál de las siguientes respuestas se refiere a un dispositivo de almacenamiento de datos equipado con funcionalidad de cifrado a nivel de hardware?

A) HSM
B) TPM
C) EFS
✓ D) SED

28. ¿Cuál de las siguientes respuestas se refiere a un algoritmo de cifrado de bloque de clave simétrica heredado?

A) RC4
✓ B) DES
C) RSA
D) DSA

29. Las funciones hash encuentran uso en una variedad de aplicaciones, que incluyen:

A) Criptografía
B) Verificación de la integridad de los datos
C) Verificación y almacenamiento de contraseña
D) Firmas digitales
E) tecnología de cadena de bloques
✓ F) Todo lo anterior

30. ¿Cuál de las respuestas enumeradas a continuación se refiere a un sistema jerárquico para la creación, gestión, almacenamiento, distribución y revocación de certificados digitales?

A) PKI
B) REAL ACADEMIA DE BELLAS ARTES
C) PKCS
D) California

31. ¿Cuál de las siguientes respuestas se refiere a un dispositivo de almacenamiento de datos equipado con funcionalidad de cifrado a nivel de hardware?

A) HSM
B) TPM
C) EFS
✓ D) SED

32. ¿Cuál de las soluciones enumeradas a continuación permite comprobar si un certificado digital ha sido revocado?

A) LOC
✓ B) CRL
C) RSE
D) OSPF

33. ¿Cuál de las siguientes respuestas se refiere a un archivo criptográfico generado por una entidad que solicita un certificado digital a una CA?

A) OID
✓ B) RSE
C) DN
D) CRL

34. ¿Cuál de las respuestas enumeradas a continuación describe las características de ECDSA? (Seleccione todo lo que corresponda)

A) Proporciona autenticación, integridad y no repudio.

✓ **B) Basado en criptografía de curva elíptica**

C) Diseñado para el cifrado de datos

✓ **D) Diseñado específicamente para crear y verificar firmas digitales.**

✓ **E) Más eficiente computacionalmente que otros algoritmos de firma**

F) Habilita el proceso de intercambio de claves.

35. ¿Cuáles son las aplicaciones de PGP? (Seleccione 3 respuestas)

A) Comprimir datos

✓ **B) Cifrar y descifrar datos**

✓ **C) Firmar y verificar firmas digitales**

✓ **D) Gestión de claves públicas y privadas.**

E) Asegurar el tráfico del sitio web

36. ¿Cuál de las siguientes respuestas se refiere a un dispositivo de almacenamiento de datos equipado con funcionalidad de cifrado a nivel de hardware?

A) HSM

B) TPM

C) EFS

✓ **D) SED**

37. ¿Cuál de las respuestas enumeradas a continuación se refiere a una situación en la que los datos confidenciales se almacenan en una ubicación separada y se pueden recuperar con un reemplazo no confidencial que también se puede procesar como los datos originales sin el riesgo de revelar el contenido de los datos originales?

A) enmascaramiento

✓ **B) Ofuscación**

C) Cifrado

✓ **D) Tokenización**

38. ¿Qué técnica criptográfica se utiliza para evitar la eficacia de las tablas arcoíris a la hora de descifrar contraseñas hash?

A) Enmascaramiento de datos

B) Autenticación de dos factores (2FA)

C) Estiramiento clave

✓ **D) Salazón**

39. ¿Cuáles de las respuestas que se enumeran a continuación se refieren a métodos comunes de autenticación de dispositivos utilizados dentro del marco AAA? (Seleccione 3 respuestas)

A) Nombres de usuario y contraseñas

✓ **B) Certificados digitales**

✓ **C) direcciones IP**

D) Ministerio de Asuntos Exteriores

E) Autenticación biométrica

✓ **F) Direcciones MAC**

40. ¿Cuál de las respuestas enumeradas a continuación se refiere a tecnología de software diseñada para brindar confidencialidad a todo un dispositivo de almacenamiento de datos?

A) TPM

B) FDE

C) EFS

D) HSM

41. La especificación MIME extiende el formato de los mensajes de correo electrónico más allá del texto plano, permitiendo la transferencia de archivos de gráficos, audio y vídeo a través del sistema de correo de Internet. S/MIME es una versión mejorada del protocolo MIME que habilita funciones de seguridad del correo electrónico al proporcionar cifrado, autenticación, integridad de mensajes y otros servicios relacionados.

A) Verdadero

B) FALSO

42. ¿Cuál de las respuestas enumeradas a continuación se refiere a un conjunto de protocolos y tecnologías que proporcionan cifrado, autenticación e integridad de datos para el tráfico de red?

A) TLS
B) SSH
✓ C) IPSec
D) vpn

43. Un protocolo de cifrado utilizado principalmente en redes Wi-Fi que implementan el estándar de seguridad WPA2 se llama:

A) TKIP
✓ B) CCMP
C) SSL
D) IPSec

44. ¿Cuál de las respuestas enumeradas a continuación se refiere a un cifrado de flujo obsoleto utilizado en algunas aplicaciones heredadas, como WEP?

A) RSA
B) DES
C) SSL
D) RC4

45. En criptografía, la cantidad de bits de una clave utilizada por un algoritmo criptográfico se denomina tamaño de clave o longitud de clave. La longitud de la clave determina el número máximo de combinaciones necesarias para romper el algoritmo de cifrado; por lo tanto, normalmente una clave más larga significa una seguridad criptográfica más sólida.

A) Verdadero
B) FALSO

46. ¿Cuál de las siguientes respuestas se refiere a un servidor centralizado que se utiliza para distribuir claves criptográficas y autenticar usuarios y servicios dentro de una red informática?

A) PKI
B) RAS
✓ C) KDC
D) NAS

47. ¿Cuál de las siguientes respuestas se refiere a algoritmos utilizados para generar y verificar firmas digitales? (Seleccione 3 respuestas)

A) ECDSA
B) RSA
C) ECDHE
D) DSA
E) GPG/PGP

48. ¿Cuál de las respuestas enumeradas a continuación se refiere a un tercero de confianza responsable de emitir, revocar y gestionar los certificados digitales?

A) REAL ACADEMIA DE BELLAS ARTES
B) DN
C) California
D) CSP

49. ¿Cuál de las siguientes respuestas se puede utilizar para describir los certificados digitales autofirmados? (Seleccione 3 respuestas)

A) Respaldado por un tercero conocido y confiable
✓ B) Los navegadores web y otras aplicaciones no confían de forma predeterminada
✓ C) Se utiliza en entornos confiables, como redes internas y entornos de desarrollo.
D) Adecuado para sitios web y otras aplicaciones accesibles al público

E) Confiado de forma predeterminada por los navegadores web y otras aplicaciones

✓ F) No respaldado por un tercero conocido y confiable

50. Los certificados digitales de terceros, emitidos por CA confiables, son automáticamente confiables para la mayoría de los navegadores y sistemas operativos, implican un costo y requieren la validación de la identidad del solicitante. Por el contrario, los certificados autofirmados, emitidos por la propia entidad, no son de confianza automáticamente, son de creación y uso gratuitos y no requieren validación por parte de una CA.

A) Verdadero

B) FALSO

Respuesta no detectada automaticamente

51. ¿Cuál de las respuestas enumeradas a continuación se refiere a un modelo de confianza PKI?

A) Modelo de CA única

B) Modelo jerárquico (CA raíz + CA intermedias)

C) Modelo de malla (CA con certificación cruzada)

D) Modelo web de confianza (todas las CA funcionan como CA raíz)

E) Modelo de cadena de confianza (múltiples CA en una cadena secuencial)

F) Modelo puente (certificación cruzada entre PKI independientes)

G) Modelo híbrido (combinando aspectos de diferentes modelos)

✓ 8) Todo lo anterior

52. Un tipo de certificado digital que se puede utilizar para proteger varios subdominios dentro de un dominio principal se conoce como:

A) Certificado de firma raíz

✓ B) Certificado de nombre alternativo del sujeto (SAN)

C) Certificado de validación extendida (EV)

✓ D) Certificado comodín

53. ¿Cuál de los siguientes facilita(n) los ataques de escalada de privilegios? (Seleccione todo lo que corresponda)

A) Vulnerabilidades del sistema/aplicación

B) Hash de contraseña

✓ C) Configuraciones erróneas del sistema/aplicación

D) Segmentación de red

✓ E) Técnicas de ingeniería social

54. ¿Cuál de las siguientes URL es un indicador potencial de un ataque de cruce de directorio?

A) http://www.example.com/var/../etc/passwd

B) http://www.example.com/var/www/../../etc/passwd

C) http://www.example.com/var/www/files/../../../etc/passwd

D) http://www.example.com/var/www/files/images/../../../../etc/passwd

✓ E) Cualquiera de los anteriores

55. ¿Cuál de las siguientes respuestas no se refiere al concepto de aislamiento de sistema/aplicación?

A) Virtualización

B) Contenedorización

C) Zona de arena

✓ D) Cifrado de datos

56. ¿Qué parte de IPsec proporciona confidencialidad, integridad de datos y autenticación?

A) AES

B) sha

C) Ah

✓ D) ESP

57. ¿Cuál de las respuestas enumeradas a continuación se refiere a las ventajas de la segmentación como método para proteger los datos? (Seleccione 3 respuestas)

A) Mejora la seguridad al limitar la propagación de ciberataques

✓ B) Ayuda a las organizaciones a cumplir con los requisitos normativos de datos aislando y protegiendo tipos de datos específicos

C) Proporciona seguridad para los datos en tránsito con el uso de cifrado.

D) Garantiza la recuperación de datos en caso de eliminación accidental o fallas del sistema.

✓ E) Proporciona un mejor control sobre el acceso de los usuarios a datos confidenciales.

---

58. ¿Cuál de las siguientes siglas se refiere a un método de autenticación de cliente utilizado en el modo WPA3 Personal?

A) SAE

B) IKE

C) PSK

D) AES

---

59. ¿Cuál de las respuestas enumeradas a continuación se refiere a un protocolo de red seguro utilizado para proporcionar cifrado, autenticación e integridad para la comunicación multimedia en tiempo real?

A) IPSec

B) SORBO

C) VoIP

✓ D) SRTP

---

60. ¿Cuál de las respuestas enumeradas a continuación se refiere a un método de autenticación que permite firmar un mensaje de correo electrónico saliente con una firma digital?

A) FPS

B) DKIM

C) DMARC

D) PEM

---

61. ¿Cuál de las respuestas enumeradas a continuación se refiere a un estándar criptográfico (y un formato de archivo) utilizado para el almacenamiento y transmisión de claves privadas en comunicaciones por correo electrónico?

A) PEM

B) DMARC

C) FPS

D) DKIM

---

62. ¿Cuál de las respuestas enumeradas a continuación se refiere a una herramienta de software diseñada específicamente para almacenar y administrar las credenciales de inicio de sesión?

A) BitLocker

B) Administrador de contraseñas

C) depósito de claves

D) Bóveda de contraseñas

---

63. ¿Qué protocolo de seguridad inalámbrica ha quedado obsoleto en favor de estándares más nuevos debido a vulnerabilidades conocidas resultantes de fallas de implementación?

A) PAE

B) AES

C) WPA2

✓ D) WEP

---

64. ¿Cuál de las respuestas enumeradas a continuación se refiere a un conjunto de protocolos y tecnologías que proporcionan cifrado, autenticación e integridad de datos para el tráfico de red?

A) TLS

B) SSH

C) IPSec

D) vpn

---

65. ¿Cuál de las siguientes respuestas se refiere a un método para crear y verificar firmas digitales?

A) DHE
B) AES
C) DSA
D) sha

66. Una tecnología de software diseñada para brindar confidencialidad a todo un dispositivo de almacenamiento de datos se conoce como:

A) TPM
✓ B) FDE
C) EFS
D) HSM

67. ¿Cuál de los acrónimos enumerados a continuación se refiere a una pieza de hardware y software/firmware asociado diseñado para proporcionar funciones criptográficas y de administración de claves?

A) EFS
✓ B) HSM
C) SFC
D) TPM

68. La especificación MIME amplía el formato de los mensajes de correo electrónico más allá del simple texto, permitiendo la transferencia de archivos de gráficos, audio y vídeo a través del sistema de correo de Internet. S/MIME es una versión mejorada del protocolo MIME que habilita funciones de seguridad del correo electrónico al proporcionar cifrado, autenticación, integridad de mensajes y otros servicios relacionados.

A) Verdadero
B) FALSO

69. ¿Cuál de las respuestas enumeradas a continuación se refiere a una operación lógica comúnmente utilizada en el contexto de la ciberseguridad, particularmente en técnicas de cifrado y ofuscación?

A) Y
B) O
C) NO
D) XOR
Respuesta no detectada automaticamente

70. ¿Cuál de las siguientes respuestas se refiere a un cifrado de flujo obsoleto utilizado en algunas aplicaciones heredadas, como WEP?

A) RSA
B) DES
C) SSL
D) RC4

71. Un componente de MS Windows que permite el cifrado de archivos individuales se llama:

A) SED
✓ B) EFS
C) BitLocker
D) FDE

72. ¿Qué protocolo criptográfico está diseñado para proporcionar comunicaciones seguras a través de una red informática y es el sucesor de SSL?

A) IPSec
✓ B) TLS
C) AES
D) CCMP

73. Un modo de cifrado de bloques que combina un contador único con una clave de cifrado para generar un flujo de bloques de datos pseudoaleatorios que luego se utilizan para cifrar datos se denomina:

A) CBC

B) GCM
C) CFB
✓ **D) marca comunitaria**

74. ¿Qué modo de cifrado en bloque combina CTM para el cifrado con un mecanismo de autenticación para garantizar la confidencialidad e integridad de los datos?

A) CBC
✓ **B) GCM**
C) BCE
D) CFB

75. ¿Cuál de las siguientes respuestas se refiere a algoritmos utilizados para generar y verificar firmas digitales? (Seleccione 3 respuestas)

A) ECDSA
B) RSA
C) ECDHE
D) DSA
E) GPG/PGP

76. ¿Cuál de las respuestas enumeradas a continuación se refiere a un tercero de confianza responsable de emitir, revocar y gestionar los certificados digitales?

A) REAL ACADEMIA DE BELLAS ARTES
B) DN
✓ **C) California**
D) CSP

77. ¿Cuál de las siguientes respuestas se puede utilizar para describir los certificados digitales autofirmados? (Seleccione 3 respuestas)

A) Respaldado por un tercero conocido y confiable
✓ **B) Los navegadores web y otras aplicaciones no confían de forma predeterminada**
✓ **C) Se utiliza en entornos confiables, como redes internas y entornos de desarrollo.**
D) Adecuado para sitios web y otras aplicaciones accesibles al público
E) Confiado de forma predeterminada por los navegadores web y otras aplicaciones
✓ **F) No respaldado por un tercero conocido y confiable**

78. Los certificados digitales de terceros, emitidos por CA confiables, son automáticamente confiables para la mayoría de los navegadores y sistemas operativos, implican un costo y requieren la validación de la identidad del solicitante. Por el contrario, los certificados autofirmados, emitidos por la propia entidad, no son de confianza automáticamente, son de creación y uso gratuitos y no requieren validación por parte de una CA.

A) Verdadero
B) FALSO
Respuesta no detectada automaticamente

79. ¿Cuál de las respuestas enumeradas a continuación se refiere a un modelo de confianza PKI?

A) Modelo de CA única
B) Modelo jerárquico (CA raíz + CA intermedias)
C) Modelo de malla (CA con certificación cruzada)
D) Modelo web de confianza (todas las CA funcionan como CA raíz)
E) Modelo de cadena de confianza (múltiples CA en una cadena secuencial)
F) Modelo puente (certificación cruzada entre PKI independientes)
G) Modelo híbrido (combinando aspectos de diferentes modelos)
✓ **8) Todo lo anterior**

80. Un tipo de certificado digital que se puede utilizar para proteger varios subdominios dentro de un dominio principal se denomina:

A) Certificado de firma raíz

✓ **B) Certificado de nombre alternativo del sujeto (SAN)**

C) Certificado de validación extendida (EV)

✓ **D) Certificado comodín**

81. ¿Cuál de las siguientes URL es un indicador potencial de un ataque de cruce de directorio?

A) http://www.example.com/var/../etc/passwd

B) http://www.example.com/var/www/../../etc/passwd

C) http://www.example.com/var/www/files/../../../etc/passwd

D) http://www.example.com/var/www/files/images/../../../../etc/passwd

✓ **E) Cualquiera de los anteriores**

82. ¿Cuál de las respuestas enumeradas a continuación se refiere a las ventajas de la segmentación como método para proteger los datos? (Seleccione 3 respuestas)

A) Mejora la seguridad al limitar la propagación de ciberataques

✓ **B) Ayuda a las organizaciones a cumplir con los requisitos normativos de datos aislando y protegiendo tipos de datos específicos**

C) Proporciona seguridad para los datos en tránsito con el uso de cifrado.

D) Garantiza la recuperación de datos en caso de eliminación accidental o fallas del sistema.

✓ **E) Proporciona un mejor control sobre el acceso de los usuarios a datos confidenciales.**

83. ¿Cuál de las siguientes siglas se refiere a un método de autenticación de cliente utilizado en el modo WPA3 Personal?

A) SAE

B) IKE

C) PSK

D) AES

84. ¿Cuál de los esquemas de cifrado inalámbrico enumerados a continuación ofrece el mayor nivel de protección?

A) WPS

✓ **B) WPA3**

C) AES

D) TKIP

85. ¿Cuál de las respuestas enumeradas a continuación se refiere a una herramienta de software diseñada específicamente para almacenar y administrar las credenciales de inicio de sesión?

A) BitLocker

B) Administrador de contraseñas

C) depósito de claves

D) Bóveda de contraseñas

86. ¿Cuál de las siguientes respuestas se puede utilizar para describir los controles técnicos de seguridad? (Seleccione 3 respuestas)

A) Enfocados en proteger los bienes materiales

✓ **B) A veces se les llama controles de seguridad lógicos.**

✓ **C) Ejecutado por sistemas informáticos (en lugar de personas)**

D) También conocidos como controles administrativos.

✓ **E) Implementado con tecnología.**

F) Principalmente implementado y ejecutado por personas (a diferencia de los sistemas informáticos)

87. ¿Cuál de las siguientes respuestas se refiere a los rasgos característicos de los controles de seguridad gerenciales? (Seleccione 3 respuestas)

A) También conocidos como controles administrativos.

B) A veces denominados controles de seguridad lógicos.

✓ **C) Enfocados en reducir el riesgo de incidentes de seguridad**

D) Ejecutado por sistemas informáticos (en lugar de personas)

✓ **E) Documentado en políticas escritas.**

F) Enfocados en proteger los bienes materiales

88. ¿Cuál de las respuestas enumeradas a continuación se puede utilizar para describir los controles de seguridad operativos? (Seleccione 3 respuestas)

A) También conocidos como controles administrativos.

✓ B) Enfocados en los procedimientos del día a día de una organización.

C) Ejecutado por sistemas informáticos (en lugar de personas)

✓ D) Se utiliza para garantizar que el equipo continúe funcionando según lo especificado.

E) Enfocados en la gestión del riesgo

✓ F) Principalmente implementado y ejecutado por personas (a diferencia de los sistemas informáticos)

89. ¿Cuál de las respuestas enumeradas a continuación se refiere a controles de seguridad diseñados para disuadir, detectar y prevenir el acceso no autorizado, el robo, el daño o la destrucción de activos materiales?

A) Controles de seguridad gerenciales

✓ B) Controles de seguridad física

C) Controles técnicos de seguridad

D) Controles operativos de seguridad

90. ¿Cuáles son los ejemplos de controles preventivos de seguridad? (Seleccione 3 respuestas)

A) Cifrado

B) identificación

C) Sensores

✓ D) Cortafuegos

E) Señales de advertencia

✓ F) software audiovisual

91. ¿Cuál de las respuestas enumeradas a continuación se refiere(s) a los controles de seguridad de detectives? (Seleccione todo lo que corresponda)

A) Iluminación

✓ B) Monitoreo de registros

C) Zona de arena

✓ D) Auditorías de seguridad

✓ E) circuito cerrado de televisión

✓ F) identificación

✓ G) Escaneo de vulnerabilidades

92. ¿Cuál de las respuestas enumeradas a continuación se refiere(s) a controles de seguridad compensatorios? (Seleccione todo lo que corresponda)

A) Sistemas de energía de respaldo

B) Videovigilancia

✓ C) Ministerio de Asuntos Exteriores

✓ D) Zona de pruebas de aplicaciones

✓ E) Segmentación de red

93. ¿Cuál de los siguientes términos entran en la categoría de controles de seguridad directivos? (Seleccione 2 respuestas)

A) PIR

✓ B) PUA

C) identificación

D) Ministerio de Asuntos Exteriores

E) IPS

94. En la arquitectura de seguridad AAA, el proceso de otorgar o denegar acceso a recursos se conoce como:

A) Autenticación

✓ B) Autorización

✓ C) Contabilidad

95. ¿Cuál de las siguientes soluciones proporciona la funcionalidad AAA? (Seleccione todo lo que corresponda)

A) CAP

✓ **B) TACACS+**

C) PAPILLA

✓ **D) RADIO**

E) MS-CHAP

---

96. Un archivo Honey se puede utilizar para:

A) Atraer a los ciberatacantes

B) Activar alertas cuando se accede

C) Monitoreo de la actividad de la red

✓ **D) Todo lo anterior**

---

97. SFTP es una extensión del protocolo FTP que agrega soporte para cifrado SSL/TLS.

A) Verdadero

✓ **B) FALSO**

---

98. Un sistema que utiliza una red pública (como Internet) como medio para crear conexiones privadas cifradas entre ubicaciones remotas se denomina:

A) WWAN

✓ **B) vpn**

C) CACEROLA

D) VLAN

---

99. ¿Cuál de las respuestas enumeradas a continuación se refiere a un método de autenticación secreto compartido utilizado en WPA, WPA2 y EAP?

A) PSK

B) 802.1X

C) SAE

D) TKIP

---

100. ¿Cuál de los algoritmos criptográficos enumerados a continuación es el menos vulnerable a los ataques?

A) AES

B) DES

C) RC4

D) 3DES

Respuesta no detectada automaticamente

---

101. ¿Qué modo de bloque transforma un cifrado de bloque en un cifrado de flujo que permite el cifrado de bits o bytes de datos individuales?

A) CFB

B) CBC

C) GCM

D) BCE

Respuesta no detectada automaticamente

---

102. En criptografía y seguridad, el término "enclave seguro" generalmente se refiere a un entorno de hardware o software protegido y aislado dentro de un dispositivo informático, como un teléfono inteligente, una tableta o una computadora, donde los datos confidenciales y las operaciones criptográficas se pueden almacenar y procesar de forma segura.

A) Verdadero

B) FALSO

Respuesta no detectada automaticamente

---

103. ¿Cuál es el propósito de la esteganografía?

A) Comprobación de la integridad de los datos

B) Verificando valores hash

✓ **C) Ocultar datos dentro de otro dato**

D) Cifrar datos

104. Reemplazar caracteres de contraseña en un campo de contraseña con una serie de asteriscos es un ejemplo de:

A) Enmascaramiento de datos

B) Tokenización

C) Anonimización

D) Pseudoanonimización

Respuesta no detectada automaticamente

105. ¿Cuál de los siguientes es un ejemplo de un algoritmo de extensión de claves?

A) RIPEMD

B) sha

C) HMAC

✓ **D) PBKDF2**

106. La tecnología Blockchain es un ejemplo de:

A) Pasarela de pago en línea

B) Base de datos centralizada

✓ **C) Libro de contabilidad público abierto**

D) sistema de almacenamiento en la nube

107. ¿Cuál de las respuestas enumeradas a continuación se refiere a un identificador utilizado para objetos PKI?

A) OID

B) DN

C) SAN

D) GUID

Respuesta no detectada automaticamente

108. Asigne el atributo de nivel de sofisticación a cada tipo de actor de amenazas que se enumera a continuación.

Respuesta no detectada automaticamente

109. En la lista desplegable de la derecha, seleccione las motivaciones típicas detrás de las acciones de cada tipo de actor de amenaza.

Respuesta no detectada automaticamente

110. ¿Cuál de los siguientes términos se utiliza para describir ciberataques sofisticados y prolongados, a menudo llevados a cabo por grupos organizados y bien financiados, como los Estados-nación?

A) MitM

✓ **B) APTO**

C) XSRF

D) DDoS

111. ¿Cuál de las respuestas enumeradas a continuación se refiere a un ejemplo de un vector de amenaza potencial en la comunicación basada en mensajería instantánea?

A) Ataque de phishing

B) Distribución de malware

C) Ataque de suplantación de identidad

D) Escuchar a escondidas

E) Secuestro de cuenta

F) Enlace/adjunto malicioso

✓ **G) Todo lo anterior**

112. ¿Cuál de las siguientes respuestas se refiere a un vector de amenaza característico únicamente de las redes cableadas?

A) Suplantación de ARP

B) salto de VLAN

✓ C) Intervención de cables

D) olfateo de puertos

E) Todo lo anterior

---

113. ¿Cuál de las respuestas enumeradas a continuación se refiere a la causa más probable de un acceso no autorizado provocado por la explotación de un punto de entrada de red específico?

A) Software AV obsoleto

B) Cookies del navegador

✓ C) Puertos de servicio abiertos

D) Registro y seguimiento insuficientes

---

114. El término "secuestro de URL" (también conocido como "Typosquatting") se refiere a una práctica engañosa que implica el registro deliberado de nombres de dominio con errores ortográficos o ligeras variaciones que se parecen mucho a nombres de dominio populares y bien establecidos. El objetivo principal de esta estrategia es explotar los errores tipográficos comunes que cometen los usuarios al ingresar URL en la barra de direcciones de su navegador web. Más allá de capturar tráfico inadvertido, la typosquatting también se puede utilizar para alojar sitios de phishing para engañar a los usuarios para que divulguen información confidencial, distribuir malware a través de sitios web engañosos, generar ingresos publicitarios al redirigir el tráfico mal escrito o participar en la suplantación de marcas para dañar la reputación de marcas auténticas o engañar a los usuarios.

A) Verdadero

B) FALSO

---

115. Una colección de funciones precompiladas diseñadas para ser utilizadas por más de una aplicación de Microsoft Windows simultáneamente para ahorrar recursos del sistema se conoce como:

A) DLL

B) API

C) EXE

D) INI

---

116. Un tipo de exploit en el que una aplicación sobrescribe el contenido de un área de memoria a la que no debería tener acceso se llama:

A) inyección de DLL

✓ B) Desbordamiento del búfer

C) pérdida de memoria

D) Escalada de privilegios

---

117. ¿Cuál de las siguientes respuestas no se refiere a un tipo común de vulnerabilidad basada en el sistema operativo?

A) Vulnerabilidades de control de acceso y permisos (contraseñas débiles, escalada de privilegios)

B) Vulnerabilidades en aplicaciones instaladas, utilidades del sistema y controladores de dispositivos.

C) Vulnerabilidades relacionadas con la memoria (pérdidas de memoria, desbordamientos de búfer, condiciones de carrera)

D) Vulnerabilidades en la gestión de parches y actualizaciones (parches de seguridad y retrasos en las actualizaciones, actualizaciones maliciosas)

E) Vulnerabilidades relacionadas con configuraciones erróneas del sistema/seguridad

F) Vulnerabilidades relacionadas con la red (ataques DoS, ataques de ejecución remota de código)

✓ G) Todas las opciones de respuesta anteriores son ejemplos de vulnerabilidades basadas en sistemas operativos.

---

118. La práctica de instalar aplicaciones móviles desde sitios web y tiendas de aplicaciones distintos de los mercados oficiales se conoce como:

A) jailbreak

B) Enraizamiento

✓ C) Carga lateral

D) Desbloqueo del operador

119. El término "Enraizamiento" se refiere a la capacidad de obtener acceso administrativo al sistema operativo y a las aplicaciones del sistema en:

A) Dispositivos Android
B) dispositivos iOS
C) Dispositivos Microsoft
D) Todo tipo de dispositivos móviles

120. El malware que restringe el acceso a un sistema informático cifrando archivos o bloqueando todo el sistema hasta que el usuario realice la acción solicitada se llama:

A) Grayware
B) software publicitario
✓ C) ransomware
D) software espía

121. Un programa informático malicioso independiente que normalmente se propaga a través de una red informática para afectar negativamente a los recursos del sistema y al ancho de banda de la red se denomina:

A) Gusano
B) virus sin archivos
C) Bot
D) Bomba lógica

122. El código malicioso activado por un evento específico se llama:

A) criptomalware
B) Puerta trasera
C) rootkit
✓ D) Bomba lógica

123. El término "clonación RFID" se refiere a copiar los datos almacenados en cualquier dispositivo habilitado para RFID (incluidas etiquetas, tarjetas, llaveros, implantes y otros objetos integrados con tecnología RFID) en otro dispositivo habilitado para RFID, que luego puede leerse y usarse de la misma manera que la etiqueta original. Si bien la clonación RFID se puede utilizar con fines legítimos, como replicar etiquetas importantes con fines de respaldo y prueba, también plantea un riesgo de seguridad significativo, ya que las etiquetas duplicadas pueden usarse potencialmente para obtener acceso no autorizado o divulgación de información no autorizada.

A) Verdadero
B) FALSO
Respuesta no detectada automaticamente

124. ¿Qué define un ataque DDoS reflejado?

A) Abrumar al objetivo con un gran volumen de tráfico para saturar su ancho de banda
B) Explotar vulnerabilidades en los protocolos de red para consumir recursos e interrumpir servicios
✓ C) Utilizar servidores de terceros para reflejar y amplificar el tráfico de ataque hacia el objetivo.
D) Apuntar a vulnerabilidades en aplicaciones o servidores web para agotar los recursos.

125. ¿Cuál de las siguientes es una característica de vulnerabilidad de la comunicación NFC?

A) Escuchar a escondidas
B) Intercepción de datos
C) Repetir ataques
D) Ataques DoS
✓ E) Todo lo anterior

126. ¿Cuál de las afirmaciones enumeradas a continuación se puede utilizar para describir las características de un ataque en ruta? (Seleccione todo lo que corresponda)

A) Un ataque en ruta también se conoce como ataque MITM.
✓ B) Los atacantes se sitúan en la ruta de comunicación entre dos dispositivos
✓ C) Los atacantes interceptan o modifican paquetes enviados entre dos dispositivos en comunicación

D) Los atacantes no tienen acceso a los paquetes intercambiados durante la comunicación entre dos dispositivos

127. ¿Cuáles son los rasgos característicos de una ID de sesión? (Seleccione todo lo que corresponda)

A) Permite al servidor identificar la sesión y recuperar los datos de la sesión correspondientes.

✓ B) Un identificador único asignado por el sitio web a un usuario específico.

C) Contiene las credenciales de autenticación del usuario, por ejemplo, nombre de usuario y contraseña.

✓ D) Un dato que puede almacenarse en una cookie o incrustarse como un parámetro de URL

✓ E) Almacenado en el lado del cliente (en el navegador del usuario) y enviado al servidor con cada solicitud

F) Un identificador único asignado a un servidor.

128. Una técnica que permite a un atacante autenticarse en un servidor remoto sin extraer una contraseña en texto claro de un resumen se llama:

A) pasar el hash

B) Repetir ataque

C) Ataque de fuerza bruta

D) Ataque de fumigación

Respuesta no detectada automaticamente

129. Un ataque de punto, punto y barra también se conoce como:

A) Ataque de disociación

B) Ataque en el camino

✓ C) Ataque transversal de directorio

D) Ataque de degradación

130. Un ataque contra datos cifrados que depende en gran medida de la potencia informática para comprobar todas las claves y contraseñas posibles hasta encontrar la correcta se denomina:

A) Repetir ataque

✓ B) Ataque de fuerza bruta

C) Ataque de diccionario

D) Ataque de cumpleaños

131. Un tipo de evidencia forense que puede usarse para detectar intentos de acceso no autorizados u otras actividades maliciosas se denomina:

A) CVE

✓ B) COI

C) AIS

D) OSINT

132. ¿Cuál de los términos enumerados a continuación describe con mayor precisión una situación en la que se utiliza una sola cuenta desde múltiples ubicaciones/dispositivos al mismo tiempo?

A) Ataque de fumigación

✓ B) Uso simultáneo de sesiones

C) Inicio de sesión único (SSO)

D) viaje imposible

133. ¿Cuál de los términos enumerados a continuación describe con mayor precisión una situación en la que se accede a una cuenta desde una ubicación en la que es físicamente imposible que se encuentre el usuario?

A) Restricciones de tiempo de inicio de sesión

✓ B) viaje imposible

C) Uso simultáneo de sesiones

D) Registro fuera de ciclo

134. ¿Cuál de las siguientes opciones indicaría un intento de ocultar evidencia de actividad maliciosa?

A) Bloqueo de cuenta

B) Inaccesibilidad de recursos

✓ C) Registros faltantes

D) Uso simultáneo de sesiones

135. ¿Cuál de las respuestas enumeradas a continuación se refiere a una solución que permite una gestión y control más sencillo de las políticas de segmentación de red a través de aplicaciones de software?

A) VDI

✓ **B) SDN**

C) VPC

D) EDR

---

136. ¿Cuál de las siguientes políticas se aplica a cualquier solicitud que no cumpla con los criterios definidos en una ACL?

A) Política de acceso justo

✓ **B) Política de denegación implícita**

C) confianza transitiva

D) Autenticación consciente del contexto

---

137. La importancia de cambiar los nombres de usuario y contraseñas predeterminados se puede ilustrar con el ejemplo de ciertos dispositivos de red (como enrutadores) que a menudo vienen con credenciales de administrador predeterminadas y conocidas que se pueden buscar en la web.

A) Verdadero

B) FALSO

---

138. El término "nube híbrida" se refiere a un entorno informático mixto que puede incluir diferentes modelos de servicios de nube, como nubes públicas y privadas, así como infraestructura local.

A) Verdadero

B) FALSO

---

139. ¿Cuál de los siguientes proporciona aislamiento de redes informáticas externas?

A) Segmentación de red

✓ **B) Entrehierro**

C) Cortafuegos de hardware

D) Distribución de cables protegida

---

140. ¿Cuál de las respuestas enumeradas a continuación se refiere a un medio para la segmentación lógica de la red?

A) Cambiar

B) VLAN

C) Subred filtrada

D) Enrutador

---

141. ¿Cuál de las respuestas enumeradas a continuación se refiere al proceso de empaquetar una aplicación y sus dependencias en una unidad única e independiente, que puede ejecutarse en diferentes entornos informáticos?

A) Computación de borde

B) Contenedorización

C) Virtualización

D) Computación en la nube

---

142. Un sistema informático o una aplicación que actúa como intermediario entre otra computadora e Internet se denomina comúnmente:

A) Puente

B) Centro activo

C) Servidor

✓ **D) Apoderado**

---

143. ¿Cuál de las respuestas enumeradas a continuación se refiere a un estándar IEEE que se puede implementar en una situación en la que un conmutador Ethernet actúa como autenticador para dispositivos que pretenden conectarse a una red a través de uno de sus puertos?

A) IEEE 802.1X

B) IEEE 802.11ac
C) IEEE 802.1D
D) IEEE 802.11x

144. ¿Cuál de las respuestas que se enumeran a continuación se refieren a un firewall de capa 7? (Seleccione 3 respuestas)

A) Ofrece filtrado de tráfico complejo (más lento)
B) Filtra el tráfico según las direcciones IP de origen/destino, los puertos y los tipos de protocolo (por ejemplo, TCP/UDP)
C) Opera en la capa de transporte del modelo OSI.
✓ D) Agrega la capacidad de inspeccionar el contenido de los paquetes de datos además de la información del encabezado.
E) Ofrece filtrado de tráfico básico (más rápido)
✓ F) Opera en la capa de aplicación del modelo OSI.

145. Un modo IPsec que proporciona cifrado sólo para la carga útil (la parte de datos del paquete) se denomina:

A) Modo protegido
B) Modo túnel
✓ C) Modo de transporte
D) Modo seguro

146. ¿Cuál de las siguientes respuestas se refiere a un marco de ciberseguridad que combina funciones de red y seguridad en un único servicio basado en la nube?

A) SASE
B) SWG
C) CASB
D) SD-WAN
Respuesta no detectada automaticamente

147. El propósito de PCI DSS es brindar protección para:

A) Datos del titular de la tarjeta de crédito
B) Software con licencia
C) Contraseñas de usuario
D) Información de salud personal

148. Los métodos de cifrado utilizados para proteger los datos en tránsito incluyen: (Seleccione todos los que correspondan)

A) NFS
✓ B) vpn
C) SED
✓ D) IPSec
E) FDE
✓ F) TLS

149. La funcionalidad integrada de un dispositivo móvil que permite el uso de aplicaciones de localización se conoce como:

A) WPS
B) GSM
C) SIM
✓ D) GPS

150. ¿Cuál de las respuestas enumeradas a continuación se refiere a una tecnología que proporciona control sobre el uso de un dispositivo móvil dentro de un área designada?

A) Geocerca
B) Seguimiento de dispositivos
C) Seguridad perimetral
D) Geolocalización

151. Nivel RAID de hardware 0: (seleccione todo lo que corresponda)

A) Requiere un mínimo de 2 unidades para implementar

✓ B) También se conoce como segmentación de discos.

✓ C) Disminuye la confiabilidad (la falla de cualquier disco en la matriz resulta en la pérdida de todos los datos en la matriz)

D) También se conoce como duplicación de disco.

E) Ofrece menos capacidad de volumen en comparación con RAID 1

F) Requiere al menos 3 unidades para implementarse

✓ G) Es adecuado para sistemas donde el rendimiento tiene mayor prioridad que la tolerancia a fallos.

8) Ofrece confiabilidad mejorada al crear conjuntos de datos idénticos en cada unidad (la falla de una unidad no destruye la matriz ya que cada unidad contiene una copia idéntica de los datos)

---

152. Hardware RAID Nivel 5: (Seleccione 3 respuestas)

A) Requiere al menos 2 unidades para implementar

B) Continúa funcionando en caso de falla de más de 1 unidad

C) También se conoce como segmentación de discos con doble paridad.

✓ D) Requiere al menos 3 unidades para implementarse

✓ E) Ofrece mayor rendimiento y tolerancia a fallas (la falla de una sola unidad no destruye la matriz y las unidades restantes pueden recrear los datos perdidos)

✓ F) Requiere al menos 4 unidades para implementarse

✓ G) También se conoce como división de discos con paridad.

---

153. Hardware RAID Nivel 10 (también conocido como RAID 1+0): (Seleccione 3 respuestas)

A) Requiere un mínimo de 4 unidades para implementar

✓ B) Se conoce como banda de espejos, es decir, una combinación de RAID 1 (duplicación de disco) y RAID 0 (división de disco).

C) Requiere un mínimo de 5 unidades para implementar

✓ D) Ofrece mayor rendimiento y tolerancia a fallos (el fallo de una unidad en cada par de unidades de disco reflejadas no destruye la matriz)

E) Requiere un mínimo de 3 unidades para implementar

F) Continúa funcionando en caso de falla de más de 2 unidades

G) Se conoce como banda de espejos, es decir, una combinación de RAID 1 (división de discos) y RAID 0 (duplicación de discos).

---

154. ¿Cuál de las respuestas enumeradas a continuación se refiere a la función principal del equilibrio de carga?

A) Mantiene copias idénticas de datos en múltiples servidores para mejorar la disponibilidad y confiabilidad de los datos.

✓ B) Distribuye la carga de trabajo entre múltiples servidores para mejorar el rendimiento.

✓ C) Agrupa servidores para proporcionar alta disponibilidad y tolerancia a fallos.

D) Distribuye contenido geográficamente entre múltiples servidores para mejorar el rendimiento, reducir la latencia y manejar grandes volúmenes de tráfico.

---

155. ¿Cuál de los términos enumerados a continuación se refiere a un duplicado del sitio original, con sistemas informáticos en pleno funcionamiento y copias de seguridad casi completas de los datos del usuario?

A) sitio caliente

B) Sitio cálido

C) Sitio frio

D) sitio móvil

Respuesta no detectada automaticamente

---

156. Una instalación de recuperación ante desastres que proporciona únicamente el espacio físico para las operaciones de recuperación se conoce como:

A) sitio caliente

B) Sitio cálido

✓ C) Sitio frio

D) Sitio espejo

157. ¿Cuál de las respuestas enumeradas a continuación se refiere a un escenario simulado llevado a cabo en un entorno controlado, que generalmente implica discusiones y planificación en torno a incidentes de seguridad hipotéticos?

A) Ejercicio de mesa

B) Zona de arena

C) caza de amenazas

D) Capacitación en concientización sobre seguridad.

Respuesta no detectada automaticamente

158. ¿Cuál de los siguientes términos se refiere a una estrategia de respaldo que se basa en la creación y el mantenimiento de copias de datos en tiempo real o casi en tiempo real en un sistema separado?

A) Duplicación

B) Virtualización

✓ C) Llevar un diario

✓ D) Replicación

159. ¿Cuál de los términos enumerados a continuación se utiliza para describir un nivel fundamental de configuraciones y ajustes de seguridad necesarios para salvaguardar un sistema?

A) Segmentación lógica

✓ B) Línea de base segura

C) Niveles de control de acceso

D) Principio de privilegio mínimo

160. Los datos de un dispositivo móvil perdido o robado se pueden borrar mediante:

A) Enraizamiento

B) Carga lateral

C) Formateo de bajo nivel

✓ D) Borrado remoto

161. La implementación del cifrado completo del dispositivo es uno de los métodos para proteger los datos confidenciales en un teléfono inteligente. Cuando está habilitado, este tipo de cifrado funciona junto con el bloqueo de pantalla del teléfono, es decir, para descifrar el teléfono (que permanece cifrado siempre que está bloqueado), el usuario primero debe desbloquear la pantalla. En los dispositivos Android, los métodos de desbloqueo incluyen ingresar un PIN, una contraseña o dibujar un patrón simple con un dedo. Los dispositivos Apple utilizan códigos de acceso, reconocimiento facial (Face ID) y huellas dactilares (Touch ID).

A) Verdadero

B) FALSO

Respuesta no detectada automaticamente

162. ¿Cuál de las respuestas que se enumeran a continuación se refieren a técnicas de refuerzo de estaciones de trabajo? (Seleccione 3 respuestas)

A) Ocultar cuentas de administrador

✓ B) Aplicar periódicamente parches de seguridad y actualizaciones del sistema operativo y del software instalado.

C) Deshabilitar todo el acceso a Internet

✓ D) Eliminar o deshabilitar controladores, servicios, software y protocolos de red innecesarios

✓ E) Limitar el acceso de usuarios no autorizados o no autenticados

163. ¿Cuál de las respuestas enumeradas a continuación se refiere al proceso de evaluación del entorno físico, como la distribución del edificio, para identificar posibles fuentes de interferencia y determinar la ubicación óptima de un WAP?

A) Análisis de brechas

B) Planificación de capacidad

✓ C) Estudio del sitio

D) Escaneo de vulnerabilidades

164. Un SSID es un identificador único (también conocido como nombre de red inalámbrica) para una WLAN. Las redes inalámbricas anuncian su presencia transmitiendo periódicamente SSID en un paquete especial

llamado marco de baliza. En redes inalámbricas con funciones de seguridad deshabilitadas, conocer el SSID de la red es suficiente para acceder a la red. SSID también identifica el enrutador inalámbrico que actúa como WAP. Los enrutadores inalámbricos del mismo fabricante suelen configurarse con nombres SSID predeterminados (conocidos). Dado que varios dispositivos con el mismo SSID mostrado en la lista de redes disponibles crean confusión y fomentan el acceso accidental por parte de usuarios no autorizados (se aplica a redes que carecen de seguridad), cambiar el SSID predeterminado es una práctica recomendada.

A) Verdadero

B) FALSO

Respuesta no detectada automaticamente

165. ¿Cuáles son las características del modo empresarial WPA2/WPA3? (Seleccione 3 respuestas)

A) Adecuado para grandes redes corporativas

B) IEEE 802.1D

C) No requiere un servidor de autenticación

✓ D) IEEE 802.1X

E) Adecuado para todo tipo de LAN inalámbricas

✓ F) Requiere servidor de autenticación RADIUS

166. ¿Cuáles son los rasgos característicos de RADIUS? (Seleccione 3 respuestas)

A) Se utiliza principalmente para acceso a la red.

B) Cifra toda la carga útil del paquete de solicitud de acceso.

✓ C) Combina autenticación y autorización

✓ D) Cifra solo la contraseña en el paquete de solicitud de acceso.

E) Se utiliza principalmente para la administración de dispositivos.

F) Separa la autenticación y la autorización

167. ¿Cuál de las siguientes respuestas se refiere a un protocolo de autenticación inalámbrica obsoleto desarrollado por Cisco?

A) PEAP

B) EAP-TTLS

✓ C) SALTO

D) EAP-TLS

168. ¿Cuáles de los aspectos de programación enumerados a continuación son críticos en el proceso de desarrollo seguro de aplicaciones? (Seleccione 2 respuestas)

A) Gestión de parches

✓ B) Validación de entrada

C) Protección con contraseña

✓ D) Manejo de errores y excepciones

E) Lista blanca de aplicaciones

169. ¿Cuál de los términos enumerados a continuación se refiere a un proceso de revisión de código manual o automatizado destinado a descubrir errores de lógica y sintaxis en el código fuente de la aplicación?

A) Validación de entrada

B) Análisis de código dinámico

C) Fuzzing

✓ D) Análisis de código estático

170. El término "análisis de código estático" se refiere al proceso de descubrir errores de tiempo de ejecución de la aplicación.

A) Verdadero

✓ B) FALSO

171. La práctica de encontrar vulnerabilidades en una aplicación dándole entradas incorrectas se llama:

A) Normalización

B) Endurecimiento

C) Análisis de código dinámico

✓ **D) Fuzzing**

172. Un tipo de mecanismo de identificación de usuarios utilizado como contramedida contra el software automatizado (como los robots de red) se conoce como:

A) Ministerio de Asuntos Exteriores

✓ **B) CAPTCHA**

C) SSO

D) NIDS

173. ¿Cuál de las siguientes tecnologías inalámbricas permite la identificación y el seguimiento de etiquetas adheridas a objetos?

A) GPS

B) IR

✓ **C) RFID**

D) NFC

174. ¿Qué política suele especificar el período durante el cual ciertos tipos de datos deben almacenarse antes de su eliminación?

A) Política de protección de datos

B) Política de clasificación de datos

C) Política de copia de seguridad de datos

✓ **D) Política de retención de datos**

175. ¿Cuál de las respuestas que se enumeran a continuación se refieren a los rasgos característicos del análisis de código estático? (Seleccione 3 respuestas)

A) Implica examinar el código sin ejecutarlo.

✓ **B) A menudo se utiliza al principio del proceso de desarrollo.**

✓ **C) Examina la estructura, la sintaxis y la semántica del código para detectar problemas como errores de sintaxis, violaciones de estándares de codificación, vulnerabilidades de seguridad y errores.**

D) Normalmente se utiliza más adelante en el ciclo de vida del desarrollo de software.

E) Implica ejecutar el código y analizar su comportamiento en tiempo de ejecución.

F) Analiza las propiedades del tiempo de ejecución, como el uso de la memoria, el rendimiento y el manejo de errores, para identificar problemas como pérdidas de memoria, cuellos de botella en el rendimiento y errores de tiempo de ejecución.

176. ¿Cuál de las siguientes afirmaciones describe las características del análisis de código dinámico? (Seleccione 3 respuestas)

A) Normalmente se utiliza más adelante en el ciclo de vida del desarrollo de software.

B) Implica examinar el código sin ejecutarlo.

✓ **C) Analiza las propiedades del tiempo de ejecución, como el uso de la memoria, el rendimiento y el manejo de errores, para identificar problemas como pérdidas de memoria, cuellos de botella en el rendimiento y errores de tiempo de ejecución.**

D) A menudo se utiliza al principio del proceso de desarrollo.

E) Examina la estructura, la sintaxis y la semántica del código para detectar problemas como errores de sintaxis, violaciones de estándares de codificación, vulnerabilidades de seguridad y errores.

✓ **F) Implica ejecutar el código y analizar su comportamiento en tiempo de ejecución.**

177. ¿Cuál de los términos enumerados a continuación se refiere al seguimiento y administración de componentes de aplicaciones de software, como bibliotecas de terceros y otras dependencias?

A) Control de versiones

B) Monitoreo de paquetes

C) Aplicación de la configuración

D) Endurecimiento de aplicaciones

178. Un mecanismo de transporte dedicado para información sobre amenazas cibernéticas se denomina:

A) TCP/IP

B) TLS

✓ **C) TAXII**

D) S/MIME

179. ¿Cuál de las siguientes afirmaciones no se aplica a la web oscura?

A) Normalmente requiere software especializado para acceder a sus contenidos.

✓ B) Forma una gran parte de la web profunda.

C) No indexado por los motores de búsqueda tradicionales.

D) A menudo se asocia con el comercio de datos robados, malware y amenazas cibernéticas.

---

180. Un programa de divulgación responsable es un proceso formal establecido por una organización para alentar a los investigadores de seguridad y a los piratas informáticos éticos a informar las vulnerabilidades que descubren en los sistemas o software de la organización. Un programa de recompensas por errores es un tipo específico de programa de divulgación responsable que ofrece recompensas financieras a los investigadores de seguridad por informar vulnerabilidades válidas.

A) Verdadero

B) FALSO

---

181. ¿Cuál de las siguientes opciones se refiere a un sistema que identifica, define y cataloga vulnerabilidades de ciberseguridad conocidas públicamente?

A) TAXII

✓ B) CVE

C) STIX

D) cvss

---

182. ¿Cuál de las afirmaciones enumeradas a continuación no se refiere a una técnica de respuesta y remediación de vulnerabilidades?

A) Aplicar actualizaciones o correcciones proporcionadas por proveedores de software para abordar la vulnerabilidad (parches)

B) Garantizar la recuperación financiera de los costos asociados con un ciberataque exitoso (seguro)

C) Dividir una red en zonas más pequeñas y aisladas para limitar el impacto potencial de una vulnerabilidad (segmentación)

D) Mitigar el riesgo asociado con una vulnerabilidad que no se puede reparar de inmediato mediante la implementación de medidas de seguridad alternativas (controles de compensación)

E) Retrasar o renunciar a un parche para un sistema específico, por ejemplo, cuando aplicar un parche puede no ser factible debido a problemas de compatibilidad o posibles interrupciones en sistemas críticos (excepciones y exenciones).

✓ F) Todas las respuestas anteriores son ejemplos de técnicas de respuesta y remediación de vulnerabilidades.

---

183. ¿Cuál de las siguientes respuestas se refiere a SCAP? (Seleccione 3 respuestas)

A) Un tipo de sistema de seguridad diseñado para recopilar registros y eventos de diversas fuentes.

✓ B) Diseñado para proporcionar una interfaz de usuario centralizada para acceder a los datos recopilados.

✓ C) Una colección de estándares desarrollados por NIST

✓ D) Proporciona un lenguaje común para comunicar información de seguridad.

✓ E) Permite que diferentes herramientas de seguridad compartan datos y trabajen juntas de manera más efectiva

F) Permite la detección de amenazas en tiempo real, la respuesta a incidentes y el monitoreo del cumplimiento

---

184. El Protocolo simple de administración de red (SNMP) es un protocolo de capa de aplicación basado en UDP que se utiliza en sistemas de administración de red para monitorear dispositivos conectados a la red. SNMP suele estar integrado en la mayoría de los dispositivos de infraestructura de red modernos, como enrutadores, puentes, conmutadores, servidores, impresoras, fotocopiadoras, máquinas de fax y otros dispositivos conectados a la red. Una red administrada por SNMP consta de tres componentes esenciales: un dispositivo administrado, un módulo de software de administración de red que reside en un dispositivo administrado (Agente) y una estación de administración de red (NMS), que ejecuta aplicaciones responsables de monitorear y controlar los dispositivos administrados, así como de recopilar información SNMP de los Agentes. El administrador recibe notificaciones (Traps e InformRequests) en el puerto UDP 162, mientras que el agente SNMP recibe solicitudes en el puerto UDP 161.

A) Verdadero

B) FALSO

Respuesta no detectada automaticamente

---

185. Las reglas del firewall se evalúan según su orden de prioridad. Las reglas que se encuentran en la parte superior de la lista tienen prioridad sobre las reglas que se encuentran más abajo en la lista. Una vez que se encuentra una regla coincidente, no se realiza ninguna evaluación adicional de las reglas posteriores. La

política de "denegación implícita" en un firewall es un comportamiento predeterminado común en el que cualquier tráfico que no coincida explícitamente con ninguna de las reglas de permiso configuradas se deniega o bloquea automáticamente. En otras palabras, si un paquete no cumple con los criterios de ninguna regla de permiso, el comportamiento predeterminado del firewall es denegar el tráfico.

A) Verdadero
B) FALSO

186. Una subred ligeramente protegida (también conocida como DMZ) que consta de servidores disponibles públicamente ubicados en el exterior del firewall de la empresa se conoce como:

A) Portal cautivo
B) Red de cuarentena
C) Extranet
✓ D) Subred filtrada

187. ¿Cuál de las respuestas enumeradas a continuación se refiere a técnicas de filtrado que pueden permitir o bloquear el acceso a un sitio en función de su dirección web? (Seleccione 2 respuestas)

A) Inspección SSL/TLS
✓ B) escaneo de URL
C) Categorización de contenido
✓ D) filtrado DNS
E) Filtrado basado en reputación

188. En el entorno Windows Active Directory, esta característica permite la administración y configuración centralizada de sistemas operativos, aplicaciones y configuraciones de cuentas de usuario.

A) Usuarios y grupos locales
B) Monitor de recursos
✓ C) Política de grupo
D) Control de cuentas de usuario

189. TCP es un ejemplo de protocolo sin conexión. Debido a que TCP no admite el protocolo de enlace de tres vías al establecer una conexión de red, se lo conoce como protocolo no confiable o de mejor esfuerzo. Las aplicaciones de ejemplo de TCP incluyen la transmisión de datos de streaming de vídeo y audio.

A) Verdadero
✓ B) FALSO

190. ¿Cuál de las siguientes respuestas se refiere a un marco de políticas que permite a los propietarios de dominios especificar cómo los receptores de correo electrónico deben manejar los correos electrónicos que no pasan las comprobaciones de autenticación?

✓ A) DKIM
B) FPS
C) PEM
✓ D) DMARC

191. ¿Cuál de las siguientes respuestas se refiere a un mecanismo de autenticación de correo electrónico que permite a los propietarios de dominios especificar qué direcciones IP están autorizadas para enviar correos electrónicos en nombre de su dominio?

A) DMARC
B) PEM
C) DKIM
D) FPS

192. OpenID Connect es un protocolo utilizado para:

A) Atestación
B) Autorización
C) Revisión de cuentas
✓ D) Autenticación

193. ¿Cuáles son los rasgos característicos de SAML? (Seleccione 3 respuestas)

A) Permite solo el intercambio de datos de autorización SSO

✓ B) Maneja tanto la autenticación como la autorización para SSO

✓ C) Utiliza XML para el intercambio de datos.

✓ D) Comúnmente utilizado en entornos empresariales y sistemas heredados.

E) Permite solo el intercambio de datos de autenticación SSO

F) Utiliza JSON para el intercambio de datos.

G) Diseñado específicamente para aplicaciones web y móviles

194. ¿Cuál de las siguientes respuestas se refiere(s) al modelo de control de acceso obligatorio (MAC)? (Seleccione todo lo que corresponda)

A) Los usuarios no pueden cambiar las políticas de acceso a su propia discreción.

✓ B) Las etiquetas y los niveles de autorización solo pueden ser aplicados y modificados por un administrador

C) Cada objeto tiene un propietario que, a su propia discreción, determina qué tipo de permisos pueden tener otros usuarios sobre ese objeto.

D) Acceso a recursos según la identidad del usuario.

✓ E) Cada recurso tiene una etiqueta de confidencialidad que coincide con un nivel de autorización asignado a un usuario.

195. En el contexto de la seguridad informática, el término "biometría" se refiere tanto a las características biológicas del cuerpo humano como a los rasgos de comportamiento que pueden utilizarse con fines de identificación y control de acceso.

A) Verdadero

B) FALSO

Respuesta no detectada automaticamente

196. ¿Cuál de las respuestas enumeradas a continuación se refiere a un tipo de medio que se puede utilizar como token de autenticación de hardware? (Seleccione todo lo que corresponda)

A) tarjeta inteligente

✓ B) llavero

✓ C) clave de seguridad

D) frase de contraseña

E) Lector biométrico

✓ F) insignia rfid

197. ¿Cuál de las respuestas enumeradas a continuación se refieren a las características de una llave de seguridad? (Seleccione 3 respuestas)

A) Se utiliza para generación de OTP, acceso remoto a vehículos y acceso a edificios.

✓ B) Token de autenticación de hardware

✓ C) Normalmente, una memoria USB física o un dispositivo del tamaño de un llavero

✓ D) Utilizado principalmente para seguridad digital (2FA/MFA)

E) Token de autenticación de software

F) Normalmente, una tarjeta de plástico del tamaño de una tarjeta de crédito con un chip integrado.

198. La configuración de política de antigüedad máxima de la contraseña determina el período de tiempo que se debe utilizar una contraseña antes de que el usuario pueda cambiarla.

A) Verdadero

✓ B) FALSO

199. ¿Cuál de las respuestas enumeradas a continuación se refiere a un término utilizado principalmente en el desarrollo de software para describir el costo de las decisiones a corto plazo que pueden generar problemas a largo plazo?

A) Entropía de código

B) factor de exposición

C) registro de riesgos

✓ D) Deuda técnica

200. En el proceso de respuesta a incidentes, el paso que implica identificar y comprender incidentes potenciales para determinar su alcance, impacto y causa raíz es parte de:

A) Etapa de preparación

✓ **B) Etapa de detección y análisis.**

C) Etapa de contención, erradicación y recuperación.

D) Etapa de actividad posterior al incidente

201. ¿Qué etapa del proceso de respuesta a incidentes implica la actualización de los planes, políticas y procedimientos de respuesta a incidentes?

A) Preparación

B) Detección y análisis

C) Contención, erradicación y recuperación

✓ **D) Actividad posterior al incidente**

202. ¿Cuál de las siguientes respuestas se refiere a un ejercicio más profundo, que puede incluir activar sistemas y realizar acciones reales para responder al incidente?

A) Pruebas de penetración

B) caza de amenazas

✓ **C) Simulación**

D) Escaneo de vulnerabilidades

203. El término "búsqueda de amenazas" se refiere a una búsqueda proactiva de IoC para identificar y abordar posibles amenazas y vulnerabilidades antes de que puedan convertirse en incidentes en toda regla.

A) Verdadero

B) FALSO

Respuesta no detectada automaticamente

204. El proceso de identificar, recopilar y producir información almacenada electrónicamente con la intención de utilizarla en un procedimiento o investigación legal se conoce como:

A) Retención por litigio

B) Gestión de pruebas

C) Forense digital

✓ **D) descubrimiento electrónico**

205. El término "Metadatos" se refiere a datos que proporcionan información sobre otros datos, pero no el contenido real de los datos. Normalmente, los metadatos no son visibles para el usuario de forma predeterminada, pero se puede acceder a ellos si es necesario. Por ejemplo, los metadatos de correo electrónico, que se encuentran en los encabezados de los correos electrónicos, incluyen información detallada sobre el remitente, el destinatario y la ruta que tomó el mensaje. Los metadatos del dispositivo móvil abarcan detalles como el modelo del dispositivo, geolocalización, información de la cámara, uso de Internet, actividad de llamadas telefónicas y mensajes de texto, estadísticas de uso de aplicaciones y metadatos de varios archivos en el dispositivo. En la navegación web, los metadatos provienen de metaetiquetas HTML ubicadas en la sección principal de una página web. Para los archivos, los metadatos incluyen detalles sobre el autor (por ejemplo, el creador del archivo), el tipo de archivo, el tamaño, la fecha y hora de creación y la fecha y hora de la última modificación.

A) Verdadero

B) FALSO

206. ¿Cuál de las respuestas enumeradas a continuación se refiere a un proceso de interceptación de datos de tráfico de red con fines de análisis y solución de problemas?

A) AIS

✓ **B) PCAP**

C) EDR

D) MaaS

207. ¿Cuál de las siguientes siglas se refiere a una estrategia integral y un conjunto de procedimientos diseñados para garantizar que una organización pueda continuar con sus operaciones y funciones críticas durante y después de un evento disruptivo?

✓ **A) DRP**

B) CP

✓ **C) BCP**

D) COOPERATIVA

208. ¿Cuál de los términos enumerados a continuación se refiere al proceso de creación y mantenimiento de aplicaciones informáticas?

A) RAD

✓ **B) SDLC**

C) POO

D) SaaS

209. Una lista de verificación de configuración para nuevos usuarios incluye todas las actividades que permiten que un nuevo empleado sea productivo. Ejemplos de tales actividades (que forman parte del llamado proceso de incorporación) incluyen la configuración del entorno de hardware y software para el nuevo usuario, así como proporcionar toda la formación necesaria. Una lista de verificación de despido del usuario final aborda todas las acciones que deben tener lugar durante el proceso de baja (es decir, cada vez que un empleado deja la empresa). Ejemplos de elementos de la lista de verificación incluyen cumplir con todos los documentos requeridos, eliminar el acceso del empleado a los recursos (por ejemplo, dispositivos propiedad de la empresa, cuentas de usuario, etc.) y discutir sus motivos para irse y sus experiencias con el empleador durante una entrevista de salida.

A) Verdadero

B) FALSO

Respuesta no detectada automaticamente

210. ¿Cuál de las respuestas enumeradas a continuación se refiere a organizaciones del sector público que establecen y hacen cumplir leyes y regulaciones a nivel local, regional o nacional?

A) Entidades gubernamentales

B) Asociaciones comerciales

C) Organismos estatutarios

D) Agencias reguladoras

211. Una estimación basada en datos históricos de la frecuencia con la que una amenaza lograría explotar una vulnerabilidad se conoce como:

A) CERVEZA INGLESA

B) SLA

✓ **C) ARO**

D) LES

212. Un valor MTBF alto indica que un componente o sistema proporciona baja confiabilidad y es más probable que falle.

A) Verdadero

✓ **B) FALSO**

213. ¿Cuál de las siguientes respuestas se refiere a una disposición contractual que otorga a una parte el derecho de inspeccionar las operaciones, instalaciones, procesos y registros de la otra parte?

A) Cláusula de derecho de auditoría

B) Cláusula de supervisión

C) Cláusula de verificación de cumplimiento

D) Cláusula de transparencia

214. Un acuerdo detallado entre un cliente y un proveedor que describe el trabajo a realizar en un proyecto se denomina:

A) MSA

B) SLA

C) WO

✓ **D) SEMBRAR**

215. ¿Cuál de los términos enumerados a continuación se utiliza para describir las acciones tomadas para abordar y mitigar los riesgos ya identificados?

A) debida diligencia

B) Estándar de atención

✓ C) debido cuidado

D) Deber fiduciario

---

216. ¿Cuál de los términos enumerados a continuación se refiere a un principio legal que permite a las personas solicitar la eliminación de información personal de búsquedas en Internet y otras fuentes públicas?

A) Desidentificación

✓ B) Derecho a ser olvidado

C) Anonimización

D) Gestión del consentimiento

---

217. En el contexto de las auditorías, una certificación suele ser proporcionada por:

A) Organismo regulador

✓ B) Auditor externo

C) comité de auditoría

D) equipo de auditoría interna

---

218. En las pruebas de penetración, el reconocimiento activo implica recopilar cualquier tipo de información disponible públicamente que pueda usarse más adelante para explotar las vulnerabilidades encontradas en el sistema objetivo.

A) Verdadero

✓ B) FALSO

---

219. En la comunicación por correo electrónico, ¿qué señales pueden ayudar a reconocer un intento de phishing?

A) El mensaje contiene mala ortografía y gramática.

B) El mensaje pide información personal.

C) El mensaje incluye un llamado a la acción con sentido de urgencia.

D) El mensaje incluye enlaces o archivos adjuntos sospechosos.

✓ E) Cualquiera de los anteriores

---

220. ¿Cuál es la mejor contramedida contra los ataques de ingeniería social?

A) Conciencia situacional

B) Política de denegación implícita

✓ C) Educación del usuario

D) Fuertes controles de seguridad

---

221. Un tipo de mecanismo de identificación de usuarios utilizado como contramedida contra el software automatizado (como los robots de red) se conoce como:

A) Ministerio de Asuntos Exteriores

✓ B) CAPTCHA

C) LCA

D) PNI

---

222. ¿Cuál de los términos enumerados a continuación se refiere al proceso de creación y mantenimiento de aplicaciones informáticas?

A) RAD

✓ B) SDLC

C) POO

D) SaaS

---

223. ¿Cuál es el nombre de un protocolo de red que protege el tráfico web mediante cifrado SSL/TLS?

A) SFTP

✓ B) HTTPS

C) FTPS
D) SHTTP

224. ¿Cuál es el término común para un grupo de protocolos utilizados para transportar datos de voz a través de una red de conmutación de paquetes?

A) RDSI
B) PBX
✓ C) VoIP
D) PSTN

225. ¿Cuál de los siguientes protocolos de transferencia de archivos no proporciona cifrado?

A) SCP
B) FTPS
✓ C) ftp
D) SFTP

226. Un subsistema de autenticación que permite a un usuario acceder a múltiples componentes del sistema conectados (como hosts separados en una red) después de un único inicio de sesión en solo uno de los componentes se denomina:

A) NAC
✓ B) SSO
C) aaa
D) Ministerio de Asuntos Exteriores

227. Un tipo de documento que estipula reglas de comportamiento que deben seguir los usuarios de computadoras, redes y recursos asociados se denomina:

A) SLA
B) CLUF
✓ C) PUA
D) BPA

228. Un tipo de protocolo de red criptográfico para comunicación segura de datos, inicio de sesión remoto en la línea de comandos, ejecución remota de comandos y otros servicios de red seguros entre dos computadoras en red se conoce como:

A) PDR
✓ B) SSH
C) Telnet
D) SCP

229. ¿Cuál de las respuestas enumeradas a continuación se refiere a un estándar de seguridad introducido para abordar las vulnerabilidades encontradas en WEP?

A) TKIP
B) AES
C) WPA
D) CCMP

230. Un tipo de red que conecta computadoras dentro de un área geográfica pequeña, como un edificio o grupo de edificios, se denomina:

A) CACEROLA
✓ B) LAN
C) HOMBRE
D) PÁLIDO

231. ¿Cuál de las siguientes respuestas se refiere a un método de autenticación secreto compartido utilizado en WPA, WPA2 y EAP?

A) PSK
B) 802.1X
C) SAE

D) TKIP

Respuesta no detectada automaticamente

232. ¿Qué tipo de mensajes no solicitados se basan en la comunicación basada en texto?

A) VAM

✓ B) SPIM

C) JMS

D) ESCUPIR

233. ¿Cuál de los términos enumerados a continuación se aplica al proceso de autenticación?

A) Ministerio de Asuntos Exteriores

B) MMC

C) DM

D) MFD

234. ¿Cuál de las respuestas enumeradas a continuación se refiere a un lenguaje de programación dedicado utilizado en la gestión de bases de datos?

A) PHP

B) do

C) SQL

D) js

235. ¿Cuál de los siguientes términos se utiliza para describir ciberataques sofisticados y prolongados, a menudo llevados a cabo por grupos organizados y bien financiados, como los Estados-nación?

A) MitM

✓ B) APTO

C) XSRF

D) DDoS

236. ¿Cuál de las respuestas enumeradas a continuación se refiere a un concepto que proporciona información sobre los métodos y herramientas que utilizan los ciberdelincuentes para llevar a cabo ataques?

A) TTP

B) CVE

C) ATT&CK

D) cvss

Respuesta no detectada automaticamente

237. ¿Qué parte de la arquitectura de seguridad AAA se ocupa de la verificación de la identidad de una persona o proceso?

A) Contabilidad

✓ B) Autenticación

C) Revisión de cuentas

D) Autorización

238. ¿Cuál de las respuestas enumeradas a continuación se refiere a un protocolo de autenticación de acceso remoto que periódicamente vuelve a autenticar al cliente a intervalos aleatorios para evitar el secuestro de sesión?

A) PAE

B) CAP

C) PAPILLA

D) PEAP

239. ¿Cuál de las siguientes siglas se refiere a una estrategia integral y un conjunto de procedimientos diseñados para garantizar que una organización pueda continuar con sus operaciones y funciones críticas durante y después de un evento disruptivo?

A) DRP

B) CP

✓ C) BCP

D) COOPERATIVA

240. El término "IA" se refiere a sistemas informáticos y algoritmos que pueden realizar tareas que normalmente requieren inteligencia humana, como la resolución de problemas, el aprendizaje y la toma de decisiones.

A) Verdadero

B) FALSO

Respuesta no detectada automaticamente

241. Un tipo de ciberataque centrado en hacer que un sitio web, servicio o red no esté disponible para los usuarios sobrecargándolo con tráfico o solicitudes maliciosas se denomina:

A) SQLi

B) XSS

C) CSRF

✓ D) DoS

242. ¿Cuál de las respuestas enumeradas a continuación se refiere a un término amplio que abarca varios sistemas de control y automatización utilizados en entornos industriales para controlar y monitorear procesos físicos y maquinaria?

A) ICS

B) SOCIEDAD ANÓNIMA

C) SCADA

D) HMI

243. ¿Cuál de las siglas enumeradas a continuación se refiere a una herramienta de software criptográfico para la comunicación segura por correo electrónico y la protección de datos?

A) DES

B) PEM

C) EFS

✓ D) PGP

244. Un tipo de vulnerabilidad en el que el estado de un recurso se verifica en un momento dado pero puede cambiar antes de que el recurso se utilice realmente se denomina:

A) TOC

✓ B) TOC/TOU

C) TÚ

D) TIG

245. ¿Cuál de las siguientes respuestas se refiere a un sistema que contiene asignaciones de nombres de dominio a varios tipos de datos, como direcciones IP numéricas?

A) TCP/IP

✓ B) DNS

C) SQL

D) DHCP

246. ¿Cuál de los acrónimos enumerados a continuación se refiere a una estrategia integral y un conjunto de procedimientos diseñados para garantizar que una organización pueda continuar con sus operaciones y funciones críticas durante y después de un evento disruptivo?

A) BIA

B) LES

✓ C) BCP

D) BPA

247. Un modelo de servicio de computación en la nube que ofrece acceso remoto a aplicaciones basado en una tarifa de suscripción mensual o anual se denomina:

A) PaaS

✓ B) SaaS

C) IaaS

D) DaaS

248. ¿Qué longitud de clave AES proporciona el mayor nivel de seguridad?

A) clave de 128 bits

B) clave de 192 bits

✓ C) clave de 256 bits

D) clave de 320 bits

249. Un conjunto de procedimientos implementados para recuperar sistemas y datos de TI después de una interrupción importante se denomina:

A) DRP

B) BIA

C) LES

D) BCP

Respuesta no detectada automaticamente

250. ¿Cuál de las respuestas enumeradas a continuación se refiere a un modelo de implementación de dispositivos móviles que permite a los empleados utilizar dispositivos móviles privados para acceder a datos y aplicaciones restringidos de la empresa?

A) AFRONTAR

B) BYOD

C) JBOD

D) CYOD

251. ¿Cuál de las respuestas enumeradas a continuación se refiere a un protocolo de autenticación inalámbrica obsoleto desarrollado por Cisco?

A) PEAP

B) EAP-TTLS

C) SALTO

D) EAP-TLS

252. Un enfoque de desarrollo de software que tiene como objetivo la creación rápida de aplicaciones y la mejora continua a través del desarrollo iterativo y la colaboración de los usuarios se denomina:

A) FDD

B) DevOps

✓ C) RAD

D) SaaS

253. ¿Cuál de las respuestas enumeradas a continuación se refiere a una tecnología que permite que los dispositivos USB actúen como hosts y periféricos, permitiéndoles conectarse y comunicarse con otros dispositivos USB directamente sin la necesidad de una computadora o un host dedicado?

A) PnP

B) OTG

C) P2P

D) HCl

254. ¿Cuál de las respuestas enumeradas a continuación se refiere a la funcionalidad integrada de un dispositivo móvil que permite el uso de aplicaciones de localización?

A) WPS

B) GSM

C) SIM

✓ D) GPS

255. En las PC más antiguas que no están basadas en UEFI, el primer sector de una unidad de almacenamiento que contiene información sobre las particiones y un fragmento de código ejecutable utilizado para cargar el sistema operativo instalado se llama:

A) MBR

B) GPT

C) PXE
D) GUID

256. ¿Cuál de los siguientes términos se refiere a una tecnología que permite la comunicación de audio y video en tiempo real entre individuos o grupos?

A) VPC
✓ B) VTC
C) VoIP
D) VDI

257. ¿Cuál de las respuestas enumeradas a continuación se puede utilizar para describir XSRF? (Seleccione 3 respuestas)

A) Explota la confianza que un sitio web tiene en el navegador web del usuario.
✓ B) Un atacante engaña a un usuario para que envíe solicitudes web no autorizadas
✓ C) El sitio web ejecuta las solicitudes del atacante
D) Explota la confianza que el navegador web de un usuario tiene en un sitio web
✓ E) Se inyecta un script malicioso en un sitio web confiable
✓ F) El navegador del usuario ejecuta el script del atacante

258. Una característica de IA que le permite realizar tareas basadas en datos de entrenamiento sin instrucciones humanas explícitas se llama:

A) AGI
✓ B) ml
C) NN
D) LLM

259. ¿Cuál de las respuestas enumeradas a continuación se refiere a un protocolo de intercambio de claves que genera claves temporales para cada sesión, proporcionando secreto directo para proteger las comunicaciones pasadas y futuras?

A) PFS
B) sha
C) PGP
✓ D) DHE

260. ¿Cuál de las respuestas que se enumeran a continuación se refieren a los rasgos característicos del NIDS? (Seleccione 3 respuestas)

A) Toma medidas proactivas para bloquear o mitigar los intentos de intrusión.
✓ B) No toma medidas directas para bloquear o prevenir ataques.
✓ C) Genera alertas y notifica al personal de seguridad o a los administradores cuando se detecta actividad sospechosa.
✓ D) Supervisa el tráfico de la red sin participación directa en el enrutamiento del tráfico o la modificación de paquetes.
E) Puede descartar o rechazar paquetes de red, finalizar conexiones o tomar otras acciones para detener el ataque.
F) Opera en modo en línea, interceptando e inspeccionando activamente el tráfico de la red.

261. ¿Cuál de las respuestas enumeradas a continuación se refiere a un método básico para establecer un enlace punto a punto dedicado entre dos dispositivos en red?

A) PPTP
B) IGMP
C) APP
D) MPLS

262. ¿Cuál de las respuestas enumeradas a continuación se refiere a un método obsoleto basado en TLS para proteger SMTP?

A) desplazados internos
B) INICIO
C) DKIM
D) SMTP

263. ¿Cuál de las respuestas enumeradas a continuación se refiere a una tarjeta inteligente utilizada en teléfonos móviles para identificar al usuario del teléfono?

A) IMSI
B) SoC
C) IMEI
✓ D) SIM

264. ¿Cuál de los términos enumerados a continuación se refiere a una iniciativa del gobierno de EE. UU. para compartir en tiempo real indicadores de amenazas cibernéticas?

A) NVD
✓ B) AIS
C) TTP
D) cvss

265. Una empresa u organización que ofrece servicios de computación en la nube a través de Internet se denomina:

A) ISP
B) MSSP
✓ C) CSP
D) MSP

266. ¿Cuál de las siguientes respuestas se refiere a un protocolo de cifrado utilizado principalmente en redes Wi-Fi que implementan el estándar de seguridad WPA2?

A) TKIP
B) CCMP
C) SSL
D) HMAC

267. ¿Cuál de las siguientes siglas hace referencia a un programa de investigación discontinuado enfocado a promover la innovación y el desarrollo en el campo de las telecomunicaciones y las tecnologías de la información?

A) IETF
B) CERN
C) DARPA
D) CARRERA

268. ¿Cuál de las siguientes respuestas se puede utilizar para describir los controles técnicos de seguridad? (Seleccione 3 respuestas)

A) Enfocados en proteger los bienes materiales
✓ B) A veces se les llama controles de seguridad lógicos.
✓ C) Ejecutado por sistemas informáticos (en lugar de personas)
D) También conocidos como controles administrativos.
✓ E) Implementado con tecnología.
F) Principalmente implementado y ejecutado por personas (a diferencia de los sistemas informáticos)

269. ¿Cuál de las siguientes respuestas se refiere a los rasgos característicos de los controles de seguridad gerenciales? (Seleccione 3 respuestas)

A) También conocidos como controles administrativos.
B) A veces denominados controles de seguridad lógicos.
✓ C) Enfocados en reducir el riesgo de incidentes de seguridad
D) Ejecutado por sistemas informáticos (en lugar de personas)
✓ E) Documentado en políticas escritas.
F) Enfocados en proteger los bienes materiales

270. ¿Cuál de las respuestas enumeradas a continuación se puede utilizar para describir los controles de seguridad operativos? (Seleccione 3 respuestas)

A) También conocidos como controles administrativos.

✓ **B) Enfocados en los procedimientos del día a día de una organización.**
C) Ejecutado por sistemas informáticos (en lugar de personas)
✓ **D) Se utiliza para garantizar que el equipo continúe funcionando según lo especificado.**
E) Enfocados en la gestión del riesgo
✓ **F) Principalmente implementado y ejecutado por personas (a diferencia de los sistemas informáticos)**

271. ¿Cuál de las respuestas enumeradas a continuación se refiere a controles de seguridad diseñados para disuadir, detectar y prevenir el acceso no autorizado, el robo, el daño o la destrucción de activos materiales?

A) Controles de seguridad gerenciales
✓ **B) Controles de seguridad física**
C) Controles técnicos de seguridad
D) Controles operativos de seguridad

272. ¿Cuáles son los ejemplos de controles preventivos de seguridad? (Seleccione 3 respuestas)

A) Cifrado
B) identificación
C) Sensores
✓ **D) Cortafuegos**
E) Señales de advertencia
✓ **F) software audiovisual**

273. ¿Cuál de las respuestas enumeradas a continuación se refiere(s) a los controles de seguridad de detectives? (Seleccione todo lo que corresponda)

A) Iluminación
✓ **B) Monitoreo de registros**
C) Zona de arena
✓ **D) Auditorías de seguridad**
✓ **E) circuito cerrado de televisión**
✓ **F) identificación**
✓ **G) Escaneo de vulnerabilidades**

274. ¿Cuál de las respuestas enumeradas a continuación se refiere(s) a controles de seguridad compensatorios? (Seleccione todo lo que corresponda)

A) Sistemas de energía de respaldo
B) Videovigilancia
✓ **C) Ministerio de Asuntos Exteriores**
✓ **D) Zona de pruebas de aplicaciones**
✓ **E) Segmentación de red**

275. ¿Cuál de los siguientes términos entran en la categoría de controles de seguridad directivos? (Seleccione 2 respuestas)

A) PIR
✓ **B) PUA**
C) identificación
D) Ministerio de Asuntos Exteriores
E) IPS

276. ¿Cuál es el nombre de un protocolo de red que protege el tráfico web mediante cifrado SSL/TLS?

✓ **A) SFTP**
✓ **B) HTTPS**
C) FTPS
D) SHTTP

277. SFTP es una extensión del protocolo FTP que agrega soporte para cifrado SSL/TLS.

A) Verdadero
✓ **B) FALSO**

278. ¿Qué parte de IPsec proporciona autenticación, integridad y confidencialidad?

A) SPD
B) PFS
C) Ah
✓ **D) ESP**

279. ¿Cuál de las siguientes respuestas se refiere a un protocolo de intercambio de claves que genera claves temporales para cada sesión, proporcionando secreto directo para proteger las comunicaciones pasadas y futuras?

A) PFS
B) sha
C) PGP
D) DHE

280. ¿Cuál de las siguientes respuestas se refiere a un protocolo de intercambio de claves criptográficas que aprovecha ECC para mejorar la seguridad y la eficiencia?

A) S/MIME
B) ECDHE
C) DHE
D) ECDSA

281. ¿Qué longitud de clave AES proporciona el mayor nivel de seguridad?

A) clave de 128 bits
B) clave de 192 bits
✓ **C) clave de 256 bits**
D) clave de 320 bits

282. Una función hash es un algoritmo matemático que asigna datos de tamaño arbitrario a un valor hash de tamaño fijo, generalmente representado como una cadena corta de caracteres. El resultado de la función hash, también conocido como resumen o suma de comprobación, proporciona una representación única de la entrada de datos original. La funcionalidad de las funciones hash se basa en el hecho de que si hay algún cambio en los datos después de generar el hash original, el nuevo valor hash calculado después de la modificación del contenido será diferente del resultado original porque las funciones hash están diseñadas para ser sensibles a los cambios en los datos de entrada.

A) Verdadero
B) FALSO
Respuesta no detectada automaticamente

283. ¿Cuál de las respuestas enumeradas a continuación se refiere a una función hash criptográfica que se ha utilizado ampliamente en el pasado pero que ahora se considera obsoleta para aplicaciones sensibles a la seguridad debido a vulnerabilidades conocidas?

A) MD5
B) sha
C) CDN
D) HMAC
Respuesta no detectada automaticamente

284. ¿Cuál de las respuestas enumeradas a continuación se refiere a un identificador utilizado para objetos PKI?

A) OID
B) DN
C) SAN
D) GUID
Respuesta no detectada automaticamente

285. Asigne el atributo de nivel de sofisticación a cada tipo de actor de amenazas que se enumera a continuación.

Respuesta no detectada automaticamente

286. En la lista desplegable de la derecha, seleccione las motivaciones típicas detrás de las acciones de cada tipo de actor de amenaza.

Respuesta no detectada automaticamente

287. ¿Cuál de los siguientes términos se utiliza para describir ciberataques sofisticados y prolongados, a menudo llevados a cabo por grupos organizados y bien financiados, como los Estados-nación?

A) MitM

✓ B) APTO

C) XSRF

D) DDoS

288. Una superficie de ataque es la suma de todos los puntos potenciales (vulnerabilidades) a través de los cuales un atacante puede interactuar o comprometer un sistema o red, lo que indica la exposición general a amenazas potenciales. Ejemplos de superficies de ataque pueden ser todo software, hardware e interfaces de red con fallas de seguridad conocidas. Un vector de amenaza representa el método o medio a través del cual se introduce o entrega una amenaza cibernética a un sistema objetivo. Describe la vía o vía utilizada por los atacantes para explotar las vulnerabilidades. Los tipos de vectores de amenazas comunes incluyen correos electrónicos de phishing, malware, descargas no autorizadas y técnicas de ingeniería social.

A) Verdadero

B) FALSO

Respuesta no detectada automaticamente

289. ¿Cuál de las respuestas enumeradas a continuación se refiere a un ejemplo de un vector de amenaza potencial en la comunicación basada en mensajería instantánea?

A) Ataque de phishing

B) Distribución de malware

C) Ataque de suplantación de identidad

D) Escuchar a escondidas

E) Secuestro de cuenta

F) Enlace/adjunto malicioso

✓ G) Todo lo anterior

290. ¿Cuál de las siguientes respuestas se refiere a ejemplos de vectores de amenazas basados ■■en imágenes? (Seleccione 3 respuestas)

A) esteganografía

B) Ataques BEC

C) Suplantación de imágenes (deepfakes)

D) Suplantación de marca

E) Imágenes con malware incorporado

291. El término "Typosquatting" se refiere a una práctica engañosa que implica el registro deliberado de nombres de dominio con errores ortográficos o ligeras variaciones que se parecen mucho a nombres de dominio populares y bien establecidos. El objetivo principal de esta estrategia es explotar los errores tipográficos comunes que cometen los usuarios al ingresar URL en la barra de direcciones de su navegador web. Más allá de capturar tráfico inadvertido, la typosquatting también se puede utilizar para alojar sitios de phishing para engañar a los usuarios para que divulguen información confidencial, distribuir malware a través de sitios web engañosos, generar ingresos publicitarios al redirigir el tráfico mal escrito o participar en la suplantación de marcas para dañar la reputación de marcas auténticas o engañar a los usuarios.

A) Verdadero

B) FALSO

Respuesta no detectada automaticamente

292. ¿Cuál sería una respuesta apropiada del usuario ante un intento de phishing por correo electrónico? (Seleccione todo lo que corresponda)

A) No responder al mensaje ni proporcionar ningún dato personal.

✓ B) Reportar el mensaje al departamento de TI o seguridad, si corresponde

✓ C) Eliminar el mensaje de la bandeja de entrada

✓ **D) No hacer clic en ningún enlace ni descargar ningún archivo adjunto en el mensaje**

E) Reenviar el mensaje al remitente para verificar su legitimidad

F) Abrir el archivo adjunto en un entorno sandbox para comprobar su seguridad

---

293. ¿Qué tipo de ataque a una aplicación se basa en la introducción de código externo en el espacio de direcciones de un programa en ejecución?

A) Desbordamiento del búfer

✓ **B) Inyección de memoria**

C) Repetir ataque

D) Desreferencia del puntero

---

294. ¿Cuál de las respuestas enumeradas a continuación se refiere a un ataque a una aplicación que se basa en la ejecución de una biblioteca de código?

A) pérdida de memoria

✓ **B) inyección de DLL**

C) Desreferencia del puntero

✓ **D) Desbordamiento del búfer**

---

295. Una actualización de aplicación maliciosa es un tipo de malware que se puede instalar mediante una actualización de software aparentemente legítima. La introducción de una actualización maliciosa en el código de la aplicación se puede habilitar a través de varios medios, que incluyen:

A) Código de aplicación sin firmar

B) Canal de actualización no cifrado (HTTP vs HTTPS)

C) Sitio web de actualización falso

D) Acceso no autorizado al servidor de actualización

E) Proceso de desarrollo de software comprometido

✓ **F) Todo lo anterior**

---

296. ¿Cuál es la principal vulnerabilidad relacionada con el hardware heredado?

A) Problemas de compatibilidad

✓ **B) Falta de actualizaciones y parches de seguridad.**

C) Componentes físicos desgastados

D) Falta de personal capacitado para operarlo y mantenerlo.

---

297. ¿Cuál de las siguientes respuestas se refiere a una vulnerabilidad relacionada con la virtualización en la que los activos virtualizados asignados a una máquina virtual están aislados incorrectamente y otra máquina virtual puede acceder a ellos o ponerlos en peligro?

A) Reutilización de recursos

B) Escalada de privilegios

C) Agotamiento de recursos

D) Uso simultáneo de sesiones

Respuesta no detectada automaticamente

---

298. La práctica de instalar aplicaciones móviles desde sitios web y tiendas de aplicaciones distintos de los mercados oficiales se conoce como:

A) jailbreak

B) Enraizamiento

✓ **C) Carga lateral**

D) Desbloqueo del operador

---

299. El término "Enraizamiento" se refiere a la capacidad de obtener acceso administrativo al sistema operativo y a las aplicaciones del sistema en:

A) Dispositivos Android

B) dispositivos iOS

C) Dispositivos Microsoft

D) Todo tipo de dispositivos móviles

---

300. El malware que restringe el acceso a un sistema informático cifrando archivos o bloqueando todo el sistema hasta que el usuario realice la acción solicitada se llama:

A) Grayware
B) software publicitario
✓ **C) ransomware**
D) software espía

301. Un programa informático malicioso independiente que normalmente se propaga a través de una red informática para afectar negativamente a los recursos del sistema y al ancho de banda de la red se denomina:

A) Gusano
B) virus sin archivos
C) Bot
D) Bomba lógica

302. El código malicioso activado por un evento específico se llama:

A) criptomalware
B) Puerta trasera
C) rootkit
✓ **D) Bomba lógica**

303. ¿Qué define un ataque DDoS reflejado?

A) Abrumar al objetivo con un gran volumen de tráfico para saturar su ancho de banda
B) Explotar vulnerabilidades en los protocolos de red para consumir recursos e interrumpir servicios
✓ **C) Utilizar servidores de terceros para reflejar y amplificar el tráfico de ataque hacia el objetivo.**
D) Apuntar a vulnerabilidades en aplicaciones o servidores web para agotar los recursos.

304. Un ataque de disociación inalámbrica es un tipo de: (Seleccione 2 respuestas)

A) Ataque de degradación
✓ **B) Ataque de desautenticación**
C) Ataque de fuerza bruta
✓ **D) Ataque DoS**
E) Ataque criptográfico

305. Un ataque de reproducción de red ocurre cuando un atacante captura datos confidenciales del usuario y los reenvía al receptor con la intención de obtener acceso no autorizado o engañar al receptor para que realice operaciones no autorizadas.

A) Verdadero
B) FALSO

306. ¿Qué tipo de acción permite a un atacante aprovechar la vulnerabilidad XSS?

A) inyección de código
B) Escalada de privilegios
C) Secuestro de sesión
D) rastreo de paquetes

307. ¿Qué tipo de exploit se dirige a aplicaciones web que generan contenido utilizado para almacenar y transportar datos?

A) Ataque de inyección SQL
B) Ataque CSRF/XSRF
✓ **C) Ataque de inyección XML**
D) Ataque de inyección LDAP

308. Una situación en la que un atacante intercepta y retransmite un intercambio de datos válido entre una aplicación y un servidor u otra aplicación se conoce como:

A) Carga lateral
✓ **B) Repetir ataque**
C) Ataque de phishing

D) Condición de carrera

309. Un tipo de evidencia forense que puede usarse para detectar intentos de acceso no autorizados u otras actividades maliciosas se denomina:

A) CVE

✓ B) COI

C) AIS

D) OSINT

310. ¿Cuál de los términos enumerados a continuación describe con mayor precisión una situación en la que se utiliza una sola cuenta desde múltiples ubicaciones/dispositivos al mismo tiempo?

A) Ataque de fumigación

✓ B) Uso simultáneo de sesiones

C) Inicio de sesión único (SSO)

D) viaje imposible

311. ¿Cuál de los términos enumerados a continuación describe con mayor precisión una situación en la que se accede a una cuenta desde una ubicación en la que es físicamente imposible que se encuentre el usuario?

A) Restricciones de tiempo de inicio de sesión

✓ B) viaje imposible

C) Uso simultáneo de sesiones

D) Registro fuera de ciclo

312. ¿Cuál de las siguientes opciones indicaría un intento de ocultar evidencia de actividad maliciosa?

A) Bloqueo de cuenta

B) Inaccesibilidad de recursos

✓ C) Registros faltantes

D) Uso simultáneo de sesiones

313. ¿Cuál de las respuestas enumeradas a continuación se refiere a algún tipo de información perteneciente a un individuo que pueda usarse para identificar de manera única a esa persona?

A) FI

B) Biometría

C) IDENTIFICACIÓN

✓ D) PII

314. ¿Cuál de las respuestas enumeradas a continuación se refiere a los métodos de cifrado utilizados para proteger los datos en reposo? (Seleccione todo lo que corresponda)

A) FDE

✓ B) SED

C) IPSec

D) TLS

✓ E) vpn

✓ F) EFS

315. ¿Cuál de los siguientes estados de datos normalmente requiere que los datos se procesen sin cifrar?

A) Datos en movimiento

B) Datos en reposo

C) Datos en tránsito

✓ D) Datos en uso

316. ¿Cuál de las respuestas enumeradas a continuación se refiere a una tecnología que proporciona control sobre el uso de un dispositivo móvil dentro de un área designada?

A) Geocerca

B) Portal cautivo

C) Mielero

D) Geolocalización

Respuesta no detectada automaticamente

317. Nivel RAID de hardware 0: (seleccione todo lo que corresponda)

A) Requiere un mínimo de 2 unidades para implementar

✓ B) También se conoce como segmentación de discos.

✓ C) Disminuye la confiabilidad (la falla de cualquier disco en la matriz resulta en la pérdida de todos los datos en la matriz)

D) También se conoce como duplicación de disco.

E) Ofrece menos capacidad de volumen en comparación con RAID 1

F) Requiere al menos 3 unidades para implementarse

✓ G) Es adecuado para sistemas donde el rendimiento tiene mayor prioridad que la tolerancia a fallos.

8) Ofrece confiabilidad mejorada al crear conjuntos de datos idénticos en cada unidad (la falla de una unidad no destruye la matriz ya que cada unidad contiene una copia idéntica de los datos)

318. Hardware RAID Nivel 5: (Seleccione 3 respuestas)

A) Requiere al menos 2 unidades para implementar

B) Continúa funcionando en caso de falla de más de 1 unidad

C) También se conoce como segmentación de discos con doble paridad.

✓ D) Requiere al menos 3 unidades para implementarse

✓ E) Ofrece mayor rendimiento y tolerancia a fallas (la falla de una sola unidad no destruye la matriz y las unidades restantes pueden recrear los datos perdidos)

✓ F) Requiere al menos 4 unidades para implementarse

✓ G) También se conoce como división de discos con paridad.

319. Hardware RAID Nivel 10 (también conocido como RAID 1+0): (Seleccione 3 respuestas)

A) Requiere un mínimo de 4 unidades para implementar

✓ B) Se conoce como banda de espejos, es decir, una combinación de RAID 1 (duplicación de disco) y RAID 0 (división de disco).

C) Requiere un mínimo de 5 unidades para implementar

✓ D) Ofrece mayor rendimiento y tolerancia a fallos (el fallo de una unidad en cada par de unidades de disco reflejadas no destruye la matriz)

E) Requiere un mínimo de 3 unidades para implementar

F) Continúa funcionando en caso de falla de más de 2 unidades

G) Se conoce como banda de espejos, es decir, una combinación de RAID 1 (división de discos) y RAID 0 (duplicación de discos).

320. ¿Cuál de las respuestas enumeradas a continuación se refiere a la función principal del equilibrio de carga?

A) Mantiene copias idénticas de datos en múltiples servidores para mejorar la disponibilidad y confiabilidad de los datos.

✓ B) Distribuye la carga de trabajo entre múltiples servidores para mejorar el rendimiento.

✓ C) Agrupa servidores para proporcionar alta disponibilidad y tolerancia a fallos.

D) Distribuye contenido geográficamente entre múltiples servidores para mejorar el rendimiento, reducir la latencia y manejar grandes volúmenes de tráfico.

321. ¿Cuál de los términos enumerados a continuación se refiere a un duplicado del sitio original, con sistemas informáticos en pleno funcionamiento y copias de seguridad casi completas de los datos del usuario?

A) sitio caliente

B) Sitio cálido

C) Sitio frio

D) sitio móvil

Respuesta no detectada automaticamente

322. Una instalación de recuperación ante desastres que proporciona únicamente el espacio físico para las operaciones de recuperación se conoce como:

A) sitio caliente

B) Sitio cálido

✓ C) Sitio frio

D) Sitio espejo

323. ¿Cuál de las respuestas enumeradas a continuación se refiere a un escenario simulado llevado a cabo en un entorno controlado, que generalmente implica discusiones y planificación en torno a incidentes de seguridad hipotéticos?

A) Ejercicio de mesa

B) Zona de arena

C) caza de amenazas

D) Capacitación en concientización sobre seguridad.

Respuesta no detectada automaticamente

324. ¿Cuál de los siguientes términos se refiere a una estrategia de respaldo que se basa en la creación y el mantenimiento de copias de datos en tiempo real o casi en tiempo real en un sistema separado?

A) Duplicación

B) Virtualización

✓ C) Llevar un diario

✓ D) Replicación

325. Un SSID es un identificador único (también conocido como nombre de red inalámbrica) para una WLAN. Las redes inalámbricas anuncian su presencia transmitiendo periódicamente SSID en un paquete especial llamado marco de baliza. En redes inalámbricas con funciones de seguridad deshabilitadas, conocer el SSID de la red es suficiente para acceder a la red. SSID también identifica el enrutador inalámbrico que actúa como WAP. Los enrutadores inalámbricos del mismo fabricante suelen configurarse con nombres SSID predeterminados (conocidos). Dado que varios dispositivos con el mismo SSID mostrado en la lista de redes disponibles crean confusión y fomentan el acceso accidental por parte de usuarios no autorizados (se aplica a redes que carecen de seguridad), cambiar el SSID predeterminado es una práctica recomendada.

A) Verdadero

B) FALSO

Respuesta no detectada automaticamente

326. ¿Cuáles son las características del modo empresarial WPA2/WPA3? (Seleccione 3 respuestas)

A) Adecuado para grandes redes corporativas

B) IEEE 802.1D

C) No requiere un servidor de autenticación

✓ D) IEEE 802.1X

E) Adecuado para todo tipo de LAN inalámbricas

✓ F) Requiere servidor de autenticación RADIUS

327. ¿Cuál de las respuestas enumeradas a continuación se refiere a un protocolo de autenticación de red inalámbrica estándar abierto que mejora la seguridad al encapsular el proceso de autenticación dentro de un túnel TLS cifrado?

A) PEAP

B) PAE

C) SALTO

D) RADIO

Respuesta no detectada automaticamente

328. ¿Cuáles de los aspectos de programación enumerados a continuación son críticos en el proceso de desarrollo seguro de aplicaciones? (Seleccione 2 respuestas)

A) Gestión de parches

✓ B) Validación de entrada

C) Protección con contraseña

✓ D) Manejo de errores y excepciones

E) Lista blanca de aplicaciones

329. ¿Cuál de los términos enumerados a continuación se refiere a un proceso de revisión de código manual o automatizado destinado a descubrir errores de lógica y sintaxis en el código fuente de la aplicación?

A) Validación de entrada

B) Análisis de código dinámico

C) Fuzzing

✓ **D) Análisis de código estático**

330. El término "análisis de código estático" se refiere al proceso de descubrir errores de tiempo de ejecución de la aplicación.

A) Verdadero

✓ **B) FALSO**

331. La práctica de encontrar vulnerabilidades en una aplicación dándole entradas incorrectas se llama:

A) Normalización

B) Endurecimiento

C) Análisis de código dinámico

✓ **D) Fuzzing**

332. Un tipo de mecanismo de identificación de usuarios utilizado como contramedida contra el software automatizado (como los robots de red) se conoce como:

A) Ministerio de Asuntos Exteriores

✓ **B) CAPTCHA**

C) SSO

D) NIDS

333. Escaneo de vulnerabilidades: (Seleccione todas las que correspondan)

A) Identifica falta de controles de seguridad

B) Prueba activamente los controles de seguridad.

✓ **C) Identifica errores de configuración comunes**

D) Explota vulnerabilidades

✓ **E) Prueba pasivamente los controles de seguridad.**

334. ¿Cuál de las siguientes afirmaciones describe las características del análisis de código dinámico? (Seleccione 3 respuestas)

A) Normalmente se utiliza más adelante en el ciclo de vida del desarrollo de software.

B) Implica examinar el código sin ejecutarlo.

✓ **C) Analiza las propiedades del tiempo de ejecución, como el uso de la memoria, el rendimiento y el manejo de errores, para identificar problemas como pérdidas de memoria, cuellos de botella en el rendimiento y errores de tiempo de ejecución.**

D) A menudo se utiliza al principio del proceso de desarrollo.

E) Examina la estructura, la sintaxis y la semántica del código para detectar problemas como errores de sintaxis, violaciones de estándares de codificación, vulnerabilidades de seguridad y errores.

✓ **F) Implica ejecutar el código y analizar su comportamiento en tiempo de ejecución.**

335. ¿Cuál de los términos enumerados a continuación se refiere al seguimiento y administración de componentes de aplicaciones de software, como bibliotecas de terceros y otras dependencias?

A) Control de versiones

B) Monitoreo de paquetes

C) Aplicación de la configuración

D) Endurecimiento de aplicaciones

336. Un mecanismo de transporte dedicado para información sobre amenazas cibernéticas se denomina:

A) TCP/IP

B) TLS

✓ **C) TAXII**

D) S/MIME

337. ¿Cuál de las siguientes afirmaciones no se aplica a la web oscura?

A) Normalmente requiere software especializado para acceder a sus contenidos.

✓ **B) Forma una gran parte de la web profunda.**

C) No indexado por los motores de búsqueda tradicionales.

D) A menudo se asocia con el comercio de datos robados, malware y amenazas cibernéticas.

338. Un programa de divulgación responsable es un proceso formal establecido por una organización para alentar a los investigadores de seguridad y a los piratas informáticos éticos a informar las vulnerabilidades que descubren en los sistemas o software de la organización. Un programa de recompensas por errores es un tipo específico de programa de divulgación responsable que ofrece recompensas financieras a los investigadores de seguridad por informar vulnerabilidades válidas.

A) Verdadero

B) FALSO

339. ¿Cuál de las siguientes opciones se refiere a un sistema que identifica, define y cataloga vulnerabilidades de ciberseguridad conocidas públicamente?

A) TAXII

✓ B) CVE

C) STIX

D) cvss

340. ¿Cuál de las afirmaciones enumeradas a continuación no se refiere a una técnica de respuesta y remediación de vulnerabilidades?

A) Aplicar actualizaciones o correcciones proporcionadas por proveedores de software para abordar la vulnerabilidad (parches)

B) Garantizar la recuperación financiera de los costos asociados con un ciberataque exitoso (seguro)

C) Dividir una red en zonas más pequeñas y aisladas para limitar el impacto potencial de una vulnerabilidad (segmentación)

D) Mitigar el riesgo asociado con una vulnerabilidad que no se puede reparar de inmediato mediante la implementación de medidas de seguridad alternativas (controles de compensación)

E) Retrasar o renunciar a un parche para un sistema específico, por ejemplo, cuando aplicar un parche puede no ser factible debido a problemas de compatibilidad o posibles interrupciones en sistemas críticos (excepciones y exenciones).

✓ F) Todas las respuestas anteriores son ejemplos de técnicas de respuesta y remediación de vulnerabilidades.

341. ¿Cuál de las siguientes respuestas se refiere(s) al modelo de control de acceso obligatorio (MAC)? (Seleccione todo lo que corresponda)

A) Los usuarios no pueden cambiar las políticas de acceso a su propia discreción.

✓ B) Las etiquetas y los niveles de autorización solo pueden ser aplicados y modificados por un administrador

C) Cada objeto tiene un propietario que, a su propia discreción, determina qué tipo de permisos pueden tener otros usuarios sobre ese objeto.

D) Acceso a recursos según la identidad del usuario.

✓ E) Cada recurso tiene una etiqueta de confidencialidad que coincide con un nivel de autorización asignado a un usuario.

342. Ejemplos de propiedades utilizadas para definir políticas de acceso en el modelo de control de acceso basado en atributos (ABAC) incluyen:

A) Asunto (es decir, usuario o proceso que solicita acceso)

B) Tipo de acción (por ejemplo "leer", "escribir", "ejecutar")

C) Tipo de recurso (historial médico, cuenta bancaria, etc.)

D) Entorno (datos contextuales, como hora del día o geolocalización)

✓ E) Todo lo anterior

343. La configuración de política de antigüedad máxima de la contraseña determina el período de tiempo que se debe utilizar una contraseña antes de que el usuario pueda cambiarla.

A) Verdadero

✓ B) FALSO

344. La importancia de cambiar los nombres de usuario y contraseñas predeterminados se puede ilustrar con el ejemplo de ciertos dispositivos de red (como enrutadores), que a menudo vienen con credenciales de administrador predeterminadas y conocidas que se pueden buscar en la web.

A) Verdadero

B) FALSO

Respuesta no detectada automaticamente

345. Un ataque contra datos cifrados que depende en gran medida de la potencia informática para comprobar todas las claves y contraseñas posibles hasta encontrar la correcta se denomina:

A) Repetir ataque

✓ **B) Ataque de fuerza bruta**

C) Ataque de diccionario

D) Ataque de cumpleaños

346. ¿Qué parte del proceso de respuesta a incidentes implica establecer y mantener la capacidad de respuesta a incidentes, así como establecer un equipo de respuesta a incidentes?

A) Preparación

B) Detección y análisis

C) Contención, erradicación y recuperación

D) Actividad posterior al incidente

347. ¿Cuál de las siguientes respuestas se refiere(s) a la etapa de contención, erradicación y recuperación del proceso de respuesta a incidentes? (Seleccione todo lo que corresponda)

A) Restaurando operaciones normales

✓ **B) Eliminando la amenaza**

C) Seguimiento y detección de posibles incidencias

D) Establecer y mantener una política de respuesta a incidentes.

✓ **E) Mitigar el impacto del incidente**

348. ¿Cuál de las respuestas enumeradas a continuación se refiere a una actividad basada en debates en la que los miembros del equipo recorren diferentes escenarios para evaluar el plan de respuesta a incidentes sin activar ningún sistema?

A) Ejercicio de mesa

✓ **B) Simulación**

C) caza de amenazas

D) Análisis de causa raíz

349. Durante la etapa de actividad posterior al incidente, este paso implica analizar registros, datos forenses y otras pruebas para evitar que el incidente vuelva a ocurrir.

A) Informes

B) descubrimiento electrónico

✓ **C) Análisis de causa raíz**

D) caza de amenazas

350. El proceso de mantener un registro documentado del manejo y movimiento de la evidencia para asegurar su integridad y admisibilidad en el tribunal se denomina:

A) cadena de custodia

B) Cadena de evidencia

C) Cadena de rendición de cuentas

D) cadena de responsabilidad

Respuesta no detectada automaticamente

351. El proceso de determinar los riesgos potenciales que podrían afectar la capacidad de una organización para alcanzar sus objetivos se denomina:

✓ **A) Evaluación de riesgos**

✓ **B) Identificación de riesgos**

C) Análisis de riesgos

D) Gestión de riesgos

352. ¿Cuál de las siguientes respuestas se refiere a un método de evaluación de riesgos basado en la necesidad, que generalmente se lleva a cabo en respuesta a eventos o cambios específicos, como después de un cambio organizacional importante o una violación de seguridad?

A) A propósito

B) Periódico

C) una sola vez

D) Continuo

353. Un valor MTBF alto indica que un componente o sistema proporciona baja confiabilidad y es más probable que falle.

A) Verdadero

✓ **B) FALSO**

354. En las pruebas de penetración, el reconocimiento activo implica recopilar cualquier tipo de información disponible públicamente que pueda usarse más adelante para explotar las vulnerabilidades encontradas en el sistema objetivo.

A) Verdadero

✓ **B) FALSO**

2.0 Amenazas, Vulnerabilidades y Mitigaciones (22% del examen)

2.1 - Comparar y contrastar los actores de amenaza comunes y sus motivaciones.

Conceptos clave:

- Actores: Estado-nacion, Atacante sin habilidades, Hacktivist, Amenaza interna, Crimen organizado, Shadow IT
- Atributos: Interno/externo, Recursos/financiacion, Nivel de sofisticacion
- Motivaciones: Exfiltracion de datos, Espionaje, Ganancia economica, Disrupcion, Venganza, Guerra

Teoria detallada:

TIPOS DE ACTORES DE AMENAZA:

- Estado-nacion (Nation-state): los mas sofisticados y con mas recursos. Motivacion: espionaje, sabotaje. Ejemplo: APT grupos como Lazarus (Corea del Norte)
- Crimen organizado: motivacion economica, ransomware, fraude
- Hacktivist: motivacion ideologica o politica. Ejemplo: Anonymous
- Amenaza interna (Insider threat): empleado o ex-empleado con acceso legitimo. Puede ser malicioso o accidental
- Atacante sin habilidades (Script kiddie): usa herramientas de otros sin entender como funcionan
- Shadow IT: sistemas o servicios usados sin aprobacion del departamento IT

ATRIBUTOS DE LOS ACTORES:

- Interno vs Externo: interno (empleado) vs externo (hacker desde fuera)
- Recursos/financiacion: desde ninguno (script kiddie) hasta presupuestos millonarios (estado-nacion)
- Sofisticacion: desde ataques de phishing basicos hasta exploits de zero-day personalizados

MOTIVACIONES (el POR QUE atacan):

- Exfiltracion de datos: robar datos para venderlos o usarlos
- Ganancia economica: ransomware, fraude, robo de credenciales bancarias
- Espionaje: robar secretos industriales o gubernamentales
- Disrupcion/Caos: tirar sistemas sin motivo economico
- Filosofico/Politico: hacktivismo
- Venganza: empleado descontento
- Guerra: ciberguerra entre estados

APT (Amenaza Persistente Avanzada): actor sofisticado (normalmente estado-nacion) que permanece en la red de la victima durante meses o anos sin ser detectado, extrayendo informacion de forma continua.

Preguntas de practica (26):

1. ¿Qué término describe mejor a un empleado descontento que abusa del acceso legítimo a los recursos internos de una empresa?

A) APTO

✓ **B) Amenaza interna**

C) sombrero gris

D) actor de amenazas

---

2. En la lista desplegable de la derecha, seleccione las motivaciones típicas detrás de las acciones de cada tipo de actor de amenaza.

Respuesta no detectada automaticamente

---

3. ¿Cuál de los siguientes términos se utiliza para describir ciberataques sofisticados y prolongados, a menudo llevados a cabo por grupos organizados y bien financiados, como los Estados-nación?

A) MitM

✓ **B) APTO**

C) XSRF

D) DDoS

---

4. ¿Cuál de los siguientes términos se utiliza para describir ciberataques sofisticados y prolongados, a menudo llevados a cabo por grupos organizados y bien financiados, como los Estados-nación?

A) MitM

✓ **B) APTO**

C) XSRF
D) DDoS

5. En la lista desplegable de la derecha, seleccione las motivaciones típicas detrás de las acciones de cada tipo de actor de amenaza.

Respuesta no detectada automaticamente

6. ¿Cuál de los siguientes términos se utiliza para describir ciberataques sofisticados y prolongados, a menudo llevados a cabo por grupos organizados y bien financiados, como los Estados-nación?

A) MitM
✓ B) APTO
C) XSRF
D) DDoS

7. ¿Cuál de las respuestas enumeradas a continuación se refiere a un enfoque de seguridad del plano de control de confianza cero que tiene en cuenta la identidad del usuario, la seguridad del dispositivo, las condiciones de la red y otra información contextual para permitir decisiones de acceso dinámico?

A) Confianza implícita
B) Monitoreo y registro
✓ C) Identidad adaptativa
D) Microsegmentación

8. Elija una respuesta de la lista desplegable de la derecha para hacer coincidir un tipo de actor de amenaza a la izquierda con su atributo de vector de ataque común.

Respuesta no detectada automaticamente

9. Relacione cada tipo de actor de amenaza con su correspondiente atributo de recursos/financiación.

Respuesta no detectada automaticamente

10. Asigne el atributo de nivel de sofisticación a cada tipo de actor de amenazas que se enumera a continuación.

Respuesta no detectada automaticamente

11. Ejemplos de vectores de amenazas directamente relacionados con el uso de dispositivos extraíbles incluyen: (Seleccione 2 respuestas)

A) Pretexto
✓ B) Entrega de malware
C) Ataques de abrevadero
✓ D) Exfiltración de datos
E) Ataques de ingeniería social

12. El término "secuestro de URL" (también conocido como "Typosquatting") se refiere a una práctica engañosa que implica el registro deliberado de nombres de dominio con errores ortográficos o ligeras variaciones que se parecen mucho a nombres de dominio populares y bien establecidos. El objetivo principal de esta estrategia es explotar los errores tipográficos comunes que cometen los usuarios al ingresar URL en la barra de direcciones de su navegador web. Más allá de capturar tráfico inadvertido, la typosquatting también se puede utilizar para alojar sitios de phishing para engañar a los usuarios para que divulguen información confidencial, distribuir malware a través de sitios web engañosos, generar ingresos publicitarios al redirigir el tráfico mal escrito o participar en la suplantación de marcas para dañar la reputación de marcas auténticas o engañar a los usuarios.

A) Verdadero
B) FALSO

13. ¿Qué tipo de troyano permite el acceso remoto no autorizado a un sistema comprometido?

A) APTO
✓ B) RATA
C) MaaS
D) CACHORRO

14. Un tipo de mecanismo de identificación de usuarios utilizado como contramedida contra el software automatizado (como los robots de red) se conoce como:

A) Ministerio de Asuntos Exteriores

✓ **B) CAPTCHA**

C) SSO

D) NIDS

15. Una subred ligeramente protegida (también conocida como DMZ) que consta de servidores disponibles públicamente ubicados en el exterior del firewall de la empresa se conoce como:

A) Portal cautivo

B) Red de cuarentena

C) Extranet

✓ **D) Subred filtrada**

16. ¿Cuál de las siguientes respuestas se refiere a una solución que ayuda a las organizaciones a mitigar los riesgos asociados con filtraciones de datos, amenazas internas e infracciones de cumplimiento?

A) EDR

B) DLP

C) SOY

D) UTM

17. ¿Cuál de los términos enumerados a continuación se refiere a una situación en la que la imparcialidad de una parte podría ser cuestionada debido a posibles ganancias personales o financieras?

A) relación dual

B) Influencia indebida

✓ **C) Incompatibilidad**

D) Auto-negociación

18. Un tipo de mecanismo de identificación de usuarios utilizado como contramedida contra el software automatizado (como los robots de red) se conoce como:

A) Ministerio de Asuntos Exteriores

✓ **B) CAPTCHA**

C) LCA

D) PNI

19. Elija una respuesta de la lista desplegable de la derecha para hacer coincidir un tipo de actor de amenaza a la izquierda con su atributo de vector de ataque común.

Respuesta no detectada automaticamente

20. Relacione cada tipo de actor de amenaza con su correspondiente atributo de recursos/financiación.

Respuesta no detectada automaticamente

21. Asigne el atributo de nivel de sofisticación a cada tipo de actor de amenazas que se enumera a continuación.

Respuesta no detectada automaticamente

22. El término "Typosquatting" se refiere a una práctica engañosa que implica el registro deliberado de nombres de dominio con errores ortográficos o ligeras variaciones que se parecen mucho a nombres de dominio populares y bien establecidos. El objetivo principal de esta estrategia es explotar los errores tipográficos comunes que cometen los usuarios al ingresar URL en la barra de direcciones de su navegador web. Más allá de capturar tráfico inadvertido, la typosquatting también se puede utilizar para alojar sitios de phishing para engañar a los usuarios para que divulguen información confidencial, distribuir malware a través de sitios web engañosos, generar ingresos publicitarios al redirigir el tráfico mal escrito o participar en la suplantación de marcas para dañar la reputación de marcas auténticas o engañar a los usuarios.

A) Verdadero

B) FALSO

Respuesta no detectada automaticamente

23. ¿Qué tipo de troyano permite el acceso remoto no autorizado a un sistema comprometido?

A) APTO

✓ **B) RATA**

C) MaaS

D) CACHORRO

---

24. Un ataque de reproducción de red ocurre cuando un atacante captura datos confidenciales del usuario y los reenvía al receptor con la intención de obtener acceso no autorizado o engañar al receptor para que realice operaciones no autorizadas.

A) Verdadero

B) FALSO

---

25. ¿Cuál de las respuestas enumeradas a continuación se refiere a una tecnología que proporciona control sobre el uso de un dispositivo móvil dentro de un área designada?

A) Geocerca

B) Portal cautivo

C) Mielero

D) Geolocalización

Respuesta no detectada automaticamente

---

26. Un tipo de mecanismo de identificación de usuarios utilizado como contramedida contra el software automatizado (como los robots de red) se conoce como:

A) Ministerio de Asuntos Exteriores

✓ **B) CAPTCHA**

C) SSO

D) NIDS

2.2 - Explicar los vectores de amenaza y superficies de ataque comunes.

Conceptos clave:

- Basados en mensajes: Email, SMS, Mensajeria instantanea
- Ingenieria social: Phishing, Vishing, Smishing, Pretexting
- Ataques a la cadena de suministro: MSP, Software de terceros, Hardware
- Redes no seguras: WiFi abierto, Bluetooth, NFC

Teoria detallada:

VECTORES DE AMENAZA - Como llega el atacante:

- Basados en mensajes: email (phishing), SMS (smishing), Mensajeria instantanea
- Basados en archivos: adjuntos maliciosos, macros en documentos Office
- Basados en imagenes: imagenes con codigo malicioso embebido
- Llamada de voz: vishing (phishing por telefono)
- Dispositivos extraibles: USB drop attack, dispositivos infectados
- Software vulnerable: explotar vulnerabilidades en aplicaciones
- Sistemas sin soporte: sin parches de seguridad (Windows XP, etc.)
- Redes no seguras: redes WiFi abiertas, redes mal configuradas

ATAQUES A LA CADENA DE SUMINISTRO:

- MSP (Proveedor de Servicios Gestionados): comprometer al proveedor para llegar a sus clientes
- Proveedores: software malicioso en actualizaciones legitimas (ej: SolarWinds 2020)
- Suministradores: hardware comprometido antes de llegar al cliente

El ataque a SolarWinds (2020) es el ejemplo clasico: los atacantes insertaron codigo malicioso en una actualizacion legitima que llego a miles de organizaciones.

INGENIERIA SOCIAL - Tecnicas:

- Phishing: email fraudulento que imita una entidad legitima
- Spear phishing: phishing dirigido a una persona o empresa especifica
- Whaling: spear phishing dirigido a ejecutivos de alto nivel
- Vishing: phishing por llamada de voz

- Smishing: phishing por SMS
- Pretexting: crear un escenario falso para obtener informacion (ej: hacerse pasar por soporte IT)
- Watering hole: comprometer un sitio web que la victima visita frecuentemente
- Typosquatting: registrar dominios con erratas (gooogle.com) para capturar trafico
- BEC (Compromiso de Email Empresarial): suplantar al CEO para ordenar transferencias bancarias

Preguntas de practica (30):

1. Un ataque BEC es un ejemplo de:

A) aplastando
✓ B) Phishing
C) vishing
D) Farmacéutica

2. ¿Qué ataque de ingeniería social se basa en el robo de identidad?

A) Pretexto
B) Phishing de lanza
C) Seguir de cerca
✓ D) Interpretación

3. La práctica de obtener acceso no autorizado a un dispositivo Bluetooth se conoce como:

A) Phishing
B) bluejacking
C) aplastando
✓ D) Bluesnarfing

4. ¿Cuál de las respuestas enumeradas a continuación se refiere a un vector de amenaza basado en correo electrónico?

A) suplantación de identidad
B) Phishing
C) Ataques BEC
D) Enlaces maliciosos
E) Archivos adjuntos de malware
✓ F) Todo lo anterior

5. Ejemplos de vectores de amenazas directamente relacionados con el uso de dispositivos extraíbles incluyen: (Seleccione 2 respuestas)

A) Pretexto
✓ B) Entrega de malware
C) Ataques de abrevadero
✓ D) Exfiltración de datos
E) Ataques de ingeniería social

6. ¿Cuál de las siguientes respuestas se refiere a vectores de amenazas de software sin agentes? (Seleccione 2 respuestas)

A) Correo electrónico de phishing
B) Unidad USB maliciosa
✓ C) Vulnerabilidad del protocolo de red
D) Macro infectada
✓ E) rastreo de paquetes

7. ¿Cuál de las respuestas enumeradas a continuación se refiere a una técnica de ingeniería social en la que un atacante crea un escenario o situación falsa para engañar a la víctima para que revele información confidencial?

A) Interpretación
B) Recolección de credenciales
✓ C) Pretexto
D) Ataque al abrevadero

8. El término "secuestro de URL" (también conocido como "Typosquatting") se refiere a una práctica engañosa que implica el registro deliberado de nombres de dominio con errores ortográficos o ligeras variaciones que se parecen mucho a nombres de dominio populares y bien establecidos. El objetivo principal de esta estrategia es explotar los errores tipográficos comunes que cometen los usuarios al ingresar URL en la barra de direcciones de su navegador web. Más allá de capturar tráfico inadvertido, la typosquatting también se puede utilizar para alojar sitios de phishing para engañar a los usuarios para que divulguen información confidencial, distribuir malware a través de sitios web engañosos, generar ingresos publicitarios al redirigir el tráfico mal escrito o participar en la suplantación de marcas para dañar la reputación de marcas auténticas o engañar a los usuarios.

A) Verdadero

B) FALSO

---

9. ¿Cuál de las respuestas enumeradas a continuación se refiere a un vector de amenaza basado en correo electrónico?

A) suplantación de identidad

B) Phishing

C) Ataques BEC

D) Enlaces maliciosos

E) Archivos adjuntos de malware

✓ F) Todo lo anterior

---

10. Una técnica de ingeniería social mediante la cual los atacantes, disfrazados de una solicitud legítima, intentan obtener acceso a información confidencial se denomina comúnmente:

A) Phishing

B) aplastando

C) Farmacéutica

D) suplantación de identidad

---

11. El término "Typosquatting" se refiere a una práctica engañosa que implica el registro deliberado de nombres de dominio con errores ortográficos o ligeras variaciones que se parecen mucho a nombres de dominio populares y bien establecidos. El objetivo principal de esta estrategia es explotar los errores tipográficos comunes que cometen los usuarios al ingresar URL en la barra de direcciones de su navegador web. Más allá de capturar tráfico inadvertido, la typosquatting también se puede utilizar para alojar sitios de phishing para engañar a los usuarios para que divulguen información confidencial, distribuir malware a través de sitios web engañosos, generar ingresos publicitarios al redirigir el tráfico mal escrito o participar en la suplantación de marcas para dañar la reputación de marcas auténticas o engañar a los usuarios.

A) Verdadero

B) FALSO

Respuesta no detectada automaticamente

---

12. ¿Cuál de las respuestas enumeradas a continuación se refiere a un ejemplo de un vector de amenaza potencial en la comunicación basada en mensajería instantánea?

A) Ataque de phishing

B) Distribución de malware

C) Ataque de suplantación de identidad

D) Escuchar a escondidas

E) Secuestro de cuenta

F) Enlace/adjunto malicioso

✓ G) Todo lo anterior

---

13. ¿Cuál de las siguientes respuestas se refiere a vectores de amenazas comunes que se aplican a los MSP, vendedores y proveedores en la cadena de suministro? (Seleccione 2 respuestas)

A) Violaciones de cumplimiento

B) Daño a la reputación de la marca

✓ C) Propagación de malware

D) Interrupciones operativas

✓ **E) Técnicas de ingeniería social**

14. Cuando los registrantes de dominio debido a acciones ilegales de terceros pierden el control sobre sus nombres de dominio, son víctimas de:

A) Ataque de sibila

✓ **B) Secuestro de dominio**

C) Error tipográfico

D) Secuestro de URL

15. ¿Cuál de las siguientes respuestas se refiere a una función de seguridad utilizada en el emparejamiento de dispositivos Bluetooth?

A) SAE

✓ **B) ALFILER**

C) Ministerio de Asuntos Exteriores

D) LCA

16. TCP es un ejemplo de protocolo sin conexión. Debido a que TCP no admite el protocolo de enlace de tres vías al establecer una conexión de red, se lo conoce como protocolo no confiable o de mejor esfuerzo. Las aplicaciones de ejemplo de TCP incluyen la transmisión de datos de streaming de vídeo y audio.

A) Verdadero

✓ **B) FALSO**

17. ¿Cuál de las respuestas enumeradas a continuación se refieren a las características de una llave de seguridad? (Seleccione 3 respuestas)

A) Se utiliza para generación de OTP, acceso remoto a vehículos y acceso a edificios.

✓ **B) Token de autenticación de hardware**

✓ **C) Normalmente, una memoria USB física o un dispositivo del tamaño de un llavero**

✓ **D) Utilizado principalmente para seguridad digital (2FA/MFA)**

E) Token de autenticación de software

F) Normalmente, una tarjeta de plástico del tamaño de una tarjeta de crédito con un chip integrado.

18. Una lista de verificación de configuración para nuevos usuarios incluye todas las actividades que permiten que un nuevo empleado sea productivo. Ejemplos de tales actividades (que forman parte del llamado proceso de incorporación) incluyen la configuración del entorno de hardware y software para el nuevo usuario, así como proporcionar toda la formación necesaria. Una lista de verificación de despido del usuario final aborda todas las acciones que deben tener lugar durante el proceso de baja (es decir, cada vez que un empleado deja la empresa). Ejemplos de elementos de la lista de verificación incluyen cumplir con todos los documentos requeridos, eliminar el acceso del empleado a los recursos (por ejemplo, dispositivos propiedad de la empresa, cuentas de usuario, etc.) y discutir sus motivos para irse y sus experiencias con el empleador durante una entrevista de salida.

A) Verdadero

B) FALSO

Respuesta no detectada automaticamente

19. En la comunicación por correo electrónico, ¿qué señales pueden ayudar a reconocer un intento de phishing?

A) El mensaje contiene mala ortografía y gramática.

B) El mensaje pide información personal.

C) El mensaje incluye un llamado a la acción con sentido de urgencia.

D) El mensaje incluye enlaces o archivos adjuntos sospechosos.

✓ **E) Cualquiera de los anteriores**

20. ¿Cuál de las respuestas enumeradas a continuación se refiere a una tecnología que permite que los dispositivos USB actúen como hosts y periféricos, permitiéndoles conectarse y comunicarse con otros dispositivos USB directamente sin la necesidad de una computadora o un host dedicado?

A) PnP

B) OTG

C) P2P
D) HCl

21. Una función hash es un algoritmo matemático que asigna datos de tamaño arbitrario a un valor hash de tamaño fijo, generalmente representado como una cadena corta de caracteres. El resultado de la función hash, también conocido como resumen o suma de comprobación, proporciona una representación única de la entrada de datos original. La funcionalidad de las funciones hash se basa en el hecho de que si hay algún cambio en los datos después de generar el hash original, el nuevo valor hash calculado después de la modificación del contenido será diferente del resultado original porque las funciones hash están diseñadas para ser sensibles a los cambios en los datos de entrada.

A) Verdadero
B) FALSO
Respuesta no detectada automaticamente

22. Una superficie de ataque es la suma de todos los puntos potenciales (vulnerabilidades) a través de los cuales un atacante puede interactuar o comprometer un sistema o red, lo que indica la exposición general a amenazas potenciales. Ejemplos de superficies de ataque pueden ser todo software, hardware e interfaces de red con fallas de seguridad conocidas. Un vector de amenaza representa el método o medio a través del cual se introduce o entrega una amenaza cibernética a un sistema objetivo. Describe la vía o vía utilizada por los atacantes para explotar las vulnerabilidades. Los tipos de vectores de amenazas comunes incluyen correos electrónicos de phishing, malware, descargas no autorizadas y técnicas de ingeniería social.

A) Verdadero
B) FALSO
Respuesta no detectada automaticamente

23. ¿Cuál de las respuestas enumeradas a continuación se refiere a un ejemplo de un vector de amenaza potencial en la comunicación basada en mensajería instantánea?

A) Ataque de phishing
B) Distribución de malware
C) Ataque de suplantación de identidad
D) Escuchar a escondidas
E) Secuestro de cuenta
F) Enlace/adjunto malicioso
✓ G) Todo lo anterior

24. ¿Cuál de las siguientes respuestas se refiere a ejemplos de vectores de amenazas basados ■■en imágenes? (Seleccione 3 respuestas)

A) esteganografía
B) Ataques BEC
C) Suplantación de imágenes (deepfakes)
D) Suplantación de marca
E) Imágenes con malware incorporado

25. ¿Cuál de las siguientes respuestas se refiere a un ataque de ingeniería social que aprovecha los SMS o mensajes de texto para engañar a los destinatarios para que realicen acciones dañinas, como revelar información confidencial o hacer clic en enlaces maliciosos?

A) Farmacéutica
B) suplantación de identidad
C) quishing
✓ D) aplastando

26. ¿Cuál de los siguientes términos se refiere a una plataforma común para ataques a abrevaderos?

A) Pasarelas de correo
✓ B) Sitios web
C) sistemas PBX
D) Navegadores web

27. ¿Cuál sería una respuesta apropiada del usuario ante un intento de phishing por correo electrónico? (Seleccione todo lo que corresponda)

A) No responder al mensaje ni proporcionar ningún dato personal.

✓ B) Reportar el mensaje al departamento de TI o seguridad, si corresponde

✓ C) Eliminar el mensaje de la bandeja de entrada

✓ D) No hacer clic en ningún enlace ni descargar ningún archivo adjunto en el mensaje

E) Reenviar el mensaje al remitente para verificar su legitimidad

F) Abrir el archivo adjunto en un entorno sandbox para comprobar su seguridad

---

28. Cuando los registrantes de dominio debido a acciones ilegales de terceros pierden el control sobre sus nombres de dominio, son víctimas de:

A) Ataque de sibila

✓ B) Secuestro de dominio

C) Error tipográfico

D) Secuestro de URL

---

29. Una situación en la que un atacante intercepta y retransmite un intercambio de datos válido entre una aplicación y un servidor u otra aplicación se conoce como:

A) Carga lateral

✓ B) Repetir ataque

C) Ataque de phishing

D) Condición de carrera

---

30. ¿Cuál de las siguientes respuestas se refiere a una función de seguridad utilizada en el emparejamiento de dispositivos Bluetooth?

A) SAE

✓ B) ALFILER

C) Ministerio de Asuntos Exteriores

D) LCA

2.3 - Explicar varios tipos de vulnerabilidades.

Conceptos clave:

- Vulnerabilidades de aplicacion: Desbordamiento de buffer, Inyeccion SQL, XSS
- Hardware: Firmware, Fin de vida, Sistemas legacy
- Virtualizacion: Escape de VM, Reutilizacion de recursos
- Zero-day: Vulnerabilidad desconocida para el fabricante

Teoria detallada:

VULNERABILIDADES DE APLICACION:

- Desbordamiento de buffer (Buffer overflow): escribir mas datos de los que cabe en un buffer, sobrescribiendo memoria adyacente
- Inyeccion de memoria (Memory injection): inyectar codigo malicioso en el espacio de memoria de otro proceso
- Condicion de carrera (TOC/TOU): el estado cambia entre la comprobacion y el uso
- Inyeccion SQL (SQLi): insertar comandos SQL en campos de entrada para manipular la base de datos

Ejemplo: ' OR '1'='1 en un campo de login

- XSS (Cross-Site Scripting): inyectar JavaScript malicioso en una pagina web que se ejecuta en el navegador de la victima

VULNERABILIDADES DE HARDWARE:

- Firmware: software de bajo nivel del hardware, dificil de actualizar y frecuentemente olvidado
- Fin de vida (EOL): hardware sin soporte del fabricante, sin parches de seguridad
- Sistemas legacy: sistemas antiguos que no pueden actualizarse por compatibilidad

VULNERABILIDADES DE VIRTUALIZACION:

- Escape de VM: el codigo malicioso sale de la maquina virtual y accede al hipervisor o a otras VMs
- Reutilizacion de recursos: datos de una VM anterior quedan accesibles en memoria para otra VM

OTRAS VULNERABILIDADES:

- Especificas de nube: misconfiguraciones en S3 buckets, IAM mal configurado, APIs expuestas
- Criptograficas: uso de algoritmos debiles (MD5, SHA-1, DES), claves cortas, mala implementacion
- Misconfiguracion: la causa mas comun de brechas. Puertos abiertos, credenciales por defecto, permisos excesivos
- Zero-day: vulnerabilidad desconocida para el fabricante, sin parche disponible
- Movil - Side loading: instalar apps fuera de la tienda oficial
- Movil - Jailbreaking/Rooting: eliminar las restricciones del SO del movil

Preguntas de practica (27):

1. ¿Cuál de las siguientes respuestas no se refiere a un tipo común de vulnerabilidad basada en el sistema operativo?

A) Vulnerabilidades de control de acceso y permisos (contraseñas débiles, escalada de privilegios)

B) Vulnerabilidades en aplicaciones instaladas, utilidades del sistema y controladores de dispositivos.

C) Vulnerabilidades relacionadas con la memoria (pérdidas de memoria, desbordamientos de búfer, condiciones de carrera)

D) Vulnerabilidades en la gestión de parches y actualizaciones (parches de seguridad y retrasos en las actualizaciones, actualizaciones maliciosas)

E) Vulnerabilidades relacionadas con configuraciones erróneas del sistema/seguridad

F) Vulnerabilidades relacionadas con la red (ataques DoS, ataques de ejecución remota de código)

✓ G) Todas las opciones de respuesta anteriores son ejemplos de vulnerabilidades basadas en sistemas operativos.

---

2. La práctica de instalar aplicaciones móviles desde sitios web y tiendas de aplicaciones distintos de los mercados oficiales se conoce como:

A) jailbreak

B) Enraizamiento

✓ C) Carga lateral

D) Desbloqueo del operador

---

3. ¿Qué tipo de ataque a una aplicación se basa en la introducción de código externo en el espacio de direcciones de un programa en ejecución?

A) Desbordamiento del búfer

✓ B) Inyección de memoria

C) Repetir ataque

D) Desreferencia del puntero

---

4. La práctica de instalar aplicaciones móviles desde sitios web y tiendas de aplicaciones distintos de los mercados oficiales se conoce como:

A) jailbreak

B) Enraizamiento

✓ C) Carga lateral

D) Desbloqueo del operador

---

5. La explotación de una vulnerabilidad conocida es un vector de amenaza común para:

A) Sistemas/aplicaciones heredados

✓ B) Sistemas/aplicaciones no compatibles

C) Sistemas/aplicaciones recientemente lanzados

D) Sistemas/aplicaciones con vulnerabilidad de día cero

---

6. Un tipo de exploit en el que una aplicación sobrescribe el contenido de un área de memoria a la que no debería tener acceso se llama:

A) inyección de DLL

✓ B) Desbordamiento del búfer

C) pérdida de memoria

D) Escalada de privilegios

---

7. ¿Cuál de las respuestas enumeradas a continuación se refiere a una vulnerabilidad de seguridad que permite insertar código malicioso en campos de entrada, como barras de búsqueda o formularios de inicio de sesión, para ejecutar comandos no autorizados en una base de datos?

A) ICE

✓ **B) SQLi**

C) XSS

D) CSRF

8. ¿Cuál de las siguientes respuestas se refiere a un tipo de software integrado en un chip de hardware?

A) firmware

B) software intermedio

C) Controlador de dispositivo

D) Código máquina

Respuesta no detectada automaticamente

9. El término "Enraizamiento" se refiere a la capacidad de obtener acceso administrativo al sistema operativo y a las aplicaciones del sistema en:

A) Dispositivos Android

B) dispositivos iOS

C) Dispositivos Microsoft

D) Todo tipo de dispositivos móviles

10. ¿Cuál de los siguientes exploits apunta a un protocolo utilizado para administrar y acceder a recursos en red?

A) Ataque CSRF/XSRF

✓ **B) Ataque de inyección XML**

✓ **C) Ataque de inyección LDAP**

D) Ataque de inyección SQL

11. ¿Cuál de los siguientes facilita(n) los ataques de escalada de privilegios? (Seleccione todo lo que corresponda)

A) Vulnerabilidades del sistema/aplicación

B) Hash de contraseña

✓ **C) Configuraciones erróneas del sistema/aplicación**

D) Segmentación de red

✓ **E) Técnicas de ingeniería social**

12. ¿Cuál de las respuestas enumeradas a continuación se refiere a una tecnología que proporciona control sobre el uso de un dispositivo móvil dentro de un área designada?

A) Geocerca

B) Seguimiento de dispositivos

C) Seguridad perimetral

D) Geolocalización

13. Los datos de un dispositivo móvil perdido o robado se pueden borrar mediante:

A) Enraizamiento

B) Carga lateral

C) Formateo de bajo nivel

✓ **D) Borrado remoto**

14. El término "Metadatos" se refiere a datos que proporcionan información sobre otros datos, pero no el contenido real de los datos. Normalmente, los metadatos no son visibles para el usuario de forma predeterminada, pero se puede acceder a ellos si es necesario. Por ejemplo, los metadatos de correo electrónico, que se encuentran en los encabezados de los correos electrónicos, incluyen información detallada sobre el remitente, el destinatario y la ruta que tomó el mensaje. Los metadatos del dispositivo móvil abarcan detalles como el modelo del dispositivo, geolocalización, información de la cámara, uso de Internet, actividad de llamadas telefónicas y mensajes de texto, estadísticas de uso de aplicaciones y metadatos de varios archivos en el dispositivo. En la navegación web, los metadatos provienen de metaetiquetas HTML ubicadas en la sección principal de una página web. Para los archivos, los metadatos incluyen detalles sobre el autor (por ejemplo, el creador del archivo), el tipo de archivo, el tamaño, la fecha y hora de creación y la fecha y hora de la última modificación.

A) Verdadero
B) FALSO

15. ¿Qué tipo de firmware realiza comprobaciones iniciales de hardware después de encender la computadora?

A) BIOS
B) CORREO
C) CMOS
D) PASEO

Respuesta no detectada automaticamente

16. Un tipo de ciberataque centrado en hacer que un sitio web, servicio o red no esté disponible para los usuarios sobrecargándolo con tráfico o solicitudes maliciosas se denomina:

A) SQLi
B) XSS
C) CSRF
✓ D) DoS

17. ¿Cuál de los acrónimos enumerados a continuación se refiere a una pieza de hardware y software/firmware asociado diseñado para proporcionar funciones criptográficas y de administración de claves?

A) EFS
✓ B) HSM
C) SFC
D) TPM

18. ¿Cuál de las respuestas enumeradas a continuación se refiere a un ataque a una aplicación que se basa en la ejecución de una biblioteca de código?

A) pérdida de memoria
✓ B) inyección de DLL
C) Desreferencia del puntero
✓ D) Desbordamiento del búfer

19. Un mal funcionamiento en un acceso secuencial preprogramado a un recurso compartido se describe como:

A) Condición de carrera
B) Error de concurrencia
C) subprocesos múltiples
D) Error de sincronización

20. ¿Cuál de las respuestas enumeradas a continuación se refiere a una vulnerabilidad de seguridad que permite insertar código malicioso en campos de entrada, como barras de búsqueda o formularios de inicio de sesión, para ejecutar comandos no autorizados en una base de datos?

A) ICE
✓ B) SQLi
C) XSS
D) CSRF

21. El término "Enraizamiento" se refiere a la capacidad de obtener acceso administrativo al sistema operativo y a las aplicaciones del sistema en:

A) Dispositivos Android
B) dispositivos iOS
C) Dispositivos Microsoft
D) Todo tipo de dispositivos móviles

22. ¿Qué tipo de acción permite a un atacante aprovechar la vulnerabilidad XSS?

A) inyección de código
B) Escalada de privilegios

C) Secuestro de sesión
D) rastreo de paquetes

23. ¿Qué tipo de exploit se dirige a aplicaciones web que generan contenido utilizado para almacenar y transportar datos?

A) Ataque de inyección SQL
B) Ataque CSRF/XSRF
✓ C) Ataque de inyección XML
D) Ataque de inyección LDAP

24. Una situación en la que un atacante intercepta y retransmite un intercambio de datos válido entre una aplicación y un servidor u otra aplicación se conoce como:

A) Carga lateral
✓ B) Repetir ataque
C) Ataque de phishing
D) Condición de carrera

25. ¿Cuál de las respuestas enumeradas a continuación se refiere a una tecnología que proporciona control sobre el uso de un dispositivo móvil dentro de un área designada?

A) Geocerca
B) Portal cautivo
C) Mielero
D) Geolocalización
Respuesta no detectada automaticamente

26. Escaneo de vulnerabilidades: (Seleccione todas las que correspondan)

A) Identifica falta de controles de seguridad
B) Prueba activamente los controles de seguridad.
✓ C) Identifica errores de configuración comunes
D) Explota vulnerabilidades
✓ E) Prueba pasivamente los controles de seguridad.

27. Ejemplos de propiedades utilizadas para definir políticas de acceso en el modelo de control de acceso basado en atributos (ABAC) incluyen:

A) Asunto (es decir, usuario o proceso que solicita acceso)
B) Tipo de acción (por ejemplo "leer", "escribir", "ejecutar")
C) Tipo de recurso (historial médico, cuenta bancaria, etc.)
D) Entorno (datos contextuales, como hora del día o geolocalización)
✓ E) Todo lo anterior

2.4 - Dado un escenario, analizar los indicadores de actividad maliciosa.

Conceptos clave:

- Malware: Virus, Gusano, Troyano, Ransomware, Spyware, Keylogger, Rootkit
- Ataques de red: DDoS, On-path (MitM), Envenenamiento DNS
- Ataques de contrasena: Fuerza bruta, Diccionario, Password spraying
- Ataques criptograficos: Downgrade, Colision, Ataque de cumpleanos

Teoria detallada:

TIPOS DE MALWARE:

- Virus: necesita un archivo huesped para propagarse, se activa cuando el usuario ejecuta el huesped
- Gusano (Worm): se propaga solo por la red sin necesitar intervencion del usuario
- Troyano (Trojan): parece software legitimo pero contiene codigo malicioso oculto
- Ransomware: cifra los archivos de la victima y pide rescate para descifrarlos
- Spyware: monitoriza la actividad del usuario sin su conocimiento
- Keylogger: registra las pulsaciones del teclado para robar contrasenas
- Rootkit: se oculta en el sistema operativo a nivel muy profundo (ring 0), muy dificil de detectar

- Bomba logica (Logic bomb): codigo que se activa cuando se cumple una condicion especifica (fecha, evento)
- Bloatware: software no deseado preinstalado que consume recursos

ATAQUES DE RED:

- DDoS (Denegacion de Servicio Distribuida): multiples sistemas atacan uno para dejarlo sin servicio

- Amplificado: usar protocolos que amplifican el trafico (DNS, NTP, SSDP)
- Reflejado: el trafico de ataque pasa por intermediarios que lo redirigen a la victima

- Ataque en ruta (On-path/MitM): el atacante se interpone entre dos partes para interceptar/modificar trafico
- Envenenamiento DNS: corromper la cache DNS para redirigir usuarios a sitios falsos
- Repeticion de credenciales (Credential replay): reutilizar credenciales capturadas

ATAQUES DE CONTRASENA:

- Fuerza bruta: probar todas las combinaciones posibles
- Ataque de diccionario: probar palabras de diccionario y variaciones comunes
- Password spraying: probar una contrasena comun contra muchas cuentas (evita el bloqueo por intentos fallidos)
- Tabla arcoiris (Rainbow table): tabla precalculada de hashes. Contramedida: salting

ATAQUES CRIPTOGRAFICOS:

- Ataque de degradacion (Downgrade): forzar el uso de versiones antiguas e inseguras de protocolos
- Ataque de colision: encontrar dos inputs distintos que producen el mismo hash
- Ataque de cumpleanos (Birthday): basado en la paradoja del cumpleanos, busca colisiones en hashes

INDICADORES DE ACTIVIDAD MALICIOSA:

- Bloqueo inesperado de cuenta: posible ataque de fuerza bruta
- Viaje imposible: login desde Madrid y desde Tokyo en 10 minutos
- Consumo de recursos anormal: CPU/RAM al 100% sin razon aparente (cryptomining)
- Logs desaparecidos: alguien borro los logs para cubrir sus huellas
- Cambios no autorizados: archivos modificados sin causa conocida

Preguntas de practica (26):

1. Un programa informático malicioso independiente que normalmente se propaga a través de una red informática para afectar negativamente a los recursos del sistema y al ancho de banda de la red se denomina:

A) Gusano
B) virus sin archivos
C) Bot
D) Bomba lógica

---

2. Un programa informático malicioso independiente que normalmente se propaga a través de una red informática para afectar negativamente a los recursos del sistema y al ancho de banda de la red se denomina:

A) Gusano
B) virus sin archivos
C) Bot
D) Bomba lógica

---

3. El malware que restringe el acceso a un sistema informático cifrando archivos o bloqueando todo el sistema hasta que el usuario realice la acción solicitada se llama:

A) Grayware
B) software publicitario
✓ C) ransomware
D) software espía

---

4. El código malicioso activado por un evento específico se llama:

A) criptomalware
B) Puerta trasera
C) rootkit
✓ D) Bomba lógica

---

5. Una breve lista de contraseñas de uso común probadas en una gran cantidad de cuentas de usuario es un rasgo característico de:

A) Repetir ataque
B) Ataque de diccionario
✓ **C) Ataque de fumigación**
D) Ataque de cumpleaños

6. Un ataque contra datos cifrados que depende en gran medida de la potencia informática para comprobar todas las claves y contraseñas posibles hasta encontrar la correcta se denomina:

A) Repetir ataque
✓ **B) Ataque de fuerza bruta**
C) Ataque de diccionario
D) Ataque de cumpleaños

7. El malware que restringe el acceso a un sistema informático cifrando archivos o bloqueando todo el sistema hasta que el usuario realice la acción solicitada se llama:

A) Grayware
B) software publicitario
✓ **C) ransomware**
D) software espía

8. El código malicioso activado por un evento específico se llama:

A) criptomalware
B) Puerta trasera
C) rootkit
✓ **D) Bomba lógica**

9. Una breve lista de contraseñas de uso común probadas en una gran cantidad de cuentas de usuario es un rasgo característico de:

A) Repetir ataque
B) Ataque de diccionario
✓ **C) Ataque de fumigación**
D) Ataque de cumpleaños

10. Un ataque contra datos cifrados que depende en gran medida de la potencia informática para comprobar todas las claves y contraseñas posibles hasta encontrar la correcta se denomina:

A) Repetir ataque
✓ **B) Ataque de fuerza bruta**
C) Ataque de diccionario
D) Ataque de cumpleaños

11. ¿Cuál de los siguientes términos se utiliza para describir ciberataques sofisticados y prolongados, a menudo llevados a cabo por grupos organizados y bien financiados, como los Estados-nación?

A) MitM
✓ **B) APTO**
C) XSRF
D) DDoS

12. ¿Qué tipo de troyano permite el acceso remoto no autorizado a un sistema comprometido?

A) APTO
✓ **B) RATA**
C) MaaS
D) CACHORRO

13. A diferencia de los simples ataques DoS que normalmente se realizan desde un solo sistema, un ataque DDoS utiliza múltiples sistemas informáticos comprometidos para realizar el ataque contra su objetivo. Los sistemas intermediarios que se utilizan como plataforma para el ataque (a menudo denominados zombies y colectivamente botnet) son las víctimas secundarias del ataque DDoS.

A) Verdadero
B) FALSO

Respuesta no detectada automaticamente

14. ¿Qué define un ataque DDoS reflejado?

A) Abrumar al objetivo con un gran volumen de tráfico para saturar su ancho de banda

B) Explotar vulnerabilidades en los protocolos de red para consumir recursos e interrumpir servicios

✓ C) Utilizar servidores de terceros para reflejar y amplificar el tráfico de ataque hacia el objetivo.

D) Apuntar a vulnerabilidades en aplicaciones o servidores web para agotar los recursos.

15. ¿Cuál de las siguientes es una característica de vulnerabilidad de la comunicación NFC?

A) Escuchar a escondidas

B) Intercepción de datos

C) Repetir ataques

D) Ataques DoS

✓ E) Todo lo anterior

16. Una técnica que permite a un atacante autenticarse en un servidor remoto sin extraer una contraseña en texto claro de un resumen se llama:

A) pasar el hash

B) Repetir ataque

C) Ataque de fuerza bruta

D) Ataque de fumigación

Respuesta no detectada automaticamente

17. ¿Cuál de los siguientes términos se utiliza para describir ciberataques sofisticados y prolongados, a menudo llevados a cabo por grupos organizados y bien financiados, como los Estados-nación?

A) MitM

✓ B) APTO

C) XSRF

D) DDoS

18. ¿Cuál de los siguientes términos se utiliza para describir ciberataques sofisticados y prolongados, a menudo llevados a cabo por grupos organizados y bien financiados, como los Estados-nación?

A) MitM

✓ B) APTO

C) XSRF

D) DDoS

19. ¿Qué tipo de ataque a una aplicación se basa en la introducción de código externo en el espacio de direcciones de un programa en ejecución?

A) Desbordamiento del búfer

✓ B) Inyección de memoria

C) Repetir ataque

D) Desreferencia del puntero

20. ¿Qué tipo de troyano permite el acceso remoto no autorizado a un sistema comprometido?

A) APTO

✓ B) RATA

C) MaaS

D) CACHORRO

21. A diferencia de los simples ataques DoS que normalmente se realizan desde un solo sistema, un ataque DDoS utiliza múltiples sistemas informáticos comprometidos para realizar el ataque contra su objetivo. Los sistemas intermediarios que se utilizan como plataforma para el ataque (a menudo denominados zombies y colectivamente botnet) son las víctimas secundarias del ataque DDoS.

A) Verdadero

B) FALSO

Respuesta no detectada automaticamente

22. ¿Qué define un ataque DDoS reflejado?

A) Abrumar al objetivo con un gran volumen de tráfico para saturar su ancho de banda

B) Explotar vulnerabilidades en los protocolos de red para consumir recursos e interrumpir servicios

✓ C) Utilizar servidores de terceros para reflejar y amplificar el tráfico de ataque hacia el objetivo.

D) Apuntar a vulnerabilidades en aplicaciones o servidores web para agotar los recursos.

---

23. Un ataque de reproducción de red ocurre cuando un atacante captura datos confidenciales del usuario y los reenvía al receptor con la intención de obtener acceso no autorizado o engañar al receptor para que realice operaciones no autorizadas.

A) Verdadero

B) FALSO

---

24. En un ataque de repetición de sesión, un atacante intercepta y roba una ID de sesión válida de un usuario y la reenvía al servidor con la intención de obtener acceso no autorizado a la sesión del usuario o engañar al servidor para que realice operaciones no autorizadas en nombre del usuario legítimo.

A) Verdadero

B) FALSO

Respuesta no detectada automaticamente

---

25. Una situación en la que un atacante intercepta y retransmite un intercambio de datos válido entre una aplicación y un servidor u otra aplicación se conoce como:

A) Carga lateral

✓ B) Repetir ataque

C) Ataque de phishing

D) Condición de carrera

---

26. ¿Qué técnica criptográfica se utiliza para evitar la eficacia de las tablas arcoíris a la hora de descifrar contraseñas hash?

A) Enmascaramiento de datos

B) Autenticación de dos factores (2FA)

C) Estiramiento clave

✓ D) Salazón

2.5 - Explicar las tecnicas de mitigacion utilizadas para asegurar la empresa.

Conceptos clave:

- Segmentacion de red, ACLs, Principio de minimo privilegio
- Parcheo, Cifrado, Monitorizacion continua
- Hardening: Deshabilitar servicios, cambiar credenciales por defecto
- Desmantelamiento de sistemas obsoletos

Teoria detallada:

TECNICAS DE MITIGACION - Como reducir el riesgo:

- Segmentacion: dividir la red en segmentos para limitar el movimiento lateral del atacante. VLANs, subredes
- ACL (Lista de Control de Acceso): reglas que definen que trafico se permite o deniega
- Minimo privilegio (Least privilege): dar a cada usuario/sistema solo los permisos minimos necesarios
- Parcheo (Patching): aplicar actualizaciones de seguridad regularmente
- Cifrado: cifrar datos en reposo y en transito
- Monitorizacion: vigilar sistemas y logs continuamente
- Desmantelamiento: dar de baja sistemas obsoletos de forma segura

HARDENING - Endurecer sistemas:

- Cambiar credenciales por defecto: lo primero siempre
- Deshabilitar servicios y puertos innecesarios
- Proteccion de endpoints: antivirus/EDR en todos los endpoints
- Firewall de host: a nivel de sistema operativo (Windows Defender Firewall)
- HIPS (Sistema de Prevencion de Intrusiones en el Host): detecta y bloquea actividad maliciosa en el host
- Lista de aplicaciones permitidas (Allow list): solo se ejecutan las aplicaciones aprobadas

• Aplicacion de configuracion: usar herramientas como Group Policy, Ansible, Puppet para mantener la configuracion correcta

Preguntas de practica (87):

1. ¿Cuál de las respuestas enumeradas a continuación se refiere a un enfoque de seguridad del plano de control de confianza cero que tiene en cuenta la identidad del usuario, la seguridad del dispositivo, las condiciones de la red y otra información contextual para permitir decisiones de acceso dinámico?

A) Confianza implícita

B) Monitoreo y registro

✓ C) Identidad adaptativa

D) Microsegmentación

---

2. ¿Cuál de las respuestas enumeradas a continuación se refiere a las ventajas de la segmentación como método para proteger los datos? (Seleccione 3 respuestas)

A) Mejora la seguridad al limitar la propagación de ciberataques

✓ B) Ayuda a las organizaciones a cumplir con los requisitos normativos de datos aislando y protegiendo tipos de datos específicos

C) Proporciona seguridad para los datos en tránsito con el uso de cifrado.

D) Garantiza la recuperación de datos en caso de eliminación accidental o fallas del sistema.

✓ E) Proporciona un mejor control sobre el acceso de los usuarios a datos confidenciales.

---

3. ¿Cuál de los términos enumerados a continuación se utiliza para describir un nivel fundamental de configuraciones y ajustes de seguridad necesarios para salvaguardar un sistema?

A) Segmentación lógica

✓ B) Línea de base segura

C) Niveles de control de acceso

D) Principio de privilegio mínimo

---

4. ¿Cuál de los términos enumerados a continuación se refiere al seguimiento y administración de componentes de aplicaciones de software, como bibliotecas de terceros y otras dependencias?

A) Control de versiones

B) Monitoreo de paquetes

C) Aplicación de la configuración

D) Endurecimiento de aplicaciones

---

5. ¿Cuál de las afirmaciones enumeradas a continuación no se refiere a una técnica de respuesta y remediación de vulnerabilidades?

A) Aplicar actualizaciones o correcciones proporcionadas por proveedores de software para abordar la vulnerabilidad (parches)

B) Garantizar la recuperación financiera de los costos asociados con un ciberataque exitoso (seguro)

C) Dividir una red en zonas más pequeñas y aisladas para limitar el impacto potencial de una vulnerabilidad (segmentación)

D) Mitigar el riesgo asociado con una vulnerabilidad que no se puede reparar de inmediato mediante la implementación de medidas de seguridad alternativas (controles de compensación)

E) Retrasar o renunciar a un parche para un sistema específico, por ejemplo, cuando aplicar un parche puede no ser factible debido a problemas de compatibilidad o posibles interrupciones en sistemas críticos (excepciones y exenciones).

✓ F) Todas las respuestas anteriores son ejemplos de técnicas de respuesta y remediación de vulnerabilidades.

---

6. ¿Cuál de las respuestas enumeradas a continuación se refiere a las ventajas de la segmentación como método para proteger los datos? (Seleccione 3 respuestas)

A) Mejora la seguridad al limitar la propagación de ciberataques

✓ B) Ayuda a las organizaciones a cumplir con los requisitos normativos de datos aislando y protegiendo tipos de datos específicos

C) Proporciona seguridad para los datos en tránsito con el uso de cifrado.

D) Garantiza la recuperación de datos en caso de eliminación accidental o fallas del sistema.

✓ E) Proporciona un mejor control sobre el acceso de los usuarios a datos confidenciales.

---

7. ¿Cuál de los términos enumerados a continuación se refiere al seguimiento y administración de componentes de aplicaciones de software, como bibliotecas de terceros y otras dependencias?

A) Control de versiones

B) Monitoreo de paquetes
C) Aplicación de la configuración
D) Endurecimiento de aplicaciones

8. ¿Cuál de las afirmaciones enumeradas a continuación no se refiere a una técnica de respuesta y remediación de vulnerabilidades?

A) Aplicar actualizaciones o correcciones proporcionadas por proveedores de software para abordar la vulnerabilidad (parches)
B) Garantizar la recuperación financiera de los costos asociados con un ciberataque exitoso (seguro)
C) Dividir una red en zonas más pequeñas y aisladas para limitar el impacto potencial de una vulnerabilidad (segmentación)
D) Mitigar el riesgo asociado con una vulnerabilidad que no se puede reparar de inmediato mediante la implementación de medidas de seguridad alternativas (controles de compensación)
E) Retrasar o renunciar a un parche para un sistema específico, por ejemplo, cuando aplicar un parche puede no ser factible debido a problemas de compatibilidad o posibles interrupciones en sistemas críticos (excepciones y exenciones).
✓ F) Todas las respuestas anteriores son ejemplos de técnicas de respuesta y remediación de vulnerabilidades.

9. ¿Cuáles son los ejemplos de controles preventivos de seguridad? (Seleccione 3 respuestas)

A) Cifrado
B) identificación
C) Sensores
✓ D) Cortafuegos
E) Señales de advertencia
✓ F) software audiovisual

10. ¿Cuál de las respuestas enumeradas a continuación se refiere(s) a los controles de seguridad de detectives? (Seleccione todo lo que corresponda)

A) Iluminación
✓ B) Monitoreo de registros
C) Zona de arena
✓ D) Auditorías de seguridad
✓ E) circuito cerrado de televisión
✓ F) identificación
✓ G) Escaneo de vulnerabilidades

11. ¿Cuál de las respuestas enumeradas a continuación se refiere(s) a controles de seguridad compensatorios? (Seleccione todo lo que corresponda)

A) Sistemas de energía de respaldo
B) Videovigilancia
✓ C) Ministerio de Asuntos Exteriores
✓ D) Zona de pruebas de aplicaciones
✓ E) Segmentación de red

12. Un archivo Honey se puede utilizar para:

A) Atraer a los ciberatacantes
B) Activar alertas cuando se accede
C) Monitoreo de la actividad de la red
✓ D) Todo lo anterior

13. ¿Cuál es el uso típico de una clave pública?

A) Cifrado de datos
B) Descifrado de datos
C) Autenticación de usuario/dispositivo
D) Todo lo anterior

14. ¿Cuál de las siguientes respuestas se refiere a un dispositivo de almacenamiento de datos equipado con funcionalidad de cifrado a nivel de hardware?

A) HSM
B) TPM

C) EFS

✓ **D) SED**

15. La especificación MIME extiende el formato de los mensajes de correo electrónico más allá del texto plano, permitiendo la transferencia de archivos de gráficos, audio y vídeo a través del sistema de correo de Internet. S/MIME es una versión mejorada del protocolo MIME que habilita funciones de seguridad del correo electrónico al proporcionar cifrado, autenticación, integridad de mensajes y otros servicios relacionados.

A) Verdadero

B) FALSO

16. SFTP es una extensión del protocolo FTP que agrega soporte para cifrado SSL/TLS.

A) Verdadero

✓ **B) FALSO**

17. ¿Cuál de las respuestas enumeradas a continuación se refiere a un conjunto de protocolos y tecnologías que proporcionan cifrado, autenticación e integridad de datos para el tráfico de red?

A) TLS

B) SSH

✓ **C) IPSec**

D) vpn

18. Un protocolo de cifrado utilizado principalmente en redes Wi-Fi que implementan el estándar de seguridad WPA2 se llama:

A) TKIP

✓ **B) CCMP**

C) SSL

D) IPSec

19. ¿Cuál de las siguientes respuestas se refiere a protocolos de cifrado y funciones hash criptográficas obsoletas o inseguras? (Seleccione todo lo que corresponda)

A) DES

B) AES-256

✓ **C) MD5**

D) ECC

✓ **E) SHA-1**

✓ **F) SSL**

✓ **G) RC4**

20. Ejemplos de técnicas utilizadas para cifrar información incluyen el cifrado simétrico (también llamado cifrado de clave pública) y el cifrado asimétrico (también llamado cifrado de clave secreta o cifrado de clave de sesión).

A) Verdadero

✓ **B) FALSO**

21. ¿Cuál de las siguientes respuestas se refiere a un algoritmo de cifrado de bloque de clave simétrica heredado?

A) RC4

✓ **B) DES**

C) RSA

D) DSA

22. ¿Qué modo de bloque transforma un cifrado de bloque en un cifrado de flujo que permite el cifrado de bits o bytes de datos individuales?

A) CFB

B) CBC

C) GCM

D) BCE

Respuesta no detectada automaticamente

23. En criptografía, la cantidad de bits de una clave utilizada por un algoritmo criptográfico se denomina tamaño de clave o longitud de clave. La longitud de la clave determina el número máximo de combinaciones necesarias para romper el algoritmo de cifrado; por lo tanto, normalmente una clave más larga significa una seguridad criptográfica más sólida.

A) Verdadero
B) FALSO

24. ¿Cuál de las siguientes respuestas se refiere a un microcontrolador integrado que se utiliza para arranque seguro, cifrado de disco y verificación de la integridad del sistema?

A) TPM
B) SoC
C) UEFI
✓ D) HSM

25. ¿Cuál de las respuestas enumeradas a continuación se refiere a la causa más probable de un acceso no autorizado provocado por la explotación de un punto de entrada de red específico?

A) Software AV obsoleto
B) Cookies del navegador
✓ C) Puertos de servicio abiertos
D) Registro y seguimiento insuficientes

26. ¿Cuál de los siguientes facilita(n) los ataques de escalada de privilegios? (Seleccione todo lo que corresponda)

A) Vulnerabilidades del sistema/aplicación
B) Hash de contraseña
✓ C) Configuraciones erróneas del sistema/aplicación
D) Segmentación de red
✓ E) Técnicas de ingeniería social

27. ¿Cuál de las respuestas enumeradas a continuación se refiere a una solución que permite una gestión y control más sencillo de las políticas de segmentación de red a través de aplicaciones de software?

A) VDI
✓ B) SDN
C) VPC
D) EDR

28. Un mecanismo de control de acceso basado en reglas implementado en enrutadores, conmutadores y firewalls se denomina:

A) IMPERMEABLE
B) PUA
C) CAD
✓ D) LCA

29. ¿Cuál de las siguientes políticas se aplica a cualquier solicitud que no cumpla con los criterios definidos en una ACL?

A) Política de acceso justo
✓ B) Política de denegación implícita
C) confianza transitiva
D) Autenticación consciente del contexto

30. ¿Cuál de las siguientes respuestas no se refiere al concepto de aislamiento de sistema/aplicación?

A) Virtualización
B) Contenedorización
C) Zona de arena
✓ D) Cifrado de datos

31. ¿Cuál de las siguientes opciones proporciona una respuesta activa a una violación de la seguridad de la red en un sistema informático individual?

A) NIDS
B) esconde
C) PNI
✓ **D) CADERAS**

32. ¿Cuál de los siguientes proporciona aislamiento de redes informáticas externas?

A) Segmentación de red
✓ **B) Entrehierro**
C) Cortafuegos de hardware
D) Distribución de cables protegida

33. ¿Cuál de las respuestas enumeradas a continuación se refiere a un medio para la segmentación lógica de la red?

A) Cambiar
B) VLAN
C) Subred filtrada
D) Enrutador

34. ¿Cuál de las siguientes respuestas se refiere a técnicas de monitoreo pasivo de redes? (Seleccione 2 respuestas)

A) Grifo de red
B) Puerto troncal
✓ **C) Duplicación de puertos**
D) trampa SNMP
E) Puerto registrado

35. Un modo IPsec que proporciona cifrado sólo para la carga útil (la parte de datos del paquete) se denomina:

A) Modo protegido
B) Modo túnel
✓ **C) Modo de transporte**
D) Modo seguro

36. Los métodos de cifrado utilizados para proteger los datos en tránsito incluyen: (Seleccione todos los que correspondan)

A) NFS
✓ **B) vpn**
C) SED
✓ **D) IPSec**
E) FDE
✓ **F) TLS**

37. ¿Cuál de las respuestas enumeradas a continuación se refiere a una técnica que permite convertir datos de entrada en una cadena de tamaño fijo, lo que dificulta revertir o recuperar los datos originales?

✓ **A) Ofuscación**
✓ **B) Tokenización**
C) hash
D) Cifrado

38. La implementación del cifrado completo del dispositivo es uno de los métodos para proteger los datos confidenciales en un teléfono inteligente. Cuando está habilitado, este tipo de cifrado funciona junto con el bloqueo de pantalla del teléfono, es decir, para descifrar el teléfono (que permanece cifrado siempre que está bloqueado), el usuario primero debe desbloquear la pantalla. En los dispositivos Android, los métodos de desbloqueo incluyen ingresar un PIN, una contraseña o dibujar un patrón simple con un dedo. Los dispositivos Apple utilizan códigos de acceso, reconocimiento facial (Face ID) y huellas dactilares (Touch ID).

A) Verdadero
B) FALSO

Respuesta no detectada automaticamente

39. ¿Cuál de las respuestas que se enumeran a continuación se refieren a técnicas de refuerzo de estaciones de trabajo? (Seleccione 3 respuestas)

A) Ocultar cuentas de administrador

✓ B) Aplicar periódicamente parches de seguridad y actualizaciones del sistema operativo y del software instalado.

C) Deshabilitar todo el acceso a Internet

✓ D) Eliminar o deshabilitar controladores, servicios, software y protocolos de red innecesarios

✓ E) Limitar el acceso de usuarios no autorizados o no autenticados

40. ¿Qué tipo de software permite un control centralizado sobre la configuración, monitoreo y seguridad de los dispositivos móviles utilizados dentro de una organización?

A) MDR

B) SOY

C) SIEM

✓ D) DM

41. ¿Cuál de las siguientes respuestas se refiere a una función de seguridad utilizada en el emparejamiento de dispositivos Bluetooth?

A) SAE

✓ B) ALFILER

C) Ministerio de Asuntos Exteriores

D) LCA

42. La práctica de encontrar vulnerabilidades en una aplicación dándole entradas incorrectas se llama:

A) Normalización

B) Endurecimiento

C) Análisis de código dinámico

✓ D) Fuzzing

43. ¿Cuál de las siguientes respuestas se refiere a SCAP? (Seleccione 3 respuestas)

A) Un tipo de sistema de seguridad diseñado para recopilar registros y eventos de diversas fuentes.

✓ B) Diseñado para proporcionar una interfaz de usuario centralizada para acceder a los datos recopilados.

✓ C) Una colección de estándares desarrollados por NIST

✓ D) Proporciona un lenguaje común para comunicar información de seguridad.

✓ E) Permite que diferentes herramientas de seguridad compartan datos y trabajen juntas de manera más efectiva

F) Permite la detección de amenazas en tiempo real, la respuesta a incidentes y el monitoreo del cumplimiento

44. El Protocolo simple de administración de red (SNMP) es un protocolo de capa de aplicación basado en UDP que se utiliza en sistemas de administración de red para monitorear dispositivos conectados a la red. SNMP suele estar integrado en la mayoría de los dispositivos de infraestructura de red modernos, como enrutadores, puentes, conmutadores, servidores, impresoras, fotocopiadoras, máquinas de fax y otros dispositivos conectados a la red. Una red administrada por SNMP consta de tres componentes esenciales: un dispositivo administrado, un módulo de software de administración de red que reside en un dispositivo administrado (Agente) y una estación de administración de red (NMS), que ejecuta aplicaciones responsables de monitorear y controlar los dispositivos administrados, así como de recopilar información SNMP de los Agentes. El administrador recibe notificaciones (Traps e InformRequests) en el puerto UDP 162, mientras que el agente SNMP recibe solicitudes en el puerto UDP 161.

A) Verdadero

B) FALSO

Respuesta no detectada automaticamente

45. ¿Cuál de las respuestas enumeradas a continuación se refiere a un protocolo de red seguro utilizado para proporcionar cifrado, autenticación e integridad para la comunicación multimedia en tiempo real?

A) IPSec

B) SORBO

C) VoIP

✓ **D) SRTP**

46. ¿Cuál de los siguientes métodos de control de acceso sería el más adecuado para programar tareas de mantenimiento del sistema durante períodos de baja actividad del usuario?

A) Aprovisionamiento de recursos

✓ **B) Restricciones horarias**

C) Principio de privilegio mínimo

D) Permisos justo a tiempo

47. Un tipo de mecanismo de identificación de usuarios utilizado como contramedida contra el software automatizado (como los robots de red) se conoce como:

A) Ministerio de Asuntos Exteriores

✓ **B) CAPTCHA**

C) LCA

D) PNI

48. ¿Cuál es el nombre de un protocolo de red que protege el tráfico web mediante cifrado SSL/TLS?

A) SFTP

✓ **B) HTTPS**

C) FTPS

D) SHTTP

49. ¿Cuál de los siguientes protocolos de transferencia de archivos no proporciona cifrado?

A) SCP

B) FTPS

✓ **C) ftp**

D) SFTP

50. ¿Cuál de las siguientes respuestas ilustra la diferencia entre respuesta pasiva y activa a una violación de seguridad de la red?

A) HIPS frente a NIPS

B) UTM frente a cortafuegos

C) NIPS frente a UTM

✓ **D) IDS frente a IPS**

51. ¿Cuál de las siguientes respuestas se refiere a un dispositivo de almacenamiento de datos equipado con funcionalidad de cifrado a nivel de hardware?

A) HSM

B) TPM

C) EFS

✓ **D) SED**

52. ¿Cuál de las respuestas enumeradas a continuación se refiere a un conjunto de protocolos y tecnologías que proporcionan cifrado, autenticación e integridad de datos para el tráfico de red?

A) TLS

B) SSH

C) IPSec

D) vpn

53. ¿Cuál de las siguientes respuestas se refiere a un microcontrolador integrado que se utiliza para arranque seguro, cifrado de disco y verificación de la integridad del sistema?

A) TPM

B) SoC

C) UEFI

D) HSM

54. ¿Cuál de las siguientes soluciones proporciona una respuesta activa a las violaciones de seguridad de la red en un sistema informático individual?

A) NIDS
B) esconde
C) PNI
✓ **D) CADERAS**

55. ¿Cuál de las respuestas enumeradas a continuación se refiere a un mecanismo de control de acceso basado en reglas asociado con archivos y/o directorios?

A) EFS
✓ **B) FACL**
C) FIM
D) NTFS

56. La especificación MIME amplía el formato de los mensajes de correo electrónico más allá del simple texto, permitiendo la transferencia de archivos de gráficos, audio y vídeo a través del sistema de correo de Internet. S/MIME es una versión mejorada del protocolo MIME que habilita funciones de seguridad del correo electrónico al proporcionar cifrado, autenticación, integridad de mensajes y otros servicios relacionados.

A) Verdadero
B) FALSO

57. ¿Cuál de las respuestas enumeradas a continuación se refiere a una operación lógica comúnmente utilizada en el contexto de la ciberseguridad, particularmente en técnicas de cifrado y ofuscación?

A) Y
B) O
C) NO
D) XOR
Respuesta no detectada automaticamente

58. ¿Cuál de las siguientes respuestas se refiere a un criptosistema de clave pública utilizado para firmas digitales, intercambio seguro de claves y cifrado?

A) DHE
B) RSA
C) AES
D) DSA

59. ¿Cuál de las siguientes respuestas se refiere a un algoritmo de cifrado de bloque de clave simétrica obsoleto (en gran medida reemplazado por AES)?

A) ECDSA
B) RSA
C) IDEA
D) DSA

60. ¿Cuál de las respuestas enumeradas a continuación se refieren a DSA? (Seleccione 3 respuestas)

A) Algoritmo asimétrico
B) Utilizado para el proceso de intercambio de claves.
C) Algoritmo simétrico
✓ **D) Proporciona autenticación, integridad y no repudio.**
✓ **E) Diseñado específicamente para crear y verificar firmas digitales.**
F) Utilizado para cifrado

61. ¿Cuál de las respuestas enumeradas a continuación describe las características de ECDSA? (Seleccione todo lo que corresponda)

A) Proporciona autenticación, integridad y no repudio.
✓ **B) Basado en criptografía de curva elíptica**
C) Diseñado para el cifrado de datos
✓ **D) Diseñado específicamente para crear y verificar firmas digitales.**
✓ **E) Más eficiente computacionalmente que otros algoritmos de firma**
F) Habilita el proceso de intercambio de claves.

62. ¿Cuál de las siguientes respuestas se refiere a un protocolo de cifrado utilizado principalmente en redes Wi-Fi que implementan el estándar de seguridad WPA2?

A) TKIP
B) CCMP
C) SSL
D) HMAC

63. ¿Cuál de las siglas enumeradas a continuación se refiere a un protocolo utilizado en los sistemas de administración de redes para monitorear dispositivos conectados a la red?

A) SSH
B) VNC
C) SNMP
D) PDR

64. ¿Cuáles son los ejemplos de controles preventivos de seguridad? (Seleccione 3 respuestas)

A) Cifrado
B) identificación
C) Sensores
✓ D) Cortafuegos
E) Señales de advertencia
✓ F) software audiovisual

65. ¿Cuál de las respuestas enumeradas a continuación se refiere(s) a los controles de seguridad de detectives? (Seleccione todo lo que corresponda)

A) Iluminación
✓ B) Monitoreo de registros
C) Zona de arena
✓ D) Auditorías de seguridad
✓ E) circuito cerrado de televisión
✓ F) identificación
✓ G) Escaneo de vulnerabilidades

66. ¿Cuál de las respuestas enumeradas a continuación se refiere(s) a controles de seguridad compensatorios? (Seleccione todo lo que corresponda)

A) Sistemas de energía de respaldo
B) Videovigilancia
✓ C) Ministerio de Asuntos Exteriores
✓ D) Zona de pruebas de aplicaciones
✓ E) Segmentación de red

67. ¿Cuál de las siguientes respuestas se refiere a un dispositivo de almacenamiento de datos equipado con funcionalidad de cifrado a nivel de hardware?

A) HSM
B) TPM
C) EFS
✓ D) SED

68. Un componente de MS Windows que permite el cifrado de archivos individuales se llama:

A) SED
✓ B) EFS
C) BitLocker
D) FDE

69. ¿Cuál es el nombre de un protocolo de red que protege el tráfico web mediante cifrado SSL/TLS?

✓ A) SFTP
✓ B) HTTPS
C) FTPS

D) SHTTP

70. SFTP es una extensión del protocolo FTP que agrega soporte para cifrado SSL/TLS.

A) Verdadero

✓ B) FALSO

71. En el cifrado asimétrico, cualquier mensaje cifrado con el uso de una clave pública sólo puede descifrarse aplicando el mismo algoritmo y una clave privada coincidente (y viceversa).

A) Verdadero

B) FALSO

72. ¿Cuál de los siguientes algoritmos no entra en la categoría de cifrado asimétrico? (Seleccione todo lo que corresponda)

A) AES

✓ B) DES

C) DHE

D) ECC

✓ E) IDEA

✓ F) RC4

G) RSA

73. ¿Cuál de las siguientes respuestas se refiere a un algoritmo de cifrado de bloque de clave simétrica obsoleto (en gran medida reemplazado por AES)?

A) ECDSA

B) RSA

C) IDEA

D) DSA

Respuesta no detectada automaticamente

74. Un modo de cifrado de bloques que combina un contador único con una clave de cifrado para generar un flujo de bloques de datos pseudoaleatorios que luego se utilizan para cifrar datos se denomina:

A) CBC

B) GCM

C) CFB

✓ D) marca comunitaria

75. ¿Qué modo de cifrado en bloque combina CTM para el cifrado con un mecanismo de autenticación para garantizar la confidencialidad e integridad de los datos?

A) CBC

✓ B) GCM

C) BCE

D) CFB

76. ¿Cuál de las respuestas enumeradas a continuación se refiere a una técnica criptográfica que verifica la autenticidad e integridad de documentos o mensajes digitales mediante el uso de un identificador cifrado único del remitente?

A) Firma digital

B) Función hash criptográfica

C) Certificado digital

D) Cifrado asimétrico

77. Un tipo de documento digital que verifica la identidad de un individuo, dispositivo, servicio u organización en las comunicaciones en línea se conoce como:

A) Clave de cifrado

✓ B) Certificado digital

C) Token de identidad

D) Firma digital

78. ¿Cuál de las respuestas enumeradas a continuación se refiere a los métodos de cifrado utilizados para proteger los datos en reposo? (Seleccione todo lo que corresponda)

A) FDE

✓ **B) SED**

C) IPSec

D) TLS

✓ **E) vpn**

✓ **F) EFS**

79. ¿Cuál de las respuestas enumeradas a continuación se refiere a una técnica que permite convertir datos de entrada en una cadena de tamaño fijo, lo que dificulta revertir o recuperar los datos originales?

A) Ofuscación

B) Tokenización

✓ **C) hash**

D) Cifrado

80. ¿Cuál de las respuestas enumeradas a continuación se refiere a una situación en la que los datos confidenciales se almacenan en una ubicación separada y se pueden recuperar con un reemplazo no confidencial que también se puede procesar como los datos originales sin el riesgo de revelar el contenido de los datos originales?

A) enmascaramiento

✓ **B) Ofuscación**

C) Cifrado

✓ **D) Tokenización**

81. ¿Cuál de las siguientes respuestas se refiere a una función de seguridad utilizada en el emparejamiento de dispositivos Bluetooth?

A) SAE

✓ **B) ALFILER**

C) Ministerio de Asuntos Exteriores

D) LCA

82. ¿Cuál de los esquemas de cifrado inalámbrico enumerados a continuación ofrece el mayor nivel de protección?

A) WPS

✓ **B) WPA3**

C) AES

D) TKIP

83. La práctica de encontrar vulnerabilidades en una aplicación dándole entradas incorrectas se llama:

A) Normalización

B) Endurecimiento

C) Análisis de código dinámico

✓ **D) Fuzzing**

84. El principio de privilegio mínimo es una regla de seguridad que impide que los usuarios accedan a información y recursos que se encuentran más allá del alcance de sus responsabilidades.

A) Verdadero

B) FALSO

Respuesta no detectada automaticamente

85. ¿Cuál de las siguientes respuestas se refiere(s) a la etapa de contención, erradicación y recuperación del proceso de respuesta a incidentes? (Seleccione todo lo que corresponda)

A) Restaurando operaciones normales

✓ **B) Eliminando la amenaza**

C) Seguimiento y detección de posibles incidencias

D) Establecer y mantener una política de respuesta a incidentes.

✓ **E) Mitigar el impacto del incidente**

86. ¿Cuál de las respuestas enumeradas a continuación se refiere a un ejemplo de evaluación de riesgos recurrentes?

✓ **A) Monitoreo en tiempo real de amenazas a la seguridad de la red**

B) Evaluación del riesgo después de un cambio organizacional importante o una violación de seguridad

C) Evaluaciones de riesgos trimestrales o anuales

D) Evaluación de riesgos para el lanzamiento de un nuevo producto.

87. ¿Cuál de las respuestas enumeradas a continuación se refiere a un ejemplo de evaluación continua de riesgos?

A) Evaluaciones de riesgos trimestrales o anuales

B) Evaluación de riesgos para el lanzamiento de un nuevo producto.

C) Evaluación del riesgo después de un cambio organizacional importante o una violación de seguridad

D) Monitoreo en tiempo real de amenazas a la seguridad de la red

3.0 Arquitectura de Seguridad (18% del examen)

3.1 - Comparar y contrastar las implicaciones de seguridad de diferentes modelos de arquitectura.

Conceptos clave:

- Nube: IaaS, PaaS, SaaS - Matriz de responsabilidad compartida
- Nube publica, privada, hibrida y comunitaria
- Serverless, Microservicios, Contenedores, IaC, SDN
- Sistemas especializados: IoT, ICS/SCADA, RTOS, Sistemas embebidos, Air-gapped

Teoria detallada:

MODELOS DE NUBE:

- IaaS (Infraestructura como Servicio): el proveedor da hardware virtual. Tu gestionas SO, apps, datos. Ej: AWS EC2
- PaaS (Plataforma como Servicio): el proveedor da la plataforma de desarrollo. Tu gestionas las apps y datos. Ej: Heroku
- SaaS (Software como Servicio): el proveedor da todo. Tu solo usas la app. Ej: Gmail, Office 365
- Matriz de responsabilidad compartida: define que responsabilidades son del proveedor y cuales del cliente. Critico para el examen.

TIPOS DE NUBE:

- Nube publica: recursos compartidos entre clientes (AWS, Azure, GCP)
- Nube privada: infraestructura dedicada a una sola organizacion
- Nube hibrida: combinacion de publica y privada
- Nube comunitaria: compartida entre organizaciones con intereses comunes

TECNOLOGIAS CLOUD:

- Serverless: codigo que se ejecuta sin gestionar servidores (AWS Lambda). Escalado automatico
- Microservicios: aplicacion dividida en servicios pequenos e independientes
- Contenedores: empaquetar apps con sus dependencias (Docker). Mas ligero que VMs
- Infraestructura como Codigo (IaC): gestionar infraestructura mediante codigo (Terraform, CloudFormation)
- SDN (Red definida por software): red gestionada por software, separando el plano de control del de datos

SISTEMAS ESPECIALIZADOS:

- IoT (Internet de las Cosas): dispositivos conectados con recursos limitados, frecuentemente sin seguridad adecuada
- ICS/SCADA: sistemas de control industrial. Prioridad: disponibilidad sobre seguridad
- RTOS (Sistema Operativo de Tiempo Real): SO para sistemas que necesitan respuesta en tiempo real
- Sistemas embebidos: hardware con software fijo integrado (routers, camaras IP, PLCs)
- Air-gapped: sistema fisicamente aislado de cualquier red. Maximo nivel de aislamiento

Preguntas de practica (46):

1. Un modelo de servicio de computación en la nube que ofrece acceso remoto a aplicaciones basado en una tarifa de suscripción mensual o anual se denomina:

A) PaaS
✓ B) SaaS
C) IaaS
D) DaaS

---

2. ¿Cuál de las siguientes respuestas se refiere a tecnología de software diseñada para simplificar la gestión de la infraestructura de red?

A) SDN
B) SaaS
C) VDI
D) SNMP

---

3. ¿Cuál de las respuestas enumeradas a continuación se refiere al proceso de empaquetar una aplicación y sus dependencias en una unidad única e independiente, que puede ejecutarse en diferentes entornos informáticos?

A) Computación de borde

B) Contenedorización
C) Virtualización
D) Computación en la nube

4. ¿Cuál de las respuestas enumeradas a continuación se refiere a un término amplio que abarca varios sistemas de control y automatización utilizados en entornos industriales para controlar y monitorear procesos físicos y maquinaria?

A) ICS
B) SOCIEDAD ANÓNIMA
C) SCADA
D) HMI

5. La especificación MIME extiende el formato de los mensajes de correo electrónico más allá del texto plano, permitiendo la transferencia de archivos de gráficos, audio y vídeo a través del sistema de correo de Internet. S/MIME es una versión mejorada del protocolo MIME que habilita funciones de seguridad del correo electrónico al proporcionar cifrado, autenticación, integridad de mensajes y otros servicios relacionados.

A) Verdadero
B) FALSO

6. ¿Cuál de las siguientes respuestas se refiere a un microcontrolador integrado que se utiliza para arranque seguro, cifrado de disco y verificación de la integridad del sistema?

A) TPM
B) SoC
C) UEFI
✓ D) HSM

7. Dadas las limitaciones computacionales de los dispositivos IoT, las tarjetas inteligentes y los dispositivos móviles, ¿cuál de los siguientes algoritmos de firma digital sería la opción más eficiente debido a su menor tamaño de clave y menores requisitos de procesamiento?

A) RSA
B) ECDHE
C) DSA
✓ D) ECDSA
E) ECC

8. La tecnología Blockchain es un ejemplo de:

A) Pasarela de pago en línea
B) Base de datos centralizada
✓ C) Libro de contabilidad público abierto
D) sistema de almacenamiento en la nube

9. ¿Cuál de las respuestas enumeradas a continuación describe las características de un ataque de secuencias de comandos entre sitios? (Seleccione 3 respuestas)

A) Explota la confianza que el navegador web de un usuario tiene en un sitio web
✓ B) Se inyecta un script malicioso en un sitio web confiable
✓ C) El navegador del usuario ejecuta el script del atacante
D) Explota la confianza que un sitio web tiene en el navegador web del usuario.
E) Un atacante engaña a un usuario para que envíe solicitudes web no autorizadas
F) El sitio web ejecuta las solicitudes del atacante

10. ¿Cuál de las siguientes respuestas se refiere a un tipo de software integrado en un chip de hardware?

A) firmware
B) software intermedio
C) Controlador de dispositivo
D) Código máquina
Respuesta no detectada automaticamente

11. El término "clonación RFID" se refiere a copiar los datos almacenados en cualquier dispositivo habilitado para RFID (incluidas etiquetas, tarjetas, llaveros, implantes y otros objetos integrados con tecnología RFID) en otro dispositivo habilitado para RFID, que luego puede leerse y usarse de la misma manera que la etiqueta original. Si bien la clonación RFID se puede utilizar con fines legítimos, como replicar etiquetas importantes con fines de respaldo y prueba, también plantea un riesgo de seguridad significativo, ya que las etiquetas duplicadas pueden usarse potencialmente para obtener acceso no autorizado o divulgación de información no autorizada.

A) Verdadero

B) FALSO

Respuesta no detectada automaticamente

12. ¿Cuál de las afirmaciones enumeradas a continuación se puede utilizar para describir las características de un ataque en ruta? (Seleccione todo lo que corresponda)

A) Un ataque en ruta también se conoce como ataque MITM.

✓ B) Los atacantes se sitúan en la ruta de comunicación entre dos dispositivos

✓ C) Los atacantes interceptan o modifican paquetes enviados entre dos dispositivos en comunicación

D) Los atacantes no tienen acceso a los paquetes intercambiados durante la comunicación entre dos dispositivos

13. ¿Cuáles son los rasgos característicos de una ID de sesión? (Seleccione todo lo que corresponda)

A) Permite al servidor identificar la sesión y recuperar los datos de la sesión correspondientes.

✓ B) Un identificador único asignado por el sitio web a un usuario específico.

C) Contiene las credenciales de autenticación del usuario, por ejemplo, nombre de usuario y contraseña.

✓ D) Un dato que puede almacenarse en una cookie o incrustarse como un parámetro de URL

✓ E) Almacenado en el lado del cliente (en el navegador del usuario) y enviado al servidor con cada solicitud

F) Un identificador único asignado a un servidor.

14. ¿Cuál de las respuestas enumeradas a continuación se refiere a una solución que permite una gestión y control más sencillo de las políticas de segmentación de red a través de aplicaciones de software?

A) VDI

✓ B) SDN

C) VPC

D) EDR

15. ¿Cuál de las siguientes respuestas no se refiere al concepto de aislamiento de sistema/aplicación?

A) Virtualización

B) Contenedorización

C) Zona de arena

✓ D) Cifrado de datos

16. ¿Cuál de las respuestas enumeradas a continuación se refiere al concepto de aislamiento de datos? (Seleccione 2 respuestas)

A) DLP

B) SDN

✓ C) EFS

D) SWG

E) EDR

17. El término "nube híbrida" se refiere a un entorno informático mixto que puede incluir diferentes modelos de servicios de nube, como nubes públicas y privadas, así como infraestructura local.

A) Verdadero

B) FALSO

18. Una arquitectura sin servidor permite a los desarrolladores crear aplicaciones y servicios sin tener que administrar los recursos de infraestructura necesarios (como servidores, bases de datos y sistemas de almacenamiento), que son manejados por:

A) CSP

B) ISP

C) MSP

D) proveedor de identidad

Respuesta no detectada automaticamente

19. ¿Cuál de las siguientes respuestas se refiere a un marco de ciberseguridad que combina funciones de red y seguridad en un único servicio basado en la nube?

A) SASE

B) SWG

C) CASB

D) SD-WAN

Respuesta no detectada automaticamente

20. ¿Cuál de las respuestas que se enumeran a continuación se refieren a los rasgos característicos del análisis de código estático? (Seleccione 3 respuestas)

A) Implica examinar el código sin ejecutarlo.

✓ B) A menudo se utiliza al principio del proceso de desarrollo.

✓ C) Examina la estructura, la sintaxis y la semántica del código para detectar problemas como errores de sintaxis, violaciones de estándares de codificación, vulnerabilidades de seguridad y errores.

D) Normalmente se utiliza más adelante en el ciclo de vida del desarrollo de software.

E) Implica ejecutar el código y analizar su comportamiento en tiempo de ejecución.

F) Analiza las propiedades del tiempo de ejecución, como el uso de la memoria, el rendimiento y el manejo de errores, para identificar problemas como pérdidas de memoria, cuellos de botella en el rendimiento y errores de tiempo de ejecución.

21. ¿Cuál de las siguientes afirmaciones describe las características del análisis de código dinámico? (Seleccione 3 respuestas)

A) Normalmente se utiliza más adelante en el ciclo de vida del desarrollo de software.

B) Implica examinar el código sin ejecutarlo.

✓ C) Analiza las propiedades del tiempo de ejecución, como el uso de la memoria, el rendimiento y el manejo de errores, para identificar problemas como pérdidas de memoria, cuellos de botella en el rendimiento y errores de tiempo de ejecución.

D) A menudo se utiliza al principio del proceso de desarrollo.

E) Examina la estructura, la sintaxis y la semántica del código para detectar problemas como errores de sintaxis, violaciones de estándares de codificación, vulnerabilidades de seguridad y errores.

✓ F) Implica ejecutar el código y analizar su comportamiento en tiempo de ejecución.

22. ¿Cuál de los siguientes términos se refiere a patrones o características predefinidos de amenazas o métodos de ataque conocidos?

A) Registros de seguridad

B) Líneas de base

C) Tendencias

✓ D) Firmas

23. En el contexto de la seguridad informática, el término "biometría" se refiere tanto a las características biológicas del cuerpo humano como a los rasgos de comportamiento que pueden utilizarse con fines de identificación y control de acceso.

A) Verdadero

B) FALSO

Respuesta no detectada automaticamente

24. ¿Cuál de las respuestas enumeradas a continuación se refieren a las características de una llave de seguridad? (Seleccione 3 respuestas)

A) Se utiliza para generación de OTP, acceso remoto a vehículos y acceso a edificios.

✓ B) Token de autenticación de hardware

✓ C) Normalmente, una memoria USB física o un dispositivo del tamaño de un llavero

✓ D) Utilizado principalmente para seguridad digital (2FA/MFA)

E) Token de autenticación de software

F) Normalmente, una tarjeta de plástico del tamaño de una tarjeta de crédito con un chip integrado.

25. El proceso de identificar, recopilar y producir información almacenada electrónicamente con la intención de utilizarla en un procedimiento o investigación legal se conoce como:

A) Retención por litigio
B) Gestión de pruebas
C) Forense digital
✓ **D) descubrimiento electrónico**

---

26. El término "Metadatos" se refiere a datos que proporcionan información sobre otros datos, pero no el contenido real de los datos. Normalmente, los metadatos no son visibles para el usuario de forma predeterminada, pero se puede acceder a ellos si es necesario. Por ejemplo, los metadatos de correo electrónico, que se encuentran en los encabezados de los correos electrónicos, incluyen información detallada sobre el remitente, el destinatario y la ruta que tomó el mensaje. Los metadatos del dispositivo móvil abarcan detalles como el modelo del dispositivo, geolocalización, información de la cámara, uso de Internet, actividad de llamadas telefónicas y mensajes de texto, estadísticas de uso de aplicaciones y metadatos de varios archivos en el dispositivo. En la navegación web, los metadatos provienen de metaetiquetas HTML ubicadas en la sección principal de una página web. Para los archivos, los metadatos incluyen detalles sobre el autor (por ejemplo, el creador del archivo), el tipo de archivo, el tamaño, la fecha y hora de creación y la fecha y hora de la última modificación.

A) Verdadero
B) FALSO

---

27. ¿Cuál de los términos enumerados a continuación se refiere al proceso de creación y mantenimiento de aplicaciones informáticas?

A) RAD
✓ **B) SDLC**
C) POO
D) SaaS

---

28. ¿Cuál de los términos enumerados a continuación se refiere al proceso de creación y mantenimiento de aplicaciones informáticas?

A) RAD
✓ **B) SDLC**
C) POO
D) SaaS

---

29. ¿Cuál es el término común para un grupo de protocolos utilizados para transportar datos de voz a través de una red de conmutación de paquetes?

A) RDSI
B) PBX
✓ **C) VoIP**
D) PSTN

---

30. ¿Cuál de las respuestas enumeradas a continuación se refiere a una tecnología de software diseñada para simplificar la gestión de la infraestructura de red?

A) SDN
B) calidad de servicio
C) VDI
D) CDN

---

31. ¿Cuál de las siguientes respuestas se refiere a un microcontrolador integrado que se utiliza para arranque seguro, cifrado de disco y verificación de la integridad del sistema?

A) TPM
B) SoC
C) UEFI
D) HSM

32. ¿Qué tipo de software se utiliza para prevenir, detectar y eliminar malware de sistemas y redes informáticas?

A) identificación

B) SaaS

✓ C) AV

D) WAF

---

33. La especificación MIME amplía el formato de los mensajes de correo electrónico más allá del simple texto, permitiendo la transferencia de archivos de gráficos, audio y vídeo a través del sistema de correo de Internet. S/MIME es una versión mejorada del protocolo MIME que habilita funciones de seguridad del correo electrónico al proporcionar cifrado, autenticación, integridad de mensajes y otros servicios relacionados.

A) Verdadero

B) FALSO

---

34. Un enfoque de desarrollo de software que tiene como objetivo la creación rápida de aplicaciones y la mejora continua a través del desarrollo iterativo y la colaboración de los usuarios se denomina:

A) FDD

B) DevOps

✓ C) RAD

D) SaaS

---

35. ¿Cuál de las siguientes respuestas se refiere a una herramienta de software que proporciona una única interfaz de administración para dispositivos móviles, PC, impresoras, dispositivos IoT y wearables?

A) DM

B) RCS

✓ C) UEM

D) mamá

---

36. ¿Cuál de las respuestas enumeradas a continuación describe las características de ECDSA? (Seleccione todo lo que corresponda)

A) Proporciona autenticación, integridad y no repudio.

✓ B) Basado en criptografía de curva elíptica

C) Diseñado para el cifrado de datos

✓ D) Diseñado específicamente para crear y verificar firmas digitales.

✓ E) Más eficiente computacionalmente que otros algoritmos de firma

F) Habilita el proceso de intercambio de claves.

---

37. ¿Cuál de las siguientes respuestas se refiere a un marco de ciberseguridad que combina funciones de red y seguridad en un único servicio basado en la nube?

A) SASE

B) SIEM

C) SWG

D) REMONTARSE

---

38. ¿Cuál de las respuestas enumeradas a continuación describe las características de un VDI no persistente? (Seleccione 2 respuestas)

A) Al final de una sesión, el escritorio del usuario vuelve a su estado original.

B) Cada usuario ejecuta su propia copia del escritorio virtual.

C) Al final de una sesión, se guardan los datos del usuario y la configuración personal.

✓ D) El escritorio virtual se comparte entre varios usuarios

---

39. ¿Cuál de las siguientes respuestas se refiere a una herramienta de software diseñada para simplificar el proceso de creación y mantenimiento de contenido en línea?

A) VDI

B) SaaS

C) CMS

D) SDK

---

40. Una empresa u organización que ofrece servicios de computación en la nube a través de Internet se denomina:

A) ISP

B) MSSP

✓ C) CSP

D) MSP

---

41. Dadas las limitaciones computacionales de los dispositivos IoT, las tarjetas inteligentes y los dispositivos móviles, ¿cuál de los siguientes algoritmos de firma digital sería la opción más eficiente debido a su menor tamaño de clave y menores requisitos de procesamiento?

A) RSA

B) ECDHE

C) DSA

✓ D) ECDSA

E) ECC

---

42. ¿Cuál de las siguientes respuestas se refiere a ejemplos de vectores de amenazas basados ■■en imágenes? (Seleccione 3 respuestas)

A) esteganografía

B) Ataques BEC

C) Suplantación de imágenes (deepfakes)

D) Suplantación de marca

E) Imágenes con malware incorporado

---

43. ¿Cuál de las respuestas enumeradas a continuación describe las características de un ataque de secuencias de comandos entre sitios? (Seleccione 3 respuestas)

A) Explota la confianza que el navegador web de un usuario tiene en un sitio web

✓ B) Se inyecta un script malicioso en un sitio web confiable

✓ C) El navegador del usuario ejecuta el script del atacante

D) Explota la confianza que un sitio web tiene en el navegador web del usuario.

E) Un atacante engaña a un usuario para que envíe solicitudes web no autorizadas

F) El sitio web ejecuta las solicitudes del atacante

---

44. ¿Cuál de las respuestas enumeradas a continuación se refiere a algún tipo de información perteneciente a un individuo que pueda usarse para identificar de manera única a esa persona?

A) FI

B) Biometría

C) IDENTIFICACIÓN

✓ D) PII

---

45. ¿Cuál de las siguientes afirmaciones describe las características del análisis de código dinámico? (Seleccione 3 respuestas)

A) Normalmente se utiliza más adelante en el ciclo de vida del desarrollo de software.

B) Implica examinar el código sin ejecutarlo.

✓ C) Analiza las propiedades del tiempo de ejecución, como el uso de la memoria, el rendimiento y el manejo de errores, para identificar problemas como pérdidas de memoria, cuellos de botella en el rendimiento y errores de tiempo de ejecución.

D) A menudo se utiliza al principio del proceso de desarrollo.

E) Examina la estructura, la sintaxis y la semántica del código para detectar problemas como errores de sintaxis, violaciones de estándares de codificación, vulnerabilidades de seguridad y errores.

✓ F) Implica ejecutar el código y analizar su comportamiento en tiempo de ejecución.

---

46. Durante la etapa de actividad posterior al incidente, este paso implica analizar registros, datos forenses y otras pruebas para evitar que el incidente vuelva a ocurrir.

A) Informes

B) descubrimiento electrónico

✓ C) Análisis de causa raíz

D) caza de amenazas

3.2 - Dado un escenario, aplicar los principios de seguridad para asegurar la infraestructura empresarial.

Conceptos clave:

- Dispositivos: Firewall, IDS, IPS, WAF, Balanceador de carga, Proxy, Jump server
- Tipos de firewall: Filtrado de paquetes, Stateful, NGFW, UTM
- Zonas: DMZ/Subred de pantalla, Fail-open vs Fail-closed
- Protocolos seguros: TLS, IPSec, VPN, SD-WAN, SASE, 802.1X

Teoria detallada:

DISPOSITIVOS DE RED Y SU COLOCACION:

- Firewall: filtra trafico entre zonas de red. Debe colocarse entre zonas de diferente nivel de confianza
- IDS (Sistema de Deteccion de Intrusiones): detecta ataques y alerta. PASIVO, no bloquea
- IPS (Sistema de Prevencion de Intrusiones): detecta Y bloquea ataques. ACTIVO, se coloca en linea
- WAF (Firewall de Aplicacion Web): protege aplicaciones web, entiende HTTP/HTTPS. Capa 7
- Balanceador de carga: distribuye el trafico entre multiples servidores para alta disponibilidad
- Proxy: intermediario entre cliente e internet. Puede filtrar contenido, cachear y anonimizar
- Servidor de salto (Jump server/Bastion host): servidor en la DMZ desde el que se administran sistemas internos

TIPOS DE FIREWALL:

- Filtrado de paquetes: filtra por IP, puerto y protocolo. Sin estado (Stateless). Rapido pero basico
- Con estado (Stateful): recuerda el estado de las conexiones. Mas seguro
- NGFW (Firewall de Nueva Generacion): incluye IPS, inspeccion SSL, control de aplicaciones
- UTM (Gestion Unificada de Amenazas): todo en uno: firewall + IPS + antivirus + VPN + filtro web

ZONAS DE RED:

- DMZ (Zona Desmilitarizada) / Subred de pantalla: zona entre internet e intranet donde van los servidores publicos
- Fail-open: si el dispositivo falla, deja pasar todo el trafico (prioriza disponibilidad)
- Fail-closed: si el dispositivo falla, bloquea todo el trafico (prioriza seguridad)

PROTOCOLOS DE COMUNICACION SEGURA:

- TLS (Seguridad de la Capa de Transporte): sucesor de SSL, cifra el trafico web (HTTPS = HTTP + TLS)
- IPSec: cifrado a nivel de red (capa 3). Dos modos: Transport (solo payload) y Tunnel (todo el paquete)
- VPN: tunel cifrado sobre internet. Tipos: Site-to-site (entre oficinas) y Remote access (usuario a red)
- SD-WAN: WAN definida por software, optimiza el trafico entre sedes
- SASE (Secure Access Service Edge): combina red y seguridad en la nube
- 802.1X: estandar de autenticacion para acceso a red (NAC)

Preguntas de practica (75):

1. ¿Cuál de las respuestas enumeradas a continuación se refiere a un conjunto de protocolos y tecnologías que proporcionan cifrado, autenticación e integridad de datos para el tráfico de red?

A) TLS

B) SSH

✓ C) IPSec

D) vpn

2. ¿Cuál de las respuestas enumeradas a continuación se refiere a la tecnología de seguridad de red diseñada para monitorear las WLAN en busca de acceso no autorizado, amenazas a la seguridad y actividades sospechosas?

A) UTM

B) WIDS

C) NGFW

D) WAF

Respuesta no detectada automaticamente

3. Los métodos de cifrado utilizados para proteger los datos en tránsito incluyen: (Seleccione todos los que correspondan)

A) NFS

✓ **B) vpn**

C) SED

✓ **D) IPSec**

E) FDE

✓ **F) TLS**

4. ¿Cuál de las siguientes respuestas ilustra la diferencia entre respuesta pasiva y activa a una violación de seguridad de la red?

A) HIPS frente a NIPS

B) UTM frente a cortafuegos

C) NIPS frente a UTM

✓ **D) IDS frente a IPS**

5. ¿Cuál de las respuestas enumeradas a continuación se refiere a un conjunto de protocolos y tecnologías que proporcionan cifrado, autenticación e integridad de datos para el tráfico de red?

A) TLS

B) SSH

C) IPSec

D) vpn

6. ¿Cuál de las respuestas enumeradas a continuación se refiere a los métodos de cifrado utilizados para proteger los datos en reposo? (Seleccione todo lo que corresponda)

A) FDE

✓ **B) SED**

C) IPSec

D) TLS

✓ **E) vpn**

✓ **F) EFS**

7. ¿Cuál de las siguientes respuestas se refiere a un protocolo utilizado para configurar conexiones seguras e intercambiar claves criptográficas en VPN IPsec?

A) SSL

B) IKE

C) ESP

D) DHE

8. ¿Cuál de las respuestas enumeradas a continuación se refiere a un protocolo utilizado para configurar conexiones seguras e intercambiar claves criptográficas en VPN IPsec?

A) SSL

✓ **B) IKE**

C) ESP

D) DHE

9. Una subred ligeramente protegida (también conocida como DMZ) que consta de servidores disponibles públicamente ubicados en el exterior del firewall de la empresa se conoce como:

A) Portal cautivo

B) Red de cuarentena

C) Extranet

✓ **D) Subred filtrada**

10. ¿Cuál de las siguientes respuestas se refiere a un protocolo utilizado para configurar conexiones seguras e intercambiar claves criptográficas en VPN IPsec?

A) SSL

✓ **B) IKE**

C) ESP

D) DHE

11. ¿Qué protocolo criptográfico está diseñado para proporcionar comunicaciones seguras a través de una red informática y es el sucesor de SSL?

A) IPSec

✓ B) TLS

C) AES

D) CCMP

---

12. ¿Cuál de las respuestas enumeradas a continuación se refiere a un protocolo utilizado para configurar conexiones seguras e intercambiar claves criptográficas en VPN IPsec?

A) SSL

✓ B) IKE

C) ESP

D) DHE

---

13. ¿Cuáles son los ejemplos de controles preventivos de seguridad? (Seleccione 3 respuestas)

A) Cifrado

B) identificación

C) Sensores

✓ D) Cortafuegos

E) Señales de advertencia

✓ F) software audiovisual

---

14. ¿Cuál de los siguientes términos entran en la categoría de controles de seguridad directivos? (Seleccione 2 respuestas)

A) PIR

✓ B) PUA

C) identificación

D) Ministerio de Asuntos Exteriores

E) IPS

---

15. Un protocolo de cifrado utilizado principalmente en redes Wi-Fi que implementan el estándar de seguridad WPA2 se llama:

A) TKIP

✓ B) CCMP

C) SSL

D) IPSec

---

16. ¿Cuál de las siguientes opciones proporciona una respuesta activa a una violación de la seguridad de la red en un sistema informático individual?

A) NIDS

B) esconde

C) PNI

✓ D) CADERAS

---

17. ¿Qué parte de IPsec proporciona confidencialidad, integridad de datos y autenticación?

A) AES

B) sha

C) Ah

✓ D) ESP

---

18. Un modo IPsec que proporciona cifrado sólo para la carga útil (la parte de datos del paquete) se denomina:

A) Modo protegido

B) Modo túnel

✓ C) Modo de transporte

D) Modo seguro

---

19. ¿Cuál de las siguientes respuestas se refiere a un marco de ciberseguridad que combina funciones de red y seguridad en un único servicio basado en la nube?

A) SASE
B) SWG
C) CASB
D) SD-WAN
Respuesta no detectada automaticamente

20. ¿Cuál de las siguientes siglas se refiere a soluciones de seguridad basadas en software o hardware diseñadas para detectar y prevenir el uso y la transmisión no autorizados de información confidencial?

A) IPS
✓ B) DLP
C) identificación
D) DEP

21. ¿Cuál de las respuestas enumeradas a continuación se refiere a un reemplazo seguro de Telnet?

A) RSH
B) IPSec
✓ C) SSH
D) RTPS

22. ¿Cuál de las respuestas enumeradas a continuación se refiere a un protocolo de red seguro utilizado para proporcionar cifrado, autenticación e integridad para la comunicación multimedia en tiempo real?

A) IPSec
B) SORBO
C) VoIP
✓ D) SRTP

23. ¿Cuál de las siguientes respuestas se refiere a una solución de seguridad de red que proporciona un único punto de protección contra varios tipos de amenazas?

A) desplazado interno
B) AV
✓ C) UTM
D) NGFW

24. ¿Cuál de las siguientes siglas se refiere a soluciones de seguridad basadas en software o hardware diseñadas para detectar y prevenir el uso y la transmisión no autorizados de información confidencial?

A) IPS
✓ B) DLP
C) identificación
D) DEP

25. ¿Cuál de las respuestas enumeradas a continuación se refiere a una tecnología de seguridad de red diseñada para monitorear, detectar y mitigar el acceso no autorizado, las amenazas a la seguridad y las actividades sospechosas en las WLAN?

A) WIPS
B) NIDS
C) PNI
D) WIDS

26. ¿Cuál de las siguientes soluciones proporciona una respuesta activa a las violaciones de seguridad de la red en un sistema informático individual?

A) NIDS
B) esconde
C) PNI
✓ D) CADERAS

27. ¿Qué tipo de software se utiliza para prevenir, detectar y eliminar malware de sistemas y redes informáticas?

A) identificación
B) SaaS
✓ **C) AV**
D) WAF

28. ¿Cuáles son los ejemplos de controles preventivos de seguridad? (Seleccione 3 respuestas)

A) Cifrado
B) identificación
C) Sensores
✓ **D) Cortafuegos**
E) Señales de advertencia
✓ **F) software audiovisual**

29. ¿Cuál de los siguientes términos entran en la categoría de controles de seguridad directivos? (Seleccione 2 respuestas)

A) PIR
✓ **B) PUA**
C) identificación
D) Ministerio de Asuntos Exteriores
E) IPS

30. ¿Qué parte de IPsec proporciona autenticación, integridad y confidencialidad?

A) SPD
B) PFS
C) Ah
✓ **D) ESP**

31. ¿Cuál de los protocolos enumerados a continuación se utiliza para permitir la navegación web segura?

A) L2TP
✓ **B) HTTPS**
C) SSH
D) IPSec

32. ¿Cuál de las respuestas enumeradas a continuación se refiere a un reemplazo seguro de Telnet?

A) RSH
B) IPSec
C) SSH
D) RTPS

33. ¿Cuál de las respuestas enumeradas a continuación se refiere(s) a los controles de seguridad de detectives? (Seleccione todo lo que corresponda)

A) Iluminación
✓ **B) Monitoreo de registros**
C) Zona de arena
✓ **D) Auditorías de seguridad**
✓ **E) circuito cerrado de televisión**
✓ **F) identificación**
✓ **G) Escaneo de vulnerabilidades**

34. SFTP es una extensión del protocolo FTP que agrega soporte para cifrado SSL/TLS.

A) Verdadero
✓ **B) FALSO**

35. Un sistema que utiliza una red pública (como Internet) como medio para crear conexiones privadas cifradas entre ubicaciones remotas se denomina:

A) WWAN

✓ **B) vpn**

C) CACEROLA

D) VLAN

36. ¿Cuál de las respuestas enumeradas a continuación se refiere a un método de autenticación secreto compartido utilizado en WPA, WPA2 y EAP?

A) PSK

B) 802.1X

C) SAE

D) TKIP

37. ¿Cuáles de las tecnologías inalámbricas enumeradas a continuación se consideran vectores de amenazas potenciales y deben evitarse debido a sus vulnerabilidades conocidas? (Seleccione todo lo que corresponda)

A) WPS

B) WAP

✓ **C) WPA**

D) WAF

✓ **E) WPA2**

✓ **F) WEP**

38. ¿Cuál de las siguientes opciones indicaría un intento de ocultar evidencia de actividad maliciosa?

A) Bloqueo de cuenta

B) Inaccesibilidad de recursos

✓ **C) Registros faltantes**

D) Uso simultáneo de sesiones

39. Un mecanismo de control de acceso basado en reglas implementado en enrutadores, conmutadores y firewalls se denomina:

A) IMPERMEABLE

B) PUA

C) CAD

✓ **D) LCA**

40. ¿Cuál de los siguientes proporciona aislamiento de redes informáticas externas?

A) Segmentación de red

✓ **B) Entrehierro**

C) Cortafuegos de hardware

D) Distribución de cables protegida

41. ¿Cuál de las respuestas enumeradas a continuación se refiere a un medio para la segmentación lógica de la red?

A) Cambiar

B) VLAN

C) Subred filtrada

D) Enrutador

42. Un sistema informático o una aplicación que actúa como intermediario entre otra computadora e Internet se denomina comúnmente:

A) Puente

B) Centro activo

C) Servidor

✓ **D) Apoderado**

43. ¿Cuál de las respuestas enumeradas a continuación se refiere a un estándar IEEE que se puede implementar en una situación en la que un conmutador Ethernet actúa como autenticador para dispositivos que pretenden conectarse a una red a través de uno de sus puertos?

A) IEEE 802.1X

B) IEEE 802.11ac
C) IEEE 802.1D
D) IEEE 802.11x

44. ¿Cuál de las respuestas que se enumeran a continuación se refieren a un firewall de capa 7? (Seleccione 3 respuestas)

A) Ofrece filtrado de tráfico complejo (más lento)
B) Filtra el tráfico según las direcciones IP de origen/destino, los puertos y los tipos de protocolo (por ejemplo, TCP/UDP)
C) Opera en la capa de transporte del modelo OSI.
✓ D) Agrega la capacidad de inspeccionar el contenido de los paquetes de datos además de la información del encabezado.
E) Ofrece filtrado de tráfico básico (más rápido)
✓ F) Opera en la capa de aplicación del modelo OSI.

45. ¿Cuál de los siguientes términos se utiliza para describir un tipo de VPN que alivia los cuellos de botella y conserva el ancho de banda al permitir la utilización tanto de la VPN como de los enlaces de la red pública?

A) Túnel dividido
B) Sin cliente
C) Túnel completo
D) Acceso remoto

46. ¿Qué tipo de VPN permite la conectividad entre dos redes?

A) Sitio a sitio
B) Host a red
C) Acceso remoto
D) Cliente a sitio
Respuesta no detectada automaticamente

47. ¿Cuál de las respuestas enumeradas a continuación se refiere a una solución de hardware o software que proporciona acceso remoto seguro a redes y recursos?

A) NAC
B) PDR
C) SSH
✓ D) RAS

48. ¿Cuál de las respuestas enumeradas a continuación se refiere al software que facilita la aplicación de políticas y procedimientos de dispositivos móviles?

A) NAC
B) DM
C) XDR
D) PAM

49. ¿Cuáles son las características del modo empresarial WPA2/WPA3? (Seleccione 3 respuestas)

A) Adecuado para grandes redes corporativas
B) IEEE 802.1D
C) No requiere un servidor de autenticación
✓ D) IEEE 802.1X
E) Adecuado para todo tipo de LAN inalámbricas
✓ F) Requiere servidor de autenticación RADIUS

50. ¿Cuál de las siguientes respuestas se refiere a un protocolo de autenticación inalámbrica obsoleto desarrollado por Cisco?

A) PEAP
B) EAP-TTLS
✓ C) SALTO
D) EAP-TLS

51. Un tipo de mecanismo de identificación de usuarios utilizado como contramedida contra el software automatizado (como los robots de red) se conoce como:

A) Ministerio de Asuntos Exteriores

✓ B) CAPTCHA

C) SSO

D) NIDS

---

52. Un mecanismo de transporte dedicado para información sobre amenazas cibernéticas se denomina:

A) TCP/IP

B) TLS

✓ C) TAXII

D) S/MIME

---

53. Las reglas del firewall se evalúan según su orden de prioridad. Las reglas que se encuentran en la parte superior de la lista tienen prioridad sobre las reglas que se encuentran más abajo en la lista. Una vez que se encuentra una regla coincidente, no se realiza ninguna evaluación adicional de las reglas posteriores. La política de "denegación implícita" en un firewall es un comportamiento predeterminado común en el que cualquier tráfico que no coincida explícitamente con ninguna de las reglas de permiso configuradas se deniega o bloquea automáticamente. En otras palabras, si un paquete no cumple con los criterios de ninguna regla de permiso, el comportamiento predeterminado del firewall es denegar el tráfico.

A) Verdadero

B) FALSO

---

54. ¿Cuál de las respuestas enumeradas a continuación se refiere a técnicas de filtrado que pueden permitir o bloquear el acceso a un sitio en función de su dirección web? (Seleccione 2 respuestas)

A) Inspección SSL/TLS

✓ B) escaneo de URL

C) Categorización de contenido

✓ D) filtrado DNS

E) Filtrado basado en reputación

---

55. ¿Cuál de los protocolos enumerados a continuación permite la recuperación segura de correos electrónicos desde un servidor de correo a un cliente de correo electrónico? (Seleccione 2 respuestas)

A) FTPS

✓ B) IMÁGENES

✓ C) pop3s

D) INICIO

E) SMTP

---

56. ¿Cuál de las siguientes respuestas se refiere a una solución que ayuda a las organizaciones a mitigar los riesgos asociados con filtraciones de datos, amenazas internas e infracciones de cumplimiento?

A) EDR

B) DLP

C) SOY

D) UTM

---

57. Un tipo de mecanismo de identificación de usuarios utilizado como contramedida contra el software automatizado (como los robots de red) se conoce como:

A) Ministerio de Asuntos Exteriores

✓ B) CAPTCHA

C) LCA

D) PNI

---

58. ¿Cuál es el nombre de un protocolo de red que protege el tráfico web mediante cifrado SSL/TLS?

A) SFTP

✓ B) HTTPS

C) FTPS

D) SHTTP

59. Un subsistema de autenticación que permite a un usuario acceder a múltiples componentes del sistema conectados (como hosts separados en una red) después de un único inicio de sesión en solo uno de los componentes se denomina:

A) NAC

✓ B) SSO

C) aaa

D) Ministerio de Asuntos Exteriores

60. ¿Cuál de las siguientes respuestas se refiere a un método de autenticación secreto compartido utilizado en WPA, WPA2 y EAP?

A) PSK

B) 802.1X

C) SAE

D) TKIP

Respuesta no detectada automaticamente

61. ¿Cuál de las siguientes respuestas se refiere a una solución de hardware o software que proporciona acceso remoto seguro a redes y recursos?

A) NAC

B) PDR

C) SSH

D) RAS

62. ¿Cuál de las respuestas enumeradas a continuación se refiere a un protocolo de autenticación inalámbrica obsoleto desarrollado por Cisco?

A) PEAP

B) EAP-TTLS

C) SALTO

D) EAP-TLS

63. ¿Cuál de las respuestas que se enumeran a continuación se refieren a los rasgos característicos del NIDS? (Seleccione 3 respuestas)

A) Toma medidas proactivas para bloquear o mitigar los intentos de intrusión.

✓ B) No toma medidas directas para bloquear o prevenir ataques.

✓ C) Genera alertas y notifica al personal de seguridad o a los administradores cuando se detecta actividad sospechosa.

✓ D) Supervisa el tráfico de la red sin participación directa en el enrutamiento del tráfico o la modificación de paquetes.

E) Puede descartar o rechazar paquetes de red, finalizar conexiones o tomar otras acciones para detener el ataque.

F) Opera en modo en línea, interceptando e inspeccionando activamente el tráfico de la red.

64. ¿Cuál de las siguientes respuestas se refiere a un marco de ciberseguridad que combina funciones de red y seguridad en un único servicio basado en la nube?

A) SASE

B) SIEM

C) SWG

D) REMONTARSE

65. ¿Cuál de las respuestas enumeradas a continuación se refiere a un método obsoleto basado en TLS para proteger SMTP?

A) desplazados internos

B) INICIO

C) DKIM

D) SMTP

66. ¿Cuál de las siguientes tecnologías permite el manejo automatizado de múltiples incidentes de seguridad?

A) JABÓN
B) SIEM
✓ **C) REMONTARSE**
D) SASE

67. ¿Cuál de las respuestas enumeradas a continuación se refiere a un protocolo de tunelización comúnmente utilizado en la creación de VPN?

A) VRRP
✓ **B) GRE**
C) RTSP
D) BGP

68. ¿Cuál de las respuestas enumeradas a continuación se refiere(s) a los controles de seguridad de detectives? (Seleccione todo lo que corresponda)

A) Iluminación
✓ **B) Monitoreo de registros**
C) Zona de arena
✓ **D) Auditorías de seguridad**
✓ **E) circuito cerrado de televisión**
✓ **F) identificación**
✓ **G) Escaneo de vulnerabilidades**

69. ¿Cuál es el nombre de un protocolo de red que protege el tráfico web mediante cifrado SSL/TLS?

✓ **A) SFTP**
✓ **B) HTTPS**
C) FTPS
D) SHTTP

70. SFTP es una extensión del protocolo FTP que agrega soporte para cifrado SSL/TLS.

A) Verdadero
✓ **B) FALSO**

71. ¿Cuál de las siguientes opciones indicaría un intento de ocultar evidencia de actividad maliciosa?

A) Bloqueo de cuenta
B) Inaccesibilidad de recursos
✓ **C) Registros faltantes**
D) Uso simultáneo de sesiones

72. ¿Cuáles son las características del modo empresarial WPA2/WPA3? (Seleccione 3 respuestas)

A) Adecuado para grandes redes corporativas
B) IEEE 802.1D
C) No requiere un servidor de autenticación
✓ **D) IEEE 802.1X**
E) Adecuado para todo tipo de LAN inalámbricas
✓ **F) Requiere servidor de autenticación RADIUS**

73. ¿Cuál de las respuestas enumeradas a continuación se refiere a un protocolo de autenticación de red inalámbrica estándar abierto que mejora la seguridad al encapsular el proceso de autenticación dentro de un túnel TLS cifrado?

A) PEAP
B) PAE
C) SALTO
D) RADIO
Respuesta no detectada automaticamente

74. Un tipo de mecanismo de identificación de usuarios utilizado como contramedida contra el software automatizado (como los robots de red) se conoce como:

A) Ministerio de Asuntos Exteriores

✓ **B) CAPTCHA**

C) SSO

D) NIDS

75. Un mecanismo de transporte dedicado para información sobre amenazas cibernéticas se denomina:

A) TCP/IP

B) TLS

✓ **C) TAXII**

D) S/MIME

3.3 - Comparar y contrastar los conceptos e implicaciones de proteccion de datos.

Conceptos clave:

- Tipos: PII, PHI, Datos financieros, Propiedad intelectual, Datos regulados
- Clasificacion: Restringido, Confidencial, Interno, Publico
- Estados: En reposo, En transito, En uso
- Proteccion: Cifrado, Tokenizacion, Enmascaramiento, Anonimizacion, DLP

Teoria detallada:

TIPOS DE DATOS (por sensibilidad):

- PII (Informacion de Identificacion Personal): cualquier dato que identifica a una persona (nombre, DNI, email)
- PHI (Informacion de Salud Protegida): informacion medica de una persona (protegida por HIPAA)
- Datos financieros: datos bancarios, tarjetas de credito (protegidos por PCI DSS)
- Propiedad intelectual: patentes, codigo fuente, secretos comerciales
- Datos regulados: cualquier dato sujeto a regulacion legal

CLASIFICACION DE DATOS (de mas a menos sensible):

- Restringido/Alto Secreto: maxima sensibilidad, acceso muy limitado
- Confidencial/Secreto: datos sensibles de negocio
- Interno/Privado: solo para uso interno
- Publico: puede compartirse libremente

ESTADOS DE LOS DATOS:

- En reposo (Data at rest): datos almacenados en disco/BD. Proteger con: cifrado de disco (BitLocker, FileVault)
- En transito (Data in transit): datos moviendose por la red. Proteger con: TLS, VPN, IPSec
- En uso (Data in use): datos en memoria RAM siendo procesados. El mas dificil de proteger. Tecnica: Secure Enclave

METODOS DE PROTECCION DE DATOS:

- Cifrado: cifrar datos para que sean ilegibles sin la clave
- Tokenizacion: sustituir el dato real por un token (sin valor matematico). Usado en pagos
- Enmascaramiento de datos: ocultar parte del dato (mostrar solo ****1234 de una tarjeta)
- Anonimizacion: eliminar toda informacion identificativa de forma irreversible
- Seudonimizacion: sustituir identificadores por seudonimos (reversible con la clave)
- DLP (Prevencion de Perdida de Datos): herramienta que detecta y bloquea fuga de datos
- Restricciones geograficas / Soberania de datos: los datos deben almacenarse en un pais especifico por ley

Preguntas de practica (81):

1. Reemplazar caracteres de contraseña en un campo de contraseña con una serie de asteriscos es un ejemplo de:

A) Enmascaramiento de datos

B) Tokenización

C) Anonimización

D) Pseudoanonimización

Respuesta no detectada automaticamente

2. ¿Cuál de los siguientes estados de datos normalmente requiere que los datos se procesen sin cifrar?

A) Datos en movimiento

B) Datos en reposo

C) Datos en tránsito

✓ **D) Datos en uso**

3. ¿Cuál de las respuestas enumeradas a continuación se refiere a algún tipo de información perteneciente a un individuo que pueda usarse para identificar de manera única a esa persona?

A) FI

B) Biometría

C) IDENTIFICACIÓN

✓ **D) PII**

4. La Ley de Responsabilidad y Portabilidad del Seguro Médico de EE. UU. (HIPAA) brinda protección de la privacidad para:

A) PII

B) PI

✓ **C) FI**

D) PIV

5. ¿Qué técnica criptográfica se utiliza para evitar la eficacia de las tablas arcoíris a la hora de descifrar contraseñas hash?

A) Enmascaramiento de datos

B) Autenticación de dos factores (2FA)

C) Estiramiento clave

✓ **D) Salazón**

6. La especificación MIME extiende el formato de los mensajes de correo electrónico más allá del texto plano, permitiendo la transferencia de archivos de gráficos, audio y vídeo a través del sistema de correo de Internet. S/MIME es una versión mejorada del protocolo MIME que habilita funciones de seguridad del correo electrónico al proporcionar cifrado, autenticación, integridad de mensajes y otros servicios relacionados.

A) Verdadero

B) FALSO

7. ¿Cuál de las siguientes respuestas se refiere a protocolos de cifrado y funciones hash criptográficas obsoletas o inseguras? (Seleccione todo lo que corresponda)

A) DES

B) AES-256

✓ **C) MD5**

D) ECC

✓ **E) SHA-1**

✓ **F) SSL**

✓ **G) RC4**

8. El término "KEK" se refiere a un tipo de clave criptográfica que se utiliza a menudo en sistemas de administración de claves para agregar una capa adicional de seguridad al cifrar y descifrar otras claves criptográficas.

A) Verdadero

B) FALSO

Respuesta no detectada automaticamente

9. ¿Cuál de las siguientes respuestas se refiere a un protocolo utilizado para configurar conexiones seguras e intercambiar claves criptográficas en VPN IPsec?

A) SSL

B) IKE

C) ESP

D) DHE

10. ¿Cuál de los algoritmos criptográficos enumerados a continuación es el menos vulnerable a los ataques?

A) AES

B) DES

C) RC4
D) 3DES
Respuesta no detectada automaticamente

11. En criptografía, la cantidad de bits de una clave utilizada por un algoritmo criptográfico se denomina tamaño de clave o longitud de clave. La longitud de la clave determina el número máximo de combinaciones necesarias para romper el algoritmo de cifrado; por lo tanto, normalmente una clave más larga significa una seguridad criptográfica más sólida.

A) Verdadero
B) FALSO

12. ¿Cuál de las siguientes respuestas se refiere a un servidor centralizado que se utiliza para distribuir claves criptográficas y autenticar usuarios y servicios dentro de una red informática?

A) PKI
B) RAS
✓ C) KDC
D) NAS

13. En criptografía y seguridad, el término "enclave seguro" generalmente se refiere a un entorno de hardware o software protegido y aislado dentro de un dispositivo informático, como un teléfono inteligente, una tableta o una computadora, donde los datos confidenciales y las operaciones criptográficas se pueden almacenar y procesar de forma segura.

A) Verdadero
B) FALSO
Respuesta no detectada automaticamente

14. ¿Cuál de las siguientes respuestas se refiere a una familia de funciones hash criptográficas diseñadas para diversas aplicaciones relacionadas con la seguridad, incluidas firmas digitales, almacenamiento de contraseñas, comunicaciones seguras y verificación de la integridad de los datos?

A) RSA
B) AES
C) PKCS
✓ D) sha

15. ¿Cuál de los siguientes combina una función hash criptográfica con una clave secreta para proporcionar un medio para verificar tanto la autenticidad como la integridad de un mensaje o datos?

A) MD5
B) DSA
✓ C) HMAC
D) DES

16. ¿Cuál de las respuestas enumeradas a continuación se refiere a una función hash no criptográfica que se utiliza a menudo con fines de verificación de errores?

A) MD5
B) CDN
C) sha
D) RIPEMD

17. ¿Cuál de las respuestas enumeradas a continuación se refiere a un conjunto de estándares y especificaciones que definen diversas técnicas criptográficas, incluidos formatos para claves públicas, claves privadas, firmas digitales y certificados digitales?

A) ITIL
B) RFC
C) PKCS
D) ISO/CEI

18. Asigne el atributo de nivel de sofisticación a cada tipo de actor de amenazas que se enumera a continuación.

Respuesta no detectada automaticamente

19. ¿Cuál de los siguientes términos se utiliza para describir ciberataques sofisticados y prolongados, a menudo llevados a cabo por grupos organizados y bien financiados, como los Estados-nación?

A) MitM

✓ B) APTO

C) XSRF

D) DDoS

20. ¿Cuál de las respuestas enumeradas a continuación se refiere a un vector de amenaza basado en correo electrónico?

A) suplantación de identidad

B) Phishing

C) Ataques BEC

D) Enlaces maliciosos

E) Archivos adjuntos de malware

✓ F) Todo lo anterior

21. ¿Cuál de las respuestas enumeradas a continuación se refiere a un ejemplo de un vector de amenaza potencial en la comunicación basada en mensajería instantánea?

A) Ataque de phishing

B) Distribución de malware

C) Ataque de suplantación de identidad

D) Escuchar a escondidas

E) Secuestro de cuenta

F) Enlace/adjunto malicioso

✓ G) Todo lo anterior

22. ¿Cuál de las siguientes respuestas se refiere a vectores de amenazas de software sin agentes? (Seleccione 2 respuestas)

A) Correo electrónico de phishing

B) Unidad USB maliciosa

✓ C) Vulnerabilidad del protocolo de red

D) Macro infectada

✓ E) rastreo de paquetes

23. ¿Qué ataque de ingeniería social se basa en el robo de identidad?

A) Pretexto

B) Phishing de lanza

C) Seguir de cerca

✓ D) Interpretación

24. El término "secuestro de URL" (también conocido como "Typosquatting") se refiere a una práctica engañosa que implica el registro deliberado de nombres de dominio con errores ortográficos o ligeras variaciones que se parecen mucho a nombres de dominio populares y bien establecidos. El objetivo principal de esta estrategia es explotar los errores tipográficos comunes que cometen los usuarios al ingresar URL en la barra de direcciones de su navegador web. Más allá de capturar tráfico inadvertido, la typosquatting también se puede utilizar para alojar sitios de phishing para engañar a los usuarios para que divulguen información confidencial, distribuir malware a través de sitios web engañosos, generar ingresos publicitarios al redirigir el tráfico mal escrito o participar en la suplantación de marcas para dañar la reputación de marcas auténticas o engañar a los usuarios.

A) Verdadero

B) FALSO

25. La práctica de obtener acceso no autorizado a un dispositivo Bluetooth se conoce como:

A) Phishing

B) bluejacking

C) aplastando

✓ **D) Bluesnarfing**

26. Un ataque de interferencia inalámbrica es un tipo de:

A) Ataque criptográfico

✓ **B) Ataque DoS**

C) Ataque de fuerza bruta

D) Ataque de degradación

27. Se produce una colisión de hash cuando la función hash criptográfica produce dos resúmenes diferentes para la misma entrada de datos.

A) Verdadero

✓ **B) FALSO**

28. ¿Cuál de las respuestas enumeradas a continuación se refiere al concepto de aislamiento de datos? (Seleccione 2 respuestas)

A) DLP

B) SDN

✓ **C) EFS**

D) SWG

E) EDR

29. ¿Cuál de las respuestas enumeradas a continuación se refiere a un protocolo utilizado para configurar conexiones seguras e intercambiar claves criptográficas en VPN IPsec?

A) SSL

✓ **B) IKE**

C) ESP

D) DHE

30. ¿Cuál de las siguientes regula la privacidad de los datos personales de los ciudadanos de la UE?

✓ **A) FI**

B) HIPAA

C) PCI DSS

✓ **D) RGPD**

31. Los métodos de cifrado utilizados para proteger los datos en tránsito incluyen: (Seleccione todos los que correspondan)

A) NFS

✓ **B) vpn**

C) SED

✓ **D) IPSec**

E) FDE

✓ **F) TLS**

32. ¿Cuál de las respuestas enumeradas a continuación se refiere a una técnica que permite convertir datos de entrada en una cadena de tamaño fijo, lo que dificulta revertir o recuperar los datos originales?

✓ **A) Ofuscación**

✓ **B) Tokenización**

C) hash

D) Cifrado

33. ¿Cuál de las respuestas enumeradas a continuación se refiere a las ventajas de la segmentación como método para proteger los datos? (Seleccione 3 respuestas)

A) Mejora la seguridad al limitar la propagación de ciberataques

✓ **B) Ayuda a las organizaciones a cumplir con los requisitos normativos de datos aislando y protegiendo tipos de datos específicos**

C) Proporciona seguridad para los datos en tránsito con el uso de cifrado.

D) Garantiza la recuperación de datos en caso de eliminación accidental o fallas del sistema.

✓ **E) Proporciona un mejor control sobre el acceso de los usuarios a datos confidenciales.**

34. ¿Cuál de las respuestas enumeradas a continuación se refiere a la función principal del equilibrio de carga?

A) Mantiene copias idénticas de datos en múltiples servidores para mejorar la disponibilidad y confiabilidad de los datos.

✓ **B) Distribuye la carga de trabajo entre múltiples servidores para mejorar el rendimiento.**

✓ **C) Agrupa servidores para proporcionar alta disponibilidad y tolerancia a fallos.**

D) Distribuye contenido geográficamente entre múltiples servidores para mejorar el rendimiento, reducir la latencia y manejar grandes volúmenes de tráfico.

35. ¿Cuál de los siguientes métodos proporciona la forma más eficaz de eliminar permanentemente los datos almacenados en una unidad magnética?

A) Borrado criptográfico

B) Sobrescritura de datos

✓ **C) Desmagnetización**

D) Formateo de bajo nivel

36. ¿Qué política suele especificar el período durante el cual ciertos tipos de datos deben almacenarse antes de su eliminación?

A) Política de protección de datos

B) Política de clasificación de datos

C) Política de copia de seguridad de datos

✓ **D) Política de retención de datos**

37. ¿Cuál de las siguientes siglas se refiere a soluciones de seguridad basadas en software o hardware diseñadas para detectar y prevenir el uso y la transmisión no autorizados de información confidencial?

A) IPS

✓ **B) DLP**

C) identificación

D) DEP

38. ¿Cuál de las respuestas enumeradas a continuación se refiere a un estándar criptográfico (y un formato de archivo) utilizado para el almacenamiento y transmisión de claves privadas en comunicaciones por correo electrónico?

A) PEM

B) DMARC

C) FPS

D) DKIM

39. ¿Cuál de las respuestas enumeradas a continuación se refiere al proceso de mantener la integridad de archivos y datos?

A) DLP

B) SIEM

C) FIM

D) sha

40. ¿Cuál de las siguientes respuestas se refiere a una solución que ayuda a las organizaciones a mitigar los riesgos asociados con filtraciones de datos, amenazas internas e infracciones de cumplimiento?

A) EDR

B) DLP

C) SOY

D) UTM

41. ¿Cuál de los términos enumerados a continuación se refiere a un principio legal que permite a las personas solicitar la eliminación de información personal de búsquedas en Internet y otras fuentes públicas?

A) Desidentificación

✓ **B) Derecho a ser olvidado**

C) Anonimización

D) Gestión del consentimiento

42. En la comunicación por correo electrónico, ¿qué señales pueden ayudar a reconocer un intento de phishing?

A) El mensaje contiene mala ortografía y gramática.
B) El mensaje pide información personal.
C) El mensaje incluye un llamado a la acción con sentido de urgencia.
D) El mensaje incluye enlaces o archivos adjuntos sospechosos.
✓ E) Cualquiera de los anteriores

43. Un tipo de protocolo de red criptográfico para comunicación segura de datos, inicio de sesión remoto en la línea de comandos, ejecución remota de comandos y otros servicios de red seguros entre dos computadoras en red se conoce como:

A) PDR
✓ B) SSH
C) Telnet
D) SCP

44. ¿Cuál de las siguientes siglas se refiere a soluciones de seguridad basadas en software o hardware diseñadas para detectar y prevenir el uso y la transmisión no autorizados de información confidencial?

A) IPS
✓ B) DLP
C) identificación
D) DEP

45. Un tipo de red que conecta computadoras dentro de un área geográfica pequeña, como un edificio o grupo de edificios, se denomina:

A) CACEROLA
✓ B) LAN
C) HOMBRE
D) PÁLIDO

46. ¿Cuál de las siguientes respuestas se refiere a una familia de funciones hash criptográficas utilizadas en una variedad de aplicaciones de seguridad, incluidas firmas digitales, almacenamiento de contraseñas, comunicaciones seguras y verificación de la integridad de los datos?

A) RSA
B) IDEA
C) AES
✓ D) sha

47. ¿Cuál de los siguientes términos se utiliza para describir ciberataques sofisticados y prolongados, a menudo llevados a cabo por grupos organizados y bien financiados, como los Estados-nación?

A) MitM
✓ B) APTO
C) XSRF
D) DDoS

48. ¿Cuál de las siguientes respuestas se refiere a un archivo criptográfico generado por una entidad que solicita un certificado digital a una CA?

A) OID
✓ B) RSE
C) DN
D) CRL

49. ¿Cuál de las siguientes respuestas se refiere a un protocolo utilizado para configurar conexiones seguras e intercambiar claves criptográficas en VPN IPsec?

A) SSL
✓ B) IKE

C) ESP
D) DHE

50. ¿Cuál de las siglas enumeradas a continuación se refiere a una herramienta de software criptográfico para la comunicación segura por correo electrónico y la protección de datos?

A) DES
B) PEM
C) EFS
✓ **D) PGP**

51. ¿Cuál de los acrónimos enumerados a continuación se refiere a una pieza de hardware y software/firmware asociado diseñado para proporcionar funciones criptográficas y de administración de claves?

A) EFS
✓ **B) HSM**
C) SFC
D) TPM

52. ¿Cuál de las respuestas enumeradas a continuación se refiere a un método criptográfico utilizado para verificar que un mensaje o dato ha permanecido inalterado durante la transmisión y proviene de una fuente autorizada?

A) IMPERMEABLE
B) CBC
C) PEM
D) GCM

53. En los sistemas operativos modernos, esta característica evita que se ejecute código malicioso en ciertas regiones de la memoria destinadas a los datos.

A) DEP
B) BCE
C) DLP
D) CDN
Respuesta no detectada automaticamente

54. La especificación MIME amplía el formato de los mensajes de correo electrónico más allá del simple texto, permitiendo la transferencia de archivos de gráficos, audio y vídeo a través del sistema de correo de Internet. S/MIME es una versión mejorada del protocolo MIME que habilita funciones de seguridad del correo electrónico al proporcionar cifrado, autenticación, integridad de mensajes y otros servicios relacionados.

A) Verdadero
B) FALSO

55. ¿Cuál de las siguientes respuestas se refiere a una función hash no criptográfica que se utiliza a menudo con fines de comprobación de errores?

A) MD5
B) CDN
C) sha
D) RIPEMD

56. ¿Cuál de las respuestas enumeradas a continuación se refiere a un conjunto de estándares y especificaciones que definen diversas técnicas criptográficas, incluidos formatos para claves públicas, claves privadas, firmas digitales y certificados digitales?

A) ITIL
B) RFC
C) PKCS
D) ISO/CEI

57. ¿Cuál de las respuestas enumeradas a continuación se refiere al proceso de mantener la integridad de archivos y datos?

A) DLP
B) SIEM
C) FIM
D) sha

58. ¿Cuál de las respuestas enumeradas a continuación se refiere a un método de codificación (y un formato de archivo) para almacenar objetos criptográficos como certificados X.509, CRL y claves privadas?

A) BCE
✓ B) PEM
C) FIM
D) PFS

59. ¿Cuál de los siguientes combina una función hash criptográfica con una clave secreta para proporcionar un medio para verificar tanto la autenticidad como la integridad de un mensaje o datos?

A) MD5
B) DSA
✓ C) HMAC
D) DES

60. ¿Qué protocolo criptográfico está diseñado para proporcionar comunicaciones seguras a través de una red informática y es el sucesor de SSL?

A) IPSec
✓ B) TLS
C) AES
D) CCMP

61. ¿Cuál de las respuestas enumeradas a continuación se refiere a un protocolo utilizado para configurar conexiones seguras e intercambiar claves criptográficas en VPN IPsec?

A) SSL
✓ B) IKE
C) ESP
D) DHE

62. ¿Cuál de las siguientes respuestas se refiere a un protocolo de intercambio de claves criptográficas que aprovecha ECC para mejorar la seguridad y la eficiencia?

A) S/MIME
B) ECDHE
C) DHE
D) ECDSA

63. ¿Cuál de las respuestas enumeradas a continuación se refiere a una función hash criptográfica que se ha utilizado ampliamente en el pasado pero que ahora se considera obsoleta para aplicaciones sensibles a la seguridad debido a vulnerabilidades conocidas?

A) MD5
B) sha
C) CDN
D) HMAC
Respuesta no detectada automaticamente

64. ¿Cuál de las respuestas enumeradas a continuación se refiere a una función hash no criptográfica que se utiliza a menudo con fines de verificación de errores?

A) MD5
✓ B) CDN
C) sha
D) RIPEMD

65. ¿Cuál de las respuestas enumeradas a continuación se refiere a una técnica criptográfica que verifica la autenticidad e integridad de documentos o mensajes digitales mediante el uso de un identificador cifrado

único del remitente?

A) Firma digital
B) Función hash criptográfica
C) Certificado digital
D) Cifrado asimétrico

---

66. Asigne el atributo de nivel de sofisticación a cada tipo de actor de amenazas que se enumera a continuación.

Respuesta no detectada automaticamente

---

67. ¿Cuál de los siguientes términos se utiliza para describir ciberataques sofisticados y prolongados, a menudo llevados a cabo por grupos organizados y bien financiados, como los Estados-nación?

A) MitM
✓ **B) APTO**
C) XSRF
D) DDoS

---

68. Una superficie de ataque es la suma de todos los puntos potenciales (vulnerabilidades) a través de los cuales un atacante puede interactuar o comprometer un sistema o red, lo que indica la exposición general a amenazas potenciales. Ejemplos de superficies de ataque pueden ser todo software, hardware e interfaces de red con fallas de seguridad conocidas. Un vector de amenaza representa el método o medio a través del cual se introduce o entrega una amenaza cibernética a un sistema objetivo. Describe la vía o vía utilizada por los atacantes para explotar las vulnerabilidades. Los tipos de vectores de amenazas comunes incluyen correos electrónicos de phishing, malware, descargas no autorizadas y técnicas de ingeniería social.

A) Verdadero
B) FALSO

Respuesta no detectada automaticamente

---

69. ¿Cuál de las respuestas enumeradas a continuación se refiere a un vector de amenaza basado en correo electrónico?

A) suplantación de identidad
B) Phishing
C) Ataques BEC
D) Enlaces maliciosos
E) Archivos adjuntos de malware
✓ **F) Todo lo anterior**

---

70. ¿Cuál de las respuestas enumeradas a continuación se refiere a un ejemplo de un vector de amenaza potencial en la comunicación basada en mensajería instantánea?

A) Ataque de phishing
B) Distribución de malware
C) Ataque de suplantación de identidad
D) Escuchar a escondidas
E) Secuestro de cuenta
F) Enlace/adjunto malicioso
✓ **G) Todo lo anterior**

---

71. Una técnica de ingeniería social mediante la cual los atacantes, disfrazados de una solicitud legítima, intentan obtener acceso a información confidencial se denomina comúnmente:

A) Phishing
B) aplastando
C) Farmacéutica
D) suplantación de identidad

---

72. Un ataque BEC es un ejemplo de:

A) aplastando
✓ **B) Phishing**

C) vishing
D) Farmacéutica

73. El término "Typosquatting" se refiere a una práctica engañosa que implica el registro deliberado de nombres de dominio con errores ortográficos o ligeras variaciones que se parecen mucho a nombres de dominio populares y bien establecidos. El objetivo principal de esta estrategia es explotar los errores tipográficos comunes que cometen los usuarios al ingresar URL en la barra de direcciones de su navegador web. Más allá de capturar tráfico inadvertido, la typosquatting también se puede utilizar para alojar sitios de phishing para engañar a los usuarios para que divulguen información confidencial, distribuir malware a través de sitios web engañosos, generar ingresos publicitarios al redirigir el tráfico mal escrito o participar en la suplantación de marcas para dañar la reputación de marcas auténticas o engañar a los usuarios.

A) Verdadero
B) FALSO
Respuesta no detectada automaticamente

74. ¿Cuál sería una respuesta apropiada del usuario ante un intento de phishing por correo electrónico? (Seleccione todo lo que corresponda)

A) No responder al mensaje ni proporcionar ningún dato personal.
✓ B) Reportar el mensaje al departamento de TI o seguridad, si corresponde
✓ C) Eliminar el mensaje de la bandeja de entrada
✓ D) No hacer clic en ningún enlace ni descargar ningún archivo adjunto en el mensaje
E) Reenviar el mensaje al remitente para verificar su legitimidad
F) Abrir el archivo adjunto en un entorno sandbox para comprobar su seguridad

75. Un ataque de disociación inalámbrica es un tipo de: (Seleccione 2 respuestas)

A) Ataque de degradación
✓ B) Ataque de desautenticación
C) Ataque de fuerza bruta
✓ D) Ataque DoS
E) Ataque criptográfico

76. Una situación en la que un atacante intercepta y retransmite un intercambio de datos válido entre una aplicación y un servidor u otra aplicación se conoce como:

A) Carga lateral
✓ B) Repetir ataque
C) Ataque de phishing
D) Condición de carrera

77. ¿Cuál de las respuestas enumeradas a continuación se refiere a los métodos de cifrado utilizados para proteger los datos en reposo? (Seleccione todo lo que corresponda)

A) FDE
✓ B) SED
C) IPSec
D) TLS
✓ E) vpn
✓ F) EFS

78. ¿Cuál de las respuestas enumeradas a continuación se refiere a una técnica que permite convertir datos de entrada en una cadena de tamaño fijo, lo que dificulta revertir o recuperar los datos originales?

A) Ofuscación
B) Tokenización
✓ C) hash
D) Cifrado

79. ¿Cuál de las respuestas enumeradas a continuación se refiere a una situación en la que los datos confidenciales se almacenan en una ubicación separada y se pueden recuperar con un reemplazo no confidencial que también se puede procesar como los datos originales sin el riesgo de revelar el contenido

de los datos originales?

A) enmascaramiento

✓ **B) Ofuscación**

C) Cifrado

✓ **D) Tokenización**

---

80. ¿Cuál de las respuestas enumeradas a continuación se refiere a las ventajas de la segmentación como método para proteger los datos? (Seleccione 3 respuestas)

A) Mejora la seguridad al limitar la propagación de ciberataques

✓ **B) Ayuda a las organizaciones a cumplir con los requisitos normativos de datos aislando y protegiendo tipos de datos específicos**

C) Proporciona seguridad para los datos en tránsito con el uso de cifrado.

D) Garantiza la recuperación de datos en caso de eliminación accidental o fallas del sistema.

✓ **E) Proporciona un mejor control sobre el acceso de los usuarios a datos confidenciales.**

---

81. ¿Cuál de las respuestas enumeradas a continuación se refiere a la función principal del equilibrio de carga?

A) Mantiene copias idénticas de datos en múltiples servidores para mejorar la disponibilidad y confiabilidad de los datos.

✓ **B) Distribuye la carga de trabajo entre múltiples servidores para mejorar el rendimiento.**

✓ **C) Agrupa servidores para proporcionar alta disponibilidad y tolerancia a fallos.**

D) Distribuye contenido geográficamente entre múltiples servidores para mejorar el rendimiento, reducir la latencia y manejar grandes volúmenes de tráfico.

3.4 - Explicar la importancia de la resiliencia y la recuperacion en la arquitectura de seguridad.

Conceptos clave:

- Alta disponibilidad: Balanceo de carga, Clustering, Redundancia
- Sitios: Hot site, Warm site, Cold site
- Metricas: RTO, RPO, MTTR, MTBF
- Backups: Completo, Incremental, Diferencial. Regla 3-2-1

Teoria detallada:

ALTA DISPONIBILIDAD:

- Balanceo de carga: distribuir trafico entre multiples servidores. Si uno cae, los otros asumen la carga
- Clustering: multiples servidores trabajan como uno. Activo-activo vs Activo-pasivo
- Redundancia: duplicar componentes criticos (fuentes de alimentacion, discos, conexiones de red)

TIPOS DE SITIOS DE RECUPERACION:

- Hot site: replica exacta del datacenter principal, siempre operativa. Recuperacion en minutos. MAS CARO
- Warm site: infraestructura preparada pero sin datos actualizados. Recuperacion en horas
- Cold site: solo espacio fisico y electricidad. Hay que traer equipos e instalar todo. Recuperacion en dias. MAS BARATO
- Dispersion geografica: sitios en ubicaciones fisicamente separadas para proteger de desastres naturales

METRICAS CRITICAS:

- RTO (Objetivo de Tiempo de Recuperacion): tiempo maximo aceptable para restaurar el servicio tras un fallo
- RPO (Objetivo de Punto de Recuperacion): cantidad maxima de datos que se puede permitir perder (en tiempo)
- MTTR (Tiempo Medio de Reparacion): tiempo medio que tarda en repararse un sistema
- MTBF (Tiempo Medio Entre Fallos): tiempo medio entre fallos de un sistema

Regla: RTO y RPO los define el negocio, no IT. Cuanto menores, mas cara la solucion.

COPIAS DE SEGURIDAD:

- Completa (Full): copia completa de todos los datos. Lento de hacer, rapido de restaurar
- Incremental: solo los cambios desde el ultimo backup. Rapido de hacer, lento de restaurar
- Diferencial: cambios desde el ultimo backup COMPLETO. Termino medio
- En sitio vs Fuera de sitio: backups locales (rapidos) vs remotos (protegen de desastres fisicos)
- Instantanea (Snapshot): copia del estado de una VM en un momento dado
- Replicacion: copia continua de datos a un sitio remoto (menor RPO)
- Regla 3-2-1: 3 copias, en 2 medios distintos, 1 fuera del sitio

PRUEBAS DE CONTINUIDAD:

- Ejercicio de mesa (Tabletop): simulacro en sala de juntas, sin afectar sistemas reales. El mas comun
- Prueba de failover: se provoca el fallo real para verificar que el sistema secundario toma el control
- Simulacion: simular un incidente especifico (ransomware, incendio) para probar la respuesta
- Procesamiento paralelo: ejecutar el sistema de recuperacion en paralelo al principal para validarlo

Preguntas de practica (42):

1. ¿Cuál de los términos enumerados a continuación se refiere a un duplicado del sitio original, con sistemas informáticos en pleno funcionamiento y copias de seguridad casi completas de los datos del usuario?

A) sitio caliente
B) Sitio cálido
C) Sitio frio
D) sitio móvil

Respuesta no detectada automaticamente

2. ¿Cuál de las siguientes define la cantidad máxima aceptable de pérdida de datos medida en un momento específico antes de un desastre o interrupción?

A) RPO
B) MTBF
C) RTO
✓ D) MTTR

3. ¿Cuál de los términos enumerados a continuación se refiere a un duplicado del sitio original, con sistemas informáticos en pleno funcionamiento y copias de seguridad casi completas de los datos del usuario?

A) sitio caliente
B) Sitio cálido
C) Sitio frio
D) sitio móvil

Respuesta no detectada automaticamente

4. ¿Cuál de las siguientes define la cantidad máxima aceptable de pérdida de datos medida en un momento específico antes de un desastre o interrupción?

A) RPO
B) MTBF
C) RTO
✓ D) MTTR

5. Una instalación de recuperación ante desastres que proporciona únicamente el espacio físico para las operaciones de recuperación se conoce como:

A) sitio caliente
B) Sitio cálido
✓ C) Sitio frio
D) Sitio espejo

6. ¿Qué sitio alternativo permite la recuperación ante desastres más rápida?

A) Sitio frio
✓ B) sitio caliente
C) sitio móvil
D) Sitio cálido

7. Una instalación de recuperación ante desastres que proporciona únicamente el espacio físico para las operaciones de recuperación se conoce como:

A) sitio caliente
B) Sitio cálido
✓ C) Sitio frio
D) Sitio espejo

8. ¿Qué sitio alternativo permite la recuperación ante desastres más rápida?

A) Sitio frio

✓ **B) sitio caliente**

C) sitio móvil

D) Sitio cálido

---

9. El término "clonación RFID" se refiere a copiar los datos almacenados en cualquier dispositivo habilitado para RFID (incluidas etiquetas, tarjetas, llaveros, implantes y otros objetos integrados con tecnología RFID) en otro dispositivo habilitado para RFID, que luego puede leerse y usarse de la misma manera que la etiqueta original. Si bien la clonación RFID se puede utilizar con fines legítimos, como replicar etiquetas importantes con fines de respaldo y prueba, también plantea un riesgo de seguridad significativo, ya que las etiquetas duplicadas pueden usarse potencialmente para obtener acceso no autorizado o divulgación de información no autorizada.

A) Verdadero

B) FALSO

Respuesta no detectada automaticamente

---

10. ¿Cuál de las respuestas enumeradas a continuación se refiere a la función principal del equilibrio de carga?

A) Mantiene copias idénticas de datos en múltiples servidores para mejorar la disponibilidad y confiabilidad de los datos.

✓ **B) Distribuye la carga de trabajo entre múltiples servidores para mejorar el rendimiento.**

✓ **C) Agrupa servidores para proporcionar alta disponibilidad y tolerancia a fallos.**

D) Distribuye contenido geográficamente entre múltiples servidores para mejorar el rendimiento, reducir la latencia y manejar grandes volúmenes de tráfico.

---

11. ¿Cuál de los siguientes términos se refiere a una estrategia de respaldo que se basa en la creación y el mantenimiento de copias de datos en tiempo real o casi en tiempo real en un sistema separado?

A) Duplicación

B) Virtualización

✓ **C) Llevar un diario**

✓ **D) Replicación**

---

12. ¿Cuál de las siguientes soluciones de redundancia de energía sería la más adecuada para proporcionar energía de emergencia a largo plazo durante un corte inesperado de la fuente de energía principal?

A) Fuente de alimentación dual

B) UPS en espera

✓ **C) Generador de respaldo**

D) PDU administrada

---

13. ¿Cuál de las siglas enumeradas a continuación se refiere a un período de tiempo máximo tolerable necesario para restaurar las funciones comerciales después de una falla o desastre?

A) SLA

B) RTO

C) PUA

D) RPO

---

14. ¿Cuál de las respuestas enumeradas a continuación se refiere a la función principal del equilibrio de carga?

A) Mantiene copias idénticas de datos en múltiples servidores para mejorar la disponibilidad y confiabilidad de los datos.

✓ **B) Distribuye la carga de trabajo entre múltiples servidores para mejorar el rendimiento.**

✓ **C) Agrupa servidores para proporcionar alta disponibilidad y tolerancia a fallos.**

D) Distribuye contenido geográficamente entre múltiples servidores para mejorar el rendimiento, reducir la latencia y manejar grandes volúmenes de tráfico.

---

15. ¿Cuál de los siguientes términos se refiere a una estrategia de respaldo que se basa en la creación y el mantenimiento de copias de datos en tiempo real o casi en tiempo real en un sistema separado?

A) Duplicación

B) Virtualización

✓ **C) Llevar un diario**

✓ **D) Replicación**

16. ¿Cuál de las siguientes soluciones de redundancia de energía sería la más adecuada para proporcionar energía de emergencia a largo plazo durante un corte inesperado de la fuente de energía principal?

A) Fuente de alimentación dual

B) UPS en espera

✓ **C) Generador de respaldo**

D) PDU administrada

17. ¿Cuál de las respuestas enumeradas a continuación se refiere(s) a controles de seguridad compensatorios? (Seleccione todo lo que corresponda)

A) Sistemas de energía de respaldo

B) Videovigilancia

✓ **C) Ministerio de Asuntos Exteriores**

✓ **D) Zona de pruebas de aplicaciones**

✓ **E) Segmentación de red**

18. ¿Cuál de los siguientes términos describe el proceso de identificar diferencias entre la postura de seguridad actual de una organización y su postura de seguridad deseada?

A) Ejercicio de mesa

✓ **B) Análisis de brechas**

C) Capacitación en concientización sobre seguridad.

D) Evaluación de riesgos

19. ¿Cuál es el propósito de la esteganografía?

A) Comprobación de la integridad de los datos

B) Verificando valores hash

✓ **C) Ocultar datos dentro de otro dato**

D) Cifrar datos

20. ¿Cuál de las respuestas enumeradas a continuación se refiere a una función hash no criptográfica que se utiliza a menudo con fines de verificación de errores?

A) MD5

B) CDN

C) sha

D) RIPEMD

21. ¿Cuál de las respuestas enumeradas a continuación se refiere a una técnica de ciberataque que se basa en proporcionar información DNS falsa a un solucionador de DNS con el fin de redirigir o manipular la resolución de nombres de dominio a direcciones IP maliciosas?

A) Suplantación de DNS

B) Relleno de credenciales

C) Secuestro de URL

D) Secuestro de dominio

22. El propósito de PCI DSS es brindar protección para:

A) Datos del titular de la tarjeta de crédito

B) Software con licencia

C) Contraseñas de usuario

D) Información de salud personal

23. ¿Cuál de las respuestas enumeradas a continuación se refiere a un escenario simulado llevado a cabo en un entorno controlado, que generalmente implica discusiones y planificación en torno a incidentes de seguridad hipotéticos?

A) Ejercicio de mesa

B) Zona de arena

C) caza de amenazas

D) Capacitación en concientización sobre seguridad.

Respuesta no detectada automaticamente

24. ¿Cuál de las siguientes respuestas se refiere a un escenario más realista que prueba la respuesta a incidentes de ciberseguridad imitando ataques reales?

A) Toma de huellas dactilares

✓ B) Simulación

C) caza de amenazas

D) Ejercicio de mesa

25. Una representación basada en archivos del estado de una máquina virtual en un momento dado se denomina:

A) Punto de restauración

B) Copia sombra

✓ C) Instantánea

D) Imagen del sistema

26. ¿Cuáles son las características del modo empresarial WPA2/WPA3? (Seleccione 3 respuestas)

A) Adecuado para grandes redes corporativas

B) IEEE 802.1D

C) No requiere un servidor de autenticación

✓ D) IEEE 802.1X

E) Adecuado para todo tipo de LAN inalámbricas

✓ F) Requiere servidor de autenticación RADIUS

27. ¿Qué política suele especificar el período durante el cual ciertos tipos de datos deben almacenarse antes de su eliminación?

A) Política de protección de datos

B) Política de clasificación de datos

C) Política de copia de seguridad de datos

✓ D) Política de retención de datos

28. En el contexto de la seguridad informática, el término "biometría" se refiere tanto a las características biológicas del cuerpo humano como a los rasgos de comportamiento que pueden utilizarse con fines de identificación y control de acceso.

A) Verdadero

B) FALSO

Respuesta no detectada automaticamente

29. ¿Cuál de las respuestas enumeradas a continuación se refiere a un proceso de interceptación de datos de tráfico de red con fines de análisis y solución de problemas?

A) AIS

✓ B) PCAP

C) EDR

D) MaaS

30. Un valor MTBF alto indica que un componente o sistema proporciona baja confiabilidad y es más probable que falle.

A) Verdadero

✓ B) FALSO

31. ¿Cuál de las siguientes respuestas se refiere a una entidad (como una organización o un individuo) que determina el propósito y los medios del procesamiento de datos personales?

✓ A) Procesador de datos

B) Propietario de los datos

✓ C) Responsable del tratamiento

D) Interesado

32. ¿Cuál de las siguientes respuestas se refiere a una función hash no criptográfica que se utiliza a menudo con fines de comprobación de errores?

A) MD5
B) CDN
C) sha
D) RIPEMD

---

33. ¿Cuál de las respuestas enumeradas a continuación se refiere(s) a controles de seguridad compensatorios? (Seleccione todo lo que corresponda)

A) Sistemas de energía de respaldo
B) Videovigilancia
✓ C) Ministerio de Asuntos Exteriores
✓ D) Zona de pruebas de aplicaciones
✓ E) Segmentación de red

---

34. ¿Cuál de las respuestas enumeradas a continuación se refiere a una función hash no criptográfica que se utiliza a menudo con fines de verificación de errores?

A) MD5
✓ B) CDN
C) sha
D) RIPEMD

---

35. ¿Cuál de las respuestas enumeradas a continuación se refiere a una técnica de ciberataque que se basa en proporcionar información DNS falsa a un solucionador de DNS con el fin de redirigir o manipular la resolución de nombres de dominio a direcciones IP maliciosas?

A) Suplantación de DNS
B) Relleno de credenciales
C) Secuestro de URL
D) Secuestro de dominio

---

36. ¿Cuál de las respuestas enumeradas a continuación se refiere a un escenario simulado llevado a cabo en un entorno controlado, que generalmente implica discusiones y planificación en torno a incidentes de seguridad hipotéticos?

A) Ejercicio de mesa
B) Zona de arena
C) caza de amenazas
D) Capacitación en concientización sobre seguridad.
Respuesta no detectada automaticamente

---

37. ¿Cuál de las siguientes respuestas se refiere a un escenario más realista que prueba la respuesta a incidentes de ciberseguridad imitando ataques reales?

A) Toma de huellas dactilares
✓ B) Simulación
C) caza de amenazas
D) Ejercicio de mesa

---

38. Una representación basada en archivos del estado de una máquina virtual en un momento dado se denomina:

A) Punto de restauración
B) Copia sombra
✓ C) Instantánea
D) Imagen del sistema

---

39. ¿Cuáles son las características del modo empresarial WPA2/WPA3? (Seleccione 3 respuestas)

A) Adecuado para grandes redes corporativas
B) IEEE 802.1D
C) No requiere un servidor de autenticación

✓ **D) IEEE 802.1X**

E) Adecuado para todo tipo de LAN inalámbricas

✓ **F) Requiere servidor de autenticación RADIUS**

40. ¿Cuál de las respuestas enumeradas a continuación se refiere a una actividad basada en debates en la que los miembros del equipo recorren diferentes escenarios para evaluar el plan de respuesta a incidentes sin activar ningún sistema?

A) Ejercicio de mesa

✓ **B) Simulación**

C) caza de amenazas

D) Análisis de causa raíz

41. ¿Cuál de las siguientes respuestas se refiere a una evaluación de riesgos realizada para un propósito o proyecto específico, sin planes para una reevaluación periódica (por ejemplo, evaluación de riesgos para el lanzamiento de un nuevo producto)?

A) una sola vez

B) Periódico

C) A propósito

D) Continuo

42. Un valor MTBF alto indica que un componente o sistema proporciona baja confiabilidad y es más probable que falle.

A) Verdadero

✓ **B) FALSO**

4.0 Operaciones de Seguridad (28% del examen)

4.1 - Dado un escenario, aplicar tecnicas comunes de seguridad a los activos.

Conceptos clave:

- Baselines seguras, CIS Benchmarks, Hardening
- Gestion movil: MDM, BYOD, COPE, CYOD, MAM
- Seguridad wireless: WPA3, WPA2, WEP (roto), 802.1X, Rogue AP
- Seguridad en apps: Validacion de entrada, Cookies seguras, SAST, DAST, Sandboxing

Teoria detallada:

BASELINES SEGURAS:

- Establecer una configuracion minima segura para cada tipo de dispositivo
- Desplegar mediante herramientas de gestion centralizada (GPO, MDM, Ansible)
- Mantener y verificar que los dispositivos no derivan de la baseline (deriva de configuracion)
- CIS Benchmarks: referencia de configuraciones seguras para multiples plataformas

HARDENING POR TIPO DE DISPOSITIVO:

- Estaciones de trabajo: deshabilitar autorun, cifrado de disco (BitLocker), antivirus, parches automaticos
- Servidores: deshabilitar servicios innecesarios, firewall de host, acceso remoto solo por SSH con clave
- Routers/Switches: cambiar credenciales por defecto, deshabilitar telnet, usar SSH, SNMP v3
- Dispositivos moviles: MDM, cifrado, borrado remoto, deshabilitar instalacion de apps no verificadas
- IoT: segmentar en VLAN separada, cambiar contrasenas por defecto, actualizar firmware

GESTION DE DISPOSITIVOS MOVILES:

- MDM (Gestion de Dispositivos Moviles): gestion centralizada (configuracion, apps, borrado remoto)
- BYOD (Trae tu propio dispositivo): el empleado usa su propio dispositivo. Menor control, mayor riesgo
- COPE (Propiedad corporativa, uso personal habilitado): la empresa da el dispositivo, el empleado puede usarlo personalmente
- CYOD (Elige tu propio dispositivo): el empleado elige entre una lista de dispositivos aprobados
- MAM (Gestion de Aplicaciones Moviles): gestiona solo las apps corporativas sin tocar el dispositivo personal

SEGURIDAD INALAMBRICA:

- WPA3: estandar actual, usa SAE (Autenticacion Simultanea de Iguales)
- WPA2: anterior estandar, vulnerable a ataque KRACK
- WEP: completamente roto, no usar nunca
- RADIUS: servidor de autenticacion centralizado para redes WiFi empresariales (802.1X)
- Rogue AP: punto de acceso no autorizado conectado a la red corporativa
- Evil twin: AP falso que imita al legitimo para capturar trafico

SEGURIDAD EN APLICACIONES:

- Validacion de entrada: verificar que los datos de entrada son del tipo y formato esperado (previene SQLi, XSS)
- Cookies seguras: flags HttpOnly (no accesible por JS) y Secure (solo HTTPS)
- Analisis estatico (SAST): analizar el codigo fuente sin ejecutarlo, busca vulnerabilidades
- Analisis dinamico (DAST): analizar la aplicacion mientras se ejecuta
- Firma de codigo: firmar digitalmente el codigo para verificar su autenticidad e integridad
- Sandboxing: ejecutar codigo en un entorno aislado para observar su comportamiento

Preguntas de practica (50):

1. ¿Cuál de las respuestas enumeradas a continuación se refiere a un modelo de implementación de dispositivos móviles en el que las organizaciones proporcionan y poseen los dispositivos y permiten su uso personal?

A) BYOD
B) AFRONTAR
C) VDI
D) CYOD

---

2. ¿Cuál de las respuestas enumeradas a continuación se refiere a un modelo de implementación de dispositivos móviles que permite a los empleados utilizar dispositivos móviles privados para acceder a datos y aplicaciones restringidos de la empresa?

A) AFRONTAR
B) BYOD
C) JBOD
D) CYOD

3. ¿Cuáles de las tecnologías inalámbricas enumeradas a continuación se consideran vectores de amenazas potenciales y deben evitarse debido a sus vulnerabilidades conocidas? (Seleccione todo lo que corresponda)

A) WPS
B) WAP
✓ C) WPA
D) WAF
✓ E) WPA2
✓ F) WEP

4. ¿Cuáles son las características del modo empresarial WPA2/WPA3? (Seleccione 3 respuestas)

A) Adecuado para grandes redes corporativas
B) IEEE 802.1D
C) No requiere un servidor de autenticación
✓ D) IEEE 802.1X
E) Adecuado para todo tipo de LAN inalámbricas
✓ F) Requiere servidor de autenticación RADIUS

5. ¿Qué protocolo de seguridad inalámbrica ha quedado obsoleto en favor de estándares más nuevos debido a vulnerabilidades conocidas resultantes de fallas de implementación?

A) PAE
B) AES
C) WPA2
✓ D) WEP

6. ¿Cuál de las siguientes respuestas se refiere a una herramienta de software que proporciona una única interfaz de administración para dispositivos móviles, PC, impresoras, dispositivos IoT y wearables?

A) DM
B) RCS
✓ C) UEM
D) mamá

7. Un protocolo diseñado para mejorar la seguridad de las implementaciones WEP existentes se conoce como:

A) SRTP
✓ B) TKIP
C) CCMP
D) WPA2

8. ¿Cuáles son las características del modo empresarial WPA2/WPA3? (Seleccione 3 respuestas)

A) Adecuado para grandes redes corporativas
B) IEEE 802.1D
C) No requiere un servidor de autenticación
✓ D) IEEE 802.1X
E) Adecuado para todo tipo de LAN inalámbricas
✓ F) Requiere servidor de autenticación RADIUS

9. ¿Cuál de las respuestas enumeradas a continuación se refiere(s) a los controles de seguridad de detectives? (Seleccione todo lo que corresponda)

A) Iluminación
✓ B) Monitoreo de registros
C) Zona de arena
✓ D) Auditorías de seguridad

✓ **E) circuito cerrado de televisión**
✓ **F) identificación**
✓ **G) Escaneo de vulnerabilidades**

10. ¿Cuál de las respuestas enumeradas a continuación se refiere(s) a controles de seguridad compensatorios? (Seleccione todo lo que corresponda)

A) Sistemas de energía de respaldo
B) Videovigilancia
✓ **C) Ministerio de Asuntos Exteriores**
✓ **D) Zona de pruebas de aplicaciones**
✓ **E) Segmentación de red**

11. Un protocolo de cifrado utilizado principalmente en redes Wi-Fi que implementan el estándar de seguridad WPA2 se llama:

A) TKIP
✓ **B) CCMP**
C) SSL
D) IPSec

12. ¿Cuál de las respuestas enumeradas a continuación se refiere a un método de autenticación secreto compartido utilizado en WPA, WPA2 y EAP?

A) PSK
B) 802.1X
C) SAE
D) TKIP

13. ¿Cuál de las respuestas enumeradas a continuación se refiere a un cifrado de flujo obsoleto utilizado en algunas aplicaciones heredadas, como WEP?

A) RSA
B) DES
C) SSL
D) RC4

14. ¿Cuál de las siguientes respuestas no se refiere al concepto de aislamiento de sistema/aplicación?

A) Virtualización
B) Contenedorización
C) Zona de arena
✓ **D) Cifrado de datos**

15. Una instalación de recuperación ante desastres que proporciona únicamente el espacio físico para las operaciones de recuperación se conoce como:

A) sitio caliente
B) Sitio cálido
✓ **C) Sitio frio**
D) Sitio espejo

16. ¿Qué sitio alternativo permite la recuperación ante desastres más rápida?

A) Sitio frio
✓ **B) sitio caliente**
C) sitio móvil
D) Sitio cálido

17. ¿Cuál de las respuestas enumeradas a continuación se refiere a un escenario simulado llevado a cabo en un entorno controlado, que generalmente implica discusiones y planificación en torno a incidentes de seguridad hipotéticos?

A) Ejercicio de mesa
B) Zona de arena
C) caza de amenazas

D) Capacitación en concientización sobre seguridad.

Respuesta no detectada automaticamente

18. ¿Cuál de los términos enumerados a continuación se utiliza para describir un nivel fundamental de configuraciones y ajustes de seguridad necesarios para salvaguardar un sistema?

A) Segmentación lógica

✓ B) Línea de base segura

C) Niveles de control de acceso

D) Principio de privilegio mínimo

19. ¿Cuál de las respuestas que se enumeran a continuación se refieren a técnicas de refuerzo de estaciones de trabajo? (Seleccione 3 respuestas)

A) Ocultar cuentas de administrador

✓ B) Aplicar periódicamente parches de seguridad y actualizaciones del sistema operativo y del software instalado.

C) Deshabilitar todo el acceso a Internet

✓ D) Eliminar o deshabilitar controladores, servicios, software y protocolos de red innecesarios

✓ E) Limitar el acceso de usuarios no autorizados o no autenticados

20. ¿Qué tipo de software permite un control centralizado sobre la configuración, monitoreo y seguridad de los dispositivos móviles utilizados dentro de una organización?

A) MDR

B) SOY

C) SIEM

✓ D) DM

21. ¿Cuál de las respuestas enumeradas a continuación se refiere al software que facilita la aplicación de políticas y procedimientos de dispositivos móviles?

A) NAC

B) DM

C) XDR

D) PAM

22. ¿Cuál de las siguientes siglas se refiere a un método de autenticación de cliente utilizado en el modo WPA3 Personal?

A) SAE

B) IKE

C) PSK

D) AES

23. ¿Cuáles de los aspectos de programación enumerados a continuación son críticos en el proceso de desarrollo seguro de aplicaciones? (Seleccione 2 respuestas)

A) Gestión de parches

✓ B) Validación de entrada

C) Protección con contraseña

✓ D) Manejo de errores y excepciones

E) Lista blanca de aplicaciones

24. ¿Cuál de las siguientes respuestas se refiere a una contramedida contra la inyección de código?

A) Fuzzing

✓ B) Validación de entrada

C) firma de código

D) Normalización

25. ¿Cuál de los términos enumerados a continuación se refiere a un proceso de revisión de código manual o automatizado destinado a descubrir errores de lógica y sintaxis en el código fuente de la aplicación?

A) Validación de entrada

B) Análisis de código dinámico

C) Fuzzing

✓ **D) Análisis de código estático**

26. La práctica de encontrar vulnerabilidades en una aplicación dándole entradas incorrectas se llama:

A) Normalización

B) Endurecimiento

C) Análisis de código dinámico

✓ **D) Fuzzing**

27. ¿Cuál de los términos enumerados a continuación se refiere al seguimiento y administración de componentes de aplicaciones de software, como bibliotecas de terceros y otras dependencias?

A) Control de versiones

B) Monitoreo de paquetes

C) Aplicación de la configuración

D) Endurecimiento de aplicaciones

28. En el proceso de respuesta a incidentes, el paso que implica identificar y comprender incidentes potenciales para determinar su alcance, impacto y causa raíz es parte de:

A) Etapa de preparación

✓ **B) Etapa de detección y análisis.**

C) Etapa de contención, erradicación y recuperación.

D) Etapa de actividad posterior al incidente

29. ¿Cuál de las siguientes define la cantidad máxima aceptable de pérdida de datos medida en un momento específico antes de un desastre o interrupción?

A) RPO

B) MTBF

C) RTO

✓ **D) MTTR**

30. ¿Cuál de las respuestas enumeradas a continuación se refiere a un estándar de seguridad introducido para abordar las vulnerabilidades encontradas en WEP?

A) TKIP

B) AES

C) WPA

D) CCMP

31. ¿Cuál de las siguientes respuestas se refiere a un método de autenticación secreto compartido utilizado en WPA, WPA2 y EAP?

A) PSK

B) 802.1X

C) SAE

D) TKIP

Respuesta no detectada automaticamente

32. ¿Cuál de los términos enumerados a continuación se aplica al proceso de autenticación?

A) Ministerio de Asuntos Exteriores

B) MMC

C) DM

D) MFD

33. ¿Cuál de las siglas enumeradas a continuación se refiere a un período de tiempo máximo tolerable necesario para restaurar las funciones comerciales después de una falla o desastre?

A) SLA

B) RTO

C) PUA

D) RPO

34. ¿Cuál de las siguientes respuestas se refiere a un cifrado de flujo obsoleto utilizado en algunas aplicaciones heredadas, como WEP?

A) RSA
B) DES
C) SSL
D) RC4

35. ¿Cuál de las siguientes respuestas se refiere a un protocolo de cifrado utilizado principalmente en redes Wi-Fi que implementan el estándar de seguridad WPA2?

A) TKIP
B) CCMP
C) SSL
D) HMAC

36. ¿Cuál de las respuestas enumeradas a continuación se refiere(s) a los controles de seguridad de detectives? (Seleccione todo lo que corresponda)

A) Iluminación
✓ B) Monitoreo de registros
C) Zona de arena
✓ D) Auditorías de seguridad
✓ E) circuito cerrado de televisión
✓ F) identificación
✓ G) Escaneo de vulnerabilidades

37. ¿Cuál de las respuestas enumeradas a continuación se refiere(s) a controles de seguridad compensatorios? (Seleccione todo lo que corresponda)

A) Sistemas de energía de respaldo
B) Videovigilancia
✓ C) Ministerio de Asuntos Exteriores
✓ D) Zona de pruebas de aplicaciones
✓ E) Segmentación de red

38. ¿Qué ataque inalámbrico se centra en explotar las vulnerabilidades encontradas en WEP?

A) ataque intravenoso
B) conducción de guerra
C) suplantación de SSID
D) bluejacking

39. Una instalación de recuperación ante desastres que proporciona únicamente el espacio físico para las operaciones de recuperación se conoce como:

A) sitio caliente
B) Sitio cálido
✓ C) Sitio frio
D) Sitio espejo

40. ¿Qué sitio alternativo permite la recuperación ante desastres más rápida?

A) Sitio frio
✓ B) sitio caliente
C) sitio móvil
D) Sitio cálido

41. ¿Cuál de las respuestas enumeradas a continuación se refiere a un escenario simulado llevado a cabo en un entorno controlado, que generalmente implica discusiones y planificación en torno a incidentes de seguridad hipotéticos?

A) Ejercicio de mesa
B) Zona de arena
C) caza de amenazas

D) Capacitación en concientización sobre seguridad.

Respuesta no detectada automaticamente

42. ¿Cuál de las siguientes siglas se refiere a un método de autenticación de cliente utilizado en el modo WPA3 Personal?

A) SAE

B) IKE

C) PSK

D) AES

43. ¿Cuál de los esquemas de cifrado inalámbrico enumerados a continuación ofrece el mayor nivel de protección?

A) WPS

✓ B) WPA3

C) AES

D) TKIP

44. ¿Cuáles de los aspectos de programación enumerados a continuación son críticos en el proceso de desarrollo seguro de aplicaciones? (Seleccione 2 respuestas)

A) Gestión de parches

✓ B) Validación de entrada

C) Protección con contraseña

✓ D) Manejo de errores y excepciones

E) Lista blanca de aplicaciones

45. ¿Cuál de las siguientes respuestas se refiere a una contramedida contra la inyección de código?

A) Fuzzing

✓ B) Validación de entrada

C) firma de código

D) Normalización

46. ¿Cuál de los términos enumerados a continuación se refiere a un proceso de revisión de código manual o automatizado destinado a descubrir errores de lógica y sintaxis en el código fuente de la aplicación?

A) Validación de entrada

B) Análisis de código dinámico

C) Fuzzing

✓ D) Análisis de código estático

47. La práctica de encontrar vulnerabilidades en una aplicación dándole entradas incorrectas se llama:

A) Normalización

B) Endurecimiento

C) Análisis de código dinámico

✓ D) Fuzzing

48. ¿Cuál de los términos enumerados a continuación se refiere al seguimiento y administración de componentes de aplicaciones de software, como bibliotecas de terceros y otras dependencias?

A) Control de versiones

B) Monitoreo de paquetes

C) Aplicación de la configuración

D) Endurecimiento de aplicaciones

49. El principio de privilegio mínimo es una regla de seguridad que impide que los usuarios accedan a información y recursos que se encuentran más allá del alcance de sus responsabilidades.

A) Verdadero

B) FALSO

Respuesta no detectada automaticamente

50. ¿Cuál de las siguientes define la cantidad máxima aceptable de pérdida de datos medida en un momento específico antes de un desastre o interrupción?

A) RPO
B) MTBF
C) RTO
✓ **D) MTTR**

4.2 - Explicar las implicaciones de seguridad de una gestion adecuada de activos.

Conceptos clave:

- Ciclo de vida: Adquisicion, Asignacion, Monitorizacion, Desmantelamiento
- Inventario de activos, CMDB, Enumeracion
- Disposicion segura: Sobreescritura, Degaussing, Borrado criptografico, Destruccion fisica
- Retencion de datos, Certificado de destruccion

Teoria detallada:

CICLO DE VIDA DE ACTIVOS:

1. Adquisicion/Aprovisionamiento: compra con proceso aprobado, verificacion de proveedores
2. Asignacion: asignar a un propietario y clasificar el activo
3. Monitorizacion: inventario continuo, saber que activos tienes y donde estan
4. Desmantelamiento: retirada segura al final de vida util

INVENTARIO Y SEGUIMIENTO:

- Inventario de activos: lista de todos los activos con sus propiedades (propietario, clasificacion, ubicacion)
- Enumeracion: proceso de descubrir activos en la red (escaneo activo)
- CMDB (Base de Datos de Gestion de Configuracion): base de datos de activos y sus relaciones

DISPOSICION SEGURA DE DATOS:

- Saneamiento de datos (Data sanitization): eliminar datos de forma que no puedan recuperarse

- Sobreescritura: sobreescribir con ceros/unos (no vale para SSDs)
- Degaussing: campo magnetico que destruye datos en discos magneticos (no vale para SSDs)
- Borrado criptografico: destruir la clave de cifrado (los datos cifrados son irrecuperables)
- Destruccion fisica: destruir fisicamente el medio (triturar, fundir)

- Retencion de datos: cuanto tiempo deben guardarse los datos (definido por ley o politica)
- Certificado de destruccion: documento que certifica la destruccion segura del medio

Preguntas de practica (3):

1. ¿Cuál de los siguientes métodos proporciona la forma más eficaz de eliminar permanentemente los datos almacenados en una unidad magnética?

A) Borrado criptográfico
B) Sobrescritura de datos
✓ **C) Desmagnetización**
D) Formateo de bajo nivel

---

2. ¿Qué política suele especificar el período durante el cual ciertos tipos de datos deben almacenarse antes de su eliminación?

A) Política de protección de datos
B) Política de clasificación de datos
C) Política de copia de seguridad de datos
✓ **D) Política de retención de datos**

---

3. Una de las formas de evitar la recuperación de datos de una unidad de almacenamiento es sobrescribir su contenido. La técnica de sobrescritura de datos la utilizan las utilidades de borrado de unidades que pueden emplear diferentes métodos (incluidas múltiples rondas de sobrescritura) para disminuir la probabilidad de recuperación de datos. Como ejemplo, una utilidad de desinfección de disco podría sobrescribir los datos de la unidad con el valor de uno en la primera pasada, cambiar ese valor a cero en la segunda pasada y, finalmente, realizar algunas pasadas más, sobrescribiendo el contenido con caracteres aleatorios.

A) Verdadero
B) FALSO

4.3 - Explicar varios actividades asociadas a la gestion de vulnerabilidades.

Conceptos clave:

- Proceso: Identificacion, Analisis, Respuesta, Validacion
- Herramientas: Vulnerability scanner, CVE, CVSS, OSINT, Threat feeds
- Analisis: Falso positivo, Falso negativo, Factor de exposicion
- Respuesta: Parcheo, Control compensatorio, Segmentacion, Aceptar

Teoria detallada:

PROCESO DE GESTION DE VULNERABILIDADES:

1. Identificacion: escaneo de vulnerabilidades, pentesting, OSINT, threat feeds, bug bounty
2. Analisis: priorizar segun criticidad (puntuacion CVSS), contexto del negocio y exposicion
3. Respuesta: parchear, mitigar o aceptar el riesgo
4. Validacion: verificar que la vulnerabilidad fue corregida (rescan)

HERRAMIENTAS DE IDENTIFICACION:

- Escaner de vulnerabilidades: Nessus, Qualys, OpenVAS. Escanea sistemas buscando vulnerabilidades conocidas
- CVE (Vulnerabilidades y Exposiciones Comunes): identificador unico para cada vulnerabilidad (CVE-2021-44228 = Log4Shell)
- CVSS (Sistema Comun de Puntuacion de Vulnerabilidades): puntuacion de 0-10 que indica la gravedad
- OSINT: inteligencia de fuentes abiertas. Buscar informacion sobre la organizacion que es publica
- Feeds de inteligencia de amenazas: fuentes de informacion sobre amenazas actuales (IOCs, TTPs)

ANALISIS DE RESULTADOS:

- Falso positivo: la herramienta reporta una vulnerabilidad que no existe
- Falso negativo: la herramienta NO reporta una vulnerabilidad que SI existe (el mas peligroso)
- Factor de exposicion: porcentaje del activo que se perderia si la vulnerabilidad se explota
- Tolerancia al riesgo: nivel de riesgo que la organizacion esta dispuesta a aceptar

RESPUESTA A VULNERABILIDADES:

- Parcheo: aplicar el parche del fabricante. Solucion preferida
- Control compensatorio: medida alternativa si no se puede parchear (ej: sistema legacy)
- Segmentacion: aislar el sistema vulnerable en un segmento de red separado
- Seguro (Insurance): transferir el riesgo economico mediante ciberseguro
- Aceptar: documentar y aceptar el riesgo conscientemente

Preguntas de practica (16):

1. ¿Cuál de los términos enumerados a continuación se refiere a inteligencia sobre amenazas recopilada de fuentes disponibles públicamente?

A) COI
✓ B) OSINT
C) RFC
D) CVE/NVD

2. Un tipo de evidencia forense que puede usarse para detectar intentos de acceso no autorizados u otras actividades maliciosas se denomina:

A) CVE
✓ B) COI
C) AIS
D) OSINT

3. Un programa de divulgación responsable es un proceso formal establecido por una organización para alentar a los investigadores de seguridad y a los piratas informáticos éticos a informar las vulnerabilidades que descubren en los sistemas o software de la organización. Un programa de recompensas por errores es un tipo específico de programa de divulgación responsable que ofrece recompensas financieras a los investigadores de seguridad por informar vulnerabilidades válidas.

A) Verdadero
B) FALSO

4. ¿Cuál de las respuestas enumeradas a continuación se refiere a una situación en la que no se activa ninguna alarma cuando se ha producido un ataque?

A) Falso negativo
B) Verdadero positivo
C) falso positivo
D) Verdadero negativo

Respuesta no detectada automaticamente

5. ¿Cuál de las siguientes opciones se refiere a un sistema que identifica, define y cataloga vulnerabilidades de ciberseguridad conocidas públicamente?

A) TAXII
✓ B) CVE
C) STIX
D) cvss

6. ¿Cuál de las respuestas enumeradas a continuación se refiere a un concepto que proporciona información sobre los métodos y herramientas que utilizan los ciberdelincuentes para llevar a cabo ataques?

A) TTP
B) CVE
C) ATT&CK
D) cvss

Respuesta no detectada automaticamente

7. ¿Cuál de las respuestas enumeradas a continuación se refiere a un estándar de la industria para evaluar y calificar la gravedad de las vulnerabilidades de seguridad de los sistemas informáticos?

A) SIEM
B) cvss
C) OSINT
D) REMONTARSE

8. Un tipo de evidencia forense que puede usarse para detectar intentos de acceso no autorizados u otras actividades maliciosas se denomina:

A) CVE
✓ B) COI
C) AIS
D) OSINT

9. Un programa de divulgación responsable es un proceso formal establecido por una organización para alentar a los investigadores de seguridad y a los piratas informáticos éticos a informar las vulnerabilidades que descubren en los sistemas o software de la organización. Un programa de recompensas por errores es un tipo específico de programa de divulgación responsable que ofrece recompensas financieras a los investigadores de seguridad por informar vulnerabilidades válidas.

A) Verdadero
B) FALSO

10. ¿Cuál de las respuestas enumeradas a continuación se refiere a una situación en la que no se activa ninguna alarma cuando se ha producido un ataque?

A) Falso negativo
B) Verdadero positivo
C) falso positivo
D) Verdadero negativo

Respuesta no detectada automaticamente

11. ¿Cuál de las siguientes opciones se refiere a un sistema que identifica, define y cataloga vulnerabilidades de ciberseguridad conocidas públicamente?

A) TAXII

✓ **B) CVE**

C) STIX

D) cvss

12. ¿Cuál de los siguientes términos se refiere a un marco y una base de conocimientos que proporciona comprensión de los TTP utilizados durante los ciberataques?

✓ **A) cvss**

✓ **B) ATT&CK**

C) STIX

D) TAXII

13. ¿Cuál de las respuestas enumeradas a continuación se refiere a un término utilizado principalmente en el desarrollo de software para describir el costo de las decisiones a corto plazo que pueden generar problemas a largo plazo?

A) Entropía de código

B) factor de exposición

C) registro de riesgos

✓ **D) Deuda técnica**

14. ¿Cuál de los siguientes términos se refiere a un marco y una base de conocimientos que proporciona comprensión de los TTP utilizados durante los ciberataques?

A) cvss

✓ **B) ATT&CK**

C) TAXII

D) STIX

15. ¿Cuál de los términos enumerados a continuación se refiere a una iniciativa del gobierno de EE. UU. para compartir en tiempo real indicadores de amenazas cibernéticas?

A) NVD

✓ **B) AIS**

C) TTP

D) cvss

16. ¿Cuál de los siguientes términos se refiere a un marco y una base de conocimientos que proporciona comprensión de los TTP utilizados durante los ciberataques?

✓ **A) cvss**

✓ **B) ATT&CK**

C) STIX

D) TAXII

4.4 - Explicar las actividades de monitorizacion y alerta de seguridad.

Conceptos clave:

- SIEM: Agregacion, Correlacion, Alerting, Dashboards
- Herramientas: SCAP, NetFlow, SNMP v3, DLP, Vulnerability scanner, EDR
- Monitorizacion de endpoints, logs, red y aplicaciones
- Alert tuning para reducir falsos positivos

Teoria detallada:

SIEM (Gestion de Informacion y Eventos de Seguridad) - El centro neuralgico del SOC:

- Agrega logs de TODAS las fuentes: firewalls, servidores, endpoints, apps, nube
- Correlaciona eventos de distintas fuentes para detectar ataques que no se ven aisladamente
- Ejemplo real: un login fallido + acceso a un recurso sensible + transferencia grande de datos = posible compromiso aunque cada evento por separado parezca normal
- Productos: Splunk (lider de mercado), IBM QRadar, Microsoft Sentinel, Elastic SIEM, ArcSight

PROCESO DE ALERTAS Y MONITORIZACION:

• Agregacion de logs: centralizar logs en un SIEM o servidor SYSLOG. Sin centralizacion no hay correlacion
• Alerting: reglas que disparan notificaciones cuando se cumplen condiciones (ej: 5 logins fallidos en 1 minuto)
• Ajuste de alertas (Alert tuning): ajustar umbrales para reducir FALSOS POSITIVOS sin perder detecciones reales. El mayor reto operativo de un SOC
• Cuarentena: aislar automaticamente un endpoint cuando el SIEM detecta comportamiento malicioso
• Archivo: retener logs el tiempo exigido por ley (GDPR: minimo 1 ano, PCI DSS: 1 ano)

HERRAMIENTAS DE MONITORIZACION CRITICAS:

• SCAP (Protocolo de Automatizacion de Contenido de Seguridad): framework NIST para automatizar verificacion de cumplimiento
• NetFlow/IPFIX: metadatos del trafico de red (origen, destino, puertos, bytes). No captura el contenido pero revela patrones
• SNMP v3: monitoreo de dispositivos de red con autenticacion y cifrado. SNMPv1/v2 son inseguros
• DLP (Prevencion de Perdida de Datos): inspecciona emails, transferencias de archivos y trafico web buscando datos sensibles
• Escaner de vulnerabilidades: Nessus, Qualys, OpenVAS. Escaneo periodico (minimo semanal en entornos criticos)
• Antivirus/EDR: AV usa firmas, EDR analiza comportamiento en tiempo real y permite investigacion forense

TRUCO EXAMEN: SIEM = correlacion y retencion. DLP = prevencion de fuga. EDR = deteccion y respuesta en endpoint. NetFlow = quien habla con quien. SNMP = estado de dispositivos de red.

Preguntas de practica (31):

1. ¿Cuál de las respuestas enumeradas a continuación se refiere al concepto de aislamiento de datos? (Seleccione 2 respuestas)

A) DLP
B) SDN
✓ C) EFS
D) SWG
E) EDR

---

2. ¿Cuál de las siguientes respuestas se refiere a técnicas de monitoreo pasivo de redes? (Seleccione 2 respuestas)

A) Grifo de red
B) Puerto troncal
✓ C) Duplicación de puertos
D) trampa SNMP
E) Puerto registrado

---

3. ¿Qué tipo de software permite un control centralizado sobre la configuración, monitoreo y seguridad de los dispositivos móviles utilizados dentro de una organización?

A) MDR
B) SOY
C) SIEM
✓ D) DM

---

4. ¿Cuál de las siguientes respuestas se refiere a SCAP? (Seleccione 3 respuestas)

A) Un tipo de sistema de seguridad diseñado para recopilar registros y eventos de diversas fuentes.
✓ B) Diseñado para proporcionar una interfaz de usuario centralizada para acceder a los datos recopilados.
✓ C) Una colección de estándares desarrollados por NIST
✓ D) Proporciona un lenguaje común para comunicar información de seguridad.
✓ E) Permite que diferentes herramientas de seguridad compartan datos y trabajen juntas de manera más efectiva
F) Permite la detección de amenazas en tiempo real, la respuesta a incidentes y el monitoreo del cumplimiento

---

5. El Protocolo simple de administración de red (SNMP) es un protocolo de capa de aplicación basado en UDP que se utiliza en sistemas de administración de red para monitorear dispositivos conectados a la red. SNMP suele estar integrado en la mayoría de los dispositivos de infraestructura de red modernos, como enrutadores, puentes, conmutadores, servidores, impresoras, fotocopiadoras, máquinas de fax y otros dispositivos conectados a la red. Una red administrada por SNMP consta de tres componentes esenciales: un dispositivo administrado, un módulo de software de administración de red que reside en un dispositivo administrado (Agente) y una estación de administración de red (NMS), que ejecuta aplicaciones responsables

de monitorear y controlar los dispositivos administrados, así como de recopilar información SNMP de los Agentes. El administrador recibe notificaciones (Traps e InformRequests) en el puerto UDP 162, mientras que el agente SNMP recibe solicitudes en el puerto UDP 161.

A) Verdadero

B) FALSO

Respuesta no detectada automaticamente

6. ¿Cuál de las respuestas enumeradas a continuación se refiere al proceso de mantener la integridad de archivos y datos?

A) DLP

B) SIEM

C) FIM

D) sha

7. ¿Cuál de las siguientes respuestas se refiere a una solución que ayuda a las organizaciones a mitigar los riesgos asociados con filtraciones de datos, amenazas internas e infracciones de cumplimiento?

A) EDR

B) DLP

C) SOY

D) UTM

8. ¿Cuál de las respuestas enumeradas a continuación se refiere al proceso de mantener la integridad de archivos y datos?

A) DLP

B) SIEM

C) FIM

D) sha

9. ¿Cuál de las siglas enumeradas a continuación se refiere a un protocolo utilizado en los sistemas de administración de redes para monitorear dispositivos conectados a la red?

A) SSH

B) VNC

C) SNMP

D) PDR

10. ¿Cuál de las respuestas enumeradas a continuación se refiere(s) a los controles de seguridad de detectives? (Seleccione todo lo que corresponda)

A) Iluminación

✓ B) Monitoreo de registros

C) Zona de arena

✓ D) Auditorías de seguridad

✓ E) circuito cerrado de televisión

✓ F) identificación

✓ G) Escaneo de vulnerabilidades

11. ¿Cuál de las respuestas enumeradas a continuación se refiere a un enfoque de seguridad del plano de control de confianza cero que tiene en cuenta la identidad del usuario, la seguridad del dispositivo, las condiciones de la red y otra información contextual para permitir decisiones de acceso dinámico?

A) Confianza implícita

B) Monitoreo y registro

✓ C) Identidad adaptativa

D) Microsegmentación

12. Un archivo Honey se puede utilizar para:

A) Atraer a los ciberatacantes

B) Activar alertas cuando se accede

C) Monitoreo de la actividad de la red

✓ **D) Todo lo anterior**

13. ¿Cuál de las respuestas enumeradas a continuación se refiere a la causa más probable de un acceso no autorizado provocado por la explotación de un punto de entrada de red específico?

A) Software AV obsoleto
B) Cookies del navegador
✓ **C) Puertos de servicio abiertos**
D) Registro y seguimiento insuficientes

14. ¿Cuál de las respuestas enumeradas a continuación se refiere a una solución que permite una gestión y control más sencillo de las políticas de segmentación de red a través de aplicaciones de software?

A) VDI
✓ **B) SDN**
C) VPC
D) EDR

15. ¿Cuál de las siguientes respuestas se refiere a tecnología de software diseñada para simplificar la gestión de la infraestructura de red?

A) SDN
B) SaaS
C) VDI
D) SNMP

16. ¿Cuál de los términos enumerados a continuación se refiere al seguimiento y administración de componentes de aplicaciones de software, como bibliotecas de terceros y otras dependencias?

A) Control de versiones
B) Monitoreo de paquetes
C) Aplicación de la configuración
D) Endurecimiento de aplicaciones

17. ¿Cuál de las siguientes siglas se refiere a soluciones de seguridad basadas en software o hardware diseñadas para detectar y prevenir el uso y la transmisión no autorizados de información confidencial?

A) IPS
✓ **B) DLP**
C) identificación
D) DEP

18. En SNMP, cada nodo en una MIB se identifica de forma única mediante un(a):

A) ESD
✓ **B) OID**
C) CSU
D) OUI

19. Una subred ligeramente protegida (también conocida como DMZ) que consta de servidores disponibles públicamente ubicados en el exterior del firewall de la empresa se conoce como:

A) Portal cautivo
B) Red de cuarentena
C) Extranet
✓ **D) Subred filtrada**

20. ¿Cuál de las respuestas enumeradas a continuación se refiere a un proceso de interceptación de datos de tráfico de red con fines de análisis y solución de problemas?

A) AIS
✓ **B) PCAP**
C) EDR
D) MaaS

21. ¿Cuál de las siguientes siglas se refiere a soluciones de seguridad basadas en software o hardware diseñadas para detectar y prevenir el uso y la transmisión no autorizados de información confidencial?

A) IPS

✓ B) DLP

C) identificación

D) DEP

22. ¿Cuál de las respuestas enumeradas a continuación se refiere a un estándar de la industria para evaluar y calificar la gravedad de las vulnerabilidades de seguridad de los sistemas informáticos?

A) SIEM

B) cvss

C) OSINT

D) REMONTARSE

23. En los sistemas operativos modernos, esta característica evita que se ejecute código malicioso en ciertas regiones de la memoria destinadas a los datos.

A) DEP

B) BCE

C) DLP

D) CDN

Respuesta no detectada automaticamente

24. ¿Cuál de las respuestas enumeradas a continuación se refiere a un protocolo utilizado por enrutadores, hosts y dispositivos de red para generar mensajes de error y solucionar problemas con la entrega de paquetes IP?

A) CCMP

B) RSTP

C) ICMP

D) SNMP

25. ¿Cuál de las siguientes respuestas se refiere a un marco de ciberseguridad que combina funciones de red y seguridad en un único servicio basado en la nube?

A) SASE

B) SIEM

C) SWG

D) REMONTARSE

26. ¿Cuál de las siguientes tecnologías permite el manejo automatizado de múltiples incidentes de seguridad?

A) JABÓN

B) SIEM

✓ C) REMONTARSE

D) SASE

27. ¿Cuál de las respuestas enumeradas a continuación se refiere(s) a los controles de seguridad de detectives? (Seleccione todo lo que corresponda)

A) Iluminación

✓ B) Monitoreo de registros

C) Zona de arena

✓ D) Auditorías de seguridad

✓ E) circuito cerrado de televisión

✓ F) identificación

✓ G) Escaneo de vulnerabilidades

28. ¿Cuál de los términos enumerados a continuación se refiere al seguimiento y administración de componentes de aplicaciones de software, como bibliotecas de terceros y otras dependencias?

A) Control de versiones

B) Monitoreo de paquetes
C) Aplicación de la configuración
D) Endurecimiento de aplicaciones

29. ¿Cuál de las siguientes respuestas se refiere(s) a la etapa de contención, erradicación y recuperación del proceso de respuesta a incidentes? (Seleccione todo lo que corresponda)

A) Restaurando operaciones normales
✓ B) Eliminando la amenaza
C) Seguimiento y detección de posibles incidencias
D) Establecer y mantener una política de respuesta a incidentes.
✓ E) Mitigar el impacto del incidente

30. ¿Cuál de las respuestas enumeradas a continuación se refiere a un ejemplo de evaluación de riesgos recurrentes?

✓ A) Monitoreo en tiempo real de amenazas a la seguridad de la red
B) Evaluación del riesgo después de un cambio organizacional importante o una violación de seguridad
C) Evaluaciones de riesgos trimestrales o anuales
D) Evaluación de riesgos para el lanzamiento de un nuevo producto.

31. ¿Cuál de las respuestas enumeradas a continuación se refiere a un ejemplo de evaluación continua de riesgos?

A) Evaluaciones de riesgos trimestrales o anuales
B) Evaluación de riesgos para el lanzamiento de un nuevo producto.
C) Evaluación del riesgo después de un cambio organizacional importante o una violación de seguridad
D) Monitoreo en tiempo real de amenazas a la seguridad de la red

4.5 - Dado un escenario, modificar o implementar controles de seguridad empresarial.

Conceptos clave:

- Firewalls: Reglas, Deny implicito, Stateful, DMZ, Fail-open/closed
- IDS vs IPS: Pasivo vs Activo, Firmas vs Anomalias, HIDS/NIDS
- Seguridad email: SPF, DKIM, DMARC, Gateway de email
- Otras: Filtro web/DNS, FIM, NAC, EDR, XDR

Teoria detallada:

FIREWALLS - Configuracion y tipos:

- Las reglas del firewall se evaluan en orden, de arriba a abajo. La primera regla que coincide gana
- Denegacion implicita: ultima regla implicita que deniega todo lo no permitido explicitamente. SIEMPRE existe aunque no se vea
- Inspeccion con estado (Stateful): recuerda el estado de las conexiones TCP. Permite respuestas a conexiones iniciadas desde dentro sin regla explicita de retorno
- Subred de pantalla (DMZ): red intermedia entre internet e intranet. Los servidores publicos van aqui
- Fail-open vs Fail-closed: si el firewall falla, fail-open deja pasar todo (disponibilidad), fail-closed bloquea todo (seguridad)

IDS vs IPS - La diferencia critica para el examen:

- IDS (Sistema de Deteccion de Intrusiones): PASIVO. Detecta y alerta. No bloquea. Se conecta a un TAP o puerto SPAN
- IPS (Sistema de Prevencion de Intrusiones): ACTIVO. Detecta Y bloquea. Se conecta EN LINEA. Puede causar falsos positivos
- Basado en firmas: compara con firmas de ataques conocidos. Rapido, pocos falsos positivos, NO detecta zero-days
- Basado en anomalias/comportamiento: aprende el trafico 'normal' y alerta ante desviaciones. Detecta zero-days, mas falsos positivos
- HIDS/HIPS: instalado en el host, ve trafico cifrado desde dentro
- NIDS/NIPS: en la red, no ve trafico cifrado sin inspeccion SSL

SEGURIDAD DE EMAIL - SPF, DKIM y DMARC:

- SPF: registro TXT en DNS que lista las IPs autorizadas a enviar email del dominio. El receptor verifica que el email viene de una IP en la lista
- DKIM: el servidor de email firma el mensaje con su clave privada. El receptor verifica la firma con la clave publica en DNS. Garantiza: el contenido no fue modificado en transito
- DMARC: politica que dice que hacer si SPF o DKIM fallan

- p=none: solo monitorizar
- p=quarantine: enviar a spam
- p=reject: rechazar el email completamente

• TRUCO: SPF = que IPs pueden enviar, DKIM = firma el contenido, DMARC = que hacer si fallan

OTRAS CAPACIDADES DE SEGURIDAD EMPRESARIAL:

• Filtro web/URL: categorizar sitios y bloquear categorias. A nivel DNS (Cisco Umbrella) o proxy (Zscaler)
• Filtrado DNS: bloquear dominios maliciosos antes de que la conexion se establezca. Primera linea de defensa contra phishing
• FIM (Monitorizacion de Integridad de Archivos): detecta cambios no autorizados en archivos criticos. Critico para detectar rootkits
• NAC (Control de Acceso a la Red): verifica que un dispositivo cumple los requisitos de seguridad ANTES de permitirle conectarse
• EDR (Deteccion y Respuesta en el Endpoint): registra TODA la actividad del endpoint para investigacion forense
• XDR (Deteccion y Respuesta Extendida): correlaciona telemetria de endpoint, red, email y nube en una sola plataforma

Preguntas de practica (61):

1. ¿Cuál de las siguientes opciones proporciona una respuesta activa a una violación de la seguridad de la red en un sistema informático individual?

A) NIDS
B) esconde
C) PNI
✓ D) CADERAS

---

2. ¿Cuál de las siguientes soluciones proporciona una respuesta activa a las violaciones de seguridad de la red en un sistema informático individual?

A) NIDS
B) esconde
C) PNI
✓ D) CADERAS

---

3. ¿Cuál de las siguientes respuestas se refiere a un marco de políticas que permite a los propietarios de dominios especificar cómo los receptores de correo electrónico deben manejar los correos electrónicos que no pasan las comprobaciones de autenticación?

✓ A) DKIM
B) FPS
C) PEM
✓ D) DMARC

---

4. ¿Cuál de las respuestas enumeradas a continuación se refiere a un método de autenticación que permite firmar un mensaje de correo electrónico saliente con una firma digital?

A) FPS
B) DKIM
C) DMARC
D) PEM

---

5. ¿Cuál de las siguientes respuestas se refiere a un mecanismo de autenticación de correo electrónico que permite a los propietarios de dominios especificar qué direcciones IP están autorizadas para enviar correos electrónicos en nombre de su dominio?

A) DMARC
B) PEM
C) DKIM
D) FPS

---

6. ¿Cuál de las respuestas enumeradas a continuación se refiere a un estándar criptográfico (y un formato de archivo) utilizado para el almacenamiento y transmisión de claves privadas en comunicaciones por correo electrónico?

A) PEM

B) DMARC
C) FPS
D) DKIM

7. ¿Cuál de las siguientes respuestas ilustra la diferencia entre respuesta pasiva y activa a una violación de seguridad de la red?

A) HIPS frente a NIPS
B) UTM frente a cortafuegos
C) NIPS frente a UTM
✓ D) IDS frente a IPS

8. ¿Cuál de las respuestas enumeradas a continuación se refiere a una tecnología de seguridad de red diseñada para monitorear, detectar y mitigar el acceso no autorizado, las amenazas a la seguridad y las actividades sospechosas en las WLAN?

A) WIPS
B) NIDS
C) PNI
D) WIDS

9. ¿Qué registros DNS TXT se utilizan para la gestión de spam? (Seleccione 3 respuestas)

A) FPS
✓ B) DKIM
C) SRV
✓ D) DMARC
E) PTR

10. ¿Cuál de los siguientes términos entran en la categoría de controles de seguridad directivos? (Seleccione 2 respuestas)

A) PIR
✓ B) PUA
C) identificación
D) Ministerio de Asuntos Exteriores
E) IPS

11. ¿Cuál de las respuestas enumeradas a continuación se refiere a la tecnología de seguridad de red diseñada para monitorear las WLAN en busca de acceso no autorizado, amenazas a la seguridad y actividades sospechosas?

A) UTM
B) WIDS
C) NGFW
D) WAF
Respuesta no detectada automaticamente

12. ¿Cuál de las respuestas enumeradas a continuación se refiere al software que facilita la aplicación de políticas y procedimientos de dispositivos móviles?

A) NAC
B) DM
C) XDR
D) PAM

13. Un tipo de mecanismo de identificación de usuarios utilizado como contramedida contra el software automatizado (como los robots de red) se conoce como:

A) Ministerio de Asuntos Exteriores
✓ B) CAPTCHA
C) SSO
D) NIDS

14. ¿Cuál de las siguientes siglas se refiere a soluciones de seguridad basadas en software o hardware diseñadas para detectar y prevenir el uso y la transmisión no autorizados de información confidencial?

A) IPS

✓ B) DLP

C) identificación

D) DEP

---

15. Las reglas del firewall se evalúan según su orden de prioridad. Las reglas que se encuentran en la parte superior de la lista tienen prioridad sobre las reglas que se encuentran más abajo en la lista. Una vez que se encuentra una regla coincidente, no se realiza ninguna evaluación adicional de las reglas posteriores. La política de "denegación implícita" en un firewall es un comportamiento predeterminado común en el que cualquier tráfico que no coincida explícitamente con ninguna de las reglas de permiso configuradas se deniega o bloquea automáticamente. En otras palabras, si un paquete no cumple con los criterios de ninguna regla de permiso, el comportamiento predeterminado del firewall es denegar el tráfico.

A) Verdadero

B) FALSO

---

16. ¿Cuál de las siguientes siglas se refiere a soluciones de seguridad basadas en software o hardware diseñadas para detectar y prevenir el uso y la transmisión no autorizados de información confidencial?

A) IPS

✓ B) DLP

C) identificación

D) DEP

---

17. ¿Qué tipo de software se utiliza para prevenir, detectar y eliminar malware de sistemas y redes informáticas?

A) identificación

B) SaaS

✓ C) AV

D) WAF

---

18. ¿Cuál de las siguientes respuestas se refiere a un registro DNS TXT que permite al propietario de un dominio especificar todos los servidores autorizados para enviar correo desde su dominio?

A) DKIM

B) SRV

C) CNOMBRE

D) FPS

---

19. ¿Cuál de las respuestas que se enumeran a continuación se refieren a los rasgos característicos del NIDS? (Seleccione 3 respuestas)

A) Toma medidas proactivas para bloquear o mitigar los intentos de intrusión.

✓ B) No toma medidas directas para bloquear o prevenir ataques.

✓ C) Genera alertas y notifica al personal de seguridad o a los administradores cuando se detecta actividad sospechosa.

✓ D) Supervisa el tráfico de la red sin participación directa en el enrutamiento del tráfico o la modificación de paquetes.

E) Puede descartar o rechazar paquetes de red, finalizar conexiones o tomar otras acciones para detener el ataque.

F) Opera en modo en línea, interceptando e inspeccionando activamente el tráfico de la red.

---

20. ¿Cuál de los siguientes términos entran en la categoría de controles de seguridad directivos? (Seleccione 2 respuestas)

A) PIR

✓ B) PUA

C) identificación

D) Ministerio de Asuntos Exteriores

E) IPS

---

21. Un tipo de mecanismo de identificación de usuarios utilizado como contramedida contra el software automatizado (como los robots de red) se conoce como:

A) Ministerio de Asuntos Exteriores

✓ B) CAPTCHA

C) SSO

D) NIDS

---

22. ¿Cuáles son los ejemplos de controles preventivos de seguridad? (Seleccione 3 respuestas)

A) Cifrado

B) identificación

C) Sensores

✓ D) Cortafuegos

E) Señales de advertencia

✓ F) software audiovisual

---

23. ¿Cuál de las respuestas enumeradas a continuación se refiere(s) a los controles de seguridad de detectives? (Seleccione todo lo que corresponda)

A) Iluminación

✓ B) Monitoreo de registros

C) Zona de arena

✓ D) Auditorías de seguridad

✓ E) circuito cerrado de televisión

✓ F) identificación

✓ G) Escaneo de vulnerabilidades

---

24. ¿Cuál de las respuestas enumeradas a continuación se refiere a un conjunto de protocolos y tecnologías que proporcionan cifrado, autenticación e integridad de datos para el tráfico de red?

A) TLS

B) SSH

✓ C) IPSec

D) vpn

---

25. Un protocolo de cifrado utilizado principalmente en redes Wi-Fi que implementan el estándar de seguridad WPA2 se llama:

A) TKIP

✓ B) CCMP

C) SSL

D) IPSec

---

26. ¿Cuál de las siguientes respuestas se refiere a un protocolo utilizado para configurar conexiones seguras e intercambiar claves criptográficas en VPN IPsec?

A) SSL

B) IKE

C) ESP

D) DHE

---

27. ¿Cuáles de las tecnologías inalámbricas enumeradas a continuación se consideran vectores de amenazas potenciales y deben evitarse debido a sus vulnerabilidades conocidas? (Seleccione todo lo que corresponda)

A) WPS

B) WAP

✓ C) WPA

D) WAF

✓ E) WPA2

✓ F) WEP

---

28. ¿Cuál de las siguientes opciones indicaría un intento de ocultar evidencia de actividad maliciosa?

A) Bloqueo de cuenta

B) Inaccesibilidad de recursos

✓ **C) Registros faltantes**

D) Uso simultáneo de sesiones

29. ¿Cuál de las siguientes políticas se aplica a cualquier solicitud que no cumpla con los criterios definidos en una ACL?

A) Política de acceso justo

✓ **B) Política de denegación implícita**

C) confianza transitiva

D) Autenticación consciente del contexto

30. ¿Cuál de las respuestas enumeradas a continuación se refiere a una solución de hardware o software que proporciona acceso remoto seguro a redes y recursos?

A) NAC

B) PDR

C) SSH

✓ **D) RAS**

31. ¿Cuál de las respuestas enumeradas a continuación se refiere a un protocolo utilizado para configurar conexiones seguras e intercambiar claves criptográficas en VPN IPsec?

A) SSL

✓ **B) IKE**

C) ESP

D) DHE

32. ¿Qué parte de IPsec proporciona confidencialidad, integridad de datos y autenticación?

A) AES

B) sha

C) Ah

✓ **D) ESP**

33. Un modo IPsec que proporciona cifrado sólo para la carga útil (la parte de datos del paquete) se denomina:

A) Modo protegido

B) Modo túnel

✓ **C) Modo de transporte**

D) Modo seguro

34. Los métodos de cifrado utilizados para proteger los datos en tránsito incluyen: (Seleccione todos los que correspondan)

A) NFS

✓ **B) vpn**

C) SED

✓ **D) IPSec**

E) FDE

✓ **F) TLS**

35. Filtrado web basado en agentes: (Seleccione 3 respuestas)

A) Requiere instalar software en cada dispositivo que necesita ser monitoreado

✓ **B) Proporciona flexibilidad y control granular sobre la actividad web a nivel de dispositivo**

✓ **C) Implica un aumento de los gastos generales de gestión y del consumo de recursos del sistema.**

D) Simplifica la administración y garantiza la aplicación consistente de las políticas de filtrado web en toda la red.

✓ **E) No requiere la instalación de software en cada dispositivo individual**

F) Requiere un servidor central en funcionamiento para que funcione el filtrado web.

36. ¿Cuál de las respuestas enumeradas a continuación se refiere a técnicas de filtrado que pueden permitir o bloquear el acceso a un sitio en función de su dirección web? (Seleccione 2 respuestas)

A) Inspección SSL/TLS

✓ **B) escaneo de URL**

C) Categorización de contenido

✓ **D) filtrado DNS**

E) Filtrado basado en reputación

---

37. ¿Cuál de las respuestas enumeradas a continuación se refiere a un reemplazo seguro de Telnet?

A) RSH

B) IPSec

✓ **C) SSH**

D) RTPS

---

38. ¿Cuál de las respuestas enumeradas a continuación se refiere a un protocolo de red seguro utilizado para proporcionar cifrado, autenticación e integridad para la comunicación multimedia en tiempo real?

A) IPSec

B) SORBO

C) VoIP

✓ **D) SRTP**

---

39. ¿Cuál de las respuestas enumeradas a continuación se refiere al proceso de mantener la integridad de archivos y datos?

A) DLP

B) SIEM

C) FIM

D) sha

---

40. ¿Cuál es la mejor contramedida contra los ataques de ingeniería social?

A) Conciencia situacional

B) Política de denegación implícita

✓ **C) Educación del usuario**

D) Fuertes controles de seguridad

---

41. Un tipo de mecanismo de identificación de usuarios utilizado como contramedida contra el software automatizado (como los robots de red) se conoce como:

A) Ministerio de Asuntos Exteriores

✓ **B) CAPTCHA**

C) LCA

D) PNI

---

42. Un subsistema de autenticación que permite a un usuario acceder a múltiples componentes del sistema conectados (como hosts separados en una red) después de un único inicio de sesión en solo uno de los componentes se denomina:

A) NAC

✓ **B) SSO**

C) aaa

D) Ministerio de Asuntos Exteriores

---

43. ¿Cuál de las respuestas enumeradas a continuación se refiere a un conjunto de protocolos y tecnologías que proporcionan cifrado, autenticación e integridad de datos para el tráfico de red?

A) TLS

B) SSH

C) IPSec

D) vpn

---

44. ¿Cuál de las soluciones enumeradas a continuación permite comprobar si un certificado digital ha sido revocado?

A) LOC

✓ **B) CRL**

C) RSE

D) OSPF

45. ¿Cuál de las siguientes respuestas se refiere a un protocolo de enrutamiento utilizado en redes informáticas para determinar la mejor ruta para enrutar paquetes de datos de un nodo de red a otro?

A) BGP
B) EIGRP
C) ROTURA
D) OSPF

46. ¿Cuál de las siguientes respuestas se refiere a una solución de hardware o software que proporciona acceso remoto seguro a redes y recursos?

A) NAC
B) PDR
C) SSH
D) RAS

47. ¿Cuál de las siguientes respuestas se refiere a un protocolo utilizado para configurar conexiones seguras e intercambiar claves criptográficas en VPN IPsec?

A) SSL
✓ B) IKE
C) ESP
D) DHE

48. ¿Cuál de las respuestas enumeradas a continuación se refiere a un mecanismo de control de acceso basado en reglas asociado con archivos y/o directorios?

A) EFS
✓ B) FACL
C) FIM
D) NTFS

49. ¿Cuál de las respuestas enumeradas a continuación se refiere al proceso de mantener la integridad de archivos y datos?

A) DLP
B) SIEM
C) FIM
D) sha

50. ¿Cuál es la forma más rápida de comprobar la validez de un certificado digital?

A) CRL
B) OSPF
C) RSE
✓ D) OCSP

51. ¿Cuál de las respuestas enumeradas a continuación se refiere a un método de codificación (y un formato de archivo) para almacenar objetos criptográficos como certificados X.509, CRL y claves privadas?

A) BCE
✓ B) PEM
C) FIM
D) PFS

52. ¿Cuál de las respuestas enumeradas a continuación se refiere a un método obsoleto basado en TLS para proteger SMTP?

A) desplazados internos
B) INICIO
C) DKIM
D) SMTP

53. ¿Cuáles son los ejemplos de controles preventivos de seguridad? (Seleccione 3 respuestas)

A) Cifrado
B) identificación
C) Sensores
✓ **D) Cortafuegos**
E) Señales de advertencia
✓ **F) software audiovisual**

54. ¿Cuál de las respuestas enumeradas a continuación se refiere(s) a los controles de seguridad de detectives? (Seleccione todo lo que corresponda)

A) Iluminación
✓ **B) Monitoreo de registros**
C) Zona de arena
✓ **D) Auditorías de seguridad**
✓ **E) circuito cerrado de televisión**
✓ **F) identificación**
✓ **G) Escaneo de vulnerabilidades**

55. ¿Qué parte de IPsec proporciona autenticación, integridad y confidencialidad?

A) SPD
B) PFS
C) Ah
✓ **D) ESP**

56. ¿Qué protocolo criptográfico está diseñado para proporcionar comunicaciones seguras a través de una red informática y es el sucesor de SSL?

A) IPSec
✓ **B) TLS**
C) AES
D) CCMP

57. ¿Cuál de las respuestas enumeradas a continuación se refiere a un protocolo utilizado para configurar conexiones seguras e intercambiar claves criptográficas en VPN IPsec?

A) SSL
✓ **B) IKE**
C) ESP
D) DHE

58. ¿Cuál de las siguientes opciones indicaría un intento de ocultar evidencia de actividad maliciosa?

A) Bloqueo de cuenta
B) Inaccesibilidad de recursos
✓ **C) Registros faltantes**
D) Uso simultáneo de sesiones

59. ¿Cuál de las respuestas enumeradas a continuación se refiere a los métodos de cifrado utilizados para proteger los datos en reposo? (Seleccione todo lo que corresponda)

A) FDE
✓ **B) SED**
C) IPSec
D) TLS
✓ **E) vpn**
✓ **F) EFS**

60. ¿Cuál de los protocolos enumerados a continuación se utiliza para permitir la navegación web segura?

A) L2TP
✓ **B) HTTPS**
C) SSH
D) IPSec

61. ¿Cuál de las respuestas enumeradas a continuación se refiere a un reemplazo seguro de Telnet?

A) RSH
B) IPSec
C) SSH
D) RTPS

4.6 - Dado un escenario, implementar y mantener la gestion de identidades y accesos.

Conceptos clave:

- Ciclo de vida de identidades: Provisionamiento, Revision de acceso, Desprovisionamiento
- Protocolos: LDAP, Kerberos, SAML, OAuth, OpenID Connect
- Modelos de acceso: MAC, DAC, RBAC, ABAC, Basado en reglas
- MFA: Algo que sabes, tienes, eres. TOTP, FIDO2, Passwordless
- PAM: Bovedan de contrasenas, Acceso justo-a-tiempo, Grabacion de sesiones

Teoria detallada:

CICLO DE VIDA DE IDENTIDADES:

- Provisionamiento: crear cuenta, asignar rol y permisos cuando el empleado entra. Principio de minimo privilegio
- Verificacion de identidad (Identity proofing): verificar la identidad antes de crear la cuenta
- Desprovisionamiento: CRITICO hacerlo el mismo dia que el empleado sale. Cuentas huerfanas son un riesgo enorme
- Revision de acceso (Access review): revision periodica para asegurarse que cada usuario solo tiene los permisos que necesita. Detecta acumulacion de privilegios
- Acumulacion de privilegios (Privilege creep): acumulacion gradual de permisos a lo largo del tiempo. El empleado gana accesos para proyectos especificos y nunca se los retiran

PROTOCOLOS DE AUTENTICACION Y FEDERACION:

- LDAP (Protocolo Ligero de Acceso a Directorios): puerto 389 (o 636 con LDAPS). Protocolo para consultar directorios (Active Directory)
- Kerberos: protocolo de autenticacion de Windows. Funciona con tickets. El KDC emite un TGT que se usa para obtener tickets de servicio sin reenviar la contrasena
- SAML 2.0: estandar XML para SSO federado entre empresas. El IdP emite aserciones que el SP acepta. Usado en SSO empresarial
- OAuth 2.0: framework de AUTORIZACION (no autenticacion). Permite a una app acceder a recursos en nombre del usuario sin compartir la contrasena. Usado por 'Iniciar sesion con Google'
- OpenID Connect (OIDC): capa de AUTENTICACION sobre OAuth 2.0. Anade el concepto de ID Token (JWT)
- TRUCO: SAML = SSO empresarial entre organizaciones, OAuth = autorizacion de APIs, OIDC = autenticacion moderna sobre OAuth

MODELOS DE CONTROL DE ACCESO - Comparativa:

- MAC (Control de Acceso Obligatorio): el administrador del sistema asigna etiquetas de clasificacion. El SO decide el acceso. Nadie puede cambiar su propio nivel. Ejemplo: sistemas militares
- DAC (Control de Acceso Discrecional): el PROPIETARIO del recurso decide quien puede acceder. El modelo de Windows/Linux con permisos de archivo
- RBAC (Control de Acceso Basado en Roles): el acceso se basa en el ROL del usuario en la organizacion. Mas facil de gestionar que DAC en organizaciones grandes
- ABAC (Control de Acceso Basado en Atributos): el acceso se decide evaluando ATRIBUTOS del usuario, el recurso y el entorno. El mas granular y flexible
- Basado en reglas: reglas fijas que se aplican a todos. Ejemplo: reglas de firewall

MFA - FACTORES DE AUTENTICACION:

- Algo que sabes: contrasena, PIN, patron de desbloqueo, preguntas de seguridad
- Algo que tienes: token hardware (YubiKey, RSA SecurID), smartphone con app TOTP, tarjeta inteligente
- Algo que eres: biometria. Tipos: huella dactilar, reconocimiento facial, iris, voz
- Donde estas: geolocalizacion, IP de red conocida
- TOTP (OTP basado en tiempo): RFC 6238. Codigo de 6 digitos que cambia cada 30 segundos
- FIDO2/WebAuthn: el estandar mas moderno. Usa criptografia asimetrica. La clave privada nunca sale del dispositivo. Resistente a phishing
- Sin contrasena (Passwordless): elimina la contrasena completamente. Usa FIDO2, magic links o biometria

PAM - GESTION DE ACCESO PRIVILEGIADO:

• El mayor riesgo son las cuentas privilegiadas (admin, root, cuentas de servicio)
• Boveda de contrasenas (Password vaulting): las contrasenas de cuentas privilegiadas se almacenan en un vault cifrado (CyberArk, HashiCorp Vault)
• Acceso justo-a-tiempo (JIT): el acceso privilegiado se concede solo cuando se necesita y por un tiempo limitado
• Grabacion de sesiones: todas las acciones de administradores privilegiados se graban para auditoria
• Credenciales efimeras: credenciales de un solo uso que expiran tras ser usadas. Ideal para pipelines CI/CD

Preguntas de practica (80):

1. ¿Qué modelo de control de acceso permite definir reglas granulares que consideran los roles de los usuarios, las limitaciones de tiempo y las restricciones de acceso a la red?

A) ABAC
B) IMPERMEABLE
✓ C) RuBAC
D) CAD
E) RBAC

---

2. ¿Qué modelo de control de acceso define reglas de control de acceso con el uso de declaraciones que se parecen mucho al lenguaje natural?

A) CAD
✓ B) ABAC
C) IMPERMEABLE
D) RBAC

---

3. ¿Cuál de los modelos de control de acceso enumerados a continuación aplica el conjunto más estricto de reglas de acceso?

A) IMPERMEABLE
B) RBAC
C) CAD
D) ABAC

---

4. ¿Cuál de las siguientes respuestas se refiere a un mecanismo de seguridad impuesto por SELinux sobre el acceso al sistema?

A) CAD
B) RBAC
✓ C) IMPERMEABLE
D) ABAC

---

5. ¿Qué tipo de modelo de control de acceso conecta los permisos de los usuarios con sus responsabilidades específicas?

A) CAD
✓ B) RBAC
C) IMPERMEABLE
D) ABAC

---

6. ¿Qué tipo de modelo de control de acceso conecta los permisos de los usuarios con sus responsabilidades específicas?

A) CAD
✓ B) RBAC
C) IMPERMEABLE
D) ABAC

---

7. ¿Qué tipo de modelo de control de acceso conecta los permisos de los usuarios con sus responsabilidades específicas?

A) CAD
✓ B) RBAC
C) IMPERMEABLE
D) ABAC

---

8. ¿Cuáles de las respuestas que se enumeran a continuación se refieren a métodos comunes de autenticación de dispositivos utilizados dentro del marco AAA? (Seleccione 3 respuestas)

A) Nombres de usuario y contraseñas

✓ B) Certificados digitales

✓ C) direcciones IP

D) Ministerio de Asuntos Exteriores

E) Autenticación biométrica

✓ F) Direcciones MAC

---

9. Un mecanismo de control de acceso basado en reglas implementado en enrutadores, conmutadores y firewalls se denomina:

A) IMPERMEABLE

B) PUA

C) CAD

✓ D) LCA

---

10. ¿Cuál de los siguientes métodos de control de acceso sería el más adecuado para programar tareas de mantenimiento del sistema durante períodos de baja actividad del usuario?

A) Aprovisionamiento de recursos

✓ B) Restricciones horarias

C) Principio de privilegio mínimo

D) Permisos justo a tiempo

---

11. ¿Cuál de las siguientes opciones proporciona control granular sobre el acceso de los usuarios a segmentos y recursos de red específicos en función de sus roles y permisos asignados?

A) SOY

B) SSO

C) PAM

D) Ministerio de Asuntos Exteriores

Respuesta no detectada automaticamente

---

12. Un tipo de mecanismo de identificación de usuarios utilizado como contramedida contra el software automatizado (como los robots de red) se conoce como:

A) Ministerio de Asuntos Exteriores

✓ B) CAPTCHA

C) SSO

D) NIDS

---

13. ¿Cuáles son los rasgos característicos de SAML? (Seleccione 3 respuestas)

A) Permite solo el intercambio de datos de autorización SSO

✓ B) Maneja tanto la autenticación como la autorización para SSO

✓ C) Utiliza XML para el intercambio de datos.

✓ D) Comúnmente utilizado en entornos empresariales y sistemas heredados.

E) Permite solo el intercambio de datos de autenticación SSO

F) Utiliza JSON para el intercambio de datos.

G) Diseñado específicamente para aplicaciones web y móviles

---

14. ¿Cuál de las siguientes respuestas se refiere(s) al modelo de control de acceso obligatorio (MAC)? (Seleccione todo lo que corresponda)

A) Los usuarios no pueden cambiar las políticas de acceso a su propia discreción.

✓ B) Las etiquetas y los niveles de autorización solo pueden ser aplicados y modificados por un administrador

C) Cada objeto tiene un propietario que, a su propia discreción, determina qué tipo de permisos pueden tener otros usuarios sobre ese objeto.

D) Acceso a recursos según la identidad del usuario.

✓ E) Cada recurso tiene una etiqueta de confidencialidad que coincide con un nivel de autorización asignado a un usuario.

---

15. En el contexto de la seguridad informática, el término "biometría" se refiere tanto a las características biológicas del cuerpo humano como a los rasgos de comportamiento que pueden utilizarse con fines de identificación y control de acceso.

A) Verdadero

B) FALSO

Respuesta no detectada automaticamente

16. ¿Cuál de los términos enumerados a continuación se refiere al concepto de acceso efímero, donde el acceso a sistemas, recursos o permisos se proporciona por un tiempo limitado? (Seleccione todo lo que corresponda)

A) TOTP

✓ B) OTP

✓ C) Permisos justo a tiempo

D) Contraseña de usuario

E) clave API

17. Un subsistema de autenticación que permite a un usuario acceder a múltiples componentes del sistema conectados (como hosts separados en una red) después de un único inicio de sesión en solo uno de los componentes se denomina:

A) NAC

✓ B) SSO

C) aaa

D) Ministerio de Asuntos Exteriores

18. ¿Cuál de las respuestas enumeradas a continuación se refiere a un mecanismo de control de acceso basado en reglas asociado con archivos y/o directorios?

A) EFS

✓ B) FACL

C) FIM

D) NTFS

19. Un tipo de mecanismo de identificación de usuarios utilizado como contramedida contra el software automatizado (como los robots de red) se conoce como:

A) Ministerio de Asuntos Exteriores

✓ B) CAPTCHA

C) SSO

D) NIDS

20. ¿Cuál de las siguientes respuestas se refiere(s) al modelo de control de acceso obligatorio (MAC)? (Seleccione todo lo que corresponda)

A) Los usuarios no pueden cambiar las políticas de acceso a su propia discreción.

✓ B) Las etiquetas y los niveles de autorización solo pueden ser aplicados y modificados por un administrador

C) Cada objeto tiene un propietario que, a su propia discreción, determina qué tipo de permisos pueden tener otros usuarios sobre ese objeto.

D) Acceso a recursos según la identidad del usuario.

✓ E) Cada recurso tiene una etiqueta de confidencialidad que coincide con un nivel de autorización asignado a un usuario.

21. Ejemplos de propiedades utilizadas para definir políticas de acceso en el modelo de control de acceso basado en atributos (ABAC) incluyen:

A) Asunto (es decir, usuario o proceso que solicita acceso)

B) Tipo de acción (por ejemplo "leer", "escribir", "ejecutar")

C) Tipo de recurso (historial médico, cuenta bancaria, etc.)

D) Entorno (datos contextuales, como hora del día o geolocalización)

✓ E) Todo lo anterior

22. ¿Cuál de las respuestas enumeradas a continuación se refiere(s) a controles de seguridad compensatorios? (Seleccione todo lo que corresponda)

A) Sistemas de energía de respaldo

B) Videovigilancia

✓ C) Ministerio de Asuntos Exteriores

✓ D) Zona de pruebas de aplicaciones

✓ E) Segmentación de red

---

23. ¿Cuál de los siguientes términos entran en la categoría de controles de seguridad directivos? (Seleccione 2 respuestas)

A) PIR

✓ B) PUA

C) identificación

D) Ministerio de Asuntos Exteriores

E) IPS

---

24. ¿Cuál de los siguientes combina una función hash criptográfica con una clave secreta para proporcionar un medio para verificar tanto la autenticidad como la integridad de un mensaje o datos?

A) MD5

B) DSA

✓ C) HMAC

D) DES

---

25. ¿Cuál de los siguientes es un ejemplo de un algoritmo de extensión de claves?

A) RIPEMD

B) sha

C) HMAC

✓ D) PBKDF2

---

26. ¿Cuál de las respuestas enumeradas a continuación se refiere a un vector de amenaza basado en archivos?

A) Explotaciones de PDF

B) Macros maliciosas en documentos

C) Archivos comprimidos (ZIP, RAR)

D) Scripts maliciosos en páginas web

E) Imágenes infectadas

F) Ejecutables maliciosos

✓ G) Todo lo anterior

---

27. ¿Cuál de las siguientes respuestas se refiere a vectores de amenazas de software sin agentes? (Seleccione 2 respuestas)

A) Correo electrónico de phishing

B) Unidad USB maliciosa

✓ C) Vulnerabilidad del protocolo de red

D) Macro infectada

✓ E) rastreo de paquetes

---

28. ¿Cuál de las siguientes respuestas no se refiere a un tipo común de vulnerabilidad basada en el sistema operativo?

A) Vulnerabilidades de control de acceso y permisos (contraseñas débiles, escalada de privilegios)

B) Vulnerabilidades en aplicaciones instaladas, utilidades del sistema y controladores de dispositivos.

C) Vulnerabilidades relacionadas con la memoria (pérdidas de memoria, desbordamientos de búfer, condiciones de carrera)

D) Vulnerabilidades en la gestión de parches y actualizaciones (parches de seguridad y retrasos en las actualizaciones, actualizaciones maliciosas)

E) Vulnerabilidades relacionadas con configuraciones erróneas del sistema/seguridad

F) Vulnerabilidades relacionadas con la red (ataques DoS, ataques de ejecución remota de código)

✓ G) Todas las opciones de respuesta anteriores son ejemplos de vulnerabilidades basadas en sistemas operativos.

29. ¿Cuál de las siguientes respuestas se refiere a un tipo de software integrado en un chip de hardware?

A) firmware

B) software intermedio

C) Controlador de dispositivo

D) Código máquina

Respuesta no detectada automaticamente

30. ¿Cuál de los siguientes exploits apunta a un protocolo utilizado para administrar y acceder a recursos en red?

A) Ataque CSRF/XSRF

✓ B) Ataque de inyección XML

✓ C) Ataque de inyección LDAP

D) Ataque de inyección SQL

31. Un ataque de punto, punto y barra también se conoce como:

A) Ataque de disociación

B) Ataque en el camino

✓ C) Ataque transversal de directorio

D) Ataque de degradación

32. ¿Cuál de los términos enumerados a continuación describe con mayor precisión una situación en la que se utiliza una sola cuenta desde múltiples ubicaciones/dispositivos al mismo tiempo?

A) Ataque de fumigación

✓ B) Uso simultáneo de sesiones

C) Inicio de sesión único (SSO)

D) viaje imposible

33. ¿Cuál de las respuestas enumeradas a continuación se refiere a una solución que simplifica las configuraciones del navegador web mediante el uso de reglas o scripts predefinidos para tomar decisiones de selección de servidores para tráfico web específico?

A) PAC

B) DDNS

C) PAM

D) NAT

34. ¿Cuáles de las respuestas enumeradas a continuación se refieren a ejemplos de tipos de datos no legibles por humanos? (Seleccione 2 respuestas)

A) código binario

B) archivos XML

✓ C) Lenguaje máquina

D) código HTML

E) consultas SQL

35. Una representación basada en archivos del estado de una máquina virtual en un momento dado se denomina:

A) Punto de restauración

B) Copia sombra

✓ C) Instantánea

D) Imagen del sistema

36. ¿Cuál de los términos enumerados a continuación se utiliza para describir un nivel fundamental de configuraciones y ajustes de seguridad necesarios para salvaguardar un sistema?

A) Segmentación lógica

✓ B) Línea de base segura

C) Niveles de control de acceso

D) Principio de privilegio mínimo

37. ¿Cuál de las respuestas enumeradas a continuación se refiere al software que facilita la aplicación de políticas y procedimientos de dispositivos móviles?

A) NAC
B) DM
C) XDR
D) PAM

38. ¿Cuál de las siguientes respuestas se refiere a una función de seguridad utilizada en el emparejamiento de dispositivos Bluetooth?

A) SAE
✓ B) ALFILER
C) Ministerio de Asuntos Exteriores
D) LCA

39. ¿Cuál de las siguientes afirmaciones no se aplica a la web oscura?

A) Normalmente requiere software especializado para acceder a sus contenidos.
✓ B) Forma una gran parte de la web profunda.
C) No indexado por los motores de búsqueda tradicionales.
D) A menudo se asocia con el comercio de datos robados, malware y amenazas cibernéticas.

40. ¿Cuál de las afirmaciones enumeradas a continuación no se refiere a una técnica de respuesta y remediación de vulnerabilidades?

A) Aplicar actualizaciones o correcciones proporcionadas por proveedores de software para abordar la vulnerabilidad (parches)
B) Garantizar la recuperación financiera de los costos asociados con un ciberataque exitoso (seguro)
C) Dividir una red en zonas más pequeñas y aisladas para limitar el impacto potencial de una vulnerabilidad (segmentación)
D) Mitigar el riesgo asociado con una vulnerabilidad que no se puede reparar de inmediato mediante la implementación de medidas de seguridad alternativas (controles de compensación)
E) Retrasar o renunciar a un parche para un sistema específico, por ejemplo, cuando aplicar un parche puede no ser factible debido a problemas de compatibilidad o posibles interrupciones en sistemas críticos (excepciones y exenciones).
✓ F) Todas las respuestas anteriores son ejemplos de técnicas de respuesta y remediación de vulnerabilidades.

41. El Protocolo simple de administración de red (SNMP) es un protocolo de capa de aplicación basado en UDP que se utiliza en sistemas de administración de red para monitorear dispositivos conectados a la red. SNMP suele estar integrado en la mayoría de los dispositivos de infraestructura de red modernos, como enrutadores, puentes, conmutadores, servidores, impresoras, fotocopiadoras, máquinas de fax y otros dispositivos conectados a la red. Una red administrada por SNMP consta de tres componentes esenciales: un dispositivo administrado, un módulo de software de administración de red que reside en un dispositivo administrado (Agente) y una estación de administración de red (NMS), que ejecuta aplicaciones responsables de monitorear y controlar los dispositivos administrados, así como de recopilar información SNMP de los Agentes. El administrador recibe notificaciones (Traps e InformRequests) en el puerto UDP 162, mientras que el agente SNMP recibe solicitudes en el puerto UDP 161.

A) Verdadero
B) FALSO
Respuesta no detectada automaticamente

42. ¿Cuál de las siguientes respuestas se refiere a una solución que ayuda a las organizaciones a mitigar los riesgos asociados con filtraciones de datos, amenazas internas e infracciones de cumplimiento?

A) EDR
B) DLP
C) SOY
D) UTM

43. OpenID Connect es un protocolo utilizado para:

A) Atestación
B) Autorización
C) Revisión de cuentas
✓ D) Autenticación

44. ¿Cuál de las respuestas enumeradas a continuación se refiere a un tipo de medio que se puede utilizar como token de autenticación de hardware? (Seleccione todo lo que corresponda)

A) tarjeta inteligente

✓ B) llavero

✓ C) clave de seguridad

D) frase de contraseña

E) Lector biométrico

✓ F) insignia rfid

---

45. ¿Cuál de las respuestas enumeradas a continuación se refieren a las características de una llave de seguridad? (Seleccione 3 respuestas)

A) Se utiliza para generación de OTP, acceso remoto a vehículos y acceso a edificios.

✓ B) Token de autenticación de hardware

✓ C) Normalmente, una memoria USB física o un dispositivo del tamaño de un llavero

✓ D) Utilizado principalmente para seguridad digital (2FA/MFA)

E) Token de autenticación de software

F) Normalmente, una tarjeta de plástico del tamaño de una tarjeta de crédito con un chip integrado.

---

46. ¿Cuál de las respuestas enumeradas a continuación se refiere a una herramienta de software diseñada específicamente para almacenar y administrar las credenciales de inicio de sesión?

A) BitLocker

B) Administrador de contraseñas

C) depósito de claves

D) Bóveda de contraseñas

---

47. ¿Cuál de las respuestas enumeradas a continuación se refiere a organizaciones del sector público que establecen y hacen cumplir leyes y regulaciones a nivel local, regional o nacional?

A) Entidades gubernamentales

B) Asociaciones comerciales

C) Organismos estatutarios

D) Agencias reguladoras

---

48. ¿Cuál de las respuestas enumeradas a continuación se refiere a organizaciones o personas responsables de garantizar el cumplimiento de las leyes de protección de datos?

A) Controladores

B) Mayordomos

C) Propietarios

D) Procesadores

---

49. ¿Cuál de las siguientes respuestas se refiere a entidades que actúan en nombre del responsable del tratamiento para realizar tareas específicas relacionadas con los datos?

A) Mayordomos

B) Propietarios

C) Procesadores

D) Controladores

---

50. ¿Cuál de las siguientes respuestas se refiere a una entidad (como una organización o un individuo) que determina el propósito y los medios del procesamiento de datos personales?

✓ A) Procesador de datos

B) Propietario de los datos

✓ C) Responsable del tratamiento

D) Interesado

---

51. Un tipo de mecanismo de identificación de usuarios utilizado como contramedida contra el software automatizado (como los robots de red) se conoce como:

A) Ministerio de Asuntos Exteriores

✓ B) CAPTCHA

C) LCA
D) PNI

52. Un tipo de documento que estipula reglas de comportamiento que deben seguir los usuarios de computadoras, redes y recursos asociados se denomina:

A) SLA
B) CLUF
✓ C) PUA
D) BPA

53. ¿Cuál de los términos enumerados a continuación se aplica al proceso de autenticación?

A) Ministerio de Asuntos Exteriores
B) MMC
C) DM
D) MFD

54. ¿Cuál de las respuestas enumeradas a continuación se refiere a un término amplio que abarca varios sistemas de control y automatización utilizados en entornos industriales para controlar y monitorear procesos físicos y maquinaria?

A) ICS
B) SOCIEDAD ANÓNIMA
C) SCADA
D) HMI

55. ¿Cuál de los acrónimos enumerados a continuación se refiere a una pieza de hardware y software/firmware asociado diseñado para proporcionar funciones criptográficas y de administración de claves?

A) EFS
✓ B) HSM
C) SFC
D) TPM

56. Una medida de la probabilidad de que un sistema de seguridad biométrico rechace incorrectamente un intento de acceso por parte de un usuario autorizado se denomina:

A) LEJOS
B) CER
C) CDN
✓ D) FRR

57. ¿Cuál de las respuestas enumeradas a continuación se refiere a un método criptográfico utilizado para verificar que un mensaje o dato ha permanecido inalterado durante la transmisión y proviene de una fuente autorizada?

A) IMPERMEABLE
B) CBC
C) PEM
D) GCM

58. En una red protegida por Kerberos, este tipo de token seguro se otorga a los usuarios durante su inicio de sesión inicial para permitirles acceder a múltiples servicios de red sin la necesidad de volver a ingresar su información de inicio de sesión.

A) OTP
✓ B) TGT
C) COMO
D) TGS

59. ¿Cuál de las siguientes respuestas se refiere a un lenguaje utilizado principalmente para automatizar la evaluación de vulnerabilidades de seguridad y problemas de configuración en sistemas informáticos?

A) OVAL

B) SAML
C) XML
D) JABÓN

60. ¿Qué registros DNS TXT se utilizan para la gestión de spam? (Seleccione 3 respuestas)

A) FPS
✓ B) DKIM
C) SRV
✓ D) DMARC
E) PTR

61. ¿Cuál de los siguientes combina una función hash criptográfica con una clave secreta para proporcionar un medio para verificar tanto la autenticidad como la integridad de un mensaje o datos?

A) MD5
B) DSA
✓ C) HMAC
D) DES

62. ¿Cuál de las respuestas enumeradas a continuación se refiere a un lenguaje utilizado para estructurar y describir datos en un formato que sea legible tanto por humanos como por máquinas?

A) HTML
B) XML
C) JSON
D) HTML

63. ¿Cuál de las siguientes respuestas se refiere a un protocolo de cifrado utilizado principalmente en redes Wi-Fi que implementan el estándar de seguridad WPA2?

A) TKIP
B) CCMP
C) SSL
D) HMAC

64. ¿Cuál de las respuestas enumeradas a continuación se refiere a una solución que simplifica las configuraciones del navegador web mediante el uso de reglas o scripts predefinidos para tomar decisiones de selección de servidores para tráfico web específico?

A) PAC
B) DDNS
C) PAM
D) NAT

65. ¿Cuál de las respuestas enumeradas a continuación se refiere(s) a controles de seguridad compensatorios? (Seleccione todo lo que corresponda)

A) Sistemas de energía de respaldo
B) Videovigilancia
✓ C) Ministerio de Asuntos Exteriores
✓ D) Zona de pruebas de aplicaciones
✓ E) Segmentación de red

66. ¿Cuál de los siguientes términos entran en la categoría de controles de seguridad directivos? (Seleccione 2 respuestas)

A) PIR
✓ B) PUA
C) identificación
D) Ministerio de Asuntos Exteriores
E) IPS

67. ¿Qué protocolo criptográfico está diseñado para proporcionar comunicaciones seguras a través de una red informática y es el sucesor de SSL?

A) IPSec

✓ **B) TLS**

C) AES

D) CCMP

68. ¿Cuál de las respuestas enumeradas a continuación se refiere a una función hash criptográfica que se ha utilizado ampliamente en el pasado pero que ahora se considera obsoleta para aplicaciones sensibles a la seguridad debido a vulnerabilidades conocidas?

A) MD5

B) sha

C) CDN

D) HMAC

Respuesta no detectada automaticamente

69. ¿Cuál de las funciones hash enumeradas a continuación ofrece el mayor nivel de seguridad?

A) MD5

✓ **B) SHA-3**

C) RIPEMD-160

✓ **D) HMAC**

70. ¿Cuál de las respuestas enumeradas a continuación se refiere a un vector de amenaza basado en archivos?

A) Explotaciones de PDF

B) Macros maliciosas en documentos

C) Archivos comprimidos (ZIP, RAR)

D) Scripts maliciosos en páginas web

E) Imágenes infectadas

F) Ejecutables maliciosos

G) Todo lo anterior

71. ¿Cuál sería una respuesta apropiada del usuario ante un intento de phishing por correo electrónico? (Seleccione todo lo que corresponda)

A) No responder al mensaje ni proporcionar ningún dato personal.

✓ **B) Reportar el mensaje al departamento de TI o seguridad, si corresponde**

✓ **C) Eliminar el mensaje de la bandeja de entrada**

✓ **D) No hacer clic en ningún enlace ni descargar ningún archivo adjunto en el mensaje**

E) Reenviar el mensaje al remitente para verificar su legitimidad

F) Abrir el archivo adjunto en un entorno sandbox para comprobar su seguridad

72. Un ataque de disociación inalámbrica es un tipo de: (Seleccione 2 respuestas)

A) Ataque de degradación

✓ **B) Ataque de desautenticación**

C) Ataque de fuerza bruta

✓ **D) Ataque DoS**

E) Ataque criptográfico

73. ¿Qué tipo de exploit se dirige a aplicaciones web que generan contenido utilizado para almacenar y transportar datos?

A) Ataque de inyección SQL

B) Ataque CSRF/XSRF

✓ **C) Ataque de inyección XML**

D) Ataque de inyección LDAP

74. ¿Cuál de los términos enumerados a continuación describe con mayor precisión una situación en la que se utiliza una sola cuenta desde múltiples ubicaciones/dispositivos al mismo tiempo?

A) Ataque de fumigación

✓ **B) Uso simultáneo de sesiones**

C) Inicio de sesión único (SSO)
D) viaje imposible

75. ¿Cuál de las respuestas enumeradas a continuación se refiere a algún tipo de información perteneciente a un individuo que pueda usarse para identificar de manera única a esa persona?

A) FI
B) Biometría
C) IDENTIFICACIÓN
✓ D) PII

76. Una representación basada en archivos del estado de una máquina virtual en un momento dado se denomina:

A) Punto de restauración
B) Copia sombra
✓ C) Instantánea
D) Imagen del sistema

77. ¿Cuál de las siguientes respuestas se refiere a una función de seguridad utilizada en el emparejamiento de dispositivos Bluetooth?

A) SAE
✓ B) ALFILER
C) Ministerio de Asuntos Exteriores
D) LCA

78. ¿Cuál de las siguientes afirmaciones no se aplica a la web oscura?

A) Normalmente requiere software especializado para acceder a sus contenidos.
✓ B) Forma una gran parte de la web profunda.
C) No indexado por los motores de búsqueda tradicionales.
D) A menudo se asocia con el comercio de datos robados, malware y amenazas cibernéticas.

79. ¿Cuál de las afirmaciones enumeradas a continuación no se refiere a una técnica de respuesta y remediación de vulnerabilidades?

A) Aplicar actualizaciones o correcciones proporcionadas por proveedores de software para abordar la vulnerabilidad (parches)
B) Garantizar la recuperación financiera de los costos asociados con un ciberataque exitoso (seguro)
C) Dividir una red en zonas más pequeñas y aisladas para limitar el impacto potencial de una vulnerabilidad (segmentación)
D) Mitigar el riesgo asociado con una vulnerabilidad que no se puede reparar de inmediato mediante la implementación de medidas de seguridad alternativas (controles de compensación)
E) Retrasar o renunciar a un parche para un sistema específico, por ejemplo, cuando aplicar un parche puede no ser factible debido a problemas de compatibilidad o posibles interrupciones en sistemas críticos (excepciones y exenciones).
✓ F) Todas las respuestas anteriores son ejemplos de técnicas de respuesta y remediación de vulnerabilidades.

80. ¿Cuál de las respuestas enumeradas a continuación se refiere a una herramienta de software diseñada específicamente para almacenar y administrar las credenciales de inicio de sesión?

A) BitLocker
B) Administrador de contraseñas
C) depósito de claves
D) Bóveda de contraseñas

4.7 - Explicar la importancia de la automatizacion y orquestacion de seguridad.

Conceptos clave:

- SOAR: Orquestacion, Automatizacion, Respuesta a incidentes
- Casos de uso: Provisionamiento, Enriquecimiento de amenazas, Creacion de tickets
- Beneficios: Velocidad, Consistencia, Escalabilidad
- Riesgos: Punto unico de fallo, Complejidad, Deuda tecnica

Teoria detallada:

AUTOMATIZACION Y ORQUESTACION EN SEGURIDAD:

- Automatizacion: ejecutar una tarea especifica sin intervencion humana (un script que bloquea una IP)
- Orquestacion: coordinar MULTIPLES herramientas y procesos automatizados en un flujo de trabajo
- SOAR (Orquestacion, Automatizacion y Respuesta de Seguridad): plataforma que integra herramientas de seguridad y automatiza la respuesta a incidentes

Ejemplo de playbook SOAR: alerta de phishing → extraer IOCs del email → buscar en SIEM → bloquear dominio en firewall → aislar endpoint → crear ticket → notificar al usuario → todo en segundos sin intervencion humana

CASOS DE USO REALES:

- Provisionamiento/desprovisionamiento de usuarios: cuando RRHH crea/desactiva un empleado, se dispara automaticamente la gestion de todas sus cuentas
- Enriquecimiento de inteligencia de amenazas: cuando el SIEM genera una alerta con una IP, el SOAR consulta automaticamente VirusTotal, Shodan y feeds de threat intel
- Creacion automatica de tickets: cada alerta critica del SIEM crea automaticamente un ticket en ServiceNow/Jira
- Remediacion de vulnerabilidades: cuando el scanner detecta una vulnerabilidad critica, se crea el ticket y se asigna al equipo correcto con el SLA establecido
- Actualizacion de grupos de seguridad: cuando un endpoint se comporta de forma sospechosa, se mueve automaticamente a una VLAN de cuarentena

BENEFICIOS vs RIESGOS:

- Beneficios: velocidad (segundos vs horas), consistencia (siempre hace lo mismo), escalabilidad (gestiona miles de alertas simultaneas), multiplicador de fuerza de trabajo
- Riesgos: Punto unico de fallo (si el SOAR falla, los procesos automatizados tambien), complejidad (bugs en playbooks pueden causar acciones incorrectas), deuda tecnica (playbooks obsoletos), sobre-automatizacion (automatizar decisiones que requieren criterio humano)

SCRIPTING Y APIs:

- Python: el lenguaje mas usado en seguridad para automatizacion. Scripts para parsear logs, interactuar con APIs, analizar malware
- APIs REST: permiten integrar herramientas de seguridad entre si. El SIEM puede llamar a la API del firewall para bloquear una IP
- DevSecOps: integrar pruebas de seguridad (SAST, DAST, escaneo de dependencias) en el pipeline de desarrollo para detectar vulnerabilidades antes de produccion

Preguntas de practica (12):

1. ¿Cuál de los siguientes términos se refiere al uso de tecnología para realizar tareas individuales con mínima intervención humana?

A) Automatización
B) secuencias de comandos
✓ C) Orquestación
D) Secuenciación

---

2. ¿Cuál de los términos enumerados a continuación se refiere a un proceso que se ocupa de coordinar y gestionar múltiples tareas repetitivas?

A) Secuenciación
B) Orquestación
C) secuencias de comandos
D) Automatización

---

3. Una colección de funciones precompiladas diseñadas para ser utilizadas por más de una aplicación de Microsoft Windows simultáneamente para ahorrar recursos del sistema se conoce como:

A) DLL
B) API
C) EXE
D) INI

---

4. ¿Cuál de las respuestas enumeradas a continuación describe las características de un ataque de secuencias de comandos entre sitios? (Seleccione 3 respuestas)

A) Explota la confianza que el navegador web de un usuario tiene en un sitio web

✓ **B) Se inyecta un script malicioso en un sitio web confiable**

✓ **C) El navegador del usuario ejecuta el script del atacante**

D) Explota la confianza que un sitio web tiene en el navegador web del usuario.

E) Un atacante engaña a un usuario para que envíe solicitudes web no autorizadas

F) El sitio web ejecuta las solicitudes del atacante

---

5. ¿Cuál de los términos enumerados a continuación se refiere al concepto de acceso efímero, donde el acceso a sistemas, recursos o permisos se proporciona por un tiempo limitado? (Seleccione todo lo que corresponda)

A) TOTP

✓ **B) OTP**

✓ **C) Permisos justo a tiempo**

D) Contraseña de usuario

E) clave API

---

6. ¿Cuál de las siguientes soluciones alivia el problema del agotamiento del espacio de direcciones IPv4 al permitir que varios hosts en la misma LAN privada compartan una única dirección IP pública?

A) DNS

B) APIPA

✓ **C) NAT**

D) DHCP

---

7. ¿Cuál de las respuestas enumeradas a continuación se refiere a un estándar de la industria para evaluar y calificar la gravedad de las vulnerabilidades de seguridad de los sistemas informáticos?

A) SIEM

B) cvss

C) OSINT

D) REMONTARSE

---

8. ¿Cuál de las respuestas enumeradas a continuación se refiere a un término amplio que abarca varios sistemas de control y automatización utilizados en entornos industriales para controlar y monitorear procesos físicos y maquinaria?

A) ICS

B) SOCIEDAD ANÓNIMA

C) SCADA

D) HMI

---

9. ¿Cuál de las siguientes respuestas se refiere a un intérprete de comandos basado en texto y un lenguaje de programación para sistemas operativos tipo Unix?

A) CLI

B) js

C) Intento

D) cmd.exe

---

10. ¿Cuál de las siguientes respuestas se refiere a un marco de ciberseguridad que combina funciones de red y seguridad en un único servicio basado en la nube?

A) SASE

B) SIEM

C) SWG

D) REMONTARSE

---

11. ¿Cuál de las siguientes tecnologías permite el manejo automatizado de múltiples incidentes de seguridad?

A) JABÓN

B) SIEM

✓ **C) REMONTARSE**

D) SASE

---

12. ¿Cuál de las respuestas enumeradas a continuación describe las características de un ataque de secuencias de comandos entre sitios? (Seleccione 3 respuestas)

A) Explota la confianza que el navegador web de un usuario tiene en un sitio web

✓ B) Se inyecta un script malicioso en un sitio web confiable

✓ C) El navegador del usuario ejecuta el script del atacante

D) Explota la confianza que un sitio web tiene en el navegador web del usuario.

E) Un atacante engaña a un usuario para que envíe solicitudes web no autorizadas

F) El sitio web ejecuta las solicitudes del atacante

4.8 - Explicar los conceptos apropiados de respuesta a incidentes.

Conceptos clave:

- Fases NIST: Preparacion, Deteccion/Analisis, Contencion, Erradicacion, Recuperacion, Lecciones aprendidas
- Forense: Legal hold, Cadena de custodia, Orden de volatilidad, Write blocker
- Threat hunting: Busqueda proactiva usando TTPs y MITRE ATT&CK

Teoria detallada:

LAS 6 FASES DE RESPUESTA A INCIDENTES (NIST SP 800-61):

- 1. PREPARACION: antes de que ocurra nada. Crear el IRP, formar el equipo, preparar herramientas forenses, establecer canales de comunicacion, realizar ejercicios de mesa periodicos
- 2. DETECCION Y ANALISIS: identificar que ha ocurrido un incidente. Fuentes: SIEM, AV, usuarios, logs. Determinar alcance, sistemas afectados y tipo de incidente. Clasificar la severidad
- 3. CONTENCION: limitar el dano. Dos tipos:

- Corto plazo: aislar el sistema afectado de la red inmediatamente

- Largo plazo: parchear la vulnerabilidad, cambiar credenciales comprometidas, reforzar controles

- 4. ERRADICACION: eliminar la causa raiz. Eliminar malware, cerrar backdoors, revocar credenciales comprometidas, aplicar parches
- 5. RECUPERACION: restaurar sistemas a operacion normal. Restaurar desde backups limpios, monitorizar intensamente
- 6. LECCIONES APRENDIDAS: post-mortem. Que paso, como se detecto, que funciono, que no funciono, que hay que mejorar. OBLIGATORIO documentarlo

MNEMOTECNICO: 'Pedro Detiene Corriendo El Recorrido Lento' → Preparacion, Deteccion, Contencion, Erradicacion, Recuperacion, Lecciones aprendidas

FORENSE DIGITAL - Conceptos criticos para el examen:

- Retencion legal (Legal hold): lo PRIMERO al inicio de una investigacion legal. Notificacion formal para preservar TODA la evidencia relevante. No se puede borrar nada una vez emitido
- Cadena de custodia (Chain of custody): registro detallado de quien ha manejado la evidencia, cuando, donde y por que. Sin cadena de custodia intacta, la evidencia puede ser inadmisible en juicio
- Orden de volatilidad (RFC 3227): orden en que recoger evidencias de mas a menos volatil:

1. Registros de CPU y cache
2. Memoria RAM (contiene procesos activos, conexiones, claves de cifrado)
3. Trafico de red activo
4. Estado del sistema operativo
5. Disco duro
6. Logs remotos y backups

- Bloqueador de escritura (Write blocker): dispositivo hardware que impide modificar el disco original al hacer la imagen forense
- Imagen forense: copia bit a bit del disco. Se verifica con hash MD5/SHA-256 que la copia es identica al original
- Descubrimiento electronico (E-discovery): proceso legal de identificar, preservar y producir evidencias digitales

CAZA DE AMENAZAS (Threat Hunting):

- Busqueda PROACTIVA de amenazas que han evadido los controles automaticos
- No espera a que el SIEM alerte. El analista formula hipotesis ('podria haber un atacante que...')
- Se basa en conocimiento de TTPs (Tacticas, Tecnicas y Procedimientos) del adversario (MITRE ATT&CK)
- Herramientas: EDR, SIEM, logs de red, feeds de inteligencia de amenazas

Preguntas de practica (27):

1. En el proceso de respuesta a incidentes, el paso que implica identificar y comprender incidentes potenciales para determinar su alcance, impacto y causa raíz es parte de:

A) Etapa de preparación

✓ B) Etapa de detección y análisis.

C) Etapa de contención, erradicación y recuperación.

D) Etapa de actividad posterior al incidente

---

2. ¿Qué etapa del proceso de respuesta a incidentes implica la actualización de los planes, políticas y procedimientos de respuesta a incidentes?

A) Preparación

B) Detección y análisis

C) Contención, erradicación y recuperación

✓ D) Actividad posterior al incidente

---

3. ¿Qué parte del proceso de respuesta a incidentes implica establecer y mantener la capacidad de respuesta a incidentes, así como establecer un equipo de respuesta a incidentes?

A) Preparación

B) Detección y análisis

C) Contención, erradicación y recuperación

D) Actividad posterior al incidente

---

4. ¿Cuál de las siguientes respuestas se refiere(s) a la etapa de contención, erradicación y recuperación del proceso de respuesta a incidentes? (Seleccione todo lo que corresponda)

A) Restaurando operaciones normales

✓ B) Eliminando la amenaza

C) Seguimiento y detección de posibles incidencias

D) Establecer y mantener una política de respuesta a incidentes.

✓ E) Mitigar el impacto del incidente

---

5. Durante la etapa de actividad posterior al incidente, este paso implica analizar registros, datos forenses y otras pruebas para evitar que el incidente vuelva a ocurrir.

A) Informes

B) descubrimiento electrónico

✓ C) Análisis de causa raíz

D) caza de amenazas

---

6. ¿Cuál de las siguientes respuestas se refiere a un escenario más realista que prueba la respuesta a incidentes de ciberseguridad imitando ataques reales?

A) Toma de huellas dactilares

✓ B) Simulación

C) caza de amenazas

D) Ejercicio de mesa

---

7. ¿Cuál de las siguientes respuestas se refiere a SCAP? (Seleccione 3 respuestas)

A) Un tipo de sistema de seguridad diseñado para recopilar registros y eventos de diversas fuentes.

✓ B) Diseñado para proporcionar una interfaz de usuario centralizada para acceder a los datos recopilados.

✓ C) Una colección de estándares desarrollados por NIST

✓ D) Proporciona un lenguaje común para comunicar información de seguridad.

✓ E) Permite que diferentes herramientas de seguridad compartan datos y trabajen juntas de manera más efectiva

F) Permite la detección de amenazas en tiempo real, la respuesta a incidentes y el monitoreo del cumplimiento

---

8. El término "búsqueda de amenazas" se refiere a una búsqueda proactiva de IoC para identificar y abordar posibles amenazas y vulnerabilidades antes de que puedan convertirse en incidentes en toda regla.

A) Verdadero

B) FALSO

Respuesta no detectada automaticamente

9. El proceso de identificar, recopilar y producir información almacenada electrónicamente con la intención de utilizarla en un procedimiento o investigación legal se conoce como:

A) Retención por litigio

B) Gestión de pruebas

C) Forense digital

✓ D) descubrimiento electrónico

---

10. ¿Cuál de las siguientes respuestas se refiere a un escenario más realista que prueba la respuesta a incidentes de ciberseguridad imitando ataques reales?

A) Toma de huellas dactilares

✓ B) Simulación

C) caza de amenazas

D) Ejercicio de mesa

---

11. ¿Cuál de las respuestas enumeradas a continuación se refiere a una actividad basada en debates en la que los miembros del equipo recorren diferentes escenarios para evaluar el plan de respuesta a incidentes sin activar ningún sistema?

A) Ejercicio de mesa

✓ B) Simulación

C) caza de amenazas

D) Análisis de causa raíz

---

12. Un tipo de evidencia forense que puede usarse para detectar intentos de acceso no autorizados u otras actividades maliciosas se denomina:

A) CVE

✓ B) COI

C) AIS

D) OSINT

---

13. ¿Cuál de las respuestas enumeradas a continuación se refiere a las ventajas de la segmentación como método para proteger los datos? (Seleccione 3 respuestas)

A) Mejora la seguridad al limitar la propagación de ciberataques

✓ B) Ayuda a las organizaciones a cumplir con los requisitos normativos de datos aislando y protegiendo tipos de datos específicos

C) Proporciona seguridad para los datos en tránsito con el uso de cifrado.

D) Garantiza la recuperación de datos en caso de eliminación accidental o fallas del sistema.

✓ E) Proporciona un mejor control sobre el acceso de los usuarios a datos confidenciales.

---

14. Una instalación de recuperación ante desastres que proporciona únicamente el espacio físico para las operaciones de recuperación se conoce como:

A) sitio caliente

B) Sitio cálido

✓ C) Sitio frio

D) Sitio espejo

---

15. ¿Qué sitio alternativo permite la recuperación ante desastres más rápida?

A) Sitio frio

✓ B) sitio caliente

C) sitio móvil

D) Sitio cálido

---

16. ¿Cuál de las respuestas enumeradas a continuación se refiere a un escenario simulado llevado a cabo en un entorno controlado, que generalmente implica discusiones y planificación en torno a incidentes de seguridad hipotéticos?

A) Ejercicio de mesa

B) Zona de arena

C) caza de amenazas

D) Capacitación en concientización sobre seguridad.

Respuesta no detectada automaticamente

17. Una de las formas de evitar la recuperación de datos de una unidad de almacenamiento es sobrescribir su contenido. La técnica de sobrescritura de datos la utilizan las utilidades de borrado de unidades que pueden emplear diferentes métodos (incluidas múltiples rondas de sobrescritura) para disminuir la probabilidad de recuperación de datos. Como ejemplo, una utilidad de desinfección de disco podría sobrescribir los datos de la unidad con el valor de uno en la primera pasada, cambiar ese valor a cero en la segunda pasada y, finalmente, realizar algunas pasadas más, sobrescribiendo el contenido con caracteres aleatorios.

A) Verdadero

B) FALSO

18. ¿Cuál de las afirmaciones enumeradas a continuación no se refiere a una técnica de respuesta y remediación de vulnerabilidades?

A) Aplicar actualizaciones o correcciones proporcionadas por proveedores de software para abordar la vulnerabilidad (parches)

B) Garantizar la recuperación financiera de los costos asociados con un ciberataque exitoso (seguro)

C) Dividir una red en zonas más pequeñas y aisladas para limitar el impacto potencial de una vulnerabilidad (segmentación)

D) Mitigar el riesgo asociado con una vulnerabilidad que no se puede reparar de inmediato mediante la implementación de medidas de seguridad alternativas (controles de compensación)

E) Retrasar o renunciar a un parche para un sistema específico, por ejemplo, cuando aplicar un parche puede no ser factible debido a problemas de compatibilidad o posibles interrupciones en sistemas críticos (excepciones y exenciones).

✓ F) Todas las respuestas anteriores son ejemplos de técnicas de respuesta y remediación de vulnerabilidades.

19. ¿Cuál de las siguientes respuestas se refiere a un ejercicio más profundo, que puede incluir activar sistemas y realizar acciones reales para responder al incidente?

A) Pruebas de penetración

B) caza de amenazas

✓ C) Simulación

D) Escaneo de vulnerabilidades

20. ¿Cuál de los términos enumerados a continuación se refiere a inteligencia sobre amenazas recopilada de fuentes disponibles públicamente?

A) COI

✓ B) OSINT

C) RFC

D) CVE/NVD

21. Un tipo de evidencia forense que puede usarse para detectar intentos de acceso no autorizados u otras actividades maliciosas se denomina:

A) CVE

✓ B) COI

C) AIS

D) OSINT

22. ¿Cuál de las respuestas enumeradas a continuación se refiere a las ventajas de la segmentación como método para proteger los datos? (Seleccione 3 respuestas)

A) Mejora la seguridad al limitar la propagación de ciberataques

✓ B) Ayuda a las organizaciones a cumplir con los requisitos normativos de datos aislando y protegiendo tipos de datos específicos

C) Proporciona seguridad para los datos en tránsito con el uso de cifrado.

D) Garantiza la recuperación de datos en caso de eliminación accidental o fallas del sistema.

✓ E) Proporciona un mejor control sobre el acceso de los usuarios a datos confidenciales.

23. Una instalación de recuperación ante desastres que proporciona únicamente el espacio físico para las operaciones de recuperación se conoce como:

A) sitio caliente

B) Sitio cálido

✓ C) Sitio frio

D) Sitio espejo

24. ¿Qué sitio alternativo permite la recuperación ante desastres más rápida?

A) Sitio frio

✓ B) sitio caliente

C) sitio móvil

D) Sitio cálido

25. ¿Cuál de las respuestas enumeradas a continuación se refiere a un escenario simulado llevado a cabo en un entorno controlado, que generalmente implica discusiones y planificación en torno a incidentes de seguridad hipotéticos?

A) Ejercicio de mesa

B) Zona de arena

C) caza de amenazas

D) Capacitación en concientización sobre seguridad.

Respuesta no detectada automaticamente

26. ¿Cuál de las afirmaciones enumeradas a continuación no se refiere a una técnica de respuesta y remediación de vulnerabilidades?

A) Aplicar actualizaciones o correcciones proporcionadas por proveedores de software para abordar la vulnerabilidad (parches)

B) Garantizar la recuperación financiera de los costos asociados con un ciberataque exitoso (seguro)

C) Dividir una red en zonas más pequeñas y aisladas para limitar el impacto potencial de una vulnerabilidad (segmentación)

D) Mitigar el riesgo asociado con una vulnerabilidad que no se puede reparar de inmediato mediante la implementación de medidas de seguridad alternativas (controles de compensación)

E) Retrasar o renunciar a un parche para un sistema específico, por ejemplo, cuando aplicar un parche puede no ser factible debido a problemas de compatibilidad o posibles interrupciones en sistemas críticos (excepciones y exenciones).

✓ F) Todas las respuestas anteriores son ejemplos de técnicas de respuesta y remediación de vulnerabilidades.

27. El proceso de mantener un registro documentado del manejo y movimiento de la evidencia para asegurar su integridad y admisibilidad en el tribunal se denomina:

A) cadena de custodia

B) Cadena de evidencia

C) Cadena de rendición de cuentas

D) cadena de responsabilidad

Respuesta no detectada automaticamente

4.9 - Dado un escenario, usar las fuentes de datos adecuadas para las investigaciones.

Conceptos clave:

- Fuentes: Logs de firewall, App logs, Logs de endpoint, Logs IDS/IPS, Logs DNS
- IDs de eventos Windows: 4624 (login OK), 4625 (login fallido), 4688 (nuevo proceso)
- Herramientas: Wireshark, tcpdump, Volatility, Autopsy, Plataformas TIP
- Metadatos: Datos sobre los datos (autor, fechas, rutas de archivo)

Teoria detallada:

FUENTES DE DATOS PARA INVESTIGACIONES - Conocer donde buscar es critico:

- Logs de firewall: registros de trafico permitido y bloqueado. Buscar: conexiones a IPs maliciosas, trafico en puertos inusuales, volumenes anormales de datos salientes (exfiltracion)
- Logs de aplicacion: errores, autenticaciones, acciones de usuarios. Buscar: logins en horas inusuales, accesos fuera del rol del usuario
- Logs de endpoint (Eventos de Windows): eventos del sistema operativo. Logs criticos:

- 4624: login exitoso
- 4625: login fallido
- 4648: login con credenciales explicitas (puede indicar pass-the-hash)
- 4688: creacion de nuevo proceso
- 7045: nuevo servicio instalado (posible malware como servicio)

- Logs IDS/IPS: alertas de ataques detectados en la red

• Logs DNS: resoluciones de nombres. Critico para detectar:
- C2 (Mando y Control): el malware resuelve dominios generados aleatoriamente (DGA)
- Tunelizacion DNS: datos exfiltrados codificados en consultas DNS
- Typosquatting: resoluciones de dominios similares al legitimo

• Logs de red/NetFlow: metadatos del trafico (origen, destino, puertos, bytes, duracion). NO el contenido. Util para detectar:
- Movimiento lateral: conexiones internas inusuales entre hosts
- Exfiltracion de datos: grandes transferencias hacia el exterior
- Escaneo de puertos: un host conectandose a muchos puertos de otro host

• Metadatos: datos SOBRE los datos. Ejemplo: metadatos de un documento Word incluyen autor, fecha de creacion, historial de revisiones (puede revelar el nombre de usuario del atacante)
• Logs de autenticacion: intentos de login. Buscar: password spraying, fuerza bruta, viaje imposible

HERRAMIENTAS DE ANALISIS:

• Wireshark: analisis de capturas de trafico (PCAP). Permite ver el contenido completo de conexiones no cifradas. Filtros: ip.addr==x.x.x.x, tcp.port==80, http.request
• tcpdump: captura de trafico desde linea de comandos. Mas eficiente para capturar en produccion
• Volatility: analisis forense de volcados de memoria RAM. Extrae procesos, conexiones de red, artefactos de malware
• Autopsy/FTK: plataformas de analisis forense de discos. Recuperan archivos borrados
• Paneles SIEM: visualizacion en tiempo real. Tendencias, picos de actividad y correlaciones
• Plataformas de inteligencia de amenazas (TIP): agregan feeds de threat intel y los correlacionan con eventos del SIEM

TRUCO EXAMEN: Logins fallidos: logs de autenticacion. Malware en red: logs IDS + NetFlow. Exfiltracion: logs firewall + logs DNS. Proceso malicioso: logs endpoint (Event ID 4688). Trafico cifrado sospechoso: NetFlow (no el contenido, pero si el patron).

Preguntas de practica (19):

1. ¿Cuál de los términos enumerados a continuación se refiere a inteligencia sobre amenazas recopilada de fuentes disponibles públicamente?

A) COI
✓ B) OSINT
C) RFC
D) CVE/NVD

---

2. ¿Cuál de las siguientes URL es un indicador potencial de un ataque de cruce de directorio?

A) http://www.example.com/var/../etc/passwd
B) http://www.example.com/var/www/../../etc/passwd
C) http://www.example.com/var/www/files/../../../etc/passwd
D) http://www.example.com/var/www/files/images/../../../../etc/passwd
✓ E) Cualquiera de los anteriores

---

3. Un tipo de evidencia forense que puede usarse para detectar intentos de acceso no autorizados u otras actividades maliciosas se denomina:

A) CVE
✓ B) COI
C) AIS
D) OSINT

---

4. ¿Cuál de los siguientes términos se refiere a un marco y una base de conocimientos que proporciona comprensión de los TTP utilizados durante los ciberataques?

✓ A) cvss
✓ B) ATT&CK
C) STIX
D) TAXII

---

5. El término "búsqueda de amenazas" se refiere a una búsqueda proactiva de IoC para identificar y abordar posibles amenazas y vulnerabilidades antes de que puedan convertirse en incidentes en toda regla.

A) Verdadero
B) FALSO
Respuesta no detectada automaticamente

6. El término "Metadatos" se refiere a datos que proporcionan información sobre otros datos, pero no el contenido real de los datos. Normalmente, los metadatos no son visibles para el usuario de forma predeterminada, pero se puede acceder a ellos si es necesario. Por ejemplo, los metadatos de correo electrónico, que se encuentran en los encabezados de los correos electrónicos, incluyen información detallada sobre el remitente, el destinatario y la ruta que tomó el mensaje. Los metadatos del dispositivo móvil abarcan detalles como el modelo del dispositivo, geolocalización, información de la cámara, uso de Internet, actividad de llamadas telefónicas y mensajes de texto, estadísticas de uso de aplicaciones y metadatos de varios archivos en el dispositivo. En la navegación web, los metadatos provienen de metaetiquetas HTML ubicadas en la sección principal de una página web. Para los archivos, los metadatos incluyen detalles sobre el autor (por ejemplo, el creador del archivo), el tipo de archivo, el tamaño, la fecha y hora de creación y la fecha y hora de la última modificación.

A) Verdadero
B) FALSO

7. ¿Cuál de las respuestas enumeradas a continuación se refiere a un proceso de interceptación de datos de tráfico de red con fines de análisis y solución de problemas?

A) AIS
✓ B) PCAP
C) EDR
D) MaaS

8. ¿Cuál de las respuestas enumeradas a continuación se refiere a un lenguaje utilizado para crear y organizar el contenido de las páginas web?

A) HTML
B) CSS
C) js
✓ D) HTTP

9. ¿Cuál es el nombre de un protocolo de red que protege el tráfico web mediante cifrado SSL/TLS?

A) SFTP
✓ B) HTTPS
C) FTPS
D) SHTTP

10. ¿Cuál de las respuestas enumeradas a continuación se refiere a un concepto que proporciona información sobre los métodos y herramientas que utilizan los ciberdelincuentes para llevar a cabo ataques?

A) TTP
B) CVE
C) ATT&CK
D) cvss
Respuesta no detectada automaticamente

11. ¿Cuál de los siguientes términos se refiere a un marco y una base de conocimientos que proporciona comprensión de los TTP utilizados durante los ciberataques?

A) cvss
✓ B) ATT&CK
C) TAXII
D) STIX

12. ¿Cuál de las siguientes respuestas se refiere a un protocolo obsoleto utilizado para la transferencia segura de datos a través de la web?

A) SMTP
B) SRTP
C) SHTTP
D) S/MIME

13. ¿Cuál de los términos enumerados a continuación se refiere a una iniciativa del gobierno de EE. UU. para compartir en tiempo real indicadores de amenazas cibernéticas?

A) NVD

✓ B) AIS

C) TTP

D) cvss

---

14. ¿Cuál es el nombre de un protocolo de red que protege el tráfico web mediante cifrado SSL/TLS?

✓ A) SFTP

✓ B) HTTPS

C) FTPS

D) SHTTP

---

15. Una actualización de aplicación maliciosa es un tipo de malware que se puede instalar mediante una actualización de software aparentemente legítima. La introducción de una actualización maliciosa en el código de la aplicación se puede habilitar a través de varios medios, que incluyen:

A) Código de aplicación sin firmar

B) Canal de actualización no cifrado (HTTP vs HTTPS)

C) Sitio web de actualización falso

D) Acceso no autorizado al servidor de actualización

E) Proceso de desarrollo de software comprometido

✓ F) Todo lo anterior

---

16. ¿Cuál de las siguientes URL es un indicador potencial de un ataque de cruce de directorio?

A) http://www.example.com/var/../etc/passwd

B) http://www.example.com/var/www/../../etc/passwd

C) http://www.example.com/var/www/files/../../../etc/passwd

D) http://www.example.com/var/www/files/images/../../../../etc/passwd

✓ E) Cualquiera de los anteriores

---

17. Un tipo de evidencia forense que puede usarse para detectar intentos de acceso no autorizados u otras actividades maliciosas se denomina:

A) CVE

✓ B) COI

C) AIS

D) OSINT

---

18. ¿Cuál de los siguientes términos se refiere a un marco y una base de conocimientos que proporciona comprensión de los TTP utilizados durante los ciberataques?

✓ A) cvss

✓ B) ATT&CK

C) STIX

D) TAXII

---

19. ¿Cuál de los protocolos enumerados a continuación se utiliza para permitir la navegación web segura?

A) L2TP

✓ B) HTTPS

C) SSH

D) IPSec

5.0 Gestión del Programa de Seguridad (20% del examen)

5.1 - Resumir los elementos de una gobernanza de seguridad eficaz.

Conceptos clave:

- Jerarquia: Politica, Estandar, Procedimiento, Directriz, Playbook
- Politicas clave: AUP, Seguridad de la informacion, BCP, DRP, IRP, SDLC
- Estructuras: Juntas, Comites, Centralizado vs Descentralizado
- Roles: Propietario, Controlador, Procesador, Custodio/Administrador

Teoria detallada:

JERARQUIA DE DOCUMENTOS DE GOBERNANZA - Del mas general al mas especifico:

- Politica (Policy): declaracion de ALTO NIVEL de la intencion de la organizacion. Aprobada por la direccion. EL QUE. No cambia frecuentemente. Ejemplo: 'Todos los datos de clientes deben protegerse segun su clasificacion'
- Estandar (Standard): requisitos ESPECIFICOS y MEDIBLES que implementan la politica. EL CUANTO. Ejemplo: 'Los datos confidenciales deben cifrarse con AES-256'
- Procedimiento (Procedure): instrucciones PASO A PASO de como implementar el estandar. EL COMO. Ejemplo: 'Para cifrar un disco: 1. Abrir BitLocker 2. Seleccionar modo...'
- Directriz (Guideline): RECOMENDACIONES no obligatorias. Buenas practicas. El mas flexible. Ejemplo: 'Se recomienda usar un gestor de contrasenas'
- Playbook: procedimiento especifico para responder a UN TIPO ESPECIFICO de incidente (playbook de ransomware, playbook de phishing)

POLITICAS CLAVE QUE DEBES CONOCER:

- AUP (Politica de Uso Aceptable): define el uso aceptable de los recursos IT. Todos los empleados deben firmarla. Cubre: uso de internet, email corporativo, dispositivos, redes sociales
- Politica de Seguridad de la Informacion: politica paraguas que gobierna toda la seguridad de la informacion
- BCP (Plan de Continuidad de Negocio): como CONTINUAR OPERANDO durante un desastre. Se centra en el negocio, no solo en IT
- DRP (Plan de Recuperacion ante Desastres): como RECUPERAR los sistemas IT tras un desastre. Parte del BCP, mas tecnico
- IRP (Plan de Respuesta a Incidentes): como responder a incidentes de seguridad. Define roles, escalado, comunicacion
- SDLC (Ciclo de Vida de Desarrollo de Software): como integrar seguridad en el desarrollo desde el principio
- Incorporacion/Desvinculacion (Onboarding/Offboarding): procedimientos para dar de alta y baja empleados de forma segura

ROLES DE DATOS - Los mas preguntados en el examen:

- Propietario de datos (Data owner): el responsable del NEGOCIO del activo. Decide la clasificacion, quien puede acceder y el tiempo de retencion. Normalmente un director o VP
- Custodio/Administrador de datos (Data custodian/steward): el responsable TECNICO. Implementa los controles definidos por el owner. Normalmente IT o el DBA
- Controlador de datos (Data controller, GDPR): entidad que decide el PROPOSITO y los MEDIOS del procesamiento de datos personales
- Procesador de datos (Data processor, GDPR): entidad que procesa datos en nombre del controller. Un proveedor cloud
- Sujeto de datos (Data subject, GDPR): la persona fisica cuyos datos se procesan
- TRUCO: Propietario = decide QUE hacer con los datos. Custodio = COMO protegerlos. Controlador = POR QUE procesarlos. Procesador = los procesa para otro.

ESTRUCTURAS DE GOBERNANZA:

- CISO (Director de Seguridad de la Informacion): maximo responsable de seguridad. Reporta al CEO o al Consejo de Administracion
- Gobernanza centralizada: el equipo central de seguridad toma todas las decisiones. Consistencia pero puede ser lento
- Gobernanza descentralizada: cada departamento gestiona su seguridad. Mas agil pero inconsistente
- Comite de direccion: comite ejecutivo que supervisa la estrategia de seguridad y aprueba inversiones
- Monitorizacion y revision: las politicas deben revisarse periodicamente (minimo anual) y tras incidentes significativos

Preguntas de practica (17):

1. ¿Cuál de las siguientes respuestas se refiere a una entidad (como una organización o un individuo) que determina el propósito y los medios del procesamiento de datos personales?

✓ A) Procesador de datos

B) Propietario de los datos

✓ **C) Responsable del tratamiento**

D) Interesado

2. Una lista de verificación de configuración para nuevos usuarios incluye todas las actividades que permiten que un nuevo empleado sea productivo. Ejemplos de tales actividades (que forman parte del llamado proceso de incorporación) incluyen la configuración del entorno de hardware y software para el nuevo usuario, así como proporcionar toda la formación necesaria. Una lista de verificación de despido del usuario final aborda todas las acciones que deben tener lugar durante el proceso de baja (es decir, cada vez que un empleado deja la empresa). Ejemplos de elementos de la lista de verificación incluyen cumplir con todos los documentos requeridos, eliminar el acceso del empleado a los recursos (por ejemplo, dispositivos propiedad de la empresa, cuentas de usuario, etc.) y discutir sus motivos para irse y sus experiencias con el empleador durante una entrevista de salida.

A) Verdadero

B) FALSO

Respuesta no detectada automaticamente

3. ¿Cuál de las respuestas enumeradas a continuación se refiere a organizaciones o personas responsables de garantizar el cumplimiento de las leyes de protección de datos?

A) Controladores

B) Mayordomos

C) Propietarios

D) Procesadores

4. ¿Cuál de las siguientes respuestas se refiere a entidades que actúan en nombre del responsable del tratamiento para realizar tareas específicas relacionadas con los datos?

A) Mayordomos

B) Propietarios

C) Procesadores

D) Controladores

5. ¿Cuál de los siguientes términos entran en la categoría de controles de seguridad directivos? (Seleccione 2 respuestas)

A) PIR

✓ **B) PUA**

C) identificación

D) Ministerio de Asuntos Exteriores

E) IPS

6. ¿Cuál de las siguientes respuestas se refiere a un microcontrolador integrado que se utiliza para arranque seguro, cifrado de disco y verificación de la integridad del sistema?

A) TPM

B) SoC

C) UEFI

✓ **D) HSM**

7. Un mecanismo de control de acceso basado en reglas implementado en enrutadores, conmutadores y firewalls se denomina:

A) IMPERMEABLE

B) PUA

C) CAD

✓ **D) LCA**

8. Una instalación de recuperación ante desastres que proporciona únicamente el espacio físico para las operaciones de recuperación se conoce como:

A) sitio caliente

B) Sitio cálido

✓ **C) Sitio frio**

D) Sitio espejo

9. ¿Qué sitio alternativo permite la recuperación ante desastres más rápida?

A) Sitio frio

✓ B) sitio caliente

C) sitio móvil

D) Sitio cálido

10. ¿Cuál de los términos enumerados a continuación se refiere al proceso de creación y mantenimiento de aplicaciones informáticas?

A) RAD

✓ B) SDLC

C) POO

D) SaaS

11. ¿Cuál de los términos enumerados a continuación se refiere al proceso de creación y mantenimiento de aplicaciones informáticas?

A) RAD

✓ B) SDLC

C) POO

D) SaaS

12. Un tipo de documento que estipula reglas de comportamiento que deben seguir los usuarios de computadoras, redes y recursos asociados se denomina:

A) SLA

B) CLUF

✓ C) PUA

D) BPA

13. ¿Cuál de las siglas enumeradas a continuación se refiere a un período de tiempo máximo tolerable necesario para restaurar las funciones comerciales después de una falla o desastre?

A) SLA

B) RTO

C) PUA

D) RPO

14. ¿Cuál de las siguientes respuestas se refiere a un microcontrolador integrado que se utiliza para arranque seguro, cifrado de disco y verificación de la integridad del sistema?

A) TPM

B) SoC

C) UEFI

D) HSM

15. ¿Cuál de los siguientes términos entran en la categoría de controles de seguridad directivos? (Seleccione 2 respuestas)

A) PIR

✓ B) PUA

C) identificación

D) Ministerio de Asuntos Exteriores

E) IPS

16. Una instalación de recuperación ante desastres que proporciona únicamente el espacio físico para las operaciones de recuperación se conoce como:

A) sitio caliente

B) Sitio cálido

✓ C) Sitio frio

D) Sitio espejo

17. ¿Qué sitio alternativo permite la recuperación ante desastres más rápida?

A) Sitio frio

✓ **B) sitio caliente**

C) sitio móvil

D) Sitio cálido

5.2 - Explicar los elementos del proceso de gestion de riesgos.

Conceptos clave:

- Identificacion, Evaluacion (Ad-hoc, Periodica, Continua)
- Analisis cuantitativo: AV, EF, SLE, ARO, ALE
- Analisis cualitativo: Matrices de riesgo, Mapas de calor
- Registro de riesgos, Apetito de riesgo, BIA: RTO, RPO, MTTR, MTBF

Teoria detallada:

PROCESO DE GESTION DE RIESGOS (NIST RMF):

- 1. Identificacion de riesgos: catalogar activos, identificar amenazas y vulnerabilidades
- 2. Evaluacion (Assessment): evaluar probabilidad e impacto. Puede ser ad-hoc, periodica o continua
- 3. Respuesta: decidir como tratar cada riesgo (mitigar, transferir, evitar, aceptar)
- 4. Monitorizacion: vigilar los riesgos y la efectividad de los controles continuamente

ANALISIS CUANTITATIVO - Las formulas del examen:

- AV (Valor del Activo): valor monetario del activo. Ej: servidor de BD = 500.000 EUR
- EF (Factor de Exposicion): porcentaje del activo que se perderia si el riesgo se materializa. Ej: 40%
- SLE (Perdida Esperada por Incidente): perdida esperada por UN incidente = AV x EF = 500.000 x 0.40 = 200.000 EUR
- ARO (Tasa Anual de Ocurrencia): cuantas veces al ano se espera que ocurra el incidente. Ej: 0.5 (una vez cada 2 anos)
- ALE (Perdida Anual Esperada): perdida anual esperada = SLE x ARO = 200.000 x 0.5 = 100.000 EUR
- TRUCO: si el control cuesta menos que el ALE, tiene sentido implementarlo. Si cuesta mas, quizas es mejor aceptar el riesgo

ANALISIS CUALITATIVO:

- Usa matrices de riesgo con escalas descriptivas (bajo/medio/alto/critico)
- Mas rapido y facil que el cuantitativo pero subjetivo
- Util cuando no hay datos suficientes para calcular valores monetarios precisos
- Herramientas: matriz de riesgo (probabilidad x impacto), mapas de calor de riesgo

ESTRATEGIAS DE RESPUESTA AL RIESGO:

- Mitigar (Mitigate): implementar controles para reducir la probabilidad o el impacto. La respuesta mas comun
- Transferir (Transfer): ciberseguro (transfiere el riesgo financiero al asegurador), contratos que transfieren responsabilidad a terceros
- Evitar (Avoid): no realizar la actividad que genera el riesgo
- Aceptar (Accept): documentar conscientemente que se asume el riesgo. Requiere aprobacion de la direccion
- Apetito de riesgo (Risk appetite): cuanto riesgo esta dispuesta a asumir la organizacion en total
- Tolerancia al riesgo (Risk tolerance): variacion aceptable alrededor del apetito de riesgo
- Riesgo residual: el riesgo que QUEDA despues de aplicar todos los controles. Nunca es cero
- Registro de riesgos (Risk register): documento vivo que lista todos los riesgos con su propietario, controles y riesgo residual

BIA (Analisis de Impacto en el Negocio) - Critico para el examen:

- Objetivo: identificar cuales son los procesos CRITICOS del negocio y que pasa si se interrumpen
- MTD (Tiempo Maximo de Inactividad Tolerable): el tiempo maximo que el negocio puede sobrevivir sin el proceso
- RTO (Objetivo de Tiempo de Recuperacion): tiempo maximo para restaurar el servicio. RTO < MTD siempre
- RPO (Objetivo de Punto de Recuperacion): cuanta perdida de datos es aceptable. Si RPO=4h, el ultimo backup debe tener maximo 4h de antiguedad
- MTTR (Tiempo Medio de Reparacion): tiempo medio para reparar un sistema
- MTBF (Tiempo Medio Entre Fallos): frecuencia media de fallos. Usado para planificar mantenimiento preventivo

Preguntas de practica (41):

1. ¿Cuál de las siguientes define la cantidad máxima aceptable de pérdida de datos medida en un momento específico antes de un desastre o interrupción?

A) RPO
B) MTBF
C) RTO
✓ **D) MTTR**

2. ¿Cuál de las siguientes define la cantidad máxima aceptable de pérdida de datos medida en un momento específico antes de un desastre o interrupción?

A) RPO
B) MTBF
C) RTO
✓ **D) MTTR**

3. Una estimación basada en datos históricos de la frecuencia con la que una amenaza lograría explotar una vulnerabilidad se conoce como:

A) CERVEZA INGLESA
B) SLA
✓ **C) ARO**
D) LES

4. ¿El seguro de ciberseguridad es un ejemplo de qué estrategia de gestión de riesgos?

A) Evitación de riesgos
B) Disuasión de riesgos
✓ **C) Transferencia de riesgo**
D) Aceptación de riesgos

5. ¿Qué término describe la pérdida de valor prevista para un activo en función de un único incidente de seguridad?

A) LES
B) ARO
C) CERVEZA INGLESA
D) SLA

6. ¿El seguro de ciberseguridad es un ejemplo de qué estrategia de gestión de riesgos?

A) Evitación de riesgos
B) Disuasión de riesgos
✓ **C) Transferencia de riesgo**
D) Aceptación de riesgos

7. ¿Cuál de las respuestas enumeradas a continuación se refiere a un documento integral utilizado en la gestión de riesgos y la gestión de proyectos para identificar, evaluar y rastrear riesgos?

A) registro de riesgos
B) Mapa de calor de riesgo
C) Matriz de riesgos
D) Repositorio de riesgos

8. ¿Cuál de los términos enumerados a continuación se refiere a un término general que describe la actitud general de una organización hacia la asunción de riesgos?

A) Estrategia de riesgo
B) control de riesgos
✓ **C) Apetito de riesgo**
D) Tolerancia al riesgo

9. ¿Cuál de los siguientes términos describe el proceso de tomar medidas proactivas para reducir el impacto de los riesgos identificados?

A) Aceptación de riesgos
B) Evitación de riesgos
C) Transferencia de riesgo
✓ **D) Mitigación de riesgos**

10. ¿Cuál de las siglas enumeradas a continuación se refiere a un período de tiempo máximo tolerable necesario para restaurar las funciones comerciales después de una falla o desastre?

A) SLA
B) RTO
C) PUA
D) RPO

11. ¿Cuál de los acrónimos enumerados a continuación se refiere a una estrategia integral y un conjunto de procedimientos diseñados para garantizar que una organización pueda continuar con sus operaciones y funciones críticas durante y después de un evento disruptivo?

A) BIA
B) LES
✓ C) BCP
D) BPA

12. Un conjunto de procedimientos implementados para recuperar sistemas y datos de TI después de una interrupción importante se denomina:

A) DRP
B) BIA
C) LES
D) BCP
Respuesta no detectada automaticamente

13. El proceso de determinar los riesgos potenciales que podrían afectar la capacidad de una organización para alcanzar sus objetivos se denomina:

✓ A) Evaluación de riesgos
✓ B) Identificación de riesgos
C) Análisis de riesgos
D) Gestión de riesgos

14. ¿Cuál de las siguientes respuestas se refiere a una evaluación de riesgos realizada para un propósito o proyecto específico, sin planes para una reevaluación periódica (por ejemplo, evaluación de riesgos para el lanzamiento de un nuevo producto)?

A) una sola vez
B) Periódico
C) A propósito
D) Continuo

15. ¿Cuál de los términos enumerados a continuación se refiere a un término general que describe la actitud general de una organización hacia la asunción de riesgos?

A) Estrategia de riesgo
B) control de riesgos
✓ C) Apetito de riesgo
D) Tolerancia al riesgo

16. ¿Cuál de los siguientes términos describe el proceso de tomar medidas proactivas para reducir el impacto de los riesgos identificados?

A) Aceptación de riesgos
B) Evitación de riesgos
C) Transferencia de riesgo
✓ D) Mitigación de riesgos

17. ¿Cuál de los siguientes términos describe el proceso de identificar diferencias entre la postura de seguridad actual de una organización y su postura de seguridad deseada?

A) Ejercicio de mesa
✓ B) Análisis de brechas
C) Capacitación en concientización sobre seguridad.

D) Evaluación de riesgos

18. Un archivo Honey se puede utilizar para:

A) Atraer a los ciberatacantes

B) Activar alertas cuando se accede

C) Monitoreo de la actividad de la red

✓ D) Todo lo anterior

19. ¿Cuál es el propósito de la esteganografía?

A) Comprobación de la integridad de los datos

B) Verificando valores hash

✓ C) Ocultar datos dentro de otro dato

D) Cifrar datos

20. ¿Cuál de las respuestas enumeradas a continuación se refiere a una función hash no criptográfica que se utiliza a menudo con fines de verificación de errores?

A) MD5

B) CDN

C) sha

D) RIPEMD

21. El término "clonación RFID" se refiere a copiar los datos almacenados en cualquier dispositivo habilitado para RFID (incluidas etiquetas, tarjetas, llaveros, implantes y otros objetos integrados con tecnología RFID) en otro dispositivo habilitado para RFID, que luego puede leerse y usarse de la misma manera que la etiqueta original. Si bien la clonación RFID se puede utilizar con fines legítimos, como replicar etiquetas importantes con fines de respaldo y prueba, también plantea un riesgo de seguridad significativo, ya que las etiquetas duplicadas pueden usarse potencialmente para obtener acceso no autorizado o divulgación de información no autorizada.

A) Verdadero

B) FALSO

Respuesta no detectada automaticamente

22. ¿Cuál de las respuestas enumeradas a continuación se refiere a una técnica de ciberataque que se basa en proporcionar información DNS falsa a un solucionador de DNS con el fin de redirigir o manipular la resolución de nombres de dominio a direcciones IP maliciosas?

A) Suplantación de DNS

B) Relleno de credenciales

C) Secuestro de URL

D) Secuestro de dominio

23. El propósito de PCI DSS es brindar protección para:

A) Datos del titular de la tarjeta de crédito

B) Software con licencia

C) Contraseñas de usuario

D) Información de salud personal

24. ¿Cuál de las respuestas enumeradas a continuación se refiere a un escenario simulado llevado a cabo en un entorno controlado, que generalmente implica discusiones y planificación en torno a incidentes de seguridad hipotéticos?

A) Ejercicio de mesa

B) Zona de arena

C) caza de amenazas

D) Capacitación en concientización sobre seguridad.

Respuesta no detectada automaticamente

25. ¿Cuáles son las características del modo empresarial WPA2/WPA3? (Seleccione 3 respuestas)

A) Adecuado para grandes redes corporativas

B) IEEE 802.1D

C) No requiere un servidor de autenticación

✓ **D) IEEE 802.1X**

E) Adecuado para todo tipo de LAN inalámbricas

✓ **F) Requiere servidor de autenticación RADIUS**

26. En el contexto de la seguridad informática, el término "biometría" se refiere tanto a las características biológicas del cuerpo humano como a los rasgos de comportamiento que pueden utilizarse con fines de identificación y control de acceso.

A) Verdadero

B) FALSO

Respuesta no detectada automaticamente

27. ¿Cuál de las respuestas enumeradas a continuación se refiere a un término utilizado principalmente en el desarrollo de software para describir el costo de las decisiones a corto plazo que pueden generar problemas a largo plazo?

A) Entropía de código

B) factor de exposición

C) registro de riesgos

✓ **D) Deuda técnica**

28. ¿Cuál de las respuestas enumeradas a continuación se refiere a un proceso de interceptación de datos de tráfico de red con fines de análisis y solución de problemas?

A) AIS

✓ **B) PCAP**

C) EDR

D) MaaS

29. Un valor MTBF alto indica que un componente o sistema proporciona baja confiabilidad y es más probable que falle.

A) Verdadero

✓ **B) FALSO**

30. ¿Cuál de las siguientes respuestas se refiere a una entidad (como una organización o un individuo) que determina el propósito y los medios del procesamiento de datos personales?

✓ **A) Procesador de datos**

B) Propietario de los datos

✓ **C) Responsable del tratamiento**

D) Interesado

31. ¿Cuál de las siguientes respuestas se refiere a una función hash no criptográfica que se utiliza a menudo con fines de comprobación de errores?

A) MD5

B) CDN

C) sha

D) RIPEMD

32. ¿Cuál de las respuestas que se enumeran a continuación se refieren a los rasgos característicos del NIDS? (Seleccione 3 respuestas)

A) Toma medidas proactivas para bloquear o mitigar los intentos de intrusión.

✓ **B) No toma medidas directas para bloquear o prevenir ataques.**

✓ **C) Genera alertas y notifica al personal de seguridad o a los administradores cuando se detecta actividad sospechosa.**

✓ **D) Supervisa el tráfico de la red sin participación directa en el enrutamiento del tráfico o la modificación de paquetes.**

E) Puede descartar o rechazar paquetes de red, finalizar conexiones o tomar otras acciones para detener el ataque.

F) Opera en modo en línea, interceptando e inspeccionando activamente el tráfico de la red.

33. ¿Cuál de las respuestas enumeradas a continuación se refiere a una función hash no criptográfica que se utiliza a menudo con fines de verificación de errores?

A) MD5

✓ **B) CDN**

C) sha

D) RIPEMD

34. ¿Cuál de los siguientes términos describe mejor información deliberadamente falsa o engañosa difundida con la intención de engañar o manipular?

A) Desinformación

B) Engaño

C) Iluminación de gas

D) Manipulación

Respuesta no detectada automaticamente

35. ¿Cuál de las respuestas enumeradas a continuación se refiere a una técnica de ciberataque que se basa en proporcionar información DNS falsa a un solucionador de DNS con el fin de redirigir o manipular la resolución de nombres de dominio a direcciones IP maliciosas?

A) Suplantación de DNS

B) Relleno de credenciales

C) Secuestro de URL

D) Secuestro de dominio

36. ¿Cuál de las respuestas enumeradas a continuación se refiere a un escenario simulado llevado a cabo en un entorno controlado, que generalmente implica discusiones y planificación en torno a incidentes de seguridad hipotéticos?

A) Ejercicio de mesa

B) Zona de arena

C) caza de amenazas

D) Capacitación en concientización sobre seguridad.

Respuesta no detectada automaticamente

37. ¿Cuáles son las características del modo empresarial WPA2/WPA3? (Seleccione 3 respuestas)

A) Adecuado para grandes redes corporativas

B) IEEE 802.1D

C) No requiere un servidor de autenticación

✓ **D) IEEE 802.1X**

E) Adecuado para todo tipo de LAN inalámbricas

✓ **F) Requiere servidor de autenticación RADIUS**

38. ¿Cuál de las siguientes respuestas se refiere a un método de evaluación de riesgos basado en la necesidad, que generalmente se lleva a cabo en respuesta a eventos o cambios específicos, como después de un cambio organizacional importante o una violación de seguridad?

A) A propósito

B) Periódico

C) una sola vez

D) Continuo

39. ¿Cuál de las respuestas enumeradas a continuación se refiere a un ejemplo de evaluación de riesgos recurrentes?

✓ **A) Monitoreo en tiempo real de amenazas a la seguridad de la red**

B) Evaluación del riesgo después de un cambio organizacional importante o una violación de seguridad

C) Evaluaciones de riesgos trimestrales o anuales

D) Evaluación de riesgos para el lanzamiento de un nuevo producto.

40. ¿Cuál de las respuestas enumeradas a continuación se refiere a un ejemplo de evaluación continua de riesgos?

A) Evaluaciones de riesgos trimestrales o anuales

B) Evaluación de riesgos para el lanzamiento de un nuevo producto.

C) Evaluación del riesgo después de un cambio organizacional importante o una violación de seguridad

D) Monitoreo en tiempo real de amenazas a la seguridad de la red

41. Un valor MTBF alto indica que un componente o sistema proporciona baja confiabilidad y es más probable que falle.

A) Verdadero

✓ B) FALSO

5.3 - Explicar la evaluacion y gestion de riesgos de terceros.

Conceptos clave:

- Evaluacion: Pruebas de penetracion, Derecho a auditoria, Analisis de cadena de suministro
- Seleccion: Due diligence, Conflicto de intereses
- Acuerdos: SLA, MOA, MOU, MSA, NDA, BPA, SOW, ISA
- Monitorizacion continua de proveedores

Teoria detallada:

GESTION DE RIESGOS DE TERCEROS - Por que es critico:

- El 60%+ de las brechas de seguridad implican a un tercero (proveedor, partner, contratista)
- Cuando contratas a un proveedor, le das acceso a tus sistemas, datos o red y heredas sus riesgos
- Ejemplos reales: Target (brecha via proveedor HVAC), SolarWinds (ataque a cadena de suministro), MOVEit (software de transferencia de archivos comprometido)

PROCESO DE EVALUACION DE PROVEEDORES:

- Diligencia debida (Due diligence): investigacion exhaustiva ANTES de contratar. Incluye: historial de brechas, certificaciones (ISO 27001, SOC 2), referencias, revision de politicas
- Cuestionario de proveedor: cuestionario de seguridad que el proveedor debe responder. Evalua sus controles tecticos, fisicos y administrativos
- Clausula de derecho a auditoria (Right-to-audit): clausula en el contrato que te da derecho a auditar al proveedor. CRITICO incluirla
- Prueba de penetracion: realizar o exigir pentests periodicos al proveedor
- Conflicto de intereses: verificar que el proveedor no tiene intereses que puedan comprometer la seguridad
- Analisis de cadena de suministro: no solo evaluar al proveedor directo, sino tambien a sus proveedores

TIPOS DE ACUERDOS - Los MAS preguntados en el examen:

- SLA (Acuerdo de Nivel de Servicio): define los niveles MINIMOS de servicio garantizados. Incluye: uptime (99.9%), tiempo de respuesta ante incidentes, penalizaciones
- NDA (Acuerdo de No Divulgacion): protege informacion sensible compartida con terceros
- MOU (Memorando de Entendimiento): acuerdo de INTENCIONES. NO es legalmente vinculante. Comun entre organismos publicos
- MOA (Memorando de Acuerdo): MAS FORMAL que MOU. Describe compromisos especificos
- MSA (Acuerdo Marco de Servicios): contrato MARCO que establece las condiciones generales de una relacion de largo plazo
- SOW (Declaracion de Trabajo): describe el ALCANCE ESPECIFICO de un proyecto concreto
- BPA (Acuerdo de Colaboracion Empresarial): acuerdo entre socios de negocio
- ISA (Acuerdo de Seguridad de Interconexion): acuerdo tecnico que define como se conectaran de forma segura dos redes de distintas organizaciones

TRUCO EXAMEN: SLA = niveles de servicio. NDA = confidencialidad. SOW = que trabajo se hace. MOU = intenciones sin fuerza legal. ISA = conexion segura entre redes de dos organizaciones.

MONITORIZACION CONTINUA DE PROVEEDORES:

- Revisiones periodicas: revisar el estado de seguridad del proveedor periodicamente (trimestral/anual)
- Servicios de calificacion de seguridad: plataformas como SecurityScorecard o BitSight que evaluan continuamente la postura de seguridad externa de proveedores
- Reglas de participacion (Rules of engagement): definir claramente el alcance, metodos y limites de cualquier prueba de seguridad al proveedor
- Desvinculacion del proveedor: cuando se termina la relacion, revocar todos los accesos y recuperar cualquier dato compartido

Preguntas de practica (64):

1. ¿Cuál de los siguientes términos se refiere a un acuerdo que especifica requisitos de desempeño para un proveedor?

A) MSA

✓ **B) SLA**

C) Memorándum de Entendimiento

D) SEMBRAR

2. Un tipo de acuerdo no vinculante que describe objetivos mutuos y el marco general para la cooperación entre dos o más partes se denomina:

A) MOA

B) SEMBRAR

✓ **C) Memorándum de Entendimiento**

✓ **D) MSA**

3. ¿Cuál de los términos enumerados a continuación se refiere a un contrato formal entre socios comerciales que describe los derechos, responsabilidades y obligaciones de cada socio con respecto a los procesos de gestión, operación y toma de decisiones dentro del negocio?

A) MSA

B) SLA

✓ **C) BPA**

D) MOA

4. Un documento menos formal que describe los objetivos mutuos y la cooperación establecida entre dos o más partes se denomina:

A) MOA

B) SEMBRAR

✓ **C) Memorándum de Entendimiento**

D) MSA

5. ¿Cuál de los siguientes términos se refiere a un acuerdo que especifica requisitos de desempeño para un proveedor?

A) MSA

✓ **B) SLA**

C) Memorándum de Entendimiento

D) SEMBRAR

6. Un tipo de acuerdo no vinculante que describe objetivos mutuos y el marco general para la cooperación entre dos o más partes se denomina:

A) MOA

B) SEMBRAR

✓ **C) Memorándum de Entendimiento**

✓ **D) MSA**

7. Un contrato legal entre el titular de información confidencial y otra persona a quien se le revela esa información que restringe a esa otra persona la divulgación de información confidencial a cualquier otra parte se conoce como:

A) ISA

✓ **B) Acuerdo de confidencialidad**

✓ **C) BPA**

D) SLA

8. ¿Cuál de las siguientes siglas se refiere a un documento que autoriza, inicia y rastrea el progreso y la finalización de un trabajo o tarea en particular?

A) SEMBRAR

✓ **B) WO**

C) SLA

D) MSA

9. Un acuerdo detallado entre un cliente y un proveedor que describe el trabajo a realizar en un proyecto se denomina:

A) MSA
B) SLA
C) WO
✓ **D) SEMBRAR**

10. Un acuerdo detallado entre un cliente y un proveedor que describe el trabajo a realizar en un proyecto se conoce como:

A) MSA
B) SLA
C) WO
✓ **D) SEMBRAR**

11. ¿Cuál de las siguientes siglas se refiere a un documento que autoriza, inicia y rastrea el progreso y la finalización de un trabajo o tarea en particular?

A) SEMBRAR
✓ **B) WO**
C) SLA
D) MSA

12. Un ataque de punto, punto y barra también se conoce como:

A) Ataque de disociación
B) Ataque en el camino
✓ **C) Ataque transversal de directorio**
D) Ataque de degradación

13. ¿Cuál de las siguientes define la cantidad máxima aceptable de pérdida de datos medida en un momento específico antes de un desastre o interrupción?

A) RPO
B) MTBF
C) RTO
✓ **D) MTTR**

14. ¿Cuál de los términos enumerados a continuación se utiliza para describir las acciones tomadas para abordar y mitigar los riesgos ya identificados?

A) debida diligencia
B) Estándar de atención
✓ **C) debido cuidado**
D) Deber fiduciario

15. Un tipo de documento que estipula reglas de comportamiento que deben seguir los usuarios de computadoras, redes y recursos asociados se denomina:

A) SLA
B) CLUF
✓ **C) PUA**
D) BPA

16. ¿Cuál de las siglas enumeradas a continuación se refiere a un período de tiempo máximo tolerable necesario para restaurar las funciones comerciales después de una falla o desastre?

A) SLA
B) RTO
C) PUA
D) RPO

17. ¿Cuál de las siguientes define la cantidad máxima aceptable de pérdida de datos medida en un momento específico antes de un desastre o interrupción?

A) RPO
B) MTBF
C) RTO
✓ **D) MTTR**

18. ¿Qué tipo de cuenta de usuario viola el concepto de no repudio?

A) Cuenta de usuario estándar
✓ **B) cuenta compartida**
C) Cuenta de usuario invitado
D) cuenta de servicio

19. Un protocolo de cifrado utilizado principalmente en redes Wi-Fi que implementan el estándar de seguridad WPA2 se llama:

A) TKIP
✓ **B) CCMP**
C) SSL
D) IPSec

20. ¿Cuál de las respuestas enumeradas a continuación se refiere a un conjunto de estándares y especificaciones que definen diversas técnicas criptográficas, incluidos formatos para claves públicas, claves privadas, firmas digitales y certificados digitales?

A) ITIL
B) RFC
C) PKCS
D) ISO/CEI

21. ¿Cuál de las siguientes sería la mejor solución para una empresa que necesita servicios de TI pero carece de personal de TI?

A) MSA
B) MaaS
✓ **C) MSP**
D) MSSP

22. ¿Cuál de las siguientes respuestas se refiere a vectores de amenazas comunes que se aplican a los MSP, vendedores y proveedores en la cadena de suministro? (Seleccione 2 respuestas)

A) Violaciones de cumplimiento
B) Daño a la reputación de la marca
✓ **C) Propagación de malware**
D) Interrupciones operativas
✓ **E) Técnicas de ingeniería social**

23. Un programa informático malicioso independiente que normalmente se propaga a través de una red informática para afectar negativamente a los recursos del sistema y al ancho de banda de la red se denomina:

A) Gusano
B) virus sin archivos
C) Bot
D) Bomba lógica

24. A diferencia de los simples ataques DoS que normalmente se realizan desde un solo sistema, un ataque DDoS utiliza múltiples sistemas informáticos comprometidos para realizar el ataque contra su objetivo. Los sistemas intermediarios que se utilizan como plataforma para el ataque (a menudo denominados zombies y colectivamente botnet) son las víctimas secundarias del ataque DDoS.

A) Verdadero
B) FALSO
Respuesta no detectada automaticamente

25. ¿Cuál de las respuestas enumeradas a continuación se refiere a un estándar IEEE que se puede implementar en una situación en la que un conmutador Ethernet actúa como autenticador para dispositivos

que pretenden conectarse a una red a través de uno de sus puertos?

A) IEEE 802.1X
B) IEEE 802.11ac
C) IEEE 802.1D
D) IEEE 802.11x

26. Una instalación de recuperación ante desastres que proporciona únicamente el espacio físico para las operaciones de recuperación se conoce como:

A) sitio caliente
B) Sitio cálido
✓ **C) Sitio frio**
D) Sitio espejo

27. ¿Qué sitio alternativo permite la recuperación ante desastres más rápida?

A) Sitio frio
✓ **B) sitio caliente**
C) sitio móvil
D) Sitio cálido

28. ¿Cuál de las siguientes soluciones de redundancia de energía sería la más adecuada para proporcionar energía de emergencia a largo plazo durante un corte inesperado de la fuente de energía principal?

A) Fuente de alimentación dual
B) UPS en espera
✓ **C) Generador de respaldo**
D) PDU administrada

29. ¿Cuál de los términos enumerados a continuación se utiliza para describir un nivel fundamental de configuraciones y ajustes de seguridad necesarios para salvaguardar un sistema?

A) Segmentación lógica
✓ **B) Línea de base segura**
C) Niveles de control de acceso
D) Principio de privilegio mínimo

30. ¿Cuál de las respuestas que se enumeran a continuación se refieren a técnicas de refuerzo de estaciones de trabajo? (Seleccione 3 respuestas)

A) Ocultar cuentas de administrador
✓ **B) Aplicar periódicamente parches de seguridad y actualizaciones del sistema operativo y del software instalado.**
C) Deshabilitar todo el acceso a Internet
✓ **D) Eliminar o deshabilitar controladores, servicios, software y protocolos de red innecesarios**
✓ **E) Limitar el acceso de usuarios no autorizados o no autenticados**

31. Un SSID es un identificador único (también conocido como nombre de red inalámbrica) para una WLAN. Las redes inalámbricas anuncian su presencia transmitiendo periódicamente SSID en un paquete especial llamado marco de baliza. En redes inalámbricas con funciones de seguridad deshabilitadas, conocer el SSID de la red es suficiente para acceder a la red. SSID también identifica el enrutador inalámbrico que actúa como WAP. Los enrutadores inalámbricos del mismo fabricante suelen configurarse con nombres SSID predeterminados (conocidos). Dado que varios dispositivos con el mismo SSID mostrado en la lista de redes disponibles crean confusión y fomentan el acceso accidental por parte de usuarios no autorizados (se aplica a redes que carecen de seguridad), cambiar el SSID predeterminado es una práctica recomendada.

A) Verdadero
B) FALSO
Respuesta no detectada automaticamente

32. ¿Cuál de las respuestas que se enumeran a continuación se refieren a los rasgos característicos del análisis de código estático? (Seleccione 3 respuestas)

A) Implica examinar el código sin ejecutarlo.
✓ **B) A menudo se utiliza al principio del proceso de desarrollo.**

✓ **C) Examina la estructura, la sintaxis y la semántica del código para detectar problemas como errores de sintaxis, violaciones de estándares de codificación, vulnerabilidades de seguridad y errores.**

D) Normalmente se utiliza más adelante en el ciclo de vida del desarrollo de software.

E) Implica ejecutar el código y analizar su comportamiento en tiempo de ejecución.

F) Analiza las propiedades del tiempo de ejecución, como el uso de la memoria, el rendimiento y el manejo de errores, para identificar problemas como pérdidas de memoria, cuellos de botella en el rendimiento y errores de tiempo de ejecución.

---

33. ¿Cuál de las siguientes afirmaciones describe las características del análisis de código dinámico? (Seleccione 3 respuestas)

A) Normalmente se utiliza más adelante en el ciclo de vida del desarrollo de software.

B) Implica examinar el código sin ejecutarlo.

✓ **C) Analiza las propiedades del tiempo de ejecución, como el uso de la memoria, el rendimiento y el manejo de errores, para identificar problemas como pérdidas de memoria, cuellos de botella en el rendimiento y errores de tiempo de ejecución.**

D) A menudo se utiliza al principio del proceso de desarrollo.

E) Examina la estructura, la sintaxis y la semántica del código para detectar problemas como errores de sintaxis, violaciones de estándares de codificación, vulnerabilidades de seguridad y errores.

✓ **F) Implica ejecutar el código y analizar su comportamiento en tiempo de ejecución.**

---

34. ¿Cuál de las siguientes respuestas se refiere a SCAP? (Seleccione 3 respuestas)

A) Un tipo de sistema de seguridad diseñado para recopilar registros y eventos de diversas fuentes.

✓ **B) Diseñado para proporcionar una interfaz de usuario centralizada para acceder a los datos recopilados.**

✓ **C) Una colección de estándares desarrollados por NIST**

✓ **D) Proporciona un lenguaje común para comunicar información de seguridad.**

✓ **E) Permite que diferentes herramientas de seguridad compartan datos y trabajen juntas de manera más efectiva**

F) Permite la detección de amenazas en tiempo real, la respuesta a incidentes y el monitoreo del cumplimiento

---

35. ¿Cuál de las respuestas enumeradas a continuación se refiere a un estándar criptográfico (y un formato de archivo) utilizado para el almacenamiento y transmisión de claves privadas en comunicaciones por correo electrónico?

A) PEM

B) DMARC

C) FPS

D) DKIM

---

36. ¿Cuál de las siguientes respuestas se refiere(s) al modelo de control de acceso obligatorio (MAC)? (Seleccione todo lo que corresponda)

A) Los usuarios no pueden cambiar las políticas de acceso a su propia discreción.

✓ **B) Las etiquetas y los niveles de autorización solo pueden ser aplicados y modificados por un administrador**

C) Cada objeto tiene un propietario que, a su propia discreción, determina qué tipo de permisos pueden tener otros usuarios sobre ese objeto.

D) Acceso a recursos según la identidad del usuario.

✓ **E) Cada recurso tiene una etiqueta de confidencialidad que coincide con un nivel de autorización asignado a un usuario.**

---

37. ¿Qué política de contraseñas impone un cambio de contraseña obligatorio después de un tiempo específico?

A) Política de caducidad de contraseñas

B) Política de historial de contraseñas

C) Política de antigüedad mínima de la contraseña

D) Política de reutilización de contraseñas

---

38. ¿Cuál de las respuestas enumeradas a continuación se refiere a una organización que desarrolla una amplia gama de estándares a nivel global?

A) IEEE

B) ANSI

C) ISO

D) NIST

39. Una estimación basada en datos históricos de la frecuencia con la que una amenaza lograría explotar una vulnerabilidad se conoce como:

A) CERVEZA INGLESA
B) SLA
✓ C) ARO
D) LES

40. En la estrategia de aceptación de riesgos, la práctica de incumplir temporalmente una norma o política debido a un escenario de riesgo específico se denomina:

A) Exclusión
✓ B) Excepción
C) Evasión
D) Exención

41. ¿Cuál de las siguientes respuestas se refiere a una disposición contractual que otorga a una parte el derecho de inspeccionar las operaciones, instalaciones, procesos y registros de la otra parte?

A) Cláusula de derecho de auditoría
B) Cláusula de supervisión
C) Cláusula de verificación de cumplimiento
D) Cláusula de transparencia

42. ¿Qué término describe la pérdida de valor prevista para un activo en función de un único incidente de seguridad?

A) LES
B) ARO
C) CERVEZA INGLESA
D) SLA

43. ¿Qué protocolo de seguridad inalámbrica ha quedado obsoleto en favor de estándares más nuevos debido a vulnerabilidades conocidas resultantes de fallas de implementación?

A) PAE
B) AES
C) WPA2
✓ D) WEP

44. ¿Cuál de las respuestas enumeradas a continuación se refiere a un estándar de seguridad introducido para abordar las vulnerabilidades encontradas en WEP?

A) TKIP
B) AES
C) WPA
D) CCMP

45. ¿Cuál de las siguientes respuestas se refiere a una organización global de desarrollo de estándares compuesta por diferentes organismos nacionales de estándares?

A) NIST
B) ISO
C) IEEE
D) ANSI

46. ¿Cuál de las respuestas enumeradas a continuación se refiere a un estándar de la industria para evaluar y calificar la gravedad de las vulnerabilidades de seguridad de los sistemas informáticos?

A) SIEM
B) cvss
C) OSINT
D) REMONTARSE

47. ¿Cuál de los acrónimos enumerados a continuación se refiere a una estrategia integral y un conjunto de procedimientos diseñados para garantizar que una organización pueda continuar con sus operaciones y funciones críticas durante y después de un evento disruptivo?

A) BIA
B) LES
✓ **C) BCP**
D) BPA

48. ¿Cuál de las respuestas enumeradas a continuación se refiere a un conjunto de estándares y especificaciones que definen diversas técnicas criptográficas, incluidos formatos para claves públicas, claves privadas, firmas digitales y certificados digitales?

A) ITIL
B) RFC
C) PKCS
D) ISO/CEI

49. ¿Cuál de las siguientes soluciones sería la más adecuada para una empresa que necesita servicios de TI integrales pero carece de personal de TI calificado?

A) MSA
B) MaaS
✓ **C) MSP**
D) MSSP

50. ¿Cuál de los términos enumerados a continuación se refiere a un proveedor externo que ofrece servicios de gestión de seguridad de TI?

A) MSP
B) MaaS
C) MSA
D) MSSP

51. ¿Cuál de las respuestas enumeradas a continuación se refiere a una organización global de desarrollo de estándares compuesta por diferentes organismos nacionales de estándares?

A) NIST
B) ISO
C) IEEE
D) ANSI

52. ¿Cuál de las siguientes respuestas se refiere a un protocolo de cifrado utilizado principalmente en redes Wi-Fi que implementan el estándar de seguridad WPA2?

A) TKIP
B) CCMP
C) SSL
D) HMAC

53. Un programa informático malicioso independiente que normalmente se propaga a través de una red informática para afectar negativamente a los recursos del sistema y al ancho de banda de la red se denomina:

A) Gusano
B) virus sin archivos
C) Bot
D) Bomba lógica

54. A diferencia de los simples ataques DoS que normalmente se realizan desde un solo sistema, un ataque DDoS utiliza múltiples sistemas informáticos comprometidos para realizar el ataque contra su objetivo. Los sistemas intermediarios que se utilizan como plataforma para el ataque (a menudo denominados zombies y colectivamente botnet) son las víctimas secundarias del ataque DDoS.

A) Verdadero
B) FALSO

Respuesta no detectada automaticamente

55. Un ataque de disociación inalámbrica es un tipo de: (Seleccione 2 respuestas)

A) Ataque de degradación

✓ B) Ataque de desautenticación

C) Ataque de fuerza bruta

✓ D) Ataque DoS

E) Ataque criptográfico

56. Una instalación de recuperación ante desastres que proporciona únicamente el espacio físico para las operaciones de recuperación se conoce como:

A) sitio caliente

B) Sitio cálido

✓ C) Sitio frio

D) Sitio espejo

57. ¿Qué sitio alternativo permite la recuperación ante desastres más rápida?

A) Sitio frio

✓ B) sitio caliente

C) sitio móvil

D) Sitio cálido

58. ¿Cuál de las siguientes soluciones de redundancia de energía sería la más adecuada para proporcionar energía de emergencia a largo plazo durante un corte inesperado de la fuente de energía principal?

A) Fuente de alimentación dual

B) UPS en espera

✓ C) Generador de respaldo

D) PDU administrada

59. Un SSID es un identificador único (también conocido como nombre de red inalámbrica) para una WLAN. Las redes inalámbricas anuncian su presencia transmitiendo periódicamente SSID en un paquete especial llamado marco de baliza. En redes inalámbricas con funciones de seguridad deshabilitadas, conocer el SSID de la red es suficiente para acceder a la red. SSID también identifica el enrutador inalámbrico que actúa como WAP. Los enrutadores inalámbricos del mismo fabricante suelen configurarse con nombres SSID predeterminados (conocidos). Dado que varios dispositivos con el mismo SSID mostrado en la lista de redes disponibles crean confusión y fomentan el acceso accidental por parte de usuarios no autorizados (se aplica a redes que carecen de seguridad), cambiar el SSID predeterminado es una práctica recomendada.

A) Verdadero

B) FALSO

Respuesta no detectada automaticamente

60. ¿Cuál de las respuestas enumeradas a continuación se refiere a un protocolo de autenticación de red inalámbrica estándar abierto que mejora la seguridad al encapsular el proceso de autenticación dentro de un túnel TLS cifrado?

A) PEAP

B) PAE

C) SALTO

D) RADIO

Respuesta no detectada automaticamente

61. ¿Cuál de las siguientes afirmaciones describe las características del análisis de código dinámico? (Seleccione 3 respuestas)

A) Normalmente se utiliza más adelante en el ciclo de vida del desarrollo de software.

B) Implica examinar el código sin ejecutarlo.

✓ C) Analiza las propiedades del tiempo de ejecución, como el uso de la memoria, el rendimiento y el manejo de errores, para identificar problemas como pérdidas de memoria, cuellos de botella en el rendimiento y errores de tiempo de ejecución.

D) A menudo se utiliza al principio del proceso de desarrollo.

E) Examina la estructura, la sintaxis y la semántica del código para detectar problemas como errores de sintaxis, violaciones de estándares de codificación, vulnerabilidades de seguridad y errores.

✓ F) Implica ejecutar el código y analizar su comportamiento en tiempo de ejecución.

62. ¿Cuál de las siguientes respuestas se refiere(s) al modelo de control de acceso obligatorio (MAC)? (Seleccione todo lo que corresponda)

A) Los usuarios no pueden cambiar las políticas de acceso a su propia discreción.

✓ B) Las etiquetas y los niveles de autorización solo pueden ser aplicados y modificados por un administrador

C) Cada objeto tiene un propietario que, a su propia discreción, determina qué tipo de permisos pueden tener otros usuarios sobre ese objeto.

D) Acceso a recursos según la identidad del usuario.

✓ E) Cada recurso tiene una etiqueta de confidencialidad que coincide con un nivel de autorización asignado a un usuario.

63. ¿Qué política de contraseñas impone un cambio de contraseña obligatorio después de un tiempo específico?

A) Política de caducidad de contraseñas

B) Política de historial de contraseñas

C) Política de antigüedad mínima de la contraseña

D) Política de reutilización de contraseñas

64. En la estrategia de aceptación de riesgos, la práctica de incumplir temporalmente una norma o política debido a un escenario de riesgo específico se denomina:

A) Exclusión

✓ B) Excepción

C) Evasión

D) Exención

5.4 - Resumir los elementos del cumplimiento normativo de seguridad.

Conceptos clave:

- Marcos: GDPR, HIPAA, PCI DSS, SOX, FERPA, COPPA
- Reporte de cumplimiento: Interno, Externo, Atestacion
- Consecuencias: Multas, Sanciones, Dano reputacional, Perdida de licencia
- Privacidad: PII, PHI, Derecho al olvido, Privacidad por diseno

Teoria detallada:

MARCOS REGULATORIOS PRINCIPALES:

- GDPR (Reglamento General de Proteccion de Datos): regulacion europea que protege los datos personales de ciudadanos de la UE. Aplica a CUALQUIER empresa del mundo que procese datos de europeos. Principios clave: minimizacion de datos, proposito limitado, exactitud. Multas: hasta 4% del revenue global anual o 20M EUR (lo que sea mayor)
- HIPAA (Ley de Portabilidad y Responsabilidad del Seguro Medico): ley de EEUU que protege la informacion medica protegida (PHI). Aplica a entidades cubiertas (hospitales, aseguradoras) y asociados de negocio (sus proveedores)
- PCI DSS (Estandar de Seguridad de Datos de la Industria de Tarjetas de Pago): estandar de la industria de tarjetas de pago. NO es una ley sino un estandar contractual. 12 requisitos de seguridad
- SOX (Ley Sarbanes-Oxley): ley de EEUU para empresas cotizadas. Seccion 404: los controles internos sobre informes financieros deben ser auditados anualmente
- FERPA: protege los registros educativos de estudiantes en EEUU
- COPPA: protege la privacidad de menores de 13 anos en EEUU en internet

CONCEPTOS CLAVE DE PRIVACIDAD:

- Sujeto de datos (Data subject): la persona fisica cuyos datos se procesan
- Controlador de datos (Data controller): entidad que decide el PROPOSITO y los MEDIOS del procesamiento
- Procesador de datos (Data processor): entidad que procesa datos EN NOMBRE del controller
- Derecho al olvido (GDPR Art. 17): derecho a solicitar la eliminacion de tus datos personales
- Portabilidad de datos: derecho a recibir tus datos en formato estructurado para transferirlos a otro proveedor
- Privacidad desde el diseno (Privacy by design): integrar la privacidad desde el DISENO del sistema, no como un anado posterior. Principio fundamental del GDPR

• Soberania de datos: los datos deben almacenarse y tratarse segun las leyes del pais donde residen
• Interes legitimo: base legal para procesar datos sin consentimiento explicito cuando hay un interes legitimo justificado

REPORTE DE CUMPLIMIENTO Y CONSECUENCIAS:

• Atestacion (Attestation): declaracion FORMAL de cumplimiento firmada por un responsable (DPO, CISO, CEO)
• Cumplimiento interno: auditorias internas, autoevaluaciones, revision de politicas
• Cumplimiento externo: auditores externos independientes, certificaciones (ISO 27001, SOC 2 Tipo II)
• Consecuencias del incumplimiento:
- Multas economicas (GDPR: hasta 4% revenue global)
- Sanciones regulatorias (suspension de licencias)
- Dano reputacional (perdida de clientes)
- Responsabilidad civil (demandas de los afectados)
- Responsabilidad penal (en casos graves de negligencia)

• DPO (Delegado de Proteccion de Datos): rol requerido por GDPR en organizaciones que procesan datos a gran escala. Supervisa el cumplimiento y actua como punto de contacto con reguladores

Preguntas de practica (32):

1. ¿Cuál de las siguientes regula la privacidad de los datos personales de los ciudadanos de la UE?

✓ A) FI
B) HIPAA
C) PCI DSS
✓ D) RGPD

---

2. ¿Cuál de los siguientes términos se refiere a una regulación específica de la industria?

A) RFC
✓ B) ISO
✓ C) PCI DSS
D) RGPD

---

3. En el contexto de las auditorías, una certificación suele ser proporcionada por:

A) Organismo regulador
✓ B) Auditor externo
C) comité de auditoría
D) equipo de auditoría interna

---

4. ¿Cuál de las respuestas enumeradas a continuación se refiere a una persona o función responsable de supervisar y garantizar el cumplimiento de las leyes y políticas de protección de datos dentro de una organización?

A) CTO
B) DPO
C) CIO
D) OSC

---

5. La Ley de Responsabilidad y Portabilidad del Seguro Médico de EE. UU. (HIPAA) brinda protección de la privacidad para:

A) PII
B) PI
✓ C) FI
D) PIV

---

6. ¿Cuál de las siguientes respuestas se refiere a una persona o función responsable de supervisar y garantizar el cumplimiento de las leyes y políticas de protección de datos dentro de una organización?

A) CTO
✓ B) DPO
C) CIO
D) OSC

---

7. En la arquitectura de seguridad Zero Trust, el punto de aplicación de políticas (PEP) es un componente del plano de datos que aplica las políticas de seguridad definidas en el plano de control por el punto de decisión de políticas (PDP).

A) Verdadero

B) FALSO

Respuesta no detectada automaticamente

8. ¿Cuál de las respuestas enumeradas a continuación se refiere a un conjunto de estándares y especificaciones que definen diversas técnicas criptográficas, incluidos formatos para claves públicas, claves privadas, firmas digitales y certificados digitales?

A) ITIL

B) RFC

C) PKCS

D) ISO/CEI

9. ¿Cuál de las siguientes respuestas se refiere a vectores de amenazas comunes que se aplican a los MSP, vendedores y proveedores en la cadena de suministro? (Seleccione 2 respuestas)

A) Violaciones de cumplimiento

B) Daño a la reputación de la marca

✓ C) Propagación de malware

D) Interrupciones operativas

✓ E) Técnicas de ingeniería social

10. ¿Qué define un ataque DDoS reflejado?

A) Abrumar al objetivo con un gran volumen de tráfico para saturar su ancho de banda

B) Explotar vulnerabilidades en los protocolos de red para consumir recursos e interrumpir servicios

✓ C) Utilizar servidores de terceros para reflejar y amplificar el tráfico de ataque hacia el objetivo.

D) Apuntar a vulnerabilidades en aplicaciones o servidores web para agotar los recursos.

11. ¿Cuál de las siguientes políticas se aplica a cualquier solicitud que no cumpla con los criterios definidos en una ACL?

A) Política de acceso justo

✓ B) Política de denegación implícita

C) confianza transitiva

D) Autenticación consciente del contexto

12. ¿Cuál de las respuestas enumeradas a continuación se refiere a una solución que simplifica las configuraciones del navegador web mediante el uso de reglas o scripts predefinidos para tomar decisiones de selección de servidores para tráfico web específico?

A) PAC

B) DDNS

C) PAM

D) NAT

13. El propósito de PCI DSS es brindar protección para:

A) Datos del titular de la tarjeta de crédito

B) Software con licencia

C) Contraseñas de usuario

D) Información de salud personal

14. ¿Cuál de las respuestas enumeradas a continuación se refiere a las ventajas de la segmentación como método para proteger los datos? (Seleccione 3 respuestas)

A) Mejora la seguridad al limitar la propagación de ciberataques

✓ B) Ayuda a las organizaciones a cumplir con los requisitos normativos de datos aislando y protegiendo tipos de datos específicos

C) Proporciona seguridad para los datos en tránsito con el uso de cifrado.

D) Garantiza la recuperación de datos en caso de eliminación accidental o fallas del sistema.

✓ **E) Proporciona un mejor control sobre el acceso de los usuarios a datos confidenciales.**

15. ¿Cuál de las siguientes opciones se refiere a un sistema que identifica, define y cataloga vulnerabilidades de ciberseguridad conocidas públicamente?

A) TAXII

✓ **B) CVE**

C) STIX

D) cvss

16. ¿Cuál de las siguientes respuestas se refiere a SCAP? (Seleccione 3 respuestas)

A) Un tipo de sistema de seguridad diseñado para recopilar registros y eventos de diversas fuentes.

✓ **B) Diseñado para proporcionar una interfaz de usuario centralizada para acceder a los datos recopilados.**

✓ **C) Una colección de estándares desarrollados por NIST**

✓ **D) Proporciona un lenguaje común para comunicar información de seguridad.**

✓ **E) Permite que diferentes herramientas de seguridad compartan datos y trabajen juntas de manera más efectiva**

F) Permite la detección de amenazas en tiempo real, la respuesta a incidentes y el monitoreo del cumplimiento

17. ¿Cuál de los siguientes términos se refiere a patrones o características predefinidos de amenazas o métodos de ataque conocidos?

A) Registros de seguridad

B) Líneas de base

C) Tendencias

✓ **D) Firmas**

18. ¿Cuál de las siguientes respuestas se refiere a una solución que ayuda a las organizaciones a mitigar los riesgos asociados con filtraciones de datos, amenazas internas e infracciones de cumplimiento?

A) EDR

B) DLP

C) SOY

D) UTM

19. OpenID Connect es un protocolo utilizado para:

A) Atestación

B) Autorización

C) Revisión de cuentas

✓ **D) Autenticación**

20. ¿Qué modelo de control de acceso define reglas de control de acceso con el uso de declaraciones que se parecen mucho al lenguaje natural?

A) CAD

✓ **B) ABAC**

C) IMPERMEABLE

D) RBAC

21. ¿Cuál de las respuestas enumeradas a continuación se refiere a organizaciones del sector público que establecen y hacen cumplir leyes y regulaciones a nivel local, regional o nacional?

A) Entidades gubernamentales

B) Asociaciones comerciales

C) Organismos estatutarios

D) Agencias reguladoras

22. ¿Cuál de las respuestas enumeradas a continuación se refiere a organizaciones o personas responsables de garantizar el cumplimiento de las leyes de protección de datos?

A) Controladores

B) Mayordomos

C) Propietarios

D) Procesadores

23. ¿Cuál de las siguientes define la cantidad máxima aceptable de pérdida de datos medida en un momento específico antes de un desastre o interrupción?

A) RPO
B) MTBF
C) RTO
✓ D) MTTR

24. ¿Cuál de las siguientes respuestas se refiere a una disposición contractual que otorga a una parte el derecho de inspeccionar las operaciones, instalaciones, procesos y registros de la otra parte?

A) Cláusula de derecho de auditoría
B) Cláusula de supervisión
C) Cláusula de verificación de cumplimiento
D) Cláusula de transparencia

25. ¿Cuál de las siguientes respuestas se refiere a una entidad (como una organización o un individuo) que determina el propósito y los medios del procesamiento de datos personales?

✓ A) Procesador de datos
B) Propietario de los datos
✓ C) Responsable del tratamiento
D) Interesado

26. ¿Cuál de los términos enumerados a continuación se refiere a un principio legal que permite a las personas solicitar la eliminación de información personal de búsquedas en Internet y otras fuentes públicas?

A) Desidentificación
✓ B) Derecho a ser olvidado
C) Anonimización
D) Gestión del consentimiento

27. ¿Cuál de las respuestas enumeradas a continuación se refiere a un conjunto de estándares y especificaciones que definen diversas técnicas criptográficas, incluidos formatos para claves públicas, claves privadas, firmas digitales y certificados digitales?

A) ITIL
B) RFC
C) PKCS
D) ISO/CEI

28. ¿Cuál de las respuestas enumeradas a continuación se refiere a una solución que simplifica las configuraciones del navegador web mediante el uso de reglas o scripts predefinidos para tomar decisiones de selección de servidores para tráfico web específico?

A) PAC
B) DDNS
C) PAM
D) NAT

29. ¿Qué define un ataque DDoS reflejado?

A) Abrumar al objetivo con un gran volumen de tráfico para saturar su ancho de banda
B) Explotar vulnerabilidades en los protocolos de red para consumir recursos e interrumpir servicios
✓ C) Utilizar servidores de terceros para reflejar y amplificar el tráfico de ataque hacia el objetivo.
D) Apuntar a vulnerabilidades en aplicaciones o servidores web para agotar los recursos.

30. ¿Cuál de las respuestas enumeradas a continuación se refiere a las ventajas de la segmentación como método para proteger los datos? (Seleccione 3 respuestas)

A) Mejora la seguridad al limitar la propagación de ciberataques
✓ B) Ayuda a las organizaciones a cumplir con los requisitos normativos de datos aislando y protegiendo tipos de datos específicos
C) Proporciona seguridad para los datos en tránsito con el uso de cifrado.
D) Garantiza la recuperación de datos en caso de eliminación accidental o fallas del sistema.

✓ **E) Proporciona un mejor control sobre el acceso de los usuarios a datos confidenciales.**

31. ¿Cuál de las siguientes opciones se refiere a un sistema que identifica, define y cataloga vulnerabilidades de ciberseguridad conocidas públicamente?

A) TAXII

✓ **B) CVE**

C) STIX

D) cvss

32. ¿Cuál de las siguientes define la cantidad máxima aceptable de pérdida de datos medida en un momento específico antes de un desastre o interrupción?

A) RPO

B) MTBF

C) RTO

✓ **D) MTTR**

5.5 - Explicar los tipos y propositos de las auditorias y evaluaciones.

Conceptos clave:

- Internas: Cumplimiento, Comite de auditoria, Autoevaluaciones
- Externas: Regulatorias, Examinaciones, Tercero independiente
- Pruebas de penetracion: Fisica, Ofensiva, Defensiva, Integrada
- Entornos: Caja negra, Caja blanca, Caja gris. Reconocimiento: Pasivo, Activo

Teoria detallada:

TIPOS DE AUDITORIAS Y EVALUACIONES:

- Auditoria interna: realizada por el propio equipo de auditoria interna. Identifica gaps antes de que los encuentre un auditor externo. Menos credibilidad externa pero mas conocimiento del negocio
- Auditoria externa: realizada por un tercero independiente acreditado. Mayor credibilidad. Requerida para certificaciones (ISO 27001) y por algunos reguladores
- Examen regulatorio: auditoria impuesta y realizada por un regulador (banco central, FDA, FCA). No es opcional
- Autoevaluacion (Self-assessment): la propia organizacion evalua su cumplimiento contra un framework (NIST CSF, CIS Controls). Rapido y barato, menos fiable
- Comite de auditoria: comite interno que supervisa el proceso de auditoria y garantiza su independencia

PRUEBAS DE PENETRACION - Clasificacion por nivel de conocimiento:

- Caja negra (Black box / Unknown environment): el pentester comienza sin ningun conocimiento previo. Simula un atacante externo real. El mas realista pero el mas lento y costoso
- Caja blanca (White box / Known environment): el pentester tiene acceso completo a documentacion, codigo fuente, arquitectura, credenciales. El mas exhaustivo
- Caja gris (Gray box / Partially known): el mas comun en la practica. El pentester tiene conocimiento parcial. Buen balance entre realismo y eficiencia

PRUEBAS DE PENETRACION - Clasificacion por tipo de equipo:

- Equipo rojo (Red Team): equipo ofensivo. Simula al atacante. Busca vulnerabilidades y las explota. Puede incluir ingenieria social y ataques fisicos
- Equipo azul (Blue Team): equipo defensivo. Monitoriza, detecta y responde a los ataques del Red Team
- Equipo morado (Purple Team): Red y Blue trabajan COLABORATIVAMENTE. El Red Team comparte sus TTPs con el Blue Team en tiempo real para mejorar las defensas. El objetivo no es 'ganar' sino mejorar
- Equipo blanco (White Team): arbitros. Gestionan las reglas del ejercicio, resuelven disputas y evaluan los resultados

RECONOCIMIENTO - CRITICO para el examen:

- Reconocimiento pasivo: recopilar informacion SIN interactuar directamente con el objetivo. El objetivo NO puede detectarlo

Tecnicas: OSINT (Google, LinkedIn, WHOIS, Shodan), analisis de metadatos de documentos publicos

Herramientas: Maltego, theHarvester, Shodan, WHOIS

- Reconocimiento activo: interactuar DIRECTAMENTE con el objetivo. El objetivo PUEDE detectarlo

Tecnicas: escaneo de puertos (nmap), banner grabbing, escaneo de vulnerabilidades

Herramientas: Nmap, Nessus, Nikto

• Reglas de participacion (RoE): documento LEGAL que debe firmarse ANTES de cualquier pentest. Define: alcance, metodos permitidos, ventanas de tiempo, contacto de emergencia

EVALUACION DE VULNERABILIDADES vs PRUEBA DE PENETRACION:

• Evaluacion de vulnerabilidades: identifica y CLASIFICA vulnerabilidades. NO las explota. Mas rapido y barato. Resultado: lista de vulnerabilidades con su severidad (CVSS)

• Prueba de penetracion: identifica Y EXPLOTA vulnerabilidades para demostrar el IMPACTO REAL. Mas lento y caro. Resultado: informe de vulnerabilidades + evidencias de explotacion exitosa

• Programa de recompensas por errores (Bug bounty): la organizacion PAGA a investigadores externos por encontrar y reportar vulnerabilidades de forma responsable

Preguntas de practica (21):

1. En los ejercicios de ciberseguridad, el equipo defensor se conoce como:

A) equipo rojo

✓ B) equipo azul

✓ C) equipo blanco

D) equipo morado

2. En las pruebas de penetración, el reconocimiento activo implica recopilar cualquier tipo de información disponible públicamente que pueda usarse más adelante para explotar las vulnerabilidades encontradas en el sistema objetivo.

A) Verdadero

✓ B) FALSO

3. En los ejercicios de ciberseguridad, el equipo defensor se conoce como:

A) equipo rojo

✓ B) equipo azul

✓ C) equipo blanco

D) equipo morado

4. En las pruebas de penetración, el reconocimiento activo implica recopilar cualquier tipo de información disponible públicamente que pueda usarse más adelante para explotar las vulnerabilidades encontradas en el sistema objetivo.

A) Verdadero

✓ B) FALSO

5. ¿Cuál de las respuestas enumeradas a continuación se refiere(s) a los controles de seguridad de detectives? (Seleccione todo lo que corresponda)

A) Iluminación

✓ B) Monitoreo de registros

C) Zona de arena

✓ D) Auditorías de seguridad

✓ E) circuito cerrado de televisión

✓ F) identificación

✓ G) Escaneo de vulnerabilidades

6. ¿Cuál de los siguientes términos describe el proceso de identificar diferencias entre la postura de seguridad actual de una organización y su postura de seguridad deseada?

A) Ejercicio de mesa

✓ B) Análisis de brechas

C) Capacitación en concientización sobre seguridad.

D) Evaluación de riesgos

7. OpenID Connect es un protocolo utilizado para:

A) Atestación

B) Autorización

C) Revisión de cuentas

✓ D) Autenticación

8. ¿Cuál de las siguientes respuestas se refiere a un ejercicio más profundo, que puede incluir activar sistemas y realizar acciones reales para responder al incidente?

A) Pruebas de penetración

B) caza de amenazas

✓ C) Simulación

D) Escaneo de vulnerabilidades

---

9. ¿Cuál de las siguientes respuestas se refiere a una disposición contractual que otorga a una parte el derecho de inspeccionar las operaciones, instalaciones, procesos y registros de la otra parte?

A) Cláusula de derecho de auditoría

B) Cláusula de supervisión

C) Cláusula de verificación de cumplimiento

D) Cláusula de transparencia

---

10. En el contexto de las auditorías, una certificación suele ser proporcionada por:

A) Organismo regulador

✓ B) Auditor externo

C) comité de auditoría

D) equipo de auditoría interna

---

11. En los ejercicios de ciberseguridad, un equipo morado asume el papel integrado de todos los demás equipos (es decir, rojo, azul y blanco).

A) Verdadero

✓ B) FALSO

---

12. ¿Qué parte de la arquitectura de seguridad AAA se ocupa de la verificación de la identidad de una persona o proceso?

A) Contabilidad

✓ B) Autenticación

C) Revisión de cuentas

D) Autorización

---

13. ¿Cuál de las siguientes respuestas se refiere a un lenguaje utilizado principalmente para automatizar la evaluación de vulnerabilidades de seguridad y problemas de configuración en sistemas informáticos?

A) OVAL

B) SAML

C) XML

D) JABÓN

---

14. ¿Cuál de las respuestas enumeradas a continuación se refiere(s) a los controles de seguridad de detectives? (Seleccione todo lo que corresponda)

A) Iluminación

✓ B) Monitoreo de registros

C) Zona de arena

✓ D) Auditorías de seguridad

✓ E) circuito cerrado de televisión

✓ F) identificación

✓ G) Escaneo de vulnerabilidades

---

15. El proceso de determinar los riesgos potenciales que podrían afectar la capacidad de una organización para alcanzar sus objetivos se denomina:

✓ A) Evaluación de riesgos

✓ B) Identificación de riesgos

C) Análisis de riesgos

D) Gestión de riesgos

---

16. ¿Cuál de las siguientes respuestas se refiere a un método de evaluación de riesgos basado en la necesidad, que generalmente se lleva a cabo en respuesta a eventos o cambios específicos, como después

de un cambio organizacional importante o una violación de seguridad?

A) A propósito
B) Periódico
C) una sola vez
D) Continuo

17. ¿Cuál de las respuestas enumeradas a continuación se refiere a un ejemplo de evaluación de riesgos recurrentes?

✓ A) Monitoreo en tiempo real de amenazas a la seguridad de la red
B) Evaluación del riesgo después de un cambio organizacional importante o una violación de seguridad
C) Evaluaciones de riesgos trimestrales o anuales
D) Evaluación de riesgos para el lanzamiento de un nuevo producto.

18. ¿Cuál de las siguientes respuestas se refiere a una evaluación de riesgos realizada para un propósito o proyecto específico, sin planes para una reevaluación periódica (por ejemplo, evaluación de riesgos para el lanzamiento de un nuevo producto)?

A) una sola vez
B) Periódico
C) A propósito
D) Continuo

19. ¿Cuál de las respuestas enumeradas a continuación se refiere a un ejemplo de evaluación continua de riesgos?

A) Evaluaciones de riesgos trimestrales o anuales
B) Evaluación de riesgos para el lanzamiento de un nuevo producto.
C) Evaluación del riesgo después de un cambio organizacional importante o una violación de seguridad
D) Monitoreo en tiempo real de amenazas a la seguridad de la red

20. Pruebas de penetración: (Seleccione todas las que correspondan)

A) Salta los controles de seguridad
B) Sólo identifica falta de controles de seguridad
✓ C) Prueba activamente los controles de seguridad.
✓ D) Explota vulnerabilidades
E) Prueba pasivamente los controles de seguridad.

21. En los ejercicios de ciberseguridad, un equipo morado asume el papel integrado de todos los demás equipos (es decir, rojo, azul y blanco).

A) Verdadero
✓ B) FALSO

5.6 - Implementar practicas de concienciacion de seguridad.

Conceptos clave:

- Phishing: Campanas, Reconocer intentos, Responder a mensajes sospechosos
- Comportamiento de riesgo: Arriesgado, Inesperado, No intencionado
- Formacion de usuarios: Politicas, Amenaza interna, Gestion de contrasenas, Ingenieria social
- Reporte y monitorizacion: Inicial, Periodico

Teoria detallada:

EL FACTOR HUMANO - Por que es el objetivo mas importante del examen:

- El 90%+ de los incidentes de seguridad tienen un componente humano (error, engano o malicia)
- La tecnologia puede ser perfecta pero un empleado que hace clic en un phishing lo anula todo
- La concienciacion de seguridad no es un evento anual, es un programa continuo
- Objetivo: cambiar el COMPORTAMIENTO de las personas, no solo su conocimiento

PROGRAMA DE CONCIENCIACION - Componentes:

• Formacion en concienciacion de seguridad: formacion periodica obligatoria para TODOS los empleados, incluyendo la direccion. Contenido: phishing, ingenieria social, manejo de datos, uso de dispositivos, incidentes
• Reconocimiento de politicas: los empleados firman que han leido, entendido y se comprometen a cumplir las politicas. Critico para demostrar cumplimiento y para procedimientos disciplinarios
• Formacion por rol: formacion especifica segun el rol. Los desarrolladores necesitan formacion sobre OWASP. Los de RRHH sobre proteccion de datos. Los ejecutivos sobre BEC y whaling
• Formacion inicial vs periodica: formacion en la incorporacion + actualizaciones periodicas (minimo anual) + formacion adicional tras incidentes

SIMULACION DE PHISHING - El metodo mas efectivo:

• Enviar emails de phishing FALSOS y controlados a empleados sin que lo sepan
• Medir: % que abre el email, % que hace clic en el enlace, % que introduce credenciales, % que reporta el intento
• Los que 'caen': reciben formacion inmediata y especifica
• Objetivo: reducir el porcentaje de clics con el tiempo. Un buen programa baja del 30% inicial al 5% en 12 meses
• NO es para castigar. Es para identificar quienes necesitan mas formacion

INDICADORES DE COMPORTAMIENTO DE RIESGO:

• Comportamiento arriesgado: acciones que aumentan el riesgo aunque no sean intencionadamente maliciosas
Ejemplos: conectar un USB encontrado en el parking, usar WiFi publica sin VPN, compartir credenciales con companeros

• Comportamiento inesperado: comportamiento inusual que puede indicar compromiso de cuenta o amenaza interna
Ejemplos: acceder a datos fuera del horario habitual, descargar grandes cantidades de datos, acceder a sistemas fuera de su rol

• Amenaza interna no intencionada: empleado bien intencionado que causa un incidente por error
Ejemplos: enviar email con datos sensibles a la direccion equivocada, publicar credenciales en GitHub por error

• Amenaza interna maliciosa: empleado que actua deliberadamente en contra de la organizacion
Indicadores: descontento laboral reciente, sancion disciplinaria, conocimiento de despido inminente

CONTENIDO CLAVE DE LA FORMACION:

• Reconocer phishing: remitente sospechoso, urgencia artificial, links que no coinciden, adjuntos no esperados, errores ortograficos
• Gestion de contrasenas: usar gestor de contrasenas (Bitwarden, 1Password), nunca reutilizar contrasenas, activar MFA en todas las cuentas
• Ingenieria social: verificar siempre la identidad del solicitante por un canal alternativo antes de dar informacion o accesos
• Manejo de datos: clasificar los datos antes de compartirlos, no enviar PII sin cifrar, no almacenar datos sensibles en dispositivos no aprobados
• Reporte de incidentes: a quien reportar, como hacerlo, que informacion incluir. El tiempo es critico

Preguntas de practica (9):

1. ¿Cuál de las respuestas enumeradas a continuación se puede utilizar para describir los controles de seguridad operativos? (Seleccione 3 respuestas)

A) También conocidos como controles administrativos.
✓ B) Enfocados en los procedimientos del día a día de una organización.
C) Ejecutado por sistemas informáticos (en lugar de personas)
✓ D) Se utiliza para garantizar que el equipo continúe funcionando según lo especificado.
E) Enfocados en la gestión del riesgo
✓ F) Principalmente implementado y ejecutado por personas (a diferencia de los sistemas informáticos)

---

2. ¿Cuál de las respuestas enumeradas a continuación se refiere a controles de seguridad diseñados para disuadir, detectar y prevenir el acceso no autorizado, el robo, el daño o la destrucción de activos materiales?

A) Controles de seguridad gerenciales
✓ B) Controles de seguridad física
C) Controles técnicos de seguridad
D) Controles operativos de seguridad

---

3. ¿Cuál de los siguientes términos describe el proceso de identificar diferencias entre la postura de seguridad actual de una organización y su postura de seguridad deseada?

A) Ejercicio de mesa
✓ B) Análisis de brechas
C) Capacitación en concientización sobre seguridad.

D) Evaluación de riesgos

4. ¿Cuál de las respuestas enumeradas a continuación se refiere a un escenario simulado llevado a cabo en un entorno controlado, que generalmente implica discusiones y planificación en torno a incidentes de seguridad hipotéticos?

A) Ejercicio de mesa
B) Zona de arena
C) caza de amenazas
D) Capacitación en concientización sobre seguridad.

Respuesta no detectada automaticamente

5. ¿Cuál de las siguientes respuestas se refiere a una solución que ayuda a las organizaciones a mitigar los riesgos asociados con filtraciones de datos, amenazas internas e infracciones de cumplimiento?

A) EDR
B) DLP
C) SOY
D) UTM

6. ¿Qué término describe mejor a un empleado descontento que abusa del acceso legítimo a los recursos internos de una empresa?

A) APTO
✓ B) Amenaza interna
C) sombrero gris
D) actor de amenazas

7. ¿Cuál de las respuestas enumeradas a continuación se puede utilizar para describir los controles de seguridad operativos? (Seleccione 3 respuestas)

A) También conocidos como controles administrativos.
✓ B) Enfocados en los procedimientos del día a día de una organización.
C) Ejecutado por sistemas informáticos (en lugar de personas)
✓ D) Se utiliza para garantizar que el equipo continúe funcionando según lo especificado.
E) Enfocados en la gestión del riesgo
✓ F) Principalmente implementado y ejecutado por personas (a diferencia de los sistemas informáticos)

8. ¿Cuál de las respuestas enumeradas a continuación se refiere a controles de seguridad diseñados para disuadir, detectar y prevenir el acceso no autorizado, el robo, el daño o la destrucción de activos materiales?

A) Controles de seguridad gerenciales
✓ B) Controles de seguridad física
C) Controles técnicos de seguridad
D) Controles operativos de seguridad

9. ¿Cuál de las respuestas enumeradas a continuación se refiere a un escenario simulado llevado a cabo en un entorno controlado, que generalmente implica discusiones y planificación en torno a incidentes de seguridad hipotéticos?

A) Ejercicio de mesa
B) Zona de arena
C) caza de amenazas
D) Capacitación en concientización sobre seguridad.

Respuesta no detectada automaticamente

Glosario de Acronimos - SY0-701

Todos los acronimos del examen CompTIA Security+ SY0-701

Acronimo	Significado / Descripcion
3DES	Triple Data Encryption Standard - Cifrado de datos triple
AAA	Authentication, Authorization, and Accounting - Autenticacion, Autorizacion y Auditoria
ABAC	Attribute-Based Access Control - Control de acceso basado en atributos
ACL	Access Control List - Lista de control de acceso
AES	Advanced Encryption Standard - Estandar de cifrado avanzado
AH	Authentication Header - Cabecera de autenticacion (IPSec)
AI	Artificial Intelligence - Inteligencia artificial
AIS	Automated Indicator Sharing - Intercambio automatizado de indicadores
ALE	Annualized Loss Expectancy - Perdida anual esperada
AP	Access Point - Punto de acceso
API	Application Programming Interface - Interfaz de programacion de aplicaciones
APT	Advanced Persistent Threat - Amenaza persistente avanzada
ARO	Annualized Rate of Occurrence - Tasa anual de ocurrencia
ARP	Address Resolution Protocol - Protocolo de resolucion de direcciones
AUP	Acceptable Use Policy - Politica de uso aceptable
AV	Asset Value - Valor del activo / Antivirus
BCP	Business Continuity Plan - Plan de continuidad de negocio
BIA	Business Impact Analysis - Analisis de impacto en el negocio
BPA	Business Partnership Agreement - Acuerdo de colaboracion empresarial
BYOD	Bring Your Own Device - Trae tu propio dispositivo
CA	Certificate Authority - Autoridad de certificacion
CASB	Cloud Access Security Broker - Intermediario de seguridad de acceso a la nube
CIA	Confidentiality, Integrity, Availability - Confidencialidad, Integridad, Disponibilidad
CISO	Chief Information Security Officer - Director de seguridad de la informacion
CMDB	Configuration Management Database - Base de datos de gestion de configuracion
COPE	Corporate Owned, Personally Enabled - Propiedad corporativa, uso personal habilitado
CSR	Certificate Signing Request - Solicitud de firma de certificado
CSRF	Cross-Site Request Forgery - Falsificacion de solicitud entre sitios
CVE	Common Vulnerabilities and Exposures - Vulnerabilidades y exposiciones comunes
CVSS	Common Vulnerability Scoring System - Sistema comun de puntuacion de vulnerabilidades
CYOD	Choose Your Own Device - Elige tu propio dispositivo
DAC	Discretionary Access Control - Control de acceso discrecional
DDoS	Distributed Denial of Service - Denegacion de servicio distribuida
DES	Data Encryption Standard - Estandar de cifrado de datos
DHCP	Dynamic Host Configuration Protocol - Protocolo de configuracion dinamica de host
DKIM	DomainKeys Identified Mail - Correo identificado con claves de dominio
DLP	Data Loss Prevention - Prevencion de perdida de datos
DMARC	Domain-based Message Authentication, Reporting, and Conformance

Acronimo	Significado / Descripcion
DMZ	Demilitarized Zone - Zona desmilitarizada
DNS	Domain Name System - Sistema de nombres de dominio
DoS	Denial of Service - Denegacion de servicio
DPO	Data Protection Officer - Delegado de proteccion de datos
DRP	Disaster Recovery Plan - Plan de recuperacion ante desastres
DSA	Digital Signature Algorithm - Algoritmo de firma digital
EAP	Extensible Authentication Protocol - Protocolo de autenticacion extensible
ECC	Elliptic Curve Cryptography - Criptografia de curva eliptica
EDR	Endpoint Detection and Response - Deteccion y respuesta en el endpoint
EF	Exposure Factor - Factor de exposicion
EOL	End of Life - Fin de vida util
ESP	Encapsulating Security Payload - Carga util de seguridad encapsulada (IPSec)
FDE	Full Disk Encryption - Cifrado de disco completo
FIDO	Fast Identity Online - Identidad rapida en linea
FIM	File Integrity Monitoring - Monitorizacion de integridad de archivos
FTP	File Transfer Protocol - Protocolo de transferencia de archivos
GDPR	General Data Protection Regulation - Reglamento general de proteccion de datos
GPO	Group Policy Object - Objeto de politica de grupo
HA	High Availability - Alta disponibilidad
HIDS	Host-based Intrusion Detection System - Sistema de deteccion de intrusiones en el host
HIPAA	Health Insurance Portability and Accountability Act
HIPS	Host-based Intrusion Prevention System - Sistema de prevencion de intrusiones en el host
HMAC	Hash-based Message Authentication Code - Codigo de autenticacion de mensaje basado en hash
HOTP	HMAC-based One-Time Password - Contrasena de un solo uso basada en HMAC
HSM	Hardware Security Module - Modulo de seguridad hardware
HTTPS	HyperText Transfer Protocol Secure - HTTP seguro
IaaS	Infrastructure as a Service - Infraestructura como servicio
IAM	Identity and Access Management - Gestion de identidades y accesos
ICS	Industrial Control System - Sistema de control industrial
IdP	Identity Provider - Proveedor de identidad
IDS	Intrusion Detection System - Sistema de deteccion de intrusiones
IoT	Internet of Things - Internet de las cosas
IPS	Intrusion Prevention System - Sistema de prevencion de intrusiones
IPSec	Internet Protocol Security - Seguridad del protocolo de internet
IRP	Incident Response Plan - Plan de respuesta a incidentes
ISA	Interconnection Security Agreement - Acuerdo de seguridad de interconexion
JIT	Just-in-Time - Justo a tiempo
LDAP	Lightweight Directory Access Protocol - Protocolo ligero de acceso a directorios
MAC	Mandatory Access Control / Message Authentication Code
MAM	Mobile Application Management - Gestion de aplicaciones moviles
MDM	Mobile Device Management - Gestion de dispositivos moviles

Acronimo	Significado / Descripcion
MFA	Multi-Factor Authentication - Autenticacion multifactor
MitM	Man-in-the-Middle - Ataque en ruta / hombre en el medio
MOA	Memorandum of Agreement - Memorando de acuerdo
MOU	Memorandum of Understanding - Memorando de entendimiento
MSA	Master Service Agreement - Acuerdo marco de servicios
MSP	Managed Service Provider - Proveedor de servicios gestionados
MTBF	Mean Time Between Failures - Tiempo medio entre fallos
MTD	Maximum Tolerable Downtime - Tiempo maximo de inactividad tolerable
MTTR	Mean Time to Repair - Tiempo medio de reparacion
NAC	Network Access Control - Control de acceso a la red
NDA	Non-Disclosure Agreement - Acuerdo de no divulgacion
NGFW	Next-Generation Firewall - Firewall de nueva generacion
NIDS	Network-based Intrusion Detection System
NIST	National Institute of Standards and Technology
OCSP	Online Certificate Status Protocol - Protocolo de estado de certificado en linea
OIDC	OpenID Connect - Protocolo de autenticacion sobre OAuth 2.0
OT	Operational Technology - Tecnologia operacional
OTP	One-Time Password - Contrasena de un solo uso
OWASP	Open Worldwide Application Security Project
PaaS	Platform as a Service - Plataforma como servicio
PAM	Privileged Access Management - Gestion de acceso privilegiado
PCI DSS	Payment Card Industry Data Security Standard
PGP	Pretty Good Privacy - Privacidad bastante buena
PHI	Protected Health Information - Informacion de salud protegida
PII	Personally Identifiable Information - Informacion de identificacion personal
PKI	Public Key Infrastructure - Infraestructura de clave publica
RADIUS	Remote Authentication Dial-in User Service
RBAC	Role-Based Access Control - Control de acceso basado en roles
RDP	Remote Desktop Protocol - Protocolo de escritorio remoto
RFC	Request for Change - Solicitud de cambio
RMF	Risk Management Framework - Marco de gestion de riesgos
RPO	Recovery Point Objective - Objetivo de punto de recuperacion
RSA	Rivest, Shamir, Adleman - Algoritmo de cifrado asimetrico
RTOS	Real-Time Operating System - Sistema operativo de tiempo real
RTO	Recovery Time Objective - Objetivo de tiempo de recuperacion
SaaS	Software as a Service - Software como servicio
SAE	Simultaneous Authentication of Equals - Autenticacion simultanea de iguales (WPA3)
SAML	Security Assertions Markup Language
SASE	Secure Access Service Edge
SCAP	Security Content Automation Protocol
SD-WAN	Software-Defined Wide Area Network - Red de area amplia definida por software

Acronimo	Significado / Descripcion
SDLC	Software Development Life Cycle - Ciclo de vida de desarrollo de software
SFTP	SSH File Transfer Protocol - Protocolo de transferencia de archivos por SSH
SHA	Secure Hashing Algorithm - Algoritmo de hash seguro
SIEM	Security Information and Event Management - Gestion de informacion y eventos de seguridad
SLA	Service Level Agreement - Acuerdo de nivel de servicio
SLE	Single Loss Expectancy - Perdida esperada por incidente
SNMP	Simple Network Management Protocol - Protocolo simple de gestion de red
SOAR	Security Orchestration, Automation, and Response
SOC	Security Operations Center - Centro de operaciones de seguridad
SOW	Statement of Work - Declaracion de trabajo
SPF	Sender Policy Framework - Marco de politica del remitente
SQLi	SQL Injection - Inyeccion SQL
SSH	Secure Shell - Protocolo de shell seguro
SSID	Service Set Identifier - Identificador de red WiFi
SSL	Secure Sockets Layer - Capa de sockets seguros (obsoleto, reemplazado por TLS)
SSO	Single Sign-On - Inicio de sesion unico
TACACS+	Terminal Access Controller Access Control System Plus
TGT	Ticket Granting Ticket - Ticket de concesion de tickets (Kerberos)
TIP	Threat Intelligence Platform - Plataforma de inteligencia de amenazas
TLS	Transport Layer Security - Seguridad de la capa de transporte
TOTP	Time-based One-Time Password - Contrasena de un solo uso basada en tiempo
TPM	Trusted Platform Module - Modulo de plataforma confiable
TTP	Tactics, Techniques, and Procedures - Tacticas, tecnicas y procedimientos
UDP	User Datagram Protocol - Protocolo de datagrama de usuario
UEFI	Unified Extensible Firmware Interface - Interfaz de firmware extensible unificada
UPS	Uninterruptible Power Supply - Sistema de alimentacion ininterrumpida
UTM	Unified Threat Management - Gestion unificada de amenazas
VLAN	Virtual Local Area Network - Red de area local virtual
VM	Virtual Machine - Maquina virtual
VPN	Virtual Private Network - Red privada virtual
WAF	Web Application Firewall - Firewall de aplicacion web
WEP	Wired Equivalent Privacy - Privacidad equivalente al cable (obsoleto)
WPA2	Wi-Fi Protected Access 2 - Acceso protegido WiFi 2
WPA3	Wi-Fi Protected Access 3 - Acceso protegido WiFi 3 (actual)
XDR	Extended Detection and Response - Deteccion y respuesta extendida
XSS	Cross-Site Scripting - Secuencias de comandos entre sitios
ZTNA	Zero Trust Network Access - Acceso a red de confianza cero